



CISA – Certified Information Systems Auditor Study Guide

2ND EDITION

Achieve CISA certification with practical examples and over 850 exam-oriented practice questions

HEMANG DOSHI

FREE ONLINE CONTENT

FLASHCARDS PRACTICE QUESTIONS EXAM TIPS

CISA – Certified Information Systems Auditor Study Guide

Second Edition

Achieve CISA certification with practical examples and over 850 exam-oriented practice questions

Hemang Doshi



BIRMINGHAM—MUMBAI

CISA – Certified Information Systems Auditor Study Guide

Second Edition

Copyright © 2023 Packt Publishing

All rights reserved. No part of this book may be reproduced, stored in a retrieval system, or transmitted in any form or by any means, without the prior written permission of the publisher, except in the case of brief quotations embedded in critical articles or reviews.

Every effort has been made in the preparation of this book to ensure the accuracy of the information presented. However, the information contained in this book is sold without warranty, either express or implied. Neither the author, nor Packt Publishing or its dealers and distributors, will be held liable for any damages caused or alleged to have been caused directly or indirectly by this book.

Packt Publishing has endeavored to provide trademark information about all of the companies and products mentioned in this book by the appropriate use of capitals. However, Packt Publishing cannot guarantee the accuracy of this information.

Author: Hemang Doshi

Reviewers: Ayush Singh Panwar, Karl Marx Thangappan, and Wei Tschang

Publishing Product Manager: Anindya Sil

Development Editor: Shubhra Mayuri

Production Editor: Salma Patel

Editorial Board: Vijin Boricha, Megan Carlisle, Ketan Giri, Alex Mazonowicz, Aaron Nash, Abhishek Rane, and Ankita Thakur

First published: August 2020

Second edition: June 2023

Production reference: 1270623

Published by Packt Publishing Ltd.

Livery Place

35 Livery Street

Birmingham

B3 2PB, UK

ISBN 978-1-80324-815-8

www.packtpub.com

Contributors

About the Author

Hemang Doshi has more than 15 years of experience in the field of system audit, IT risk and compliance, internal audit, risk management, information security audit, third-party risk management, and operational risk management. He has authored several books for certification such as CISA, CRISC, CISM, DISA, and enterprise risk management.

About the Reviewers

Ayush Singh Panwar is an accomplished professional with over 8 years of experience in the field of Information Technology, Information Cyber Security Governance, Risk, and Compliance. He possesses several notable security certifications, including CISSP, CISA, CISM, ISO 27001 (Lead Implementer), and PCI DSS (CPCISI). Throughout his career, Ayush has primarily served as an internal auditor and security consultant for multinational organizations operating in the finance, telecom, and automobile sectors. Currently, he holds the position of Assistant Vice President of the Chief Control Office at a leading global bank based in the United Kingdom. Ayush's expertise lies in conducting information and cyber security audit, evaluating third-party risks, ensuring data privacy, managing cloud security, and implementing ISMS standards.

Karl Marx Thangappan is an IT professional with over 14 years of experience in the field of Information Systems, Technology, Databases, Audit, and Cybersecurity. He holds certifications such as CISSP, CISA, CEH, and Cloud certificates from Azure, Oracle, and AWS. Additionally, he pursued advanced computer security studies at Stanford University. Throughout his career, Karl has traveled to work with a diverse range of clients spanning Australia, the Middle East, and Africa, including large enterprise n-built financial institutions, consulting firms, and startups. Currently, he serves as a Cloud Product Security Consultant in the United Kingdom. As a security entrepreneur, he has developed products like Privileged Access Management (PAM), risk-based vulnerability management and threat modelling with in-built integrations. He has also been involved in projects focused on the robotic automation of complaints and security controls for IT operations. Karl shares his expertise by teaching cybersecurity courses as an adjunct instructor.

Karl expresses gratitude to his brother Siva Anna, his late father, his wife, and his friends for their unwavering support throughout his professional journey.

Wei Tschang has more than 20 years of experience spanning various information technology disciplines within the banking, legal, and manufacturing industries. He is a passionate member of the ISACA Community, serving as a board member in various leadership roles for his local ISACA chapter since 2013 and has received multiple volunteer awards for his contributions to the chapter. He presented at conferences on cybersecurity topics and holds the following certifications: CISA, CISM, CGEIT, CISSP, CIPP, SSCP, and ABCP. Wei lives in New Jersey with his wife, daughter, and golden retriever.

Table of Contents

Preface

xiii

1

Audit Planning	1
The Contents of an Audit Charter	3
Key Aspects from the CISA Exam Perspective	4
Audit Planning	5
Benefits of Audit Planning	5
Selection Criteria	6
Reviewing Audit Planning	6
Individual Audit Assignments	6
Key Aspects from the CISA Exam Perspective	8
Business Process Applications and Controls	8
E-Commerce	8
Electronic Data Interchange (EDI)	9
Point of Sale (POS)	10
Electronic Banking	11
Electronic Funds Transfer (EFT)	12
Image Processing	12
Artificial Intelligence and Expert Systems	13
Key Aspects from the CISA Exam Perspective	14
Types of Controls	15
Preventive Controls	16
Detective Controls	17
Corrective Controls	17
Deterrent Controls	17
The Difference between Preventive and Deterrent Controls	18
Compensating Controls	18
Control Objectives	18
Control Measures	19
Key Aspects from the CISA Exam Perspective	19
Risk-Based Audit Planning	19
What Is Risk?	20
Understanding Vulnerability and Threats	20
Understanding Inherent Risk and Residual Risk	21
Advantages of Risk-Based Audit Planning	22
Audit Risk	22
Risk-Based Auditing Approach	23
Risk Assessments	24
Risk Response Methodology	24
Top-Down and Bottom-Up Approaches to Policy Development	25
Key Aspects from the CISA Exam Perspective	26
Types of Audits and Assessments	27
Summary	29
Chapter Review Questions	30

2

Audit Execution	35
Audit Project Management	36
Audit Objectives	37
Audit Phases	37
Fraud, Irregularities, and Illegal Acts	40
Key Aspects from the CISA Exam Perspective	40
Sampling Methodology	40
Sampling Types	41
Sampling Risk	42
Other Sampling Terms	42
Compliance versus Substantive Testing	44
Key Aspects from the CISA Exam Perspective	45
Audit Evidence	
Collection Techniques	47
Reliability of Evidence	47
Evidence-Gathering Techniques	48
Key Aspects from the CISA Exam Perspective	50
Data Analytics	51
Examples of the Effective Use of Data Analytics	51
CAATs	51
Examples of the Effective Use of CAAT Tools	52
Precautions while Using CAAT	52
Continuous Auditing and Monitoring	52
Continuous Auditing Techniques	53
Key Aspects from the CISA Exam Perspective	55
Reporting and Communication Techniques	56
Exit Interview	56
Audit Reporting	56
Audit Report Objectives	57
Audit Report Structure	57
Follow-Up Activities	57
Key Aspects from the CISA Exam Perspective	58
Control Self-Assessment	58
Objectives of CSA	58
Benefits of CSA	58
Precautions while Implementing CSA	59
An IS Auditor's Role in CSA	59
Key Aspects from the CISA Exam Perspective	59
Summary	60
Chapter Review Questions	61

3

IT Governance	65
Enterprise Governance of IT (EGIT)	67
EGIT Processes	67
The Differences between Governance and Management	68
EGIT Good Practices	68
Effective Information Security Governance	68
EGIT – Success Factors	69
Key Aspects from the CISA Exam Perspective	70
IT-Related Frameworks	70
IT Standards, Policies, and Procedures	71
Policies	72
Standards	72
Procedures	72
Guidelines	72
Information Security Policy	73

Key Aspects from the CISA Exam Perspective	75	Risk Analysis Methods	81
Organizational Structure	75	Risk Treatment	83
Relationship between the IT Strategy Committee and the IT Steering Committee	77	Key Aspects from the CISA Exam Perspective	83
Differences between the IT Strategy Committee and the IT Steering Committee	78	Maturity Model	84
Key Aspects from the CISA Exam Perspective	78	Laws, Regulations, and Industry Standards Affecting the Organization	84
Enterprise Architecture	79	An IS Auditor's Role in Determining Adherence to Laws and Regulations	84
Enterprise Security Architecture	79	Key Aspects from the CISA Exam Perspective	85
Key Aspects from the CISA Exam Perspective	80	Summary	86
Enterprise Risk Management	80	Chapter Review Questions	87
Risk Management Process Steps	80		

4

IT Management 91

IT Resource Management	91	Key Aspects from the CISA Exam Perspective	99
Human Resource Management	92	IT Performance Monitoring and Reporting	100
IT Management Practices	94	Development of Performance Metrics	100
Financial Management Practices	94	Effectiveness of Performance Metrics	101
Key Aspects from the CISA Exam Perspective	94	Tools and Techniques	101
IT Service Provider Acquisition and Management	95	Key Aspects from the CISA Exam Perspective	103
Evaluation Criteria for Outsourcing	95	Quality Assurance and Quality Management in IT	103
Steps for Outsourcing	96	Quality Assurance	104
Outsourcing – Risk Reduction Options	97	Quality Management	105
Provisions for Outsourcing Contracts	97	Key Aspects from the CISA Exam Perspective	105
Role of IS Auditors in Monitoring Outsourced Activities	97	Summary	105
Globalization of IT Functions	97	Chapter Review Questions	107
Outsourcing and Third-Party Audit Reports	98		
Monitoring and Review of Third-Party Services	98		

5

Information Systems Acquisition and Development 111

Project Management Structure	111	Software Reengineering and Reverse Engineering	123
Project Roles and Responsibilities	112	Key Aspects from the CISA Exam Perspective	123
Project Objectives, OBS, and WBS	116	Control Identification and Design	124
Key Aspects from the CISA Exam Perspective	117	Check Digits	125
Business Case and Feasibility Analysis	117	Parity Bits	125
Business Cases	118	Checksums	126
Feasibility Analysis	118	Forward Error Control	126
The IS Auditor's Role in Business Case Development	119	Data Integrity Principles	126
System Development Methodologies	119	Decision Support Systems	127
SDLC Models	119	Decision Trees	128
SDLC phases	120	Key Aspects from the CISA Exam Perspective	128
Software Development Methods	121	Summary	130
		Chapter Review Questions	131

6

Information Systems Implementation 135

Testing Methodology	135	Phased Changeover	144
Unit Testing	136	Abrupt Changeover	144
Integration Testing	136	Key Aspects from the CISA Exam Perspective	145
System Testing	137	Post-Implementation Review	145
Testing Approach	140	Key Aspects from the CISA Exam Perspective	146
Testing Phases	141	Summary	146
Key Aspects from the CISA Exam Perspective	142	Chapter Review Questions	148
System Migration	143		
Parallel Changeover	144		

7

Information Systems Operations 151

Understanding Common Technology Components	152	Key Aspects from a CISA Exam Perspective	162
The Types of Servers	152	Change Management, Configuration Management, and Patch Management	162
Universal Serial Bus	152	Change Management Process	162
Radio Frequency Identification	153	Patch Management	163
IT Asset Management	155	Configuration Management	163
Performance Reports	156	Emergency Change Management	163
Job Scheduling	157	Backout Process	164
End User Computing	157	The Effectiveness of a Change Management Process	164
System Performance Management	158	Key Aspects from a CISA Exam Perspective	164
Nucleus (Kernel) Functions	158	IT Service-Level Management	165
Utility Programs	158	Evaluating the Database Management Process	165
Parameter Setting for the Operating System	158	Advantages of Database Management	166
Registry	158	Database Structures	166
Activity Logging	159	Key Aspects from a CISA Exam Perspective	171
Software Licensing Issues	159	Summary	172
Source Code Management	159	Chapter Review Questions	173
Capacity Management	160		
Key Aspects from a CISA Exam Perspective	160		
Problem and Incident Management	160		
Network Management Tools	161		

8

Business Resilience 177

Business Impact Analysis	177	Key Aspects from the Perspective of the CISA Exam	182
Key Aspects from the Perspective of the CISA Exam	179	System Resiliency	182
Data Backup and Restoration	179	Application Resiliency – Clustering	182
Types of Backup Strategy	179	Telecommunication Network Resiliency	183
Storage Capacity for Each Backup Scheme	181		

Business Continuity Plan	184	Key Aspects from the CISA Exam Perspective	191
Steps of the BCP Life Cycle	184	Recovery Time Objective (RTO) and Recovery Point Objective (RPO)	192
Contents of the BCP	184	RPO	192
Backup Procedure for Critical Operations	185	RTO and RPO for Critical Systems	193
The Involvement of Process Owners in the BCP	185	RTO and RPO and Maintenance Costs	194
BCP and Risk Assessments	185	RTO, RPO, and Disaster Tolerance	194
Testing the BCP	186	Key Aspects from the CISA Exam Perspective	194
Key Aspects from the Perspective of the CISA Exam	187	Alternate Recovery Sites	195
Disaster Recovery Plan	188	Mirrored Site	195
The BCP versus the DRP	188	Hot Site	196
Key Aspects from the CISA Exam Perspective	190	Warm Site	196
DRP – Test Methods	190	Cold Site	196
Checklist Review	190	Mobile Site	197
Structured Walkthrough	191	Reciprocal Agreement	197
Tabletop Test	191	Summary	197
Simulation Test	191	Summary	198
Parallel Test	191	Chapter Review Questions	199
Full Interruption Test	191		

9

Information Asset Security and Control	203
Information Asset Security Frameworks, Standards, and Guidelines	203
Auditing the Information Security Management Framework	204
Key Aspects from the CISA Exam Perspective	204
Privacy Principles	205
Physical Access and Environmental Controls	205
Environmental Controls	205
Alarm Controls	206
Water and Smoke Detectors	206
Fire Suppression Systems	207
Physical Access Control	208
Key Aspects from the CISA Exam Perspective	209
Identity and Access Management	210
Access Control Categories	211
Default Deny Policy – Allow All Policy	212
Degaussing (Demagnetizing)	212
Naming Convention	213
Single Sign-On	213
Key Aspects from the CISA Exam Perspective	214

Biometrics	215	Types of Biometric Attacks	216
Biometrics Accuracy Measure	215	Summary	217
Control over the Biometric Process	216	Chapter Review Questions	218

10

Network Security and Control 223

Network and Endpoint Devices	223	VPNs – security risks	238
Open System Interconnection (OSI) Layers	223	VPNs – Technical Aspects	238
Networking Devices	225	Key Aspects from the Perspective of the CISA Exam	238
Network Devices and the OSI Layer	226	Voice over Internet Protocol (VoIP)	238
Network Physical Media	227	Key Aspects from the CISA Exam Perspective	240
Identifying the Risks of Physical Network Media	228	Wireless Networks	241
Network Protocols	229	Enabling MAC Filtering	241
Key Aspects from the CISA Exam Perspective	230	Enabling Encryption	242
Firewall Types and Implementation	231	Disabling a Service Set Identifier (SSID)	242
Types of Firewalls	231	Disabling DHCP	243
What is a Bastion Host?	232	Common Attack Methods and Techniques for a Wireless Network	243
What is a Proxy?	233	Key Aspects from the CISA Exam Perspective	244
Types of Firewall Implementation	233	Email Security	245
The Firewall and the Corresponding OSI layer	236	Key Aspects from the CISA Exam Perspective	246
Key Aspects from the CISA Exam Perspective	236	Summary	246
VPN	237	Chapter Review Questions	248
Types of VPN	237		

11

Public Key Cryptography and Other Emerging Technologies 253

Public Key Cryptography	253	Methods	258
Symmetric Encryption versus Asymmetric Encryption	254	Key Aspects from the CISA Exam Perspective	258
Encryption Keys	255	Elements of PKI	259
The Hash of the Message	257	PKI Terminology	259
Combining Symmetric and Asymmetric		Processes Involved in PKI	260

Certifying Authority versus Registration Authority	260	Cloud Computing – the IS Auditor’s Role	263
Key Aspects from the CISA Exam Perspective	261	Virtualization	264
Cloud Computing	261	Mobile Computing	265
Cloud Computing – Deployment Models	262	Internet of Things (IoT)	266
Types of Cloud Services	263	Summary	266
		Chapter Review Questions	267

12

Security Event Management 271

Security Awareness Training and Programs	271	Key Aspects from the CISA Exam Perspective	283
Participants	272	Security Monitoring Tools and Techniques	283
Security Awareness Methods	272	IDS	283
Social Engineering Attacks	272	IPS	286
Evaluating the Effectiveness of Security Programs	272	Honeypots and Honey Nets	286
Key Aspects from the CISA Exam Perspective	273	Key Aspects from the CISA Exam Perspective	286
Information System Attack Methods and Techniques	273	Incident Response Management	287
Malicious Code	275	Computer Security Incident Response Team	287
Biometric Attacks	277	Key Aspects from the CISA Exam Perspective	288
Key Aspects from the CISA Exam Perspective	278	Evidence Collection and Forensics	288
Security Testing Tools and Techniques	278	Chain of Custody	288
General Security Controls	279	Key Elements of Computer Forensics	289
Network Penetration Tests	281	Summary	291
		Chapter Review Questions	292

Index 295

Other Books You May Enjoy 300

Preface

Certified Information System Auditor (CISA) is one of the most sought-after courses in the field of auditing, control, and information security. CISA is a globally recognized certification that validates your expertise and gives you the leverage you need to advance in your career. CISA certification is key to a successful career in IT.

A CISA certification can showcase your expertise and assert your ability to apply a risk-based approach to planning, executing, and reporting on projects and engagements. It helps you gain instant credibility in your interactions with internal stakeholders, regulators, external auditors, and customers.

As per ISACA's official website (www.isaca.org), the average salary of a CISA holder is US\$149,000.

Online Exam-Prep Tools

With this book, you will unlock unlimited access to our online exam-prep platform (*Figure 0.1*). This is your place to practice everything you've learned in the book.

Dashboard

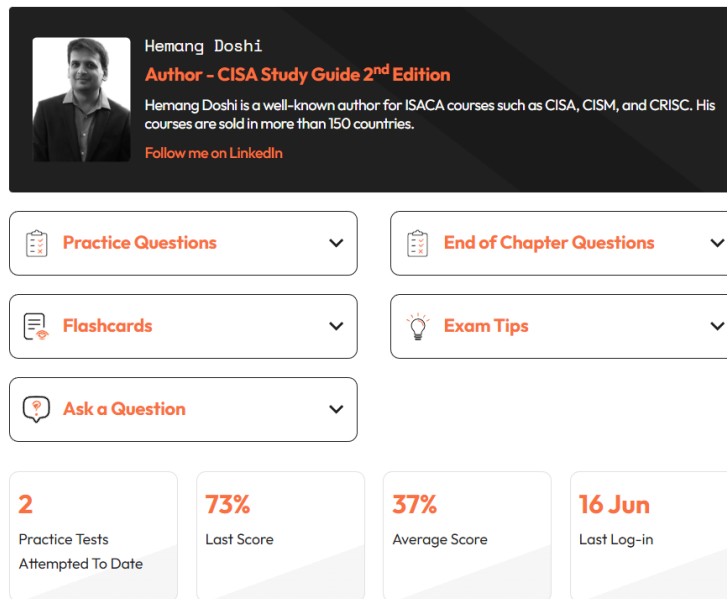


Figure 0.1: Online exam-prep platform

Sharpen your concepts with multiple sets of practice questions and interactive flashcards, accessible from all modern web browsers. If you get stuck, you can raise your concerns with the author directly through the website. Before doing that, make sure to go through the list of resolved doubts as well. These are based on questions asked by other users. Finally, go through the exam tips on the website to make sure you are well prepared.

Who This Book Is For

If you are a passionate auditor, risk practitioner, IT professional, or security professional, and are planning to enhance your career by obtaining a CISA certificate, this book is for you.

What This Book Covers

Chapter 1, Audit Planning, deals with the audit processes, standards, guidelines, practices, and techniques that an **Information Systems (IS)** auditor is expected to use during audit assignments. An IS auditor must have a detailed knowledge of IS processes, business processes, and risk management processes in order to protect an organization's assets.

Chapter 2, Audit Execution, covers project management techniques, sampling methodology, and audit evidence collection techniques. It provides details regarding data analysis techniques, reporting and communication techniques, and quality assurance processes.

Chapter 3, IT Governance, provides an introduction to IT governance and aspects related to IT enterprise governance. Enterprise governance includes the active involvement of management in IT. Effective IT governance and management involves an organization's structure as well as IT standards, policies, and procedures.

Chapter 4, IT Management, walks you through various aspects of designing and approving an IT management policy and effective information security governance. It will also teach you how to audit and evaluate IT resource management, along with services provided by third-party service providers, while also covering IT performance monitoring and reporting.

Chapter 5, Information Systems Acquisition and Development, provides information about project governance and management techniques. This chapter discusses how an organization evaluates, develops, implements, maintains, and disposes of its information systems and related components.

Chapter 6, Information Systems Implementation, covers various aspects of IS implementation. The implementation process comprises a variety of stages, including system migration, infrastructure deployment, data conversion or migration, user training, post-implementation review, and user acceptance testing.

Chapter 7, Information Systems Operations, explains how to identify risks related to technology components and how to audit and evaluate IT service management practices; systems performance management; problem and incident management policies and practices; change, configuration, release, and patch management processes; and database management processes.

Chapter 8, Business Resilience, covers all aspects of business impact analysis, system resiliency, data backup, storage and restoration, the business continuity plan, and disaster recovery plans.

Chapter 9, Information Asset Security and Control, discusses the information security management framework, privacy principles, physical access and environmental controls, and identity and access management.

Chapter 10, Network Security and Control, provides an introduction to various components of networks, network-related risks and controls, types of firewalls, and wireless security.

Chapter 11, Public Key Cryptography and Other Emerging Technologies, details various aspects of public key cryptography, cloud computing, virtualization, mobile computing, and the Internet of Things.

Chapter 12, Security Event Management, takes you through the process of evaluating an organization's information security and privacy policies and practices in depth. It also discusses various types of IS attack methods and techniques and covers different security monitoring tools and techniques, as well as evidence collection and forensics methodology.

How to Get the Most out of This Book

This book is directly aligned with ISACA's CISA Review Manual (27th Edition) and covers all the topics that a CISA aspirant needs to grasp in order to pass the exam. The key aspect of this book is its use of simple language, which makes it ideal for candidates with non-technical backgrounds. At the end of each topic, key pointers from the CISA exam perspective are presented in a tabular format. This is the unique feature of this book. It also contains more than 850 exam-oriented practice questions that are designed in consideration of the language and testing methodology used in an actual CISA exam.

It is advisable to stick to the following steps when preparing for the CISA exam:

Step 1: Read the complete book.

Step 2: Attempt the end-of-chapter practice questions in each chapter before moving on to the next one.

Step 3: Go through ISACA's QAE book or database.

Step 4: Refer to ISACA's CISA Review Manual.

Step 5: Memorize key concepts using the flashcards on the website.

Step 6: Attempt the online practice question sets. Make a note of the concepts you are weak in, revisit those in the book, and re-attempt the practice questions.

Step 7: Keep repeating the practice question sets till you are able to answer all the questions in each practice set correctly within the time limit.

Step 8: Review exam tips on the website.

CISA aspirants will gain a lot of confidence if they approach their preparation as per the mentioned steps.

Recorded Lectures

This book is also available in video lecture format along with 200+ exam-oriented practice questions on Udemy. Buyers of this book are entitled to 30% off of Hemang Doshi's recorded lectures. For a discount coupon, please write to training@hemangdoshiacademy.in.

Requirements for the Online Content

The online content includes interactive elements like practice questions, flashcards, and exam tips. For optimal experience, it is recommended that you use the latest version of a modern, desktop (or mobile) web browser such as Edge, Chrome, Safari, or Firefox.

Instructions for Unlocking the Online Content

To unlock the online content, you will need to create an account on our exam-prep website using the unique sign-up code provided in this book.

Where to find the sign-up code

You can find your unique sign-up code at the start of *Chapter 7, Information Systems Operations*

1. Visit the section mentioned above. There, you'll find your unique sign-up link and code. Open the link, make a note of the sign-up code, and return to this section.

2. Open the sign-up link. Once the page loads, enter your name and email address (1).



Sign Up

The sign-up form contains the following elements:

- Name** and **Email** input fields: These two fields are grouped together and enclosed in a red rectangular box. A red circle with the number "1" is positioned to the right of this box.
- Password** input field: Located below the Name and Email fields, it includes a toggle icon for password visibility.
- Sign Up Code** input field: Located below the Password field, it includes a help icon (i) to its right.
- ☐ **Email me when new features or practice resources are added.** This checkbox is followed by a help icon (i).
- By signing up you will accept our [terms & conditions](#) and [privacy policies](#).**
- SIGN UP** button: A black button with white text.
- Already have an account? [Login](#)**

Figure 0.2: Enter your name and email address in the sign-up form

3. Create a strong alphanumeric password (2) (minimum 6 characters in length):



Sign Up





☐ Email me when new features or practice resources are added. 

By signing up you will accept our [terms & conditions](#) and [privacy policies](#).

Already have an account? [Login](#)

Figure 0.3: Create a strong password in the sign-up form

4. Enter the unique sign-up code (3). As mentioned in *Step 1*, the sign-up code can be found at the start of *Chapter 7, Information Systems Operations*. Once you have entered the code, click the Sign Up button.



Sign Up

The image shows a "Sign Up" form with four input fields: "Name", "Email", "Password", and "Sign Up Code". The "Sign Up Code" field is highlighted with a red rectangular border, and a red circle with the number "3" is placed to its right. Below the fields is a checkbox for "Email me when new features or practice resources are added." and a line of text stating "By signing up you will accept our terms & conditions and privacy policies." At the bottom is a black "SIGN UP" button. Below the button is a link that says "Already have an account? Login".

Name

Email

Password

Sign Up Code

☐ Email me when new features or practice resources are added.

By signing up you will accept our [terms & conditions](#) and [privacy policies](#).

SIGN UP

Already have an account? [Login](#)

Figure 0.4: Enter the unique sign-up code

Important

You only need to input the sign-up code once. After your account is created, you will be able to access the website using just your email address and password from any device.

5. You can select the checkbox (4) if you wish to be notified whenever we add new practice resources or features to the platform.



Sign Up

☐ Email me when new features or practice resources are added. ⓘ

By signing up you will accept our [terms & conditions](#) and [privacy policies](#).

SIGN UP

Already have an account? [Login](#)

Figure 0.5: Select the checkbox to receive notifications about new features or practice resources

6. Upon a successful sign-up, you will be redirected to the dashboard (see Figure 0.6). Going forward, you will simply need to login using your email address and password to access the dashboard.

Dashboard

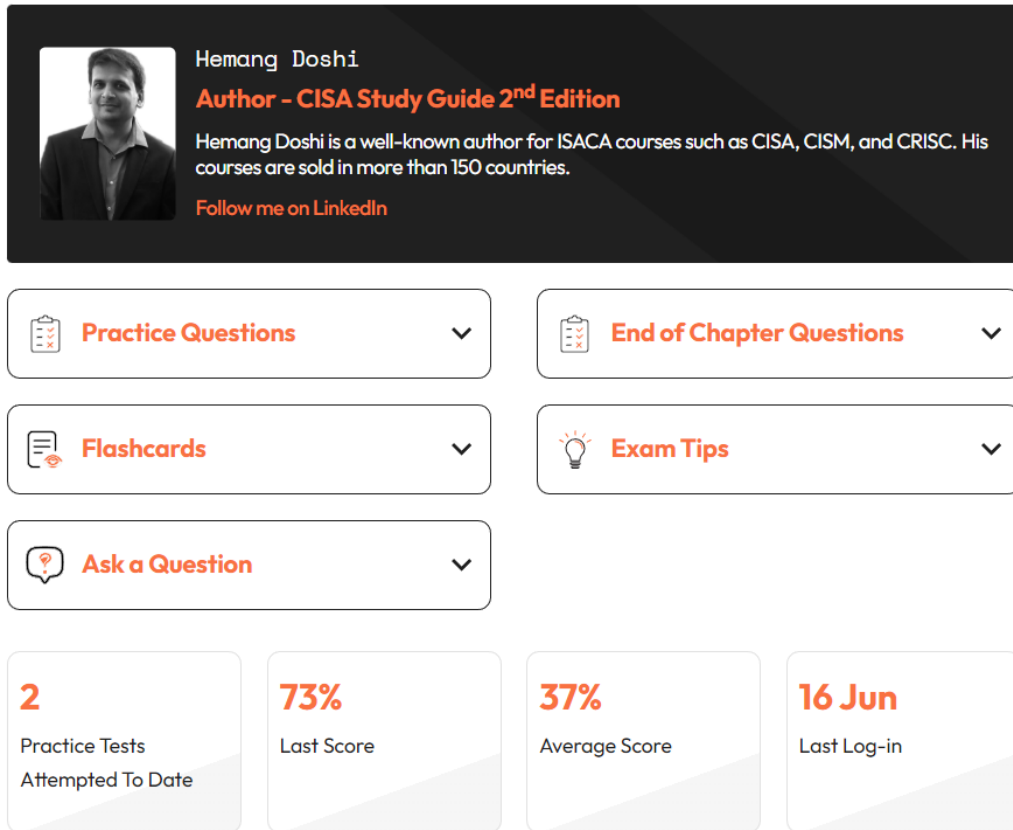


Figure 0.6: Online exam-prep platform dashboard

Note

If you are facing issues signing up, reach out to customercare@packt.com.

Quick Access to the Website

If you have successfully signed up, it is recommended that you bookmark this link for quick access to the website: <https://packt.link/cisastudyguidewebsite>. Click the Login link on the top-right corner of the page to open the login page. Use the credentials you created in *Steps 2* and *3* of the *Instructions for Unlocking the Online Content* section above.

Alternatively, you can scan the following QR code to open the website:



Figure 0.7: QR Code for the CISA online exam-prep platform

Conventions Used

New terms and important words are shown like this: “An **Information Systems (IS)** audit examines the management controls in IT infrastructure and business applications.”

Tips or important notes

Appear like this.

Get in Touch

Feedback from our readers is always welcome.

General feedback: If you have any questions about this book, please mention the book title in the subject of your message and email us at customercare@packtpub.com.

Errata: Although we have taken every care to ensure the accuracy of our content, mistakes do happen. If you have found a mistake in this book, we would be grateful if you could report this to us. Please visit www.packtpub.com/support/errata and complete the form.

Piracy: If you come across any illegal copies of our works in any form on the Internet, we would be grateful if you could provide us with the location address or website name. Please contact us at copyright@packt.com with a link to the material.

If you are interested in becoming an author: If there is a topic that you have expertise in and you are interested in either writing or contributing to a book, please visit authors.packtpub.com.

Share Your Thoughts

Once you've read *CISA – Certified Information Systems Auditor Study Guide, Second Edition*, we'd love to hear your thoughts! Please [click here](#) to go straight to the Amazon review page for this book and share your feedback.

Your review is important to us and the tech community and will help us make sure we're delivering excellent quality content.

Download a Free PDF Copy of This Book

Thanks for purchasing this book!

Do you like to read on the go but are unable to carry your print books everywhere?

Is your eBook purchase not compatible with the device of your choice?

Don't worry, now with every Packt book you get a DRM-free PDF version of that book at no cost.

Read anywhere, any place, on any device. Search, copy, and paste code from your favorite technical books directly into your application.

The perks don't stop there, you can get exclusive access to discounts, newsletters, and great free content in your inbox daily.

Follow these simple steps to get the benefits:

1. Scan the QR code or visit the link below:



2. Submit your proof of purchase.
3. That's it! We'll send your free PDF and other benefits to your email directly.

Audit Planning

This Book Comes with Free Online Content

With this book, you get unlimited access to web-based CISA exam prep tools which include practice questions, flashcards, exam tips, and more.



Hemang Doshi
Author - CISA Study Guide 2nd Edition
Hemang Doshi is a well-known author for ISACA courses such as CISA, CISM, and CRISC. His courses are sold in more than 150 countries.
[Follow me on LinkedIn](#)

 **Practice Questions** ▼

 **End of Chapter Questions** ▼

 **Flashcards** ▼

 **Exam Tips** ▼

 **Ask a Question** ▼

Figure 1.1: CISA online practice resources dashboard

To unlock the content, you'll need to create an account using your unique sign-up code provided with this book. Refer to the *Instructions for Unlocking the Online Content* section in the *Preface* on how to do that.

Accessing the Online Content

If you've already created your account using those instructions, visit packt.link/cisastudyguidewebsite or scan the following QR code to quickly open the website.



Figure 1.2: QR Code to access CISA online practice resources main page

Once there, click the `Login` link in the top-right corner of the page to access the content using your credentials.

An **Information Systems (IS)** audit examines the management controls in IT infrastructure and business applications. The objective of an IS audit is to evaluate whether implemented controls are efficient and effective in protecting information assets, maintaining data integrity, and ensuring the availability of assets in order to meet the organization's goals and objectives.

An audit plan is a step-wise approach to be followed to conduct an audit. It helps to establish the overall audit process in an effective and efficient manner. An audit plan should be aligned with the audit charter of the organization. To plan an audit, the IS auditor is required to have a thorough understanding of business processes, business applications, and relevant controls. Audit planning includes both short- and long-term planning.

The following topics will be covered in this chapter:

- The content of an audit charter
- Audit planning
- Business process applications and controls
- Types of controls
- Risk-based audit planning
- Types of audits and assessment

The Contents of an Audit Charter

An internal audit is an independent activity and should ideally be reported to a board-level committee. In most organizations, the internal audit function reports to the audit committee of the board. This helps to protect the independence of the audit function. Audit reporting may be biased in the absence of an independent audit function.

The independence of the audit function is further ensured through a management-approved **audit charter**.

The following figure shows the features of an audit charter:

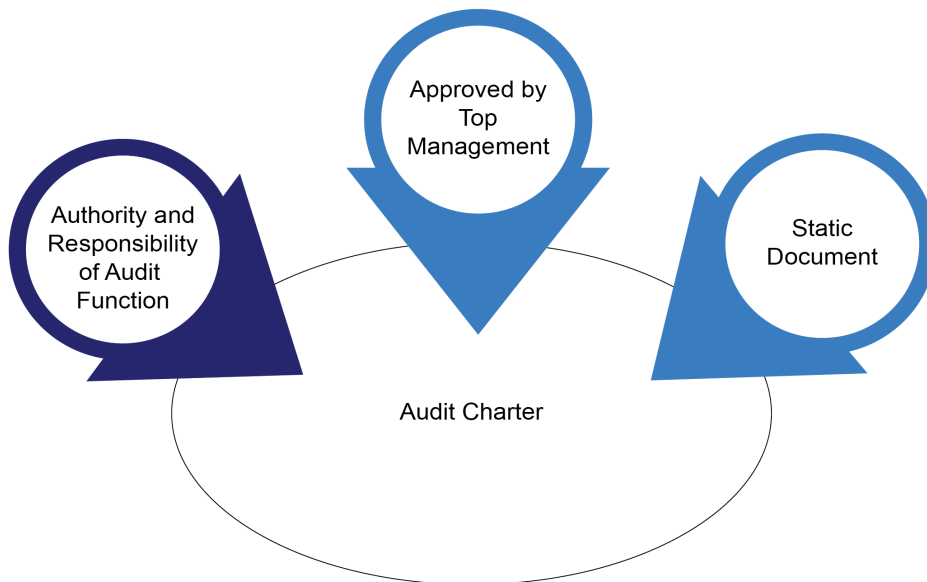


Figure 1.3: Features of an audit charter

The CISA candidate should note the following features of the audit charter:

- An audit charter is a formal document defining the internal audit's objective, authority, and responsibility. The audit charter covers the entire scope of audit activities. An audit charter must be approved by senior management.
- An audit charter should not be changed too often as it defines the objective of the audit function, and hence procedural aspects should not be included. Also, it is recommended to not include a detailed annual audit calendar including things such as planning, resource allocation, and other details such as audit fees and expenses.
- An audit charter should be reviewed minimum annually to ensure that it is aligned with business objectives.

Essentially, an auditor's activities are impacted by the charter of the audit department, which authorizes the accountability and responsibility of the audit department.

An audit charter includes the following:

- The mission, purpose, and objective of the audit function
- The scope of the audit function
- The responsibilities of management
- The responsibilities of internal auditors
- The authorized personnel of the internal audit work

If an audit is outsourced to an audit firm, the objective of the audit, along with its detailed scope, should be incorporated in an audit engagement letter.

An audit charter forms the basis of structured audit planning. Activities relevant to audit planning are discussed in the next section.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
Who should approve the audit charter of an organization?	Senior management
What should the content of an audit charter be?	The scope, authority, and responsibilities of the audit function
What is the prime reason for the review of an organization chart?	An organization chart is a diagram that shows the structure of an organization and the responsibilities and authorities of various positions and job roles. An IS auditor reviews the organization chart to understand the authority and responsibility of individuals.
The actions of an IS auditor are primarily influenced by:	The audit charter
Which document provides the overall authority for an auditor to perform an audit?	The audit charter

CISA Questions	Possible Answers
What is the primary reason for the audit function directly reporting to the audit committee?	The audit function must be independent of the business function and should have direct access to the audit committee of the board

Table 1.1: Key aspects from the CISA exam perspective

Audit Planning

CISA aspirants should understand the following important terms before reading about the different aspects of audit planning:

- **Audit universe:** An inventory of all the functions/processes/units under the organization.
- **Qualitative risk assessment:** In a qualitative risk assessment, risk is assessed using qualitative parameters such as high, medium, and low.
- **Quantitative risk assessment:** In a quantitative risk assessment, risk is assessed using numerical parameters and is quantified; for example, for a 50% chance of failure, the amount at risk is 1000 \$.
- **Risk factors:** Factors that have an impact on risk. The presence of such factors increases the risk, whereas their absence decreases the risk.

All the preceding elements are important prerequisites for the design of a structured audit plan. Next, you will explore the benefits of a structured and well-designed audit plan.

Benefits of Audit Planning

Audit planning is the initial stage of the audit process. It helps to establish the overall audit strategy and the technique to complete the audit. Audit planning makes the audit process more structured and objective oriented.

An audit plan helps to determine the following:

- The objectives of the audit
- The scope of the audit
- The periodicity of the audit
- The members of the audit team
- The method of audit

A well-thought-out audit plan helps the auditor:

- Focus on high-risk areas
- Identify required resources
- Estimate a budget
- Work to a defined structure, which ultimately benefits the auditor as well as the auditee units

Selection Criteria

An IS auditor should have a sufficient understanding of the various criteria for the selection of audit processes.

One such criterion is to have an audit universe. All the significant processes of the enterprise's business should be included in the audit universe.

Each business process may undergo a qualitative or quantitative risk assessment by evaluating the risk with respect to relevant risk factors. Risk factors influence the frequency of the audit. After the risk is determined using qualitative or quantitative techniques, the resultant risk is evaluated against the criteria set by management. The audit plan can then be designed to consider all high-risk areas.

Reviewing Audit Planning

The audit plan should be reviewed and approved by senior management. Generally, approval is obtained from the audit committee of the board, but sometimes, the board might also grant approval.

The audit plan should be flexible enough to address any changes in the risk environment (that is, new regulatory requirements, changes in market conditions, and other risk factors).

The approved audit plan should be communicated promptly to the following groups:

- Senior management
- Business functions and other stakeholders
- The internal audit team

Individual Audit Assignments

The next step after the annual planning is to plan individual audit assignments. The IS auditor must understand the overall environment under review. While planning an individual audit assignment, an IS auditor should consider the following:

- Prior audit reports
- Risk assessment reports

- Regulatory requirements
- Standard operating processes
- Technological requirements

Like every other process, the audit process will have some input and output. Elements of input include knowledge about the organization's objective and processes and knowledge about regulatory requirements, audit resources, and logistics.

Processing involves the identification and review of policies, standards, and guidelines; setting the audit scope; conducting a risk analysis; and developing an audit approach.

The output of the audit process is the audit report, which includes the auditor's observations and recommendations.

The following diagram will help you understand the input and output elements of the audit process:

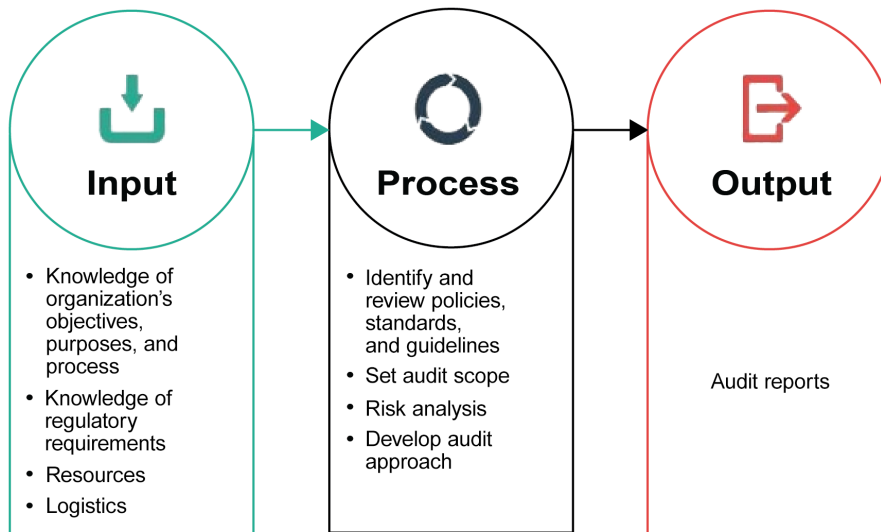


Figure 1.4: Audit process flow

For effective audit planning, it is of utmost importance that the IS auditor has a thorough understanding of business process applications and controls. The basic architecture of some commonly used applications and their associated risks are discussed in the next section.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the first step in risk-based audit planning?	Identifying areas of high risk
What is a major benefit of risk-based audit planning?	The utilization of resources for high-risk areas
What is the first step of conducting a physical security review of a data center?	Evaluating vulnerabilities and threats related to data center location

Table 1.2: Key aspects from the CISA exam perspective

Business Process Applications and Controls

Working knowledge of the business environment and business objectives is required to plan a risk-based audit. The IS auditor should have a sufficient understanding of the overall architecture and the technical specifications of the various applications used by the organization and the risks associated with them.

In understanding the issues and current risks facing the business, the IS auditor should focus on areas that are most meaningful to management. To effectively audit business application systems, an IS auditor is required to gain a thorough understanding of the system under the scope of the audit.

The following are some of the widely used applications in business processes. The CISA candidate should be aware of the risks associated with each of them.

E-Commerce

Start with understanding how e-commerce works:

- Single-tier architecture runs on a single computer, that is, a client-based application.
- Two-tier architecture includes a client and server.
- Three-tier architecture consists of the following:
 - A presentation tier (for interaction with the user)
 - An application tier (for processing)
 - A data tier (for the database)

The risks are as follows:

- A compromise of confidential user data
- Data integrity issues due to unauthorized alterations
- An unavailable system that impacts business continuity
- The repudiation of transactions by either party

The IS auditor's roles are as follows:

- To review the overall security architecture related to firewalls, encryption, networks, and PKI to ensure confidentiality, integrity, availability, and the non-repudiation of e-commerce transactions
- To review the process of log capturing and monitoring for e-commerce transactions
- To review the incident management process
- To review the effectiveness of controls implemented for privacy laws
- To review anti-malware controls
- To review business continuity arrangements

Electronic Data Interchange (EDI)

Start with understanding how EDI works:

- EDI is the online transfer of data or information between two enterprises.
- EDI ensures an effective and efficient transfer platform without the use of paper.
- EDI applications contain processing features such as transmission, translation, and the storage of transactions flowing between two enterprises.
- An EDI setup can be either traditional EDI (batch transmission within each trading partner's computer) or web-based EDI (accessed through an internet service provider).

The risks are as follows:

- One of the biggest risks applicable to EDI is transaction authorization.
- Due to electronic interactions, no inherent authentication occurs.
- There could be related uncertainty with a specific legal liability when there is no trading partner agreement in place.
- Any performance-related issues with EDI applications could negatively impact both parties.
- Other EDI-related risks include unauthorized access, data integrity and confidentiality, and the loss or duplication of EDI transactions.

The IS auditor's roles are as follows:

- To verify the data's confidentiality, integrity, and authenticity, as well as the non-repudiation of transactions
- To determine invalid transactions and data before they are uploaded to the system
- To determine the accuracy, validity, and reasonableness of data
- To validate and ensure the reconciliation of totals between the EDI system and the trading partner's system

The IS auditor should also verify the use of some controls to validate the sender as follows:

- The use of control fields within an EDI message
- The use of VAN sequential control numbers or reports
- Acknowledgment from the sender for the transactions

The auditor should also verify the availability of the following controls:

Control requirements for inbound transactions:

- A log of each inbound transaction on receipt.
- Segment count totals should be built into the transaction set trailer.
- Checking digits to detect transposition and transcription errors.

Control requirements for outbound transactions:

- Transactions to be compared with the trading partner's profile
- Proper segregation of duties for high-risk transactions
- A log to be maintained for outbound transactions

EDI audits also involve the use of audit monitors (to capture EDI transactions) and expert systems (to evaluate transactions).

Point of Sale (POS)

Start with understanding how POS works:

- Debit and credit card transactions are the most common examples of POS.
- Data is captured at the time and place of sale.

The risks of POS are as follows:

- The risk of skimming, that is, the unauthorized capturing of card data with the purpose of duplicating the card
- The risk of unauthorized disclosure of PINs

The IS auditor's objectives are as follows:

- To determine that data used for authentication (PIN/CVV) is not stored in the local POS system
- To determine that the cardholder's data (either at rest or in transit) is encrypted
- To determine compliance with regulatory requirements.

Electronic Banking

Start with understanding how it works:

- E-banking websites and mobile-based systems are integrated with the bank's core system to support automatic transactions without any manual intervention.
- Automated processing improves processing speed and reduces opportunities for human error and fraud.
- Electronic banking increases the dependence on the internet and communication infrastructure.

Two of the risks of this are as follows:

- Heavy dependence on internet service providers, telecommunication companies, and other technology firms
- Cyber risks such as system hacking, system unavailability, and a lack of transaction integrity

The IS auditor's objectives are as follows:

- To validate the effectiveness of the governance and detect any oversight in e-banking activities
- To determine arrangements for the confidentiality, integrity, and availability of e-banking infrastructure
- To determine the effectiveness of security controls with respect to authentication and the non-repudiation of electronic transactions
- To review the effectiveness of the controls implemented for privacy laws
- To review anti-malware controls
- To review business continuity arrangements

Electronic Funds Transfer (EFT)

Start with understanding how EFT works:

- Through EFT, money can be transferred from one account to another electronically, that is, without cheque writing and cash collection procedures.

Some of the risks are as follows:

- Heavy dependence on internet service providers, telecommunication companies, and other technology firms
- Cyber risks such as system hacking, system unavailability, and a lack of transaction integrity

The IS auditor's objectives are as follows:

- To determine the availability of two-factor authentication for secure transactions.
- To ensure that systems and communication channels have undergone appropriate security testing.
- To determine that transaction data (either at rest or in transit) is encrypted.
- To determine the effectiveness of controls on data transmission.
- To review security arrangements for the integrity of switch operations: an EFT switch connects with all equipment in the network.
- To review the log capturing and monitoring process of EFT transactions. In the absence of paper documents, it is important to have an alternate audit trail for each transaction.

Image Processing

Start with understanding how image processing works:

- An image processing system processes, stores, and retrieves image data.
- An image processing system requires huge amounts of storage resources and strong processing power for scanning, compression, displays, and printing.
- Such systems are capable of identifying colors and shades.
- The use of image processing (in place of paper documents) can result in increased productivity, immediate retrieval of documents, enhanced control over document storage, and efficient disaster recovery procedures.

Some of the risks are as follows:

- Implementation without appropriate planning and testing may result in system failure.
- The workflow system may need to be completely redesigned to integrate with the image processing system.
- Traditional controls and audit processes may not be applicable to image processing systems. New controls must be designed for automated processes.
- Cyber risks such as system hacking, system unavailability, and a lack of transaction integrity are present.

The IS auditor's objectives are as follows:

- To determine the effectiveness of controls on the inputs, processing, and outputs of image processing systems
- To determine the reliability of the scanners used for image processing
- To review the retention process for original documents
- To determine that original documents are retained at least until a good image has been captured
- To review the confidentiality, integrity, and availability arrangements of image processing systems
- To review the training arrangements for employees to ensure that the processes of image scanning and storing are maintained as per the quality control matrix

Artificial Intelligence and Expert Systems

Artificial intelligence (AI) and expert systems do the following:

- Capture and utilize the knowledge and experience of individuals
- Improve performance and productivity
- Automate skilled processes without manual intervention

A knowledge base in AI contains information about a particular subject and rules for interpreting that information. The components of a knowledge base include the following:

- **Decision trees:** Questions to lead the user through a series of choices
- **Rules:** Rules that use “if” and “then” conditions
- **Semantic nets:** A knowledge base that conveys meaning
- **Knowledge interface:** Stores expert-level knowledge
- **Data interface:** Stores data for analysis and decision-making

The risks are as follows:

- Incorrect decisions made or incorrect actions performed by the system due to incorrect assumptions, formulas, or databases in the system
- Cyber risks such as system hacking, system unavailability, and a lack of transaction integrity

The IS auditor's roles are as follows:

- To assess the applicability of AI in various business processes and determine the associated risks
- To review adherence to documented policies and procedures
- To review the appropriateness of the assumptions, formulas, and decision logic built into the system
- To review the change management process for updating the system
- To review the security arrangements to maintain the confidentiality, integrity, and availability of the system

Once the IS auditor understands the basic architecture of the business applications and associated risks, the next step is to understand the appropriateness and effectiveness of the implemented controls to mitigate those risks.

Key Aspects from the CISA Exam Perspective

The following covers the important aspects from a CISA exam perspective:

CISA Questions	Possible Answers
What is the major risk of EDI transactions?	The absence of agreement (in the absence of a trading partner agreement, there could be uncertainty related to specific legal liability).
What is the objective of encryption?	To ensure the integrity and confidentiality of transactions.
How are inbound transactions controlled in an EDI environment?	Inbound transactions are controlled via logs of the receipt of inbound transactions, the use of segment count totals, and the use of check digits to detect transposition and transcription errors.
What is the objective of key verification control?	Key verification is a method where data is entered a second time and compared with the initial data entry to ensure that the data entered is correct. This is generally used in EFT transactions, where another employee re-enters the same data to perform this check before any money is transferred.

CISA Questions	Possible Answers
What is the objective of non-repudiation?	Non-repudiation ensures that a transaction is enforceable and that the claimed sender cannot later deny generating and sending the message.
What is the most important component of the AI/expert system area?	Knowledge base: The knowledge base contains specific information or fact patterns associated with a particular subject matter and the rules for interpreting these facts. Therefore, strict access control should be implemented and monitored to ensure the integrity of the decision rules.

Table 1.3: Key aspects from the CISA exam perspective

Types of Controls

An internal control is a process used to safeguard the assets of an organization. Assets can include systems, data, people, hardware, or the reputation of the organization. Internal controls help in achieving the objectives of the organization by mitigating various risks.

Internal controls are implemented through policies, procedures, practices, and organizational structures to address risks. Internal controls provide reasonable assurance to management about the achievement of business objectives. Through internal controls, risk events are prevented or detected and corrected.

Top management is responsible for implementing a culture that supports efficient and effective internal control processes.

Effective controls in an organization can be categorized into preventive, detective, deterrent, and corrective as shown in the following figure:

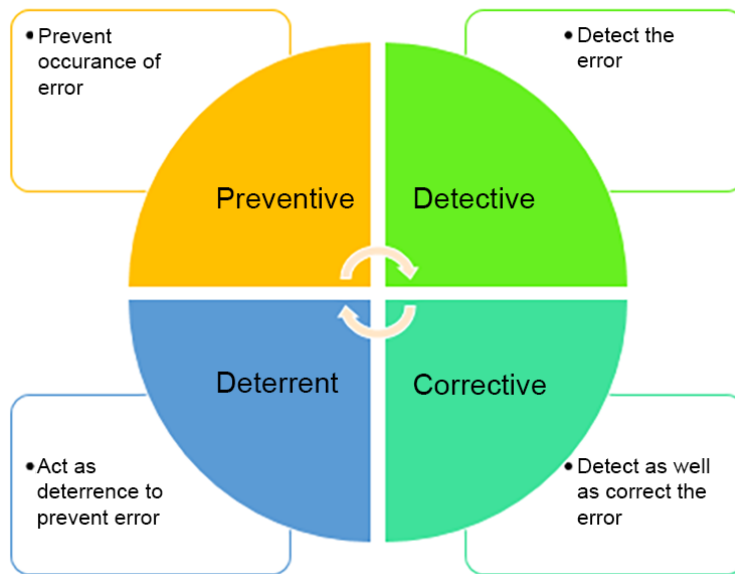


Figure 1.5: Types of effective controls in an organization

You will now explore these control types in detail.

Preventive Controls

Preventive controls are designed to be implemented in such a way that prevents a threat event and thus avoids any potential impact of that threat event.

Examples of preventive controls include the following:

- The use of qualified personnel
- The segregation of duties
- The use of SOPs to prevent errors
- Transaction authorization procedures
- Edit checks
- Access control procedures
- Firewalls
- Physical barriers

Detective Controls

Detective controls are designed to detect a threat event once that event has occurred. Detective controls aim to reduce the impact of such events.

Examples of detective controls include the following:

- Internal audits and other reviews
- Log monitoring
- Checkpoints in production jobs
- Echo controls in telecommunications
- Error messages over tape labels
- Variance analysis
- Quality assurance

Corrective Controls

Corrective controls, as their name suggests, are designed to minimize the impact of a threat event once it has occurred, and help in restoring, or correcting, a business to normal operations.

Examples of corrective controls include the following:

- Business continuity planning
- Disaster recovery planning
- Incident response planning
- Backup procedures

Deterrent Controls

The purpose of a deterrent control is to issue a warning signal to deter a threat event.

Examples of deterrent controls include the following:

- CCTV cameras or “under surveillance” signs
- Warning signs

The Difference between Preventive and Deterrent Controls

For the CISA exam, it is important to understand the difference between preventive and deterrent controls. When a preventive control is implemented, an intruder is prevented from performing an act. They do not have a choice in whether or not to perform the act.

When a deterrent control is implemented, the intruder is given a warning. Here, the intruder has a choice: either to act as per the warning or ignore the warning.

A locked door to a room is a preventive control. Intruders cannot go through the door. On the other hand, just a warning sign that says “No Entry” is a deterrent control. Intruders can ignore the warning and enter the room.

Apart from the controls you have covered thus far, CISA candidates should also understand compensating controls. It should be noted that the absence of one control can be compensated for by having another strong control.

Compensating Controls

Compensating controls are alternate measures employed to ensure that weaknesses in a system are not exploited. In many cases, a strong control in one area can compensate for a weakness in another area.

For example, in small organizations, the segregation of duties may not always be feasible. In such cases, compensatory controls such as reviews of logs should be implemented.

Similarly, some organizations may prefer to have alternate security measures in place of encryption.

Control Objectives

A control objective is a reason why a control is implemented. Control objectives are linked to business objectives.

A control objective generally addresses the following:

- The effectiveness and efficiency of operational processes. For example, preventive controls attempt to prevent invalid transactions from being processed and assets from being misappropriated. However, detective controls have the objective of detecting errors or fraud that could result in the misstatement of financial statements.
- Adherence to regulatory requirements.
- The protection of assets.

It is advisable to document objectives for each and every control. Periodic reviews and the monitoring of controls are required to validate results against these objectives.

Control Measures

Control measures are implemented to achieve control objectives. Control measures are activities that are taken to prevent, eliminate, or minimize the risk of threat occurrence.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects from a CISA exam perspective:

CISA Questions	Possible Answers
Segregation of duties is an example of which type of control?	Preventive control
Controls that enable a risk or deficiency to be corrected before a loss occurs are known as what?	Corrective controls
Controls that directly mitigate a risk or lack of controls directly acting upon a risk are known as what?	Compensating controls

Table 1.4: Key aspects from the CISA exam perspective

Risk-Based Audit Planning

CISA aspirants are expected to understand the following aspects of risk-based audit planning:

- What is risk?
- Vulnerabilities and threats
- Inherent risk and residual risk
- The advantages of risk-based audit planning
- Audit risk
- The steps of the risk-based audit approach
- The steps of risk assessment
- The four methodologies for risk treatment

What Is Risk?

You will now explore some of the widely accepted definitions of *risk*.

Most of the CISA questions are framed around risk. Therefore, CISA candidates should have a thorough understanding of the term risk, which has multiple definitions/formulas. If you look carefully, every definition speaks either directly or indirectly about two terms: **probability** and **impact**.

Some of the more commonly used definitions of risk are presented here:

- COSO ERM defines risk as “potential events that may impact the entity.”
- The Oxford English Dictionary defines risk as “the probability of something happening multiplied by the resulting cost or benefit if it does.”
- Risk can be defined as the potential for loss, harm, or negative outcomes that may occur during the pursuit of business objectives or activities. It involves uncertainty and the possibility of events or circumstances that could have adverse effects on an organization’s financial, operational, or strategic goals.
- ISO 31000 defines risk as “the effect of uncertainty on objectives.”

In simple words, “risk” is the product of probability and impact:

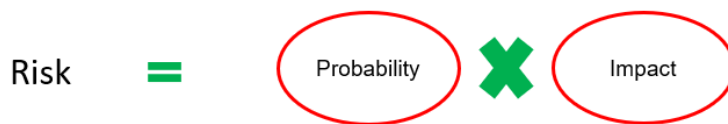


Figure 1.6: Calculation of risk

Probability and impact are equally important when identifying risk. For example, if the probability or likelihood of a product being damaged is very high, with a value of “1,” but that product barely costs anything, the impact is “0” even if the product is damaged.

So, the risk in this scenario would be calculated as follows:

$$\text{Risk} = P * I$$

$$\text{Risk} = 1 * 0 = 0$$

Understanding Vulnerability and Threats

Another way of understanding risk is by understanding the notion of vulnerability and threats. In simple terms, a vulnerability is a weakness and a threat is something that could exploit said weakness. Again, both elements (V and T) should be present in order to constitute a risk.

There is no threat to a useless system, even if it is highly vulnerable. As such, the risk to that system would be nil despite the high vulnerability.

The following table presents the differences between threat and vulnerability:

Vulnerability	Threat
A vulnerability is a weakness in a system. Generally, a vulnerability can be controlled by the organization.	A threat is an element that exploits a weakness. Generally, a threat is not in the control of the organization.
Vulnerabilities are mostly internal elements.	Threats are mostly external elements.
Examples include weak coding, missing anti-virus, and weak access control.	Examples include hackers, malware, criminals, and natural disasters.

Table 1.5: Differences between vulnerabilities and threats

There are various definitions and formulas for risk. However, for CISA certification, please remember only the following two formulas:

$$\text{Risk} = \text{Probability} * \text{Impact}$$

$$\text{Risk} = A * V * T$$

In the second formula, *A*, *V*, and *T* denote the value of assets, the vulnerability of assets, and threats to assets, respectively.

Understanding Inherent Risk and Residual Risk

Inherent risk and residual risk are two important types of risk. A CISA candidate should understand the difference between them:

Inherent Risk	Residual Risk
The risk that an activity poses, excluding any controls or mitigating factors	The risk that remains after taking controls into account
Gross risk – the risk before controls are applied	Net risk – the risk after controls are applied

Table 1.6: Differences between inherent and residual risk

The following is the formula for residual risk:

$$\text{Residual Risk} = \text{Inherent Risk} - \text{Control}$$

Advantages of Risk-Based Audit Planning

Risk-based audit planning is essential to determine an audit's scope (the areas/processes/assets to be audited) effectively. It helps to deploy audit resources to areas within an organization that are subject to the greatest risk.

The following are the advantages of risk-based audit planning:

- Effective risk-based auditing reduces the risk that arises during an audit.
- Risk-based auditing is a proactive approach that helps to identify issues at an early stage.
- One of the major factors in risk assessment is compliance with contractual and legal requirements. Risk-based auditing helps an organization identify any major deviation from contractual and legal requirements. This improves compliance awareness throughout the organization.
- Risk-based auditing promotes preventive controls over reactive measures.
- Risk-based auditing helps align internal audit activities with the risk management practices of the organization.

Audit Risk

An auditor may not be able to detect material errors during the course of an audit. This is known as audit risk. Audit risk is influenced by inherent risk, control risk, and detection risk. The following list describes each of these risks:

- **Inherent risk:** This refers to the risk that exists before applying a control.
- **Control risk:** This refers to the risk that internal controls fail to prevent or detect.
- **Detection risk:** This refers to the risk that internal audits fail to prevent or detect.

The following figure explains the relationship between all three risk types:

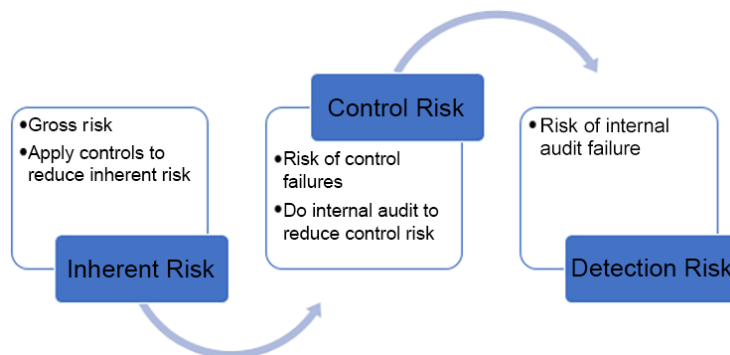


Figure 1.7: The relationship between three kinds of risk and steps taken

The following is the formula for calculating audit risk:

$$\text{Audit Risk} = \text{Inherent Risk} * \text{Control Risk} * \text{Detection Risk}$$

An IS auditor should have a sound awareness of audit risk when planning auditing activities. Some ways to minimize audit risk are listed here:

- Conduct risk-based audit planning
- Review the internal control system
- Select appropriate statistical sampling
- Assess the materiality of processes/systems in the audit scope

It is the experience and expertise of the auditor that minimizes audit risk. However, it must be noted that the auditor is a watchdog and not a bloodhound.

Risk-Based Auditing Approach

In a risk-based auditing approach, it is important to understand the steps to be performed by the IS auditor. The following structured approach will help to minimize the audit risk and provide assurance about the state of affairs of the auditee organization:

1. Acquire pre-audit requirements:
 - Knowledge about industry and regulatory requirements
 - Knowledge about the applicable risk to the concerned business
 - Prior audit results
2. Obtain information about internal controls:
 - Get knowledge about the control environment and procedures.
 - Understand control risks
 - Understand detection risks
3. Conduct a compliance test:
 - Identify the controls to be tested
 - Determine the effectiveness of the controls

4. Conduct a substantive test:
 - Identify the process for the substantive test
 - See that the substantive test includes analytical procedures, detailed tests of account balances, and other procedures

Risk Assessments

A risk assessment includes the following:

Steps	Particulars
Step 1	Identification of critical assets and processes
Step 2	Identification of relevant risk, that is, vulnerabilities and threats
Step 3	Conducting an impact analysis (either qualitative or quantitative)
Step 4	Prioritizing the risk
Step 5	Risk treatment

Table 1.7: Steps in a risk assessment

Risk assessments should be conducted at regular intervals to account for changes in risk factors. The risk assessment process has an iterative life cycle. Risk assessments should be performed methodically, and the outputs should be comparable and reproducible.

Also, it is important to determine the risk appetite of the organization. Risk appetite helps to prioritize various risks for mitigation.

Risk Response Methodology

Risk response is the process of dealing with a risk to minimize its impact. It is a very important step in the risk management process. Here are the four main risk response methodologies:

- **Risk mitigation/risk reduction:** Take some action to mitigate/reduce the risk
- **Risk avoidance:** Change the strategy or business process to avoid the risk
- **Risk acceptance:** Decide to accept the risk
- **Risk transfer:** Transfer the risk to a third party: insurance is the best example

The risk culture and risk appetite of the organization in question determine the risk response method. Of the preceding responses, the most widely used response is risk mitigation by implementing some level of control.

It makes sense to explain the preceding risk response methodologies with a practical example. Suppose a meteorological department has forecast heavy rain during the day and you need to attend CISA lectures. The risk of rain can be handled in the following manner:

- The majority of candidates will try to mitigate the risk of potential rain by arranging for an umbrella/raincoat to safeguard them (mitigation of risk).
- Some courageous candidates will not worry about carrying an umbrella/raincoat (risk acceptance).
- Some candidates will not attend classes (risk avoidance).

It is not always feasible to mitigate all the risks at an organizational level. A risk-free enterprise is an illusion.

You cannot run a business without taking risks. In this regard, risk management is the process of determining whether the amount of risk taken by an organization is in accordance with the organization's capabilities and needs.

Top-Down and Bottom-Up Approaches to Policy Development

Policies can be developed either through a top-down or a bottom-up approach. A candidate must understand the difference between the two approaches to policy development.

The Top-Down Approach

In the top-down approach, a policy is developed and designed from a senior management perspective and is aligned with business objectives. The involvement of senior management in designing the risk scenario is of utmost importance. One advantage of the top-down approach for developing organizational policies is that it ensures consistency across the organization.

The Bottom-Up Approach

In the bottom-up approach, policies are designed and developed from the process owner's/employee's perspective. This approach begins by defining operational-level requirements and policies. The bottom-up approach is derived from and implemented on the basis of the results of risk assessments.

The Best Approach

An organization should make use of both the top-down and the bottom-up approaches when developing organizational policies. In a top-down approach, major risks to business objectives are addressed, whereas in the bottom-up approach, process-level risks are addressed. Therefore, they are complementary to each other and should be used simultaneously.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
The most important step in a risk assessment is to identify what?	Threats and vulnerabilities
In risk-based audit planning, an IS auditor's first step is to identify what?	High-risk areas
Once threats and vulnerabilities are identified, what should be the next step?	Identify and evaluate existing controls
What is the advantage of risk-based audit planning?	Resources can be utilized for high-risk areas
What does the level of protection of information assets depend on?	The criticality of assets
The level of which risk is influenced by an auditor's actions?	Detection risk
What is audit risk?	Audit risk is the sum total of inherent risk, control risk, and detection risk
What is risk the product of?	Probability and impact
What are the results of risk management processes used for?	Designing controls
Whose responsibility is the management of risk to an acceptable level?	Senior management
What is the absence of proper security measures known as?	Vulnerability
What is the advantage of the bottom-up approach for the development of organizational policies?	Policies are created on the basis of a risk analysis
What is risk before controls are applied known as?	Inherent risk/gross risk (after the implementation of controls, it is known as residual risk/net risk)

Table 1.8: Key aspects from the CISA exam perspective

Types of Audits and Assessments

CISA candidates are expected to have a basic understanding of the various types of audits that can be performed, internally or externally, and the basic audit procedures associated with each of them. These are as follows:

Type of Audit	Description
IS audit	An IS audit is conducted to evaluate and determine whether an information system and any related infrastructure are adequately safeguarded and protected to maintain confidentiality, integrity, and availability.
Compliance audit	A compliance audit is conducted to evaluate and determine whether specific regulatory requirements are being complied with.
Financial audit	A financial audit is conducted to evaluate and determine the accuracy of financial reporting. A financial audit involves a detailed and substantive testing approach.
Operational audit	An operational audit is conducted to evaluate and determine the accuracy of an internal control system. It is designed to assess issues related to the efficiency of operational productivity within an organization.
Integrated audit	Here, different types of audits, such as financial and operational, are combined to form a multi-faceted audit. An integrated audit is performed to assess the overall objectives to safeguard an asset's efficiency and compliance. It can be performed both by internal and external auditors. An integrated audit includes compliance tests of internal controls.
Specialized audit	A specialized audit includes the following: • A third-party service audit • A fraud audit • A forensic audit
Computer forensic audit	A computer forensic audit includes the analysis of electronic devices. An IS auditor can help in performing forensic investigations and conduct an audit of the system to ensure compliance.

Type of Audit	Description
Functional audit	A functional audit is conducted to evaluate and determine the accuracy of software functionality. A functional audit is conducted prior to software implementation.

Figure 1.9: Types of audit and their descriptions

The following diagram shows various audits combined to form an integrated audit, providing an overall view of an organization's functioning:



Figure 1.8: Integrated audit

As you can see, an integrated audit tests the internal controls of an organization. It can be performed by either the internal audit team or an external audit firm.

Summary

In this chapter, you explored various audit processes, standards, guidelines, practices, and techniques that an IS auditor is expected to use during audit assignments. You learned about risk-based audit planning and its advantages. The most important benefit of audit planning is that it helps the auditor focus on high-risk areas. You explored the major risks associated with business applications.

The important topics covered in this chapter were as follows:

- The audit department's activities are influenced by the audit charter. The approved audit charter is the basis on which the chief audit officer carries out audit processes. The audit charter should ideally be approved by top management.
- The identification of high-risk areas within the audit scope is the first step in the audit procedure. Audit planning can be done in accordance with the findings regarding the risk-prone areas.
- Preventive controls are designed to prevent omissions, errors, or negative acts from occurring. Preventive controls are incorporated in such a way that prevents a threat event and thus avoids its potential impact. Detective controls are implemented to detect threat events once they have occurred; they aim to reduce the impact of an event. Corrective controls are designed to minimize the impact of a threat event once it has occurred and help in restoring a business to its routine operations. Compensating controls are alternate measures employed to ensure that weaknesses in a system are not exploited. In many cases, a strong control in one area can compensate for a weakness in another area.
- The identification of vulnerabilities is an important aspect of conducting a risk assessment. If a vulnerability is not appropriately recognized, controls and audit planning may not be effective.
- The objective of an information system audit is to determine the adequacy of the processes and controls to safeguard the confidentiality, integrity, and availability of information systems and related infrastructure and resources.

In the next chapter, you will be exploring audit execution, which includes project management techniques, sampling methodology, audit evidence collection techniques, and other aspects of conducting an audit.

Chapter Review Questions

Before you move on to *Chapter 2, Audit Execution*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

Dashboard > Set 1 (The Contents of an Audit Charter)

Question 1 of 22

1%

Time Left:
34 mins 35 secs

END QUIZ

Who should provide the final approval for an audit charter?

☐ Higher management

☐ The head of the audit

☐ The information security department

☐ The project steering committee

NEXT [Don't Know](#)

Feedback 

Figure 1.9: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/dkrqI`. You will see the following screen:

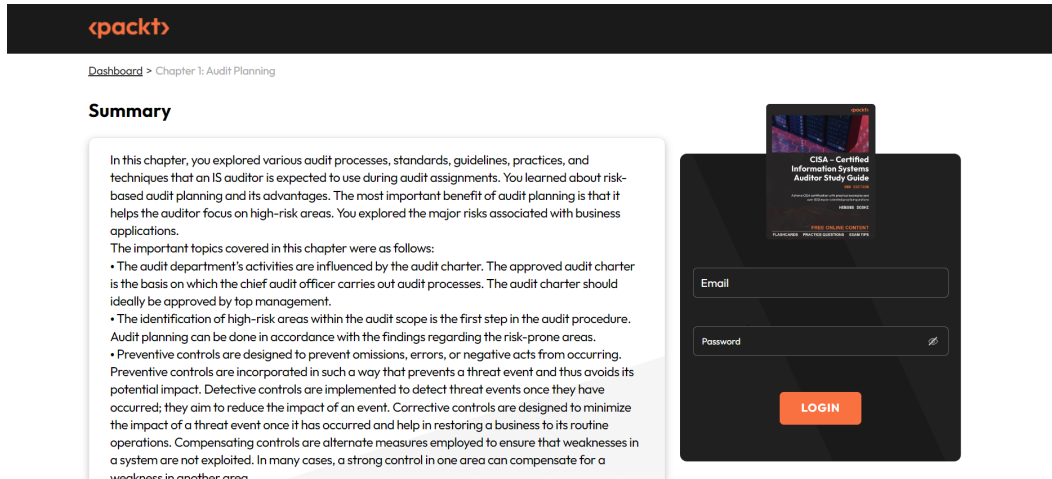


Figure 1.10: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 1.11: QR code to access *Chapter 1* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

The screenshot shows the Packt dashboard interface. At the top, there's a navigation bar with the Packt logo, a 'SHARE FEEDBACK' button, and a user profile for 'Shubhra Mayur'. Below the navigation bar, the breadcrumb trail reads 'Dashboard > Chapter 1: Audit Planning'. The main content area is titled 'Chapter 1: Audit Planning' and includes a 'Summary' section. The summary text states: 'In this chapter, you explored various audit processes, standards, guidelines, practices, and techniques that an IS auditor is expected to use during audit assignments. You learned about risk-based audit planning and its advantages. The most important benefit of audit planning is that it helps the auditor focus on high-risk areas. You explored the major risks associated with business applications. The important topics covered in this chapter were as follows:'. It then lists three bullet points: 'The audit department's activities are influenced by the audit charter. The approved audit charter is the basis on which the chief audit officer carries out audit processes. The audit charter should ideally be approved by top management.', 'The identification of high-risk areas within the audit scope is the first step in the audit procedure. Audit planning can be done in accordance with the findings regarding the risk-prone areas.', and 'Preventive controls are designed to prevent omissions, errors, or negative acts from occurring. Preventive controls are incorporated in such a way that prevents a threat event and thus avoids its potential impact. Detective controls are implemented to detect threat events once they have occurred; they aim to reduce the impact of an event. Corrective controls are designed to minimize the impact of a threat event once it has occurred and help in restoring a business to its routine'. To the right of the summary is a 'Chapter 1 Quizzes' section, which lists three quiz sets: 'Set 1 (22 Questions)', 'Set 2 (17 Questions)', and 'Set 3 (36 Questions)'. Each set has a 'START' button and a 'View Previous Result' link.

Figure 1.12: Chapter summary and end-of-chapter question sets

- Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

The screenshot shows the practice questions interface. At the top, the breadcrumb trail reads 'Dashboard > Set 1 (The Contents of an Audit Charter)'. The main content area is titled 'Question 1 of 22' and includes a progress bar showing '1%'. The question text is 'Who should provide the final approval for an audit charter?'. There are four radio button options: 'Higher management', 'The head of the audit', 'The information security department', and 'The project steering committee'. At the bottom left, there are 'NEXT' and 'Don't Know' buttons. At the bottom right, there is a 'Feedback' dropdown menu. In the top right corner, there is a 'Time Left' section showing '34 mins 35 secs' and an 'END QUIZ' button.

Figure 1.13: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Audit Execution

This Book Comes with Free Online Content

With this book, you get unlimited access to web-based CISA exam prep tools which include practice questions, flashcards, exam tips, and more.



Hemang Doshi

Author - CISA Study Guide 2nd Edition

Hemang Doshi is a well-known author for ISACA courses such as CISA, CISM, and CRISC. His courses are sold in more than 150 countries.

[Follow me on LinkedIn](#)

 **Practice Questions** ▼

 **End of Chapter Questions** ▼

 **Flashcards** ▼

 **Exam Tips** ▼

 **Ask a Question** ▼

Figure 2.1: CISA online practice resources dashboard

To unlock the content, you'll need to create an account using your unique sign-up code provided with this book. Refer to the *Instructions for Unlocking the Online Content* section in the *Preface* on how to do that.

Accessing the Online Content

If you've already created your account using those instructions, visit packt.link/cisastudyguidewebsite or scan the following QR code to quickly open the website.



Figure 2.2: QR Code to access CISA online practice resources main page

Once there, click the `Login` link in the top-right corner of the page to access the content using your credentials.

In this chapter, you will learn about audit execution processes such as project management techniques, sampling methodology, and audit evidence collection techniques. These topics are important because **Information Systems (IS)** auditors should be aware of the audit execution process.

The following topics will be covered in this chapter:

- Audit project management
- Sampling methodology
- Audit evidence collection techniques
- Data analytics
- Reporting and communication techniques
- Control self-assessment

By the end of the chapter, you will have detailed knowledge of IS, business, and risk management processes that help protect the assets of an organization.

Audit Project Management

An audit includes various activities, such as audit planning, resource allocation, determining the audit scope and audit criteria, reviewing and evaluating audit evidence, forming audit conclusions, and reporting to management. All these activities are integral parts of an audit, and project management techniques are equally applicable to audit projects.

The following are the basic steps for managing and monitoring audit projects:

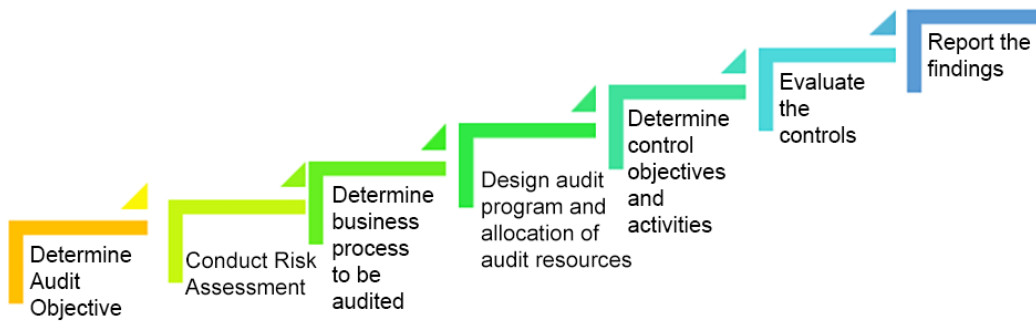


Figure 2.3: Basic steps for managing and monitoring audit projects

The activities mentioned in the preceding figure are all performed to achieve specific audit objectives. These are discussed in the next section.

Audit Objectives

Audit objectives are the expected outcomes of the audit activities. They refer to the intended goals that the audit must accomplish. Determining the audit objectives is a very important step in planning an audit. Generally, audits are conducted to achieve the following objectives:

- To confirm that internal control exists
- To evaluate the effectiveness of internal controls
- To confirm compliance with statutory and regulatory requirements

An audit also provides reasonable assurance about the coverage of material items.

Audit Phases

The audit process has three phases. The first phase is about planning, the second phase is about execution, and the third phase is about reporting. An IS auditor should be aware of the phases of an audit process shown in the following tables.

Phase	Audit Steps	Description
Planning Phase	Assess risk and determine audit area	The first step is to conduct a risk assessment and identify the function, process, system, and physical location to be audited.
	Determine audit objective	- The primary goal during the planning stage of an IS audit is to address the audit objectives. - The audit objective, i.e. the audit purpose, is also to be determine. - An audit may be conducted for regulatory or contractual requirements.
	Determine the audit scope	- The next step is to identify and determine the scope of the audit. - The scope may be restricted to a few applications or few processes only. - Defining the scope will the help auditor determine the resources required for conducting of the audit
	Conduct pre-audit planning	- Pre audit planning includes understanding the business environment and the relevant regulations. - It includes conducting risk assessments to determine areas of high risk. - It also includes determining resource requirements and audit timings.
	Determine audit procedures	- The audit program is designed on the basis of pre-audit information, which includes resource allocation and audit procedures to be followed. - During this step, audit tools and audit methodology are developed to test and verify the controls.
Execution Phase	Gather data	Next step is to gather relevant data and documents for the conduct of audit.

Phase	Audit Steps	Description
	Evaluate controls	Once the required information, data and documents are available, the auditor is required to evaluate the controls to verify their effectiveness and efficiency of the controls.
	Validate and document the results	Audit observations should be validated and documented along with the relevant evidence.
Reporting Phase	Draft report	- A draft report should be issued for obtaining comments from management on the audit observations. - Before issuance of the final report, the draft report should be discussed with management.
	Issue report	The final report should contain audit findings, recommendations, comments, and the expected date of closure of the audit findings.
	Follow up	Follow-up should be done to determine whether the audit findings are closed and a follow-up report should be issued.

Table 2.1: Phases of an audit process

For the CISA exam, please note down the following steps for the audit process:



Figure 2.4: Steps followed in an audit

It should be noted that the steps should be followed in chronological sequence for the success of the audit project and to achieve the audit objectives.

Fraud, Irregularities, and Illegal Acts

The implementation of internal controls does not necessarily eliminate fraud. An IS auditor should be aware of the possibilities, circumstances, and opportunities that can lead to fraud and other irregularities. The IS auditor should observe and exercise due professional care to ensure that internal controls are appropriate, effective, and efficient to prevent or detect fraud, irregularities, and illegal acts.

In the case of suspicious activity, the IS auditor may communicate the need for a detailed investigation. In the case of a major fraud being identified, audit management should consider reporting it to the audit committee board.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What does an IS audit provide?	Reasonable assurance about the coverage of material items
What is the first step of an audit project?	To develop an audit plan
What is the major concern in the absence of established audit objectives?	Not being able to determine key business risks
What is the primary objective of performing a risk assessment prior to the audit?	Allocating audit resources to areas of high risk
What is the first step of the audit planning phase?	Conducting risk assessments to determine the areas of high risk

Table 2.2: Key aspects from the CISA exam perspective

Sampling Methodology

Sampling is the process of selecting data from a population. By analyzing samples, characteristics of the entire population can be identified. Sampling is performed when it is not feasible to study the entire population due to time and cost constraints. Therefore, samples are a subset of the population.

Sampling Types

This is a very important topic from a CISA exam perspective. Two or three questions can be expected from this topic. A CISA candidate should have an understanding of the following sampling techniques:

Sampling Types	Description
Statistical sampling	This is an objective sampling technique. This is also known as non-judgmental sampling. It uses the laws of probability, where each unit has an equal chance of selection. In statistical sampling, the probability of error can be objectively quantified, and hence the detection risk can be reduced.
Non-statistical sampling	This is a subjective sampling technique. It's also known as judgmental sampling. The auditor uses their experience and judgment to select the samples that are material and represent a higher risk.
Attribute sampling	Attribute sampling is the simplest kind of sampling based on certain attributes; it measures basic compliance. It answers the question, "How many?" It is expressed as a percentage—for example, "90% complied." Attribute sampling is usually used in compliance testing.
Variable sampling	Variable sampling offers more information than attribute sampling. It answers the question, "How much?" It is expressed in monetary value, weight, height, or some other measurement—for example, "an average profit of \$25,000." Variable sampling is usually used in substantive testing.
Stop-or-go sampling	Stop-or-go sampling is used where controls are strong and very few errors are expected. It helps to prevent excess sampling by allowing the audit test to end at the earliest possible moment.

Sampling Types	Description
Discovery sampling	Discovery sampling is used when the objective is to detect fraud or other irregularities. If a single error is found, the entire sample is believed to be fraudulent/irregular.

Table 2.3: Types of sampling and their descriptions

The following diagram will help you to understand the answers to specific CISA questions:

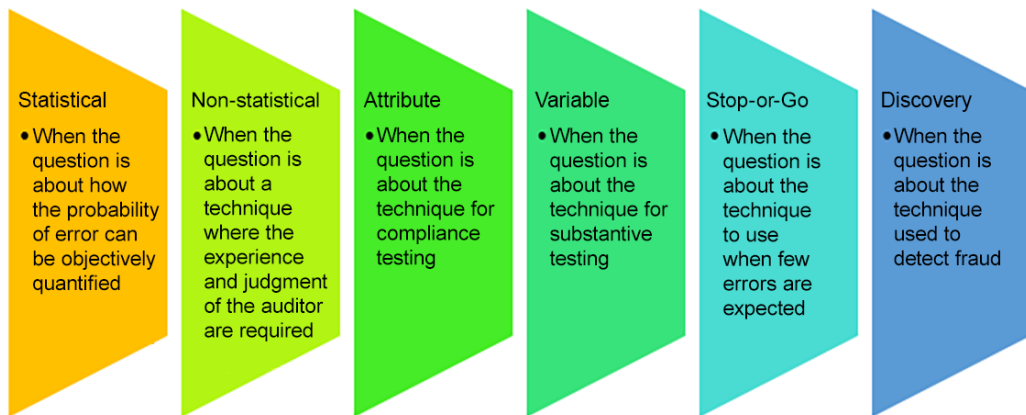


Figure 2.5: Different types of sampling

Also, remember the term **AC-VS—Attribute Sampling for Compliance Testing and Variable Sampling for Substantive Testing**.

Sampling Risk

Sampling risk refers to the risk that a sample is not a true representation of the population. The conclusion drawn by analyzing the sample may be different from the conclusion that would have been drawn by analyzing the entire population.

Other Sampling Terms

A CISA candidate should be aware of the following terms related to sampling.

The Confidence Coefficient

A confidence coefficient, or confidence level, is a measure of the accuracy of and confidence in the quality of a sample. The sample size and confidence correlation are directly related. A high sample size will give a high confidence coefficient.

Look at the following example:

Population	Sample Size	Confidence Correlation
100	95	95%
	50	50%
	25	25%

Table 2.4: Example of confidence coefficient

In the case of poor internal controls, the auditor may want to verify 95 samples (sample size) out of a total population of 100. This gives a 95% confidence correlation.

In the case of strong internal controls, the auditor may be satisfied with only 25 samples out of the total population of 100. This gives a 25% confidence correlation.

Level of Risk

The level of risk can be derived by deducting the confidence coefficient from 1. For example, if the confidence coefficient is 95%, then the level of risk is 5% (100%–95%).

Expected Error Rate

This indicates the expected percentage of errors that may exist. When the expected error rate is high, the auditor should select a higher sample size.

Tolerable Error Rate

This indicates the maximum error rate that can exist without the audit result being materially misstated.

Sample Mean

The sample mean is the average of all collected samples. It is derived by adding all the samples and dividing the sum by the number of samples.

Sample Standard Deviation

This indicates the variance of the sample value from the sample mean.

Compliance versus Substantive Testing

A CISA candidate should be able to differentiate between compliance testing and substantive testing. They should be able to determine which type of testing is to be performed under different scenarios.

The Differences between Compliance Testing and Substantive Testing

The following table differentiates between compliance and substantive testing:

Compliance Testing	Substantive Testing
Compliance testing involves the verification of the controls of a process.	Substantive testing involves the verification of data or transactions.
Compliance testing checks for the presence of controls.	Substantive testing checks for the completeness, accuracy, and validity of the data.
In compliance testing, attribute sampling is preferred.	In substantive testing, variable sampling is preferred.

Table 2.5: Differences between compliance testing and substantive testing

Essentially, verifying whether a control is present or not is compliance testing. Meanwhile, verification of the complete process by testing the data/transaction to “substantiate” that the process is working is substantive testing.

Examples of Compliance Testing and Substantive Testing

The following examples will further help you understand the different use cases of compliance testing and substantive testing:

Compliance Testing	Substantive Testing
To check for controls in router configuration	To count and confirm the physical inventory
To check for controls in the change management process	To confirm the validity of inventory valuation calculations
Verification of system access rights	To count and confirm cash balance
Verification of firewall settings	Examining the trial balance
Reviewing compliance with the password policy	Examining other financial statements

Table 2.6: Differences between the use cases of compliance testing and substantive testing

The Relationship between Compliance Testing and Substantive Testing

A CISA candidate should understand the following points about the relationship between compliance testing and substantive testing:

- Ideally, compliance testing should be performed first and should be followed by substantive testing.
- The outcome of compliance testing is used to plan for a substantive test. If the outcome of compliance testing indicates the existence of effective internal controls, then substantive testing may not be required or may be reduced. However, if the outcome of compliance testing indicates a poor internal control system, more rigorous substantive testing is required. Thus, the design of substantive tests is often dependent on the result of compliance testing.
- The attribute sampling technique (which indicates that a control is either present or absent) is useful for compliance testing, whereas variable sampling will be useful for substantive testing.

Apart from the appropriate sampling technique, another important aspect of the audit process is using appropriate evidence-gathering techniques. Audit evidence should be collected properly to establish its reliability. Details on the reliability of audit evidence and collection techniques are covered in the next section.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
Which sampling technique should be used when the probability of error must be objectively quantified?	Statistical sampling.
How can sampling risk be mitigated?	By using statistical sampling.
Which sampling method is most useful when testing for compliance?	Attribute sampling.
In the case of a strong internal control, should the confidence coefficient/sample size be increased or lowered?	The confidence coefficient/sampling size may be lowered.
Which sampling method would best assist auditors when there are concerns of fraud?	Discovery sampling.

CISA Questions	Possible Answers
How can you differentiate between compliance testing and substantive testing?	The objective of compliance testing is to test the presence of controls, whereas the objective of substantive testing is to test individual transactions. Take the example of asset inventory: Compliance testing verifies whether a control exists for inward/outward movement of the assets. Verifying the count of physical assets and comparing it with records is substantive testing.
What are some examples of compliance testing?	To verify the configuration of a router for controls. To verify the change management process to ensure controls are effective. Reviewing system access rights. Reviewing firewall settings. Reviewing compliance with a password policy.
What are some examples of substantive testing?	A physical inventory of the tapes at the location of offsite processing. Confirming the validity of the inventory valuation calculations. Conducting a bank confirmation to test cash balances. Examining the trial balance. Examining other financial statements.
In what scenario can the substantive test procedure be reduced?	The internal control is strong/the control risk is within acceptable limits.

Table 2.7: Key aspects from the CISA exam perspective

Audit Evidence Collection Techniques

Auditing is a process of providing an opinion (in the form of a written audit report) about the functions or processes under the scope of an audit. This audit opinion is based on the evidence obtained during the audit. Audit evidence is critical in the audit as audit opinions are based on reliability, competence, and objectivity. The objective and scope of an audit are the most significant factors when determining the extent of the data requirements.

Reliability of Evidence

An IS auditor should consider the sufficiency, competency, and reliability of the audit evidence. Evidence can be considered competent when it is valid and relevant. The following factors determine the reliability of audit evidence.

Independence of the Evidence Provider

The source of the evidence determines the reliability of the evidence. External evidence (obtained from a source outside the organization) is more reliable than evidence obtained from within the organization. A signed agreement with external parties is considered more reliable.

Qualifications of the Evidence Provider

The qualifications and experience of the evidence provider are major factors when determining the reliability of audit evidence. Information gathered from someone without relevant qualifications or experience may not be reliable.

Objectivity of the Evidence

Evidence based on judgment (involving subjectivity) is less reliable than objective evidence. Objective audit evidence does not have scope for different interpretations.

Timing of the Evidence

Audit evidence that is dynamic in nature (such as logs, files, and documents that are updated frequently) should be considered based on relevant timing.

The following figure highlights the evidence-related guidelines:

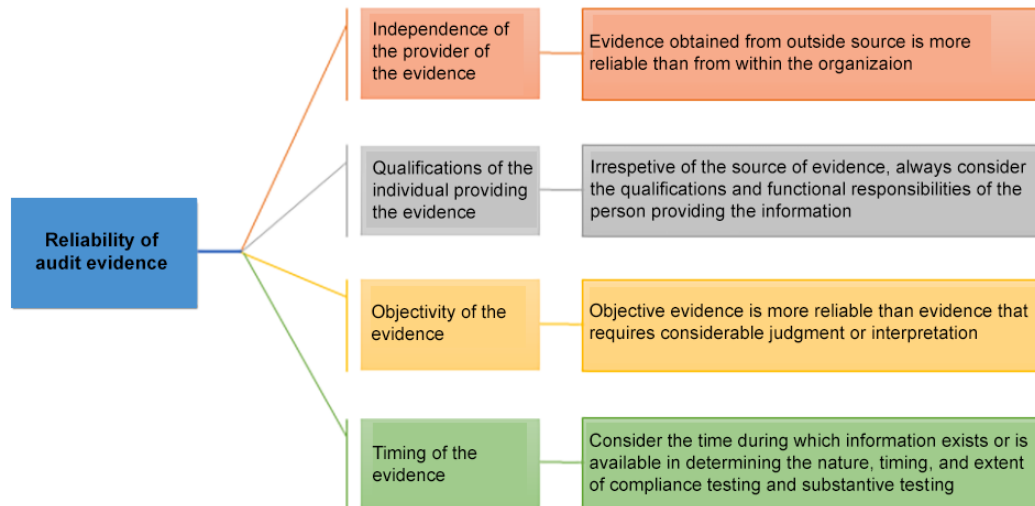


Figure 2.6: Evidence-related guidelines

The rules shown in the preceding figure are very important from a CISA exam perspective. An IS auditor should also be aware of the best practices and techniques to gather evidence. These are discussed in the next section.

Evidence-Gathering Techniques

The following techniques are used by IS auditors to gather evidence during the audit process:

Factors	Descriptions
Review the organization's structure	- The IS auditor should review the organization's structure and governance model. - This will help the auditor determine the control environment of the enterprise.
Review IS policies, processes, and standards	- The audit team should review the IS policies, procedures, and standards and determine the effectiveness of the controls implemented. - The audit team should also determine whether IS policies and procedures are reviewed periodically and approved by a competent authority.

Factors	Descriptions
Observations	- The IS auditor should observe the process to determine the following: - The skill and experience of the staff - The security awareness of the staff - The existence of segregation of duties (SoD)
Interview technique	- The IS auditor should have the skill and competency to conduct interviews tactfully. - Interview questions should be designed in advance to ensure that all topics are covered. - To the greatest extent possible, interview questions should be open-ended to gain insight into the process. - The staff being interviewed should be made comfortable and encouraged to share information and areas of concern.
Re-performance	- In re-performance, the IS auditor performs the activity that is originally performed by the staff of the organization. - Re-performance provides better evidence than other techniques. - It should be used when other methods do not provide sufficient assurance about control effectiveness.
Process walk-through	A process walk-through is done by the auditor to confirm the understanding of the policies and processes.

Table 2.8: Evidence-gathering factors and their descriptions

The evaluation of evidence is a subjective matter, and the auditor needs the relevant skills, experience, and qualifications to judge the relevance, sufficiency, and appropriateness of the audit evidence. In the case of inconclusive evidence, it is recommended to perform an additional test to confirm the accuracy of the audit findings.

Evidence should be evaluated based on the business environment and the complexity of the business processes. The following are some general guidelines for evidence evaluation:

- In the case of unavailability of evidence, the auditor should report the relevant risk in the audit report.

- Evidence obtained from a relevant third party is considered more reliable compared to internal evidence. An audit report by a qualified auditor is considered more reliable than a confirmation letter received from a third party.
- Evidence collected by the audit team directly from the source is considered more reliable compared to evidence provided by business units.

Computer-Assisted Audit Techniques (CAATs) are the most effective auditing tools for computerized environments. The use of a CAAT ensures the reliability of audit evidence as data is directly collected, processed, and analyzed by the IS auditor.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What does the extent of the data requirements for the audit depend on?	The objective and scope of the audit.
What should audit findings be supported by?	Sufficient and appropriate audit evidence.
What is the most important reason to obtain sufficient audit evidence?	To provide a reasonable basis for drawing conclusions.
What is the most effective tool for obtaining audit evidence through digital data?	Computer-assisted auditing techniques.
What is the most important advantage of using CAATs for gathering audit evidence?	CAATs provide assurance about the reliability of the evidence collected.
What type of evidence is considered most reliable?	Evidence directly collected from the source by an IS auditor is considered to be the most reliable. The source of evidence should be independent.
What is the primary reason for a functional walk-through?	To understand the business process.

Table 2.9: Key aspects from the CISA exam perspective

Data Analytics

Data Analytics (DA) is the method of examining data or information. It helps you to understand the data by transforming raw data into usable and meaningful information.

Examples of the Effective Use of Data Analytics

The following are some examples of the use of DA:

- To determine whether a user is authorized by combining logical access files with the human resource employee database
- To determine whether events are authorized by combining the file library settings with change management system data and the date of file changes
- To identify tailgating by combining input with output records
- To review system configuration settings
- To review logs for unauthorized access

CAATs

CAATs are extremely useful to IS auditors for gathering and analyzing large and complex data during an IS audit. CAATs help an IS auditor collect evidence from different hardware, software environments, and data formats.

The following table presents a breakdown of the functions of CAAT tools:

CAAT Tools	Functions
General Audit Software	This is a standard type of software that is used to read and access data directly from various database platforms.
Utility and Scanning Software	This helps in generating reports of the database management system. It scans all the vulnerabilities in the system.
Debugging	This helps in identifying and removing errors from computer hardware or software.
Test Data	This is used to test processing logic, computations, and controls programmed in computer applications.

Table 2.10: Breakdown of CAAT functions

A CAAT helps an IS auditor collect information independently. Information obtained through CAATs is considered more reliable.

Examples of the Effective Use of CAAT Tools

The following are some examples of use cases for CAAT tools:

- To determine the accuracy of transactions and balances
- For detailed analysis
- To ascertain compliance with IS general controls
- To ascertain compliance with IS application controls
- To assess network and operating system controls
- For vulnerability and penetration testing
- For the security scanning of source code and AppSec testing

Precautions while Using CAAT

An auditor should be aware of the following precautions when using CAAT tools:

- Ensure the integrity of imported data by safeguarding its authenticity, integrity, and confidentiality
- Obtain approval for installing the CAAT software on the auditee servers
- Obtain only read-only access when using CAATs on production data
- Edits/modifications should be applied to duplicate data and the integrity of the original data should be ensured

Continuous Auditing and Monitoring

A CISA candidate should understand the difference between continuous auditing and continuous monitoring:

Continuous Auditing	Continuous Monitoring
In continuous auditing, an audit is conducted in a real-time or near-real-time environment. In continuous auditing, the gap between operations and an audit is much shorter than under a traditional audit approach.	In continuous monitoring, the relevant process of a system is observed on a continuous basis.

Continuous Auditing	Continuous Monitoring
For example, high payouts are audited immediately after a payment is made.	For example, antivirus or IDSs may continuously monitor a system or a network for abnormalities.

Table 2.11: Differences between continuous auditing and continuous monitoring

Continuous auditing and continuous monitoring are mutually exclusive. Continuous assurance can be ensured if both continuous monitoring and continuous auditing are in place. Generally, the results of continuous auditing are the precursor for the introduction of a continuous monitoring process.

Continuous Auditing Techniques

For IS audits, continuous audit techniques are extremely important tools. The following are the five widely used continuous audit tools.

Integrated Test Facility

The following are the features of an **Integrated Test Facility (ITF)**.

In an ITF, a fictitious entity is created in the production environment:

- The auditor may enter test or dummy transactions and check the processing and results of these transactions for correctness.
- Processed results and expected results are evaluated to check the proper functioning of systems.
- For example, with the ITF technique, a test transaction is entered. The processing results of the test transaction are compared with the expected results to determine the accuracy of processing. If the processed results match the expected results, then it determines that the processing is correct. Once the verification is complete, test data is deleted from the system.

System Control Audit Review File

The following are the features of a **System Control Audit Review File (SCARF)**:

- In this technique, an audit module is embedded (inbuilt) into the organization's host application to track transactions on an ongoing basis.
- A SCARF is used to obtain data or information for audit purposes.
- SCARFs record transactions above a specified limit or deviation-/exception-related transactions. These transactions are then reviewed by the auditor.
- SCARFs are useful when regular processing cannot be interrupted.

Snapshot Technique

The following are the features of the snapshot technique:

- This technique captures snapshots or pictures of the transaction as it is processed at different stages in the system.
- Details are captured both before and after the execution of the transaction. The correctness of the transaction is verified by validating the before-processing and after-processing snapshots of the transactions.
- Snapshots are useful when an audit trail is required.
- The IS auditor should consider the following significant factors when working with this technique:
 - At what location snapshots are captured
 - At what time snapshots are captured
 - How the reporting of snapshot data is done

Audit Hook

The following are the features of an audit hook:

- Audit hooks are embedded in the application system to capture exceptions.
- The auditor can set different criteria to capture exceptions or suspicious transactions.
- For example, with the close monitoring of cash transactions, the auditor can set criteria to capture cash transactions exceeding \$10,000. All these transactions are then reviewed by the auditor to identify fraud, if any.
- Audit hooks are helpful in the early identification of irregularities, such as fraud or error.
- Audit hooks are generally applied when only selected transactions need to be evaluated.

Continuous and Intermittent Simulation

The following are the features of **Continuous and Intermittent Simulation (CIS)**:

- CIS replicates or simulates the processing of the application system.
- In this technique, a simulator identifies transactions as per the predefined parameters. Identified transactions are then audited for further verification and review.
- CIS compares its own results with the results produced by application systems. If any discrepancies are noted, it is written to the exception log file.
- CIS is useful to identify the transactions as per the predefined criteria in a complex environment.

The following table summarizes the features of continuous audit tools:

Audit Tool	Usage
SCARF/EAM	This is useful when regular processing cannot be interrupted.
Snapshots	Pictures or snapshots are used when an audit trail is required.
Audit hooks	When early detection of fraud or error is required.
ITF	Test data is used in a production environment
CIS	CIS is useful for the identification of transactions as per predefined criteria in a complex environment.

Table 2.12: Types of continuous audit tools and their features

An IS auditor should be aware of the methods and procedures through which analysis and findings are reported to the audit committee and senior management. The effective reporting of audit findings and communicating the findings to all the stakeholders are very important parts of audit execution; these are covered in more detail in the next section.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the first step of conducting data analytics?	The first step will be determining the objective and scope of analytics.
Which is the most effective online audit technique when an audit trail is required?	The snapshot technique.
What is the advantage of an Integrated Test Facility (ITF)?	Setting up a separate test environment/test process is not required. An ITF helps validate the accuracy of the system processing.
Which is the most effective online audit technique when the objective is to identify transactions as per predefined criteria?	CIS is most useful to identify transactions as per predefined criteria in a complex environment.

Table 2.13: Key aspects from the CISA exam perspective

Reporting and Communication Techniques

Audit reporting and following up for closure are the last steps of the audit process. The effectiveness of an audit largely depends on how the audit results are communicated and how follow-up is done for the closure of recommendations. Effective verbal and written communication skills are key attributes of a good auditor. A CISA candidate is expected to have a thorough understanding of the elements of an exit interview, audit report objectives, the process and structure, and follow-up activities.

Exit Interview

Auditing is not about finding errors. It is about adding value to the existing processes of an organization.

A formal exit interview is essential before the audit report is released. The following are the objectives of an exit interview:

- To ensure that the facts are appropriately and correctly presented in the report
- To discuss recommendations with auditee management
- To discuss an implementation date

The exit meeting ensures that facts are not misunderstood or misinterpreted. Exit meetings help to align the audit team and auditee management on the findings that are presented, discussed, and agreed upon.

Audit Reporting

A CISA candidate should note the following best practices with respect to audit reporting:

- The IS auditor is ultimately responsible for senior management and the final audit report should be sent to the **Audit Committee of the Board (ACB)**. If the IS auditor has no access to the top officials and the audit committee, it will impact the auditor's independence.
- Before the report is placed with the ACB, the IS auditor should discuss with auditee management to determine the accuracy of the audit observations and to understand the correction plan.
- Sometimes, auditee management may not agree with the audit findings and recommendations. In such cases, IS auditors should emphasize the significance of the audit findings and the risk of not taking any corrective action.
- If there is any control weakness that is not within the scope of the audit, it should be reported to management during the audit process. This should not be overlooked. Generally, accepted audit procedures require audit results to be reported even if the auditee takes corrective action prior to reporting.
- To support the audit results, the IS auditor should have clear and accurate audit facts.

Audit Report Objectives

The following are the six objectives of audit reporting:

- The presentation of audit findings/results to all the stakeholders (that is, the auditees).
- The audit report serves as a formal closure for the audit committee.
- The audit report provides assurance to the organization. It identifies the areas that require corrective action and associated suggestions.
- The audit report serves as a reference for any party researching the auditee or audit topic.
- It helps in follow-ups of audit findings presented in the audit reports for closure.
- A well-defined audit report promotes audit credibility. This depends on the report being well developed and well written.

Audit Report Structure

An audit report includes the following content:

- An introduction to the report, which includes the scope of the audit, the limitations of the audit, a statement of the audit objective, the audit period, and so on
- Audit findings and recommendations
- Opinion about the adequacy, effectiveness, and efficiency of the control environment

Now you will see a rundown of the main objectives of follow-up activities.

Follow-Up Activities

The main objective of follow-up activities is to validate whether management has implemented the recommendations. An IS auditor needs to determine whether management has acted on corrective actions to close the audit findings. It is essential to have a structured process to determine that corrective actions have been implemented.

Follow-up activities should be taken on the basis of the timeline agreed on by auditee management for the closure of audit findings. The status of compliance should be placed at the appropriate level of management.

Although audit follow-ups are primarily applicable to internal audit functions, external audit firms may be required to do the follow-up if it is included in the letter of engagement.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the objective of an audit closure meeting?	To ensure that there have been no misunderstandings or misinterpretations of the facts
What is the objective of conducting a follow-up audit?	To validate remediation action
What is the best way to schedule a follow-up audit?	On the basis of the due date agreed upon by auditee management

Table 2.14: Key aspects from the CISA exam perspective

Control Self-Assessment

Control Self-Assessment (CSA), as the name suggests, is the self-assessment of controls by process owners. For CSA, the employee understands the business process and evaluates the various risks and controls. CSA is a process whereby the process owner gains a realistic view of their own performance.

CSA ensures the involvement of the user group in a periodic and proactive review of risk and control.

Objectives of CSA

The following are the objectives of implementing a CSA program:

- Make functional staff responsible for control monitoring
- Enhance audit responsibilities (not to replace the audit's responsibilities)
- Concentrate on critical processes and areas of high risk

Benefits of CSA

The following are the benefits of implementing a CSA program:

- It allows risk detection at an early stage of the process and reduces control costs.
- It helps in ensuring effective and stronger internal controls, which improves the audit rating process.
- It helps the process owner take responsibility for control monitoring.
- It helps in increasing employee awareness of organizational goals. It also helps in understanding the risk and internal controls.

- It improves communication between senior officials and operational staff.
- It improves the motivational level of the employees.
- It provides assurance to all the stakeholders and customers.
- It provides assurance to top management about the adequacy, effectiveness, and efficiency of the control requirements.

Precautions while Implementing CSA

Due care should be taken when implementing the CSA function. It should not be considered a replacement for the audit function. An audit is an independent function and should not be waived even if CSA is being implemented. CSA and an audit are different functions, and one cannot replace the other.

An IS Auditor's Role in CSA

The IS auditor's role is to act as a facilitator for the implementation of CSA. It is the IS auditor's responsibility to guide the process owners in assessing the risk and control of their environment. The IS auditor should provide insight into the objectives of CSA.

An audit is an independent function and should not be waived even if CSA is being implemented. Both CSA and an audit are different functions and one cannot replace the other.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the primary objective of implementing CSA?	To monitor and control high-risk areas To enhance audit responsibilities
What is the role of the auditor in the implementation of CSA?	To act as a facilitator for the CSA program
What is the most significant requirement for a successful CSA?	Involvement of line management

Table 2.15: Key aspects from the CISA exam perspective

Summary

In this chapter, you explored various aspects of audit project management and learned about different sampling techniques. You also explored different audit evidence collection techniques, reporting techniques, and practical aspects of CSA.

The following are some of the important topics that were covered in this chapter:

- The initial step in designing an audit plan is to determine the audit universe for the organization. The audit universe is the list of all the processes and systems under the scope of the audit. Once the audit universe is identified, a risk assessment is to be conducted to identify the critical processes and systems.
- Statistical sampling is the preferred mode of sampling when the probability of error must be objectively quantified.
- It is advisable to report the finding even if corrective action is taken by the auditee. For any action taken on the basis of audit observation, the audit report should identify the finding and describe the corrective action taken.
- The objective of CSA is to involve functional staff to monitor high-risk processes. CSA aims to educate line management in the area of control responsibility and monitoring. The replacement of audit functions is not the objective of CSA.

In the next chapter, you will explore the enterprise governance of IT and related frameworks.

Chapter Review Questions

Before you proceed to *Chapter 3, IT Governance*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

[Dashboard](#) > Set 1 (Audit Project Management)

Question 1 of 18

1%

🕒 **Time Left:**
28 mins 51 secs

END QUIZ

An IS auditor is reviewing a service-oriented application. What should be the auditor's first step?

☐ To understand services and their allocation to business processes

☐ To review the coding process in accordance with service security standards

☐ To review the service-level agreement

☐ To audit the application security procedure

NEXT

[Don't Know](#)

Feedback ▾

Figure 2.7: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/WYjVC`. You will see the following screen:

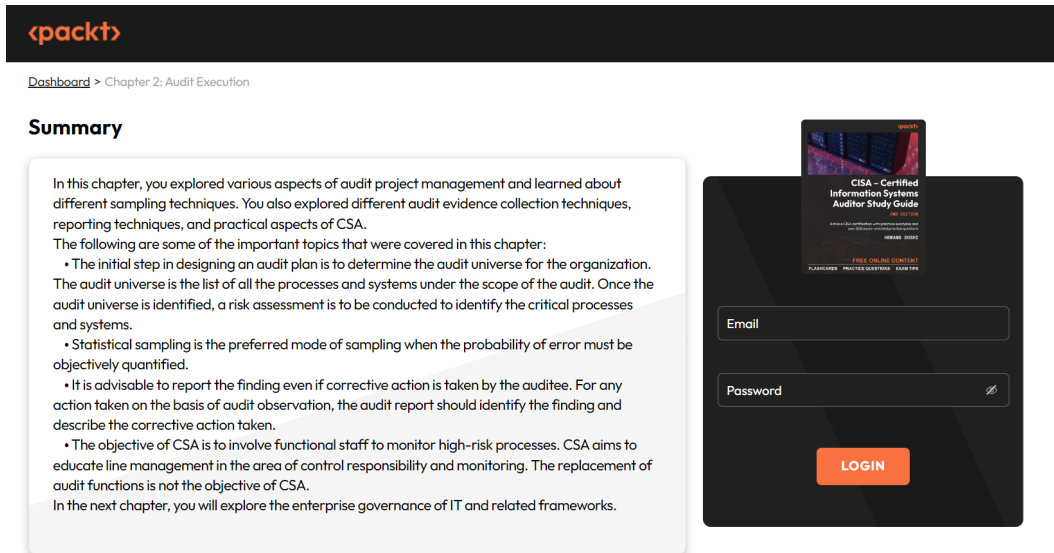


Figure 2.8: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 2.9: QR code to access *Chapter 2* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

The screenshot shows a user interface for Chapter 2. At the top, there is a navigation bar with the 'packt' logo, a 'SHARE FEEDBACK' button, and a user profile for 'Shubhra Mayuri'. Below the navigation bar, the 'Summary' section on the left contains text about audit project management and CSA, followed by a list of bullet points. On the right, the 'Chapter 2 Quizzes' section lists six quiz sets, each with a 'START' button.

Summary

In this chapter, you explored various aspects of audit project management and learned about different sampling techniques. You also explored different audit evidence collection techniques, reporting techniques, and practical aspects of CSA.

The following are some of the important topics that were covered in this chapter:

- The initial step in designing an audit plan is to determine the audit universe for the organization. The audit universe is the list of all the processes and systems under the scope of the audit. Once the audit universe is identified, a risk assessment is to be conducted to identify the critical processes and systems.
- Statistical sampling is the preferred mode of sampling when the probability of error must be objectively quantified.
- It is advisable to report the finding even if corrective action is taken by the auditee. For any action taken on the basis of audit observation, the audit report should identify the finding and describe the corrective action taken.
- The objective of CSA is to involve functional staff to monitor high-risk processes. CSA aims to educate line management in the area of control responsibility and monitoring. The replacement of audit functions is not the objective of CSA.

In the next chapter, you will explore the enterprise governance of IT and related frameworks.

Chapter 2 Quizzes
CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

- Set 1 (18 Questions) **START**
- Set 2 (18 Questions) **START**
- Set 3 (18 Questions) **START**
- Set 4 (11 Questions) **START**
- Set 5 (20 Questions) **START**
- Set 6 (11 Questions) **START**

Figure 2.10: Chapter summary and end-of-chapter question sets

- Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

The screenshot shows a practice quiz interface. At the top, there is a breadcrumb trail 'Dashboard > Set 1 (Audit Project Management)'. Below this, the 'Question 1 of 18' is displayed with a progress bar showing 1%. The question text is 'An IS auditor is reviewing a service-oriented application. What should be the auditor's first step?'. There are four radio button options. On the right, a 'Time Left' section shows '28 mins 51 secs' and an 'END QUIZ' button. At the bottom, there are 'NEXT' and 'Don't Know' buttons, and a 'Feedback' dropdown menu.

[Dashboard](#) > [Set 1 \(Audit Project Management\)](#)

Question 1 of 18 1%

An IS auditor is reviewing a service-oriented application. What should be the auditor's first step?

- ☐ To understand services and their allocation to business processes
- ☐ To review the coding process in accordance with service security standards
- ☐ To review the service-level agreement
- ☐ To audit the application security procedure

Time Left:
28 mins 51 secs

END QUIZ

NEXT [Don't Know](#)

Feedback

Figure 2.11: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

3

IT Governance

This Book Comes with Free Online Content

With this book, you get unlimited access to web-based CISA exam prep tools which include practice questions, flashcards, exam tips, and more.



Hemang Doshi

Author - CISA Study Guide 2nd Edition

Hemang Doshi is a well-known author for ISACA courses such as CISA, CISM, and CRISC. His courses are sold in more than 150 countries.

[Follow me on LinkedIn](#)

 **Practice Questions** 

 **End of Chapter Questions** 

 **Flashcards** 

 **Exam Tips** 

 **Ask a Question** 

Figure 3.1: CISA online practice resources dashboard

To unlock the content, you'll need to create an account using your unique sign-up code provided with this book. Refer to the *Instructions for Unlocking the Online Content* section in the *Preface* on how to do that.

Accessing the Online Content

If you've already created your account using those instructions, visit packt.link/cisastudyguidewebsite or scan the following QR code to quickly open the website.



Figure 3.2: QR Code to access CISA online practice resources main page

Once there, click the **Login** link in the top-right corner of the page to access the content using your credentials.

An **Information Systems (IS)** auditor must have knowledge of enterprise governance of IT and aspects related to it.

In this chapter, you will explore the following topics:

- **Enterprise Governance of IT (EGIT)**
- IT-related frameworks
- IT standards, policies, and procedures
- Organizational structure
- Enterprise architecture
- Enterprise risk management
- Maturity models
- Laws, regulations, and industry standards affecting the organization

By the end of this chapter, you, as an IS auditor, will have understood the concepts of IT governance.

Enterprise Governance of IT (EGIT)

EGIT is a process used to monitor and control IT activities. IT governance ensures that information technology provides added value to business processes and also that IT risks are appropriately addressed. The purpose of EGIT is to ensure that IT activities are aligned with business objectives. Such an alignment of IT and business leads to the attainment of business value.

The **Board of Directors** is primarily responsible for EGIT. It implements governance through leadership, organizational structures, policies, and performance monitoring to ensure that business objectives are achieved.

The following diagram depicts EGIT in a nutshell:

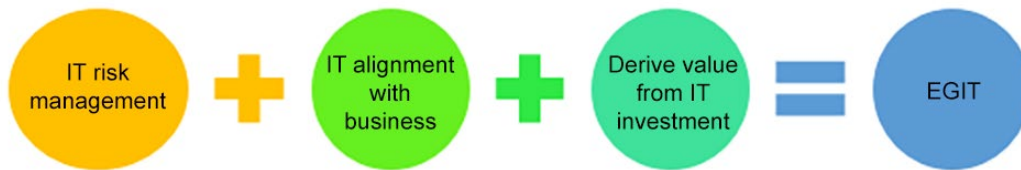


Figure 3.3: EGIT in a nutshell

For the successful implementation of EGIT, it is essential to design and document well-structured processes. This is discussed in the next topic.

EGIT Processes

The EGIT framework can be implemented by establishing and managing the following processes:

Processes	Description
IT resource management	Aims to create and update the inventory of all IT resources. Aims to manage the risks associated with IT.
Performance measurement	Aims to monitor the performance of IT resources on the basis of predetermined indicators. Aims to analyze deviations and take appropriate action to improve performance.
Compliance management	Aims to implement processes with a view to managing legal, contractual, and regulatory requirements.

Table 3.1: EGIT processes

It is essential to govern and manage the preceding processes. Therefore, a CISA aspirant should understand the differences between governance and management.

The Differences between Governance and Management

The following table outlines the differences between governance and management:

Governance	Management
Governance aims to provide direction for the attainment of business objectives. This also involves the monitoring of performance and compliance with the agreed-upon direction and objectives.	Management aims to implement policies and procedures to achieve the goals and direction set by the governance body.

Table 3.2: Differences between governance and management

EGIT Good Practices

CISA aspirants should be aware of the following EGIT good practices:

- Business and IT processes should be aligned to achieve the organization’s overall objectives.
- It is important that the Board of Directors and senior officials are involved in IT governance.
- There should be enhanced control over outsourced IT activities.
- Performance monitoring should be ensured vis-à-vis generally accepted standards and benchmarking with peers.
- A structured approach to monitoring compliance with legal, regulatory, and contractual requirements should be adopted.

Effective Information Security Governance

Information security governance is an integral part of overall IT governance. It addresses concerns regarding the safeguarding of information assets.

Like EGIT, accountability and responsibility for information security governance lies with the Board of Directors and senior management. The CEO is responsible for ensuring that appropriate policies and procedures are in place for the control of information assets.

The information security policy should be approved by the management of various functions within the enterprise to ensure that all aspects have been covered regarding the protection of information assets.

An information security governance committee should comprise the following members:

- A board representative
- The CEO
- The CIO (Chief Information Officer)
- The CTO (Chief Technology Officer)
- The COO (Chief Operating Officer)
- The CFO (Chief Financial Officer)
- The CRO (Chief Risk Officer)
- The CAO (Chief Audit Officer)
- The CCO (Chief Compliance Officer)
- The CLO (Chief Legal Officer)
- The head of HR

EGIT – Success Factors

CISA aspirants should remember the factors mentioned in this section for the successful implementation of EGIT:

- IT governance is primarily the responsibility of directors and senior management. It is designed to ensure the optimal use of IT resources to support business objectives.
- The effectiveness of an IT governance implementation can be determined most effectively by ensuring the involvement of all stakeholders.
- It is crucial to define the accountability of each critical function.
- The IS auditor is required to review the organization's chart to understand the roles, responsibilities, and authority of various functionaries.
- IT can add value to the business only if IT strategies are aligned with the business strategy. The IS auditor should determine whether IT and business requirements are integrated and heading in the same direction. A strategic IT plan must contain a clear statement regarding IT's vision and mission.

- The participation of senior officials is very important to ensure that the information security policy is in accordance with business objectives. Mediation between senior officials in terms of business and technology needs is the best option when it comes to improving strategic alignment.
- To achieve an organization's objective, the IT department should have both long- and short-term plans. These plans should be consistent with the organization's business objectives.
- IT Governance helps identify compliance with framework, IT security policy, and legal and privacy requirements.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA questions	Possible answers
What is the primary reason for reviewing the organizational chart?	To understand the structure of the organization and different roles and responsibilities
How do you determine whether IT adds value to the organization?	Alignment of the IT strategy with the organizational strategy.
Who has the final responsibility for IT governance?	Board of Directors.
What is the main objective of IT governance?	Optimal use of technology resources.
What is the prime purpose of corporate governance?	Providing strategic direction. (Corporate governance refers to overall governance and is not only restricted to IT.)

Table 3.3: Key aspects from the CISA exam perspective

IT-Related Frameworks

IT-related processes should be defined and documented in a structured manner. The adoption of IT-related frameworks helps an organization add value to its stakeholders and also ensures confidentiality, integrity, and the availability of IT assets. The following are some of the EGIT frameworks:

Framework	Description
COBIT	COBIT was developed by ISACA. It stands for Control Objective for Information and Related Technology. COBIT is an EGIT framework that ensures that IT is aligned with the business and delivers value for the business.
ISO 27000 series	The ISO 27000 series is a set of best practices for information security programs. ISO/IEC 27001 is a well-recognized standard for an Information Security Management System (ISMS).
ITIL	ITIL stands for Information Technology Infrastructure Library. It is developed by the UK Office of Government Commerce (OGC) in partnership with the IT Service Management Forum. ITIL is a detailed framework for the operational service management of IT.
O-ISM3	O-ISM3 stands for Open Information Security Management Maturity Model. It is a process-based ISM maturity model for security.
ISO/IEC 38500:2015	This standard relates to the governance of IT. It provides guidance for the effective, efficient, and acceptable use of IT within an organization.
ISO/IEC 20000	This standard relates to IT service management. It is aligned with ITIL's service management framework.
ISO 31000:2018	This standard relates to risk management. It provides guidelines on risk management for organizations.

Table 3.4: IT frameworks

CISA aspirants should understand that there will not be any direct questions on any specific framework.

IT Standards, Policies, and Procedures

EGIT is implemented through a specific set of standards, policies, and procedures. Let's understand how each one of these operates.

Policies

A policy is a set of ideas or strategies that are used as a basis for decision-making. They are high-level statements of direction issued by management:

- There can be multiple policies at the corporate level as well as the department level. It should be ensured that department-wise, policies are consistent and aligned with corporate-level policies.
- Policies should be reviewed at periodic intervals to incorporate new processes, technology, and regulatory requirements. An appropriate version history should also be maintained. An IS auditor should check for currency.
- IS auditors should use policies to evaluate and verify compliance.
- An IS auditor should also consider the applicability of policies to third-party vendors and service providers and their adherence to said policies.

Standards

Here are a few significant aspects of IT standards:

- A standard is a mandatory requirement to be followed in order to comply with a given framework or certification.
- A standard helps to ensure an efficient and effective process resulting in reliable products or services.
- Standards are updated as and when required to be embedded within the current environment.

Procedures

Procedures are detailed steps and actions that support the policy objectives.

- A procedure is considered to be more dynamic than a policy.
- A procedure document should be made available to all users.
- An IS auditor should verify adherence to documented procedural aspects.

Guidelines

In some cases, guidelines are required to implement procedures:

- Guidelines should contain information such as examples, suggestions, requirements, and other details for executing procedures:

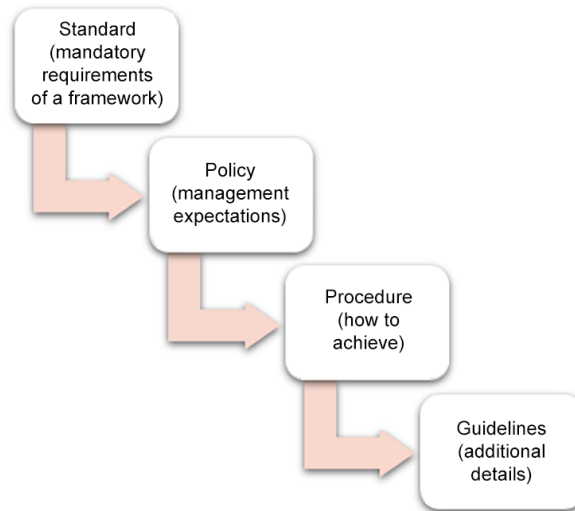


Figure 3.4: EGIT standards, policies, procedures, and guidelines

CISA aspirants are required to understand the difference between IT standards, policies, procedures, and guidelines.

Information Security Policy

The information security policy entails a commitment from the management and a plan of action to safeguard the information assets of the enterprise. An IS auditor should use the information security policy as a reference document while conducting information system audits. An IS auditor should review and evaluate the following:

- Is the information security policy approved by senior management?
- Is the information security policy documented and communicated to relevant users and third-party suppliers?
- Is the information security policy adequate and appropriate to the functioning of the organization?

Content of the Information Security Policy

An IS auditor should ensure that the information security policy includes the following elements:

- A statement of management commitment vis-à-vis information security
- A structure for conducting a risk assessment and risk management
- Information security policies, principles, and compliance requirements
- Information security awareness and training requirements for employees and third-party suppliers

- Roles and responsibilities relating to information security
- Business continuity arrangements
- Reference to other relevant documents that supplement the information security policy

An organization may capture all these requirements in a single policy or different policies. These are documented in detail as follows:

Policy	Areas Covered
Information security policy	This includes the management commitment vis-à-vis the safeguarding of information assets.
Data classification policy	This includes classification requirements and levels of control at each classification.
Acceptable use policy	This includes information relating to permissions and restrictions regarding the utilization of IT resources.
Access control policy	This includes a process for providing access in order to use information system assets.

Table 3.5: Different policies and the areas they cover

Information Security Policy Users

The policy should be disseminated to all end users. A relevant portion of information security requirements should also be made available to third-party suppliers.

Sign-off should be obtained from all employees and third parties having access to information assets regarding their readiness and preparedness to comply with the information security policy.

Information Security Policy Audit

An IS auditor should consider the following aspects when evaluating the information security policy:

- The information security policy should be reviewed at least annually or when there are significant changes to the environment of the organization.
- The policy should have an owner responsible for updating it.
- A competent authority should review the policy.
- The policy implementation process.
- The process to impart awareness and training related to the policy.

Information Security Policy Review

Management should consider the following aspects when reviewing the information security policy:

- Feedback from relevant parties
- Audit findings
- Significant changes to the environment of the organization
- Imminent threats and vulnerabilities
- Reported incidents
- Legal, contractual, and statutory requirements

The policy should be revised on account of the preceding factors to align information security requirements with business objectives.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA questions	Possible answers
What is the most important action following the dismissal of an employee?	Disabling their rights to access
The information security policy should be approved by	The Board of Directors
What is one advantage of developing operational policies by means of a top-down approach?	Consistency across the organization
What is one advantage of developing operational policies by means of a bottom-up approach?	Risk assessment is considered

Table 3.6: Key aspects from the CISA exam perspective

For more details on the top-down and bottom-up approaches, please refer to *Chapter 1, Audit Planning*.

Organizational Structure

A CISA candidate is expected to have an understanding of the organizational structure as well as the various roles and responsibilities of important IT functions.

The following table depicts the roles of IT-related functions:

Authority/committee	Description
Board of Directors	Corporate governance is mainly the responsibility of the Board of Directors.
Strategy committee	Advises the board on IT initiatives. This committee consists of members of the board and specialist members of the non-board.
IT steering committee	Ensures that the IS department is in line with the goals and priorities of the organization. The committee must determine whether IT processes support business requirements. Monitors and encourages the implementation of IT services in support of business plans for specific projects.
Project steering committee	This committee consists of a senior representative who will be affected by the new system. Provides general feedback and monitors costs and timetables for the project. Ultimately, the project steering committee is responsible for all project costs and schedules. Ensures the project's progress. Escalates issues that may impact the expected outcomes.
User management	User management takes over the project's ownership and the resulting framework. Reviews and approves the findings as described and achieved.
System development management	System development management provides technical support to the hardware and software environments through the production, implementation, and operation of the system requested.

Authority/committee	Description
Project sponsor	The project sponsor is the person responsible for the business function. It is the data owner and the owner of the developing system. Provides functional requirements to functional users.

Table 3.7: IT-related Roles and their description

Relationship between the IT Strategy Committee and the IT Steering Committee

The relationship between the IT strategy committee and the IT steering committee is shown in the following diagram:

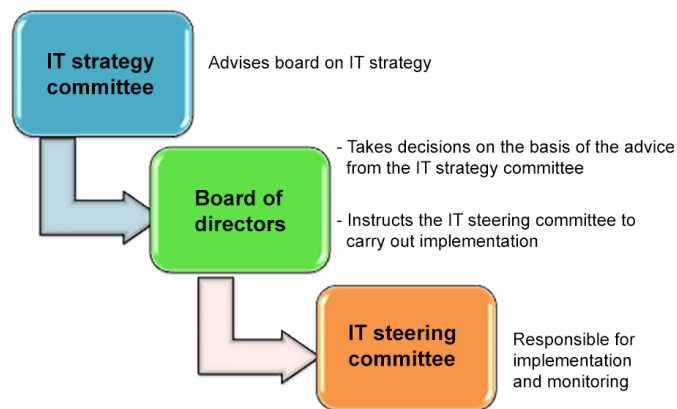


Figure 3.5: The relationship between the IT strategy committee and the IT steering committee

Differences between the IT Strategy Committee and the IT Steering Committee

A CISA aspirant should understand the functions of the IT strategy and IT steering committees. The following table outlines the differences between the two:

Strategy committee	Steering committee
Members include board members and specialist officers.	Members include the CEO, CIO, and other functionaries as required.
The strategy committee advises the board on IT strategies.	The steering committee focuses on the implementation and monitoring of IT projects.
Responsibilities include: • Aligning IT and business objectives • Identifying any exposure to IT risks • Providing direction to management regarding IT strategies	Responsibilities include: • Approving project plans and budgets • Setting priorities and milestones • Acquiring and assigning appropriate resources • Ensuring that the project meets business requirements and providing continuous monitoring • Ensuring efficient use of IT resources

Table 3.8: Differences between strategy committee and steering committee

In a nutshell, the strategy committee sets out the IT roadmap, whereas the IT steering committee drives IT-related projects.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA questions	Possible answers
The IT steering committee is primarily responsible for what?	Approving and monitoring major projects, the status of IT plans, and budgets. Monitoring project milestones and aligning project and business requirements. Prioritizing IT projects as per business requirements.

CISA questions	Possible answers
Overall responsibility for system development projects is assumed by who?	The steering committee
Ownership of a project should be assumed by who?	User management
Accountability for ensuring relevant controls over IS resources rests with who?	The resource owner (data owner/system owner)

Table 3.9: Key aspects from the CISA exam perspective

Enterprise Architecture

An **Enterprise Architecture (EA)** defines the structure and operations of the organization. The objective of EA is to determine how an organization can achieve its current as well as future objectives. It is important for the EA to include the entire future outcome. If a future-state description is not included in the EA, it is incomplete.

The EA's primary focus is to ensure that technology initiatives are compatible with the IT framework. Hence, the EA's goal is to help the organization adopt the most successful technologies. The Zachman Framework was one of the first EAs created by John Zachman. It is a fundamental EA structure that provides a formal and structured way of viewing and defining an enterprise.

Enterprise Security Architecture

Enterprise security architecture is a subset of overall enterprise architecture and includes security processes and procedures and how these are linked across the organization from a strategic, tactical, and operational perspective.

The first step in developing a security architecture is to establish a security policy for information and related technology. A security policy provides customers, administrators, and technical staff with a consistent security framework. An organization should carry out a risk assessment before implementing new technology.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA questions	Possible answers
What is the main advantage of EA?	It facilitates technology selection and adoption.
What is the best level of control when customized software is developed by a third-party vendor?	An escrow arrangement. An escrow arrangement involves storing the original code with a neutral third party. The licensee often requests escrow as a safeguard against the software being abandoned or left orphaned. If the licensor declares bankruptcy or otherwise fails to update and maintain the program as promised in the software license agreement, the licensee is entitled to receive the source code from the neutral third party.
What is the most important advantage of open system architecture?	It facilitates interoperability within different systems.

Table 3.10: Key aspects from the CISA exam perspective

Enterprise Risk Management

Enterprise risk management (ERM) is a set of practices, methods, and processes adopted by organizations to manage and monitor risks. ERM is a structured process for managing various risks that can adversely impact business objectives. For effective risk management, it is important to determine an organization's appetite for risk.

Risk Management Process Steps

Risk management is a process by means of which potential risks are identified, monitored, and managed. The following table depicts five steps to effective risk management:

Steps	Description
Asset identification	The first step is the identification of assets that are critical to the organization and that need to be adequately protected. Assets can be in the form of data, hardware, software, and people. Once assets are identified, they should be classified in terms of criticality and sensitivity. The purpose of classification is to prioritize the assets that need to be protected. Classification also helps in applying appropriate levels of protection in accordance with the critical nature of the assets. High-value assets may require more levels of control compared to other assets.
The identification of threats and vulnerabilities	The next step involves the identification of threats and vulnerabilities applicable to critical assets. Threats can include hackers, fraudsters, and natural calamities. Vulnerabilities may take the form of weak security, unprotected networks, a lack of user awareness, or a lack of business continuity arrangements.
Evaluation of impact	Once the threats and vulnerabilities are identified, the next step is to determine their impact. Impacts may take the form of financial losses, the loss of reputation, or the interruption of business activity.
Calculation of risk	The next step is to calculate the overall risk for each threat. Risk is the product of probability and effect.
Risk response	The final step is to evaluate each risk and prepare an appropriate risk response in accordance with the risk appetite of the organization. Factors that may impact risk treatment include organizational processes and policies, the cost of control vis-à-vis benefits, and the organization's appetite for risk.

Table 3.11: Risk management steps and description

Risk Analysis Methods

A risk analysis method is a method of determining the level of risk in an organization. There are three methods to determine the level – qualitative, semi-quantitative, and quantitative:

Methods	Description
Qualitative	In qualitative risk analysis, descriptions such as high, medium, and low are used to define the impacts or likelihood. This is a very simple and widely used method. While often less complicated and less time-consuming than the other methods, this method is more subjective in nature and also lacks consistency when it comes to managerial decision-making.
Semi-quantitative	A semi-quantitative method includes a descriptive ranking along with a numerical rating. This method is regarded as midway between the qualitative and quantitative methods and is generally employed when it is difficult to use the quantitative method and management is not in favor of the qualitative method. For example, the qualitative measure of “high” may be given a quantitative weight of 5, “medium” may be given a quantitative weight of 3, and “low” may be given a quantitative weight of 1. The total weight for the subject area that is evaluated may be the aggregate of the weights thus derived for the various factors under consideration.
Quantitative	Quantitative analysis is a method that makes use of mathematical and statistical modeling, measurement, and research to determine risk behavior. The goal of quantitative analysts is to quantify risk in numerical terms. For quantitative analysis, data is used from several sources, including historical records, predictive analysis, statistical records, and test results. Measurable results are one of the important advantages associated with this method. Military, nuclear, chemical, and financial entities, along with other areas, currently use many quantitative risk analysis methods. In business impact analysis, a quantitative approach provides more accuracy in terms of selecting critical processes or assets. However, it is important that there is a standardized approach for conducting a quantitative analysis across the organization.

Table 3.12: Risk assessment steps and description

Risk Treatment

Risk management includes the identification, analysis, evaluation, treatment, monitoring, and communication of risk impacts on IT processes. Four approaches are generally observed regarding the treatment of risk:

Risk treatment options	Description
Mitigate	This is also known as risk reduction. Risk can be mitigated or reduced by implementing necessary checks and controls. Out of all four options, risk mitigation is employed more frequently.
Accept	This option requires acceptance of the risk as it stands. This is generally applied to low-risk situations, where the cost of control is higher than the impact of the risk.
Avoid	This option requires the avoidance of the activity that would cause risk. This is generally applied in relation to high-risk scenarios, where the impact could be devastating.
Transfer	This is also known as sharing of risk. Risk is transferred or shared by way of insurance or by entering into partnership and suchlike.

Table 3.13: Risk treatment options and description

Therefore, risk can be avoided, reduced, transferred, or accepted. An organization can also choose to reject risk by ignoring it, but this can be dangerous and should be considered a red flag by the IS auditor.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA questions	Possible answers
What is the first step in implementing a risk management program?	Asset identification (the first step) Determine the threat, vulnerability, and risk profiles of the organization (if the asset identification option is not available)

Table 3.14: Key aspects from the CISA exam perspective

Maturity Model

Implementing IT governance involves the ongoing performance measurement of the assets of an organization. Maintaining consistent processes, productivity, and efficiency requires the implementation of a process maturity framework. The system can be based on different models, for example, **Capability Maturity Model Integration (CMMI)** and the **Initiating, Diagnosing, Establishing, Acting, and Learning (IDEAL)** model. CISA aspirants should be aware that there will be no direct questions in the exam on any of the particular frameworks or models.

Laws, Regulations, and Industry Standards Affecting the Organization

Laws and regulations are being enacted with the aim of protecting the interests of stakeholders. In the field of IT, the most common objectives of laws and regulations include the safeguarding of privacy and the confidentiality of personal data, the protection of intellectual property rights, and the integrity of financial information.

All these laws and regulations mandate various policies and procedures to protect the interests of stakeholders. CISA aspirants should be aware that there will be no direct questions in the exam on any particular laws or regulations.

An IS Auditor's Role in Determining Adherence to Laws and Regulations

An IS auditor should consider the following factors in determining the level of adherence to laws and regulations by an organization:

- Has an organization identified applicable laws and regulations pertaining to IT?
- How is the **Governance, Risk, and Compliance (GRC)** program implemented within the organization?
- Has the organization identified compliance- and legal-related risks and implemented appropriate controls to address these risks?
- Has an organization operating in multiple jurisdictions determined the legal and regulatory requirements for all areas where they operate?
- Has overall responsibility for adherence to regulatory requirements been assigned to an individual at the senior management level?
- Is there an appropriate monitoring, auditing, and reporting process in place in relation to legal and regulatory requirements?

The following guidelines (issued by IIA) need to be considered when auditing regulatory compliance:

- Standards and procedures: Employees and other entities should follow the provision of compliance requirements and procedures to reduce the risk of a regulatory violation.
- The assignment of responsibility to senior personnel: Individual(s) from senior management within the organization should have responsibility for compliance.
- Reliable staff background: Proper background checks need to be carried out before access or authority positions are established in order to ensure that such power is not assigned to people who have carried out illegal activities.
- Communication of procedures: Both staff and other stakeholders should be fully aware of policies and procedures.
- Compliance monitoring and auditing: Appropriate monitoring and reporting measures need to be taken to conform with requirements.
- Consistent enforcement: Organizations should ensure that compliance with effective disciplinary action against offenders is regularly applied throughout the organization.
- An appropriate response to an offense and mitigation of similar offenses: Once an offense is detected/has occurred, organizations need to disclose it to the appropriate authorities and act in a timely manner to prevent future offenses.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA questions	Possible answers
What is a major factor to be considered in relation to offshore data storage/transfer?	Privacy laws
What are the concerns regarding the use of cloud services?	Compliance with laws and regulations (first preference) Data confidentiality

Table 3.15: Key aspects from the CISA exam perspective

Summary

In this chapter, you learned about the important aspects of enterprise governance and related frameworks that an IS auditor is expected to use during audit assignments. You also explored the practical aspects of IT standards, policies, and procedures. The most important benefit of audit planning is that it helps the auditor focus on high-risk areas. Further, you studied organizational structure, enterprise architecture, and enterprise risk management.

The following is a recap of the important topics learned about in this chapter:

- EGIT is a process used to monitor and control IT activities. Information security governance is an integral part of overall IT governance. Information security governance addresses concerns regarding the protection of information assets, in other words, the confidentiality, integrity, and availability of the information.
- The primary responsibility and accountability for setting up the IS security policy reside with the Board of Directors.
- An organization's mission, vision, and goals can be achieved by creating and implementing strategic plans. Top management should be involved in developing strategic plans, ensuring that plans are aligned with business goals.
- It is important for the EA to consider the entire future outcome because IT strategic and tactical plans will be determined by the difference between the present state and the future state. If a future-state description is not included in the EA, it is not complete, and this problem should be identified as an observation.
- To be successful in managing risk, IT management must be matched with business objectives. This can be achieved by using appropriate terminology that is known by everyone, and the best way to do this is to present IT risks in business terms.

In the next chapter, you will learn about IT management with respect to the auditing of resource management processes, third-party suppliers, and performance monitoring processes.

Chapter Review Questions

Before you proceed to *Chapter 4, IT Management*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

[Dashboard](#) > [Set 1](#) (Enterprise Governance of IT)

Question 2 of 21

10%

 **Time Left:**

33 mins 49 secs

END QUIZ

The IS auditor noted that roles and responsibilities in terms of IT governance and management are not properly documented and defined. What is the most appropriate recommendation?

☐

To review the alignment of IT with business objectives

☐

To define the accountability for each critical function

☐

To conduct an IS audit on an ongoing basis

☐

To create the role of CRO in the organization

PREVIOUS

NEXT

[Don't Know](#)

Feedback



Figure 3.6: CISA practice question interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to <https://packt.link/UiKaw>. You will see the following screen:

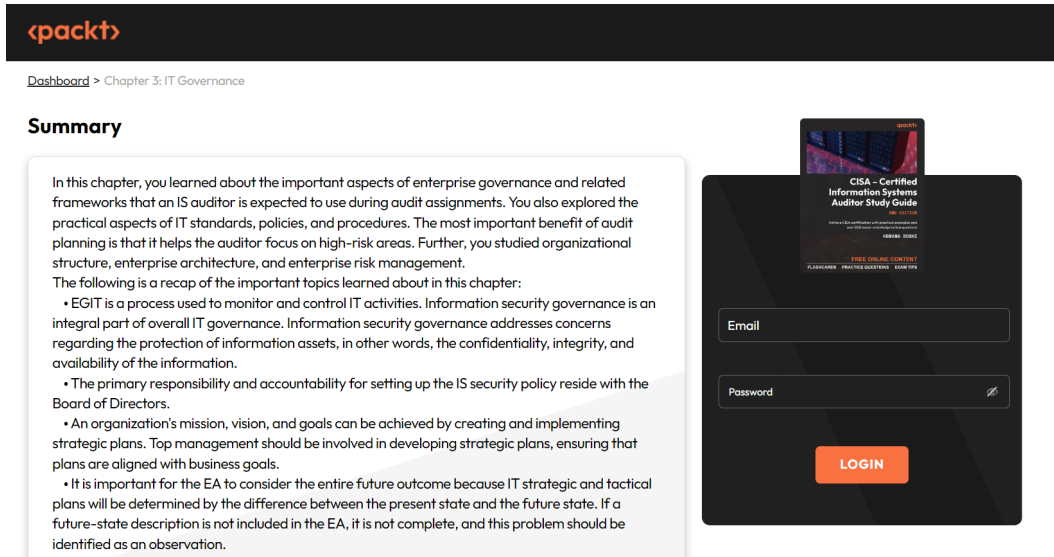


Figure 3.7: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 3.8: QR code to access *Chapter 3* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

The screenshot shows the Packt dashboard interface. At the top, there's a navigation bar with the Packt logo, a 'SHARE FEEDBACK' button, and a user profile for 'Shubhra Mayuri'. Below the navigation bar, the breadcrumb trail reads 'Dashboard > Chapter 3: IT Governance'. The main content area is titled 'Chapter 3: IT Governance' with a 'Summary' section. The summary text discusses the importance of enterprise governance and IT standards. To the right of the summary is a 'Chapter 3 Quizzes' section, which lists five quiz sets with 'START' buttons. The quiz sets are: Set 1 (21 Questions), Set 2 (21 Questions), Set 3 (20 Questions), Set 4 (10 Questions), and Set 5 (20 Questions).

Figure 3.9: Chapter summary and end-of-chapter question sets

- Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

The screenshot shows the practice questions interface. At the top, the breadcrumb trail reads 'Dashboard > Set 1 (Enterprise Governance of IT)'. The main content area is titled 'Question 2 of 21' with a progress bar showing 10% completion. The question text is: 'The IS auditor noted that roles and responsibilities in terms of IT governance and management are not properly documented and defined. What is the most appropriate recommendation?'. There are four radio button options: 'To review the alignment of IT with business objectives', 'To define the accountability for each critical function', 'To conduct an IS audit on an ongoing basis', and 'To create the role of CRO in the organization'. At the bottom, there are buttons for 'PREVIOUS', 'NEXT', and 'Don't Know', along with a 'Feedback' dropdown menu. On the right side, there is a timer showing 'Time Left: 33 mins 49 secs' and an 'END QUIZ' button.

Figure 3.10: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure you are well-equipped to tackle the concepts in the upcoming chapter.

4

IT Management

The monitoring, administration, and control of an organization's IT assets are referred to as IT management. The primary goal of IT management is to make sure that IT assets are working properly and efficiently. IT management also aims to align the performance of IT assets in accordance with business requirements. The following topics are covered in this chapter:

- IT resource management (training, scheduling, and time-reporting terms and conditions of employment)
- IT service provider acquisition and management

IT performance monitoring and reporting

- Quality assurance and quality management in IT

In this chapter, CISA aspirants will learn about and come to understand the practical aspects of IT resource management, including managing third-party risks and various aspects of the performance-monitoring process and identifying opportunities for improvements.

IT Resource Management

One important part of IT governance is ensuring that IT resources are used to their full potential. The resources deployed should focus on attaining business objectives. An IS auditor should be familiar with the management of various resources required to supply IT services. IT service control can be further divided into the following domains:

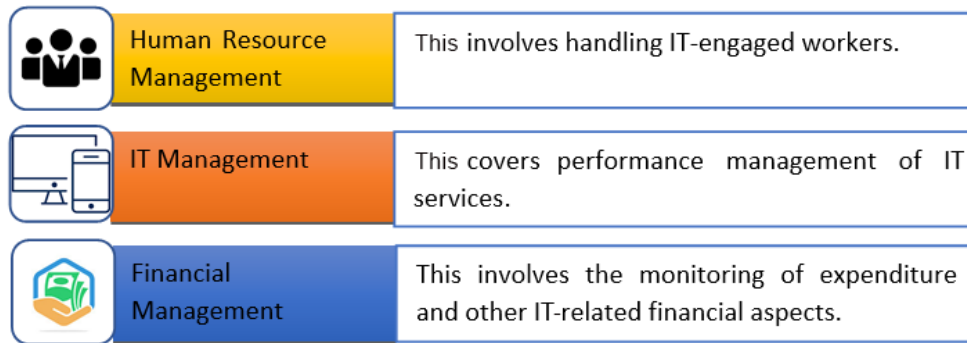


Figure 4.1: Domains of IT control services

You will now explore each of the preceding IT resources in detail.

Human Resource Management

Human Resource (HR) management includes processes such as new employee onboarding, job allocation, performance evaluations, and other HR-related operations and procedures. Some of the most critical areas of HR management are listed in the following subsections.

Hiring

The hiring procedure includes the following:

- Conducting due diligence and background verification prior to onboarding employees
- Obtaining the employee's acknowledgment with respect to a non-disclosure agreement and other employment-related terms and conditions
- Distributing a rule book for employees that includes the following:
 - IS policies and procedures
 - The organization's acceptable usage policy
 - The employee code of conduct
 - The disciplinary procedure for non-compliance
 - Other relevant roles and responsibilities

Training

Another significant aspect of HR management is training. This includes the following:

- Providing training to all employees on the organization's IS requirements.
- Offering training at regular intervals as part of employees' induction and continuing throughout their employment or for the time their contract is valid.
- Covering the organization's method of change management, crisis management, and business continuity structure as part of the training.
- Conducting relevant training after each infrastructure change.
- In the case of cross-training, it is important to consider the risk where a single employee has knowledge of the full system. Employees having full knowledge may try to circumvent the system for their own benefit.

Scheduling and Time Reporting

Structured scheduling helps ensure efficient and effective organizational processes. Time monitoring helps management track the organization's resource efficiency.

Detailed feedback from HR to employees is important for efficient planning and time reporting. Scheduling and time monitoring can be used to measure expenditure allocations, charges, invoices, and KPIs.

During Employment

The following are some of the important HR controls that should be in place during employment:

- Employee roles and responsibilities should be documented in a job description, and employees should be aware of their respective roles and responsibilities.
- The preceding point improves employees' understanding of the responsibility associated with their position and reduces the chances of human error.
- Administrative management processes for security violations should be reported and made accessible to all employees and related third-party vendors.
- Standards for the performance evaluation of employees should be structured and quantified as much as possible.
- Mandatory vacation policies should be implemented for each employee. The majority of fraud is uncovered when the particular fraudster is not present in the office.
- Mandatory job rotation policies should also be implemented. This expands the possibilities for monitoring the risk of fraudulent or malicious acts.

Termination Policies

The termination policies and procedures should be reported by the organization. This includes the appropriate procedure for terminating employees due to fraud or other illegal actions to protect the company's assets. Further, employees are required to obtain clearance from the departments involved to ensure that all belongings, access keys, ID cards, and so on are returned to the organization.

IT Management Practices

The following are some of the important aspects of IT management practices:

- IT administration requires rules and procedures for the design, delivery, control, and maintenance of the manner in which technology is used within an organization
- IT management practices should be consistent with strategic business priorities
- Senior management should authorize management policies and procedures to ensure that the IT management team efficiently and effectively manages the organization's activities
- IT activities and procedures related to infrastructure need to be periodically updated to keep them aligned with the new operating environment of the company

Financial Management Practices

Sound financial management practices are essential for any company process to be effective. There are many ways of allocating IT-related expenditures to various functions/users.

One way of managing and regulating IT expenditures is by introducing a user-pay system that is a form of chargeback. A standard structure is used in this system to distribute the costs of IT programs to end users. This method of redistribution of costs (also known as chargeback) increases the efficiency and effectiveness of the service provided by the information processing facility. At the same time, budget-based reporting is meant to predict and monitor IT costs.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects of the preceding topic from the CISA exam perspective:

CISA questions	Possible answers
What is the objective of the software escrow agreement?	To address the risk of the closure of vendors of customized written software
What is the primary objective of mandatory holidays?	To detect fraud or illegal acts

CISA questions	Possible answers
What is the primary objective of job rotation?	To detect fraud or illegal acts
What is the primary compensating control in the absence of segregation of duties?	Transaction and log monitoring
What is the first step when an employee is terminated?	To revoke the employee's access to all systems
What is the primary consideration when reviewing IT priorities and coordination?	Alignment of the project with business objectives

Table 4.1: Key aspects from the CISA exam perspective

IT Service Provider Acquisition and Management

Outsourcing services to a third-party vendor is a widely accepted practice in today's world for two major reasons. One of them is the tremendous savings in cost and the other is to avail the service of experts in the field.

CISA aspirants should be aware of the following important terms with respect to outsourcing:

- **Insourced:** Activities performed by the organization's own staff
- **Outsourced:** Activities performed by the vendor's staff
- **Hybrid:** Activities performed jointly by staff from both the organization and the vendor
- **Onsite:** Staff working onsite in the IT department
- **Offsite:** Staff working from remote locations in the same geographical area
- **Offshore:** Staff working from remote locations in different geographical areas

Evaluation Criteria for Outsourcing

CISA aspirants should understand the evaluation criteria for the outsourcing of any function. The following functions should not be outsourced:

- The core functions of the organization
- Roles that require specific expertise, procedures, and key resources that cannot be replicated externally or anywhere else
- Functions that cannot be outsourced due to contractual or regulatory constraints

The outsourcing of functions can be done if the following apply:

- Functions can be carried out by another party to the same level of quality or better, at the same price or lower, without increasing risk
- The organization has sufficient experience in managing third parties working on its behalf

Steps for Outsourcing

The following steps will help you determine whether outsourcing will enable the company to achieve its desired goal considering the costs and risks involved:

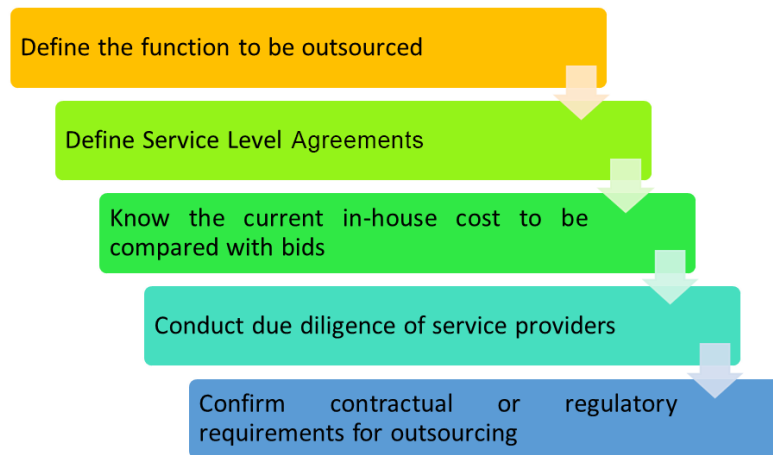


Figure 4.2: Steps for outsourcing

The following are detailed steps for the outsourcing of any function:

1. Define the function to be outsourced: The organization should first define and determine the functions that need to be outsourced.
2. Define a **Service-Level Agreement (SLA)**: Defining an SLA is a very important aspect of outsourcing. SLAs should be approved by the legal, risk management, and compliance teams.
3. Determine the cost: Here, you need to determine the cost of outsourcing. Knowledge of the in-house cost of the operations will help with analyzing the bids from vendors and ensure that they are reasonable.
4. Conduct due diligence: Due diligence includes verifying the profile of the service provider and their market credibility, financial stability, capability to serve on a long-term basis, and other relevant details.
5. Confirm contractual or regulatory requirements for outsourcing: It is of utmost importance to determine any regulatory and contractual requirements when outsourcing any activity.

Outsourcing – Risk Reduction Options

The following are important aspects for reducing the risk related to outsourcing:

- A requirement for achievable output should be included in the SLA
- The use of an escrow arrangement for software assets
- The use of multiple suppliers helps to lower the risk of dependence
- Periodic reviews of performance
- Building a cross-functional contract management team
- Setting up appropriate controls for any anticipated contingencies

Provisions for Outsourcing Contracts

SLAs serve as a monitoring tool for the outsourcing process. They should contain, at least, the following clauses:

- Requirements for achievable output
- **Confidentiality, Integrity, and Availability (CIA)** requirements for resources/systems/data
- Confidentiality agreements to protect both parties
- A right-to-audit clause
- Business continuity and disaster recovery provisions
- Intellectual property rights

Role of IS Auditors in Monitoring Outsourced Activities

The following are some of the important functions of the IS auditor in monitoring outsourced activities:

- To review contracts at the service level at periodic intervals
- To review documented procedures and outcomes of the outsourcer's quality assurance programs
- Periodic checks to ensure that the processes and procedures comply with the outsourcer's quality standards

Globalization of IT Functions

CISA aspirants should understand the following aspects with respect to the globalization of IT functions:

- Globalization includes remote or offshore setups of IT systems
- Outsourcing may or may not require globalization

- For outsourcing reasons, many companies are globalizing their IT functions
- To promote the smooth operation of IT functions from offsite locations, certain issues need to be addressed, including the following:
 - Legal and regulatory issues
 - Continuity of operations
 - Telecommunication issues
 - Cross-border and cross-cultural issues

Outsourcing and Third-Party Audit Reports

Monitoring third-party performance and compliance with the SLA and other statutory requirements is important. Obtaining an independent third-party audit report will provide clarity regarding the state of affairs of service providers.

An audit report should cover any confidentiality, integrity, data, and system availability issues. Regulatory bodies mandate some third-party audits. One example is reporting by the **Service Organization Control (SOC)**, covering the following details:

Report	Description
SOC 1	This report focuses on program controls for financial reporting by the service organization.
SOC 2	Security, availability, processing integrity, confidentiality, and privacy are aspects of the audit (that is, the trust service principles). SOC 2 reports are restricted to the use of the service organization's management, customers, and other related parties.
SOC 3	Similar to SOC 2 reports; these reports, however, are for general use and can be distributed freely.

Table 4.2: SOC reports

IS auditors should review reports of penetration testing activities, vulnerability assessments, and other compliance reviews in accordance with the service's criticality. All SOC's, that is, SOC 1, 2, and 3, are based on Statement on Standards of Attestation Engagements Version 18, also called SSAE 18.

Monitoring and Review of Third-Party Services

Critical services managed by third parties can increase the risk to the organization's business continuity and, ultimately, reputation. Further, poor third-party system controls increase the risk of data leakage. Therefore, continuous monitoring and control of third-party risks and performance are important.

The monitoring and analysis of third-party providers described so far in this section will ensure compliance with the SLA and other legal requirements. IS auditors should ensure proper monitoring covering the following details:

- The risk management and legal teams review the SLA and ensure that the applicable provisions are included.
- A documented process is implemented to track compliance with the agreements.
- Management analyzes the results of the work of third parties at regular intervals.
- Third parties are audited to analyze their IS policies at least annually.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects of the preceding from the perspective of the CISA examination:

CISA questions	Possible answers
What is the primary objective of outsourcing?	To obtain the services of expert firms and to save on costs
What is the primary concern about outsourcing to offshore locations?	Privacy laws and regulatory requirements
What is the primary function of IT management when a service has been outsourced?	To monitor the outsourcing provider's performance
What is the objective of the software escrow agreement?	To address the risk of the closure of vendors of customized written software
What is the best way to determine whether the terms of the contract are adhered to in accordance with the SLA?	An independent audit
What is the primary requirement for the development of software by a vendor?	An escrow arrangement for source code

CISA questions	Possible answers
What is the primary risk of subcontracting?	The requirement to protect information may be compromised. Subcontracting refers to the involvement of a third party for processing. A subcontract increases the risk of data leakage and requirements to protect information may be compromised.

Table 4.3: Key aspects from the CISA exam perspective

IT Performance Monitoring and Reporting

One of the important elements of IT governance is the monitoring of IT performance. The knowledge that IT operations are moving in the desired direction provides management with a level of comfort. It is extremely important to develop metrics for monitoring performance. The following sections explain these metrics.

Development of Performance Metrics

Developing performance metrics usually involves three steps:



Figure 4.3: Steps for developing performance metrics

1. Identify the critical processes: The first step is to identify the critical processes that need to be monitored.
2. Identify the expected output: The second step is to define the expected output or target for each process that needs to be monitored.
3. Compare the actual output with the target: On a periodic basis, compare the actual output with the target. If the target is not achieved, conduct a root cause analysis to determine areas of improvement.

Effectiveness of Performance Metrics

The effectiveness and reliability of the metrics can be enhanced by considering the best practices listed as follows:

- Metrics should be regularly assessed
- Data should be readily available to be used for metric measurements
- The data should be complete, accurate, and reliable
- Quantified and comparable data should be available
- Targets should be set from the top down and should be aligned with business goals
- Metrics should be set from the bottom up and should attempt to cover the fulfillment of the target at all levels to allow progress to be monitored
- All key IT processes should have proper metrics
- Targets should be approved by stakeholders, and accountability and responsibility for achieving targets should be clearly defined

Tools and Techniques

The following table outlines some of the industry-recognized tools and techniques for performance measurement:

Tools	Description
Six Sigma	Six Sigma is a quantitative process analysis methodology for process improvement and the reduction of defects. Anything outside the customer specification is defined as a Six Sigma defect.
Lean Six Sigma	Lean Six Sigma has a similar approach to Six Sigma. It seeks to remove unnecessary steps that do not add value.

Tools	Description
An IT Balanced Scorecard (BSC)	An IT BSC is one of the most effective IT governance tools; it shows the efficiency and value creation of the IT team and assesses IT performance, risks, and capabilities. A BSC helps to align IT with business needs. An IT BSC assesses measures relating to customer satisfaction, internal (operational) processes, and innovation abilities. An IT BSC looks at four aspects: • The organization's mission • Strategies • Measures • Sources
KPIs	A Key Performance Indicator (KPI) is a measurable attribute related to the organization's key business goals. KPIs are used for measuring performance against predetermined goals. KPIs are a key indicator of goal achievement. They also reflect abilities, practices, and skills.
Benchmarking	Benchmarking includes the evaluation and comparison of business processes and performance metrics with other organizations' best practices. Benchmarking helps professionals to learn the best ways to implement processes.
BPR	Business Process Reengineering (BPR) is the process of redesigning performance improvement and cost reduction processes. Processes are synchronized across BPR and are responsive to the customer base and market needs.
Root cause analysis	This involves finding the basic cause behind an incident in order to find an appropriate solution. Once the root cause analysis has been performed, effective corrective action is taken to prevent a system failure or deficiency. It helps us to learn from errors and issues and to ensure that the given incident does not occur again.

Tools	Description
Life cycle cost-benefit analysis	Life cycle cost-benefit analysis is used to determine the strategic direction for the IT team and overall IT portfolio management. It covers the various phases of IT development, along with life cycle cost estimates such as the maintenance and upgrade of IT infrastructure.

Table 4.4: Industry-recognized tools and techniques

Key Aspects from the CISA Exam Perspective

The following table covers important aspects of the preceding discussion from the CISA exam perspective:

CISA questions	Possible answers
What is the prerequisite for the implementation of a balanced scorecard?	Availability of key performance indicators
What is the primary objective of an IT performance measurement process?	Optimizing the performance
Which is the best method to understand the effectiveness of an organization's IT asset planning and management?	Analyzing the IT balanced scorecard
What is the risk of a lack of measurable performance indicators?	In the absence of measurable performance indicators, misleading indications of IT performance could be presented to management

Table 4.5: Key aspects from the CISA exam perspective

Quality Assurance and Quality Management in IT

You will now explore quality assurance and quality management processes in IT in detail. According to the **CISA Review Manual (CRM)**, an IS auditor must understand the concepts, processes, roles, and responsibilities of quality assurance and quality management within the company.

Quality Assurance

Quality Assurance (QA) is a process that aims to provide adequate confidence that an item or product conforms to the requirements developed. QA staff verify that changes to the system are approved, checked, and implemented in a controlled manner. **Quality Control (QC)** is a method for performing tests or reviews to verify that the product is free of defects and meets the user's requirements.

Generally, QA personnel perform two distinct tasks:

- QA: This provides assurance that an object or product meets the requirements as laid down.
- QC: These are observation strategies or exercises that ensure that quality-related criteria are fulfilled.

The following table differentiates between QA and QC:

QA	QC
Proactive	Reactive
Prevents defects	Finds defects
More focused on processes	More focused on products

Table 4.6: Differences between QA and QC

This is covered in more detail as follows.

The QC team is responsible for ensuring that the program meets consumer standards and is free from defects.

Before the programs are moved into development, QC must be completed.

It is recommended that the QA department be autonomous within the company in order to achieve successful QA output.

The role of QC should not be performed by an individual whose position would create a conflict with SoD. An individual should not, under any circumstances, review their own work. For example, a database administrator should not carry out a quality assessment of processes that would affect the database because they work on the system themselves.

Quality Management

Quality management is all about monitoring, tracking, and enhancing quality management processes. Some quality management areas include the following:

- Software development, maintenance, and implementation
- The purchase of hardware and software
- Operational activities
- Service management
- Security
- HR management

Key Aspects from the CISA Exam Perspective

The following table covers an important aspect from the perspective of the CISA exam:

CISA questions	Possible answers
What is the primary objective of implementing a quality management system?	Continuous improvement

Table 4.7: Key aspects from the CISA exam perspective

Summary

In this chapter, you learned about various aspects of IT resource management, the different criteria and risks associated with outsourcing, IT monitoring, and reporting structures, and aspects of QA and quality management.

You learned about the following important topics in this chapter:

- The main goal of IT projects is to add value to business processes. The IS auditor's primary consideration is to determine and ensure that IT initiatives are aligned with business objectives while designing and approving the project.
- An escrow agreement is entered into between a service provider and a client to ensure the permanent availability of the client's source code. The source code is held by a third party. In the event of the vendor going out of business, the client can claim the source code back from the third party.

- In no circumstances can accountability be transferred to external parties. Regardless of the function outsourced, it is the ultimate responsibility of the organization to be accountable to the relevant stakeholders.
- The most important requirement for the implementation of an IT BSC is defining KPIs. KPIs are necessary for measuring and monitoring effectiveness.

In the next chapter, you will explore project governance and management aspects, the importance of the business case and feasibility analysis, and various system development methodologies.

Chapter Review Questions

Before you proceed to *Chapter 5, Information Systems Acquisition and Development*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

[Dashboard](#) > Set 1 (IT Resource Management)

Question 1 of 14

1%

Time Left:
19 mins 58 secs

END QUIZ

An IS auditor is reviewing IT priorities and coordination. Which of the following should be the primary consideration?

☐ Alignment of the project with business objectives

☐ Management of project risk

☐ Cost of project controls

☐ IT project escalation process

NEXT

Don't Know

Feedback

Figure 4.4: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to <https://packt.link/a8S6v>. You will see the following screen:

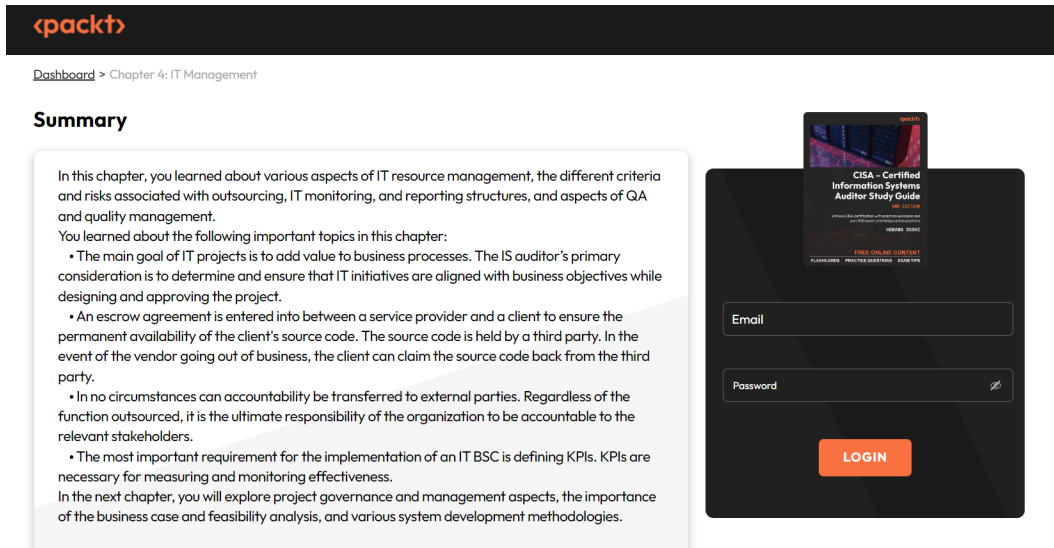


Figure 4.5: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 4.6: QR code to access *Chapter 4* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

The screenshot shows the Packt chapter summary and quizzes interface. At the top, there's a dark header with the Packt logo, a 'SHARE FEEDBACK' button, and a user profile 'Shubhra Mayur'. Below the header, the chapter title 'Chapter 4: IT Management' is displayed in orange. Underneath, the 'Summary' section contains a paragraph about IT resource management, followed by three bullet points: 'The main goal of IT projects is to add value to business processes...', 'An escrow agreement is entered into between a service provider and a client...', and 'In no circumstances can accountability be transferred to external parties...'. To the right, the 'Chapter 4 Quizzes' section lists three quiz sets: 'Set 1 (14 Questions)', 'Set 2 (30 Questions)', and 'Set 3 (10 Questions)', each with a 'START' button.

Chapter 4: IT Management

Summary

In this chapter, you learned about various aspects of IT resource management, the different criteria and risks associated with outsourcing, IT monitoring, and reporting structures, and aspects of QA and quality management.

You learned about the following important topics in this chapter:

- The main goal of IT projects is to add value to business processes. The IS auditor's primary consideration is to determine and ensure that IT initiatives are aligned with business objectives while designing and approving the project.
- An escrow agreement is entered into between a service provider and a client to ensure the permanent availability of the client's source code. The source code is held by a third party. In the event of the vendor going out of business, the client can claim the source code back from the third party.
- In no circumstances can accountability be transferred to external parties. Regardless of the function outsourced, it is the ultimate responsibility of the organization to be accountable to the relevant stakeholders.
- The most important requirement for the implementation of an IT BSC is defining KPIs. KPIs are necessary for measuring and monitoring effectiveness.

In the next chapter, you will explore project governance and management aspects, the importance of the business case and feasibility analysis, and various system development methodologies.

Chapter 4 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (14 Questions) **START**

Set 2 (30 Questions) **START**

Set 3 (10 Questions) **START**

Figure 4.7: Chapter summary and end-of-chapter question sets

3. Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

The screenshot shows the practice questions interface. At the top, there's a breadcrumb 'Dashboard > Set 1 (IT Resource Management)'. Below it, the question number 'Question 1 of 14' is displayed in large bold text, followed by a progress bar showing '1%'. To the right, a 'Time Left' section shows '19 mins 58 secs' and an 'END QUIZ' button. The question text is 'An IS auditor is reviewing IT priorities and coordination. Which of the following should be the primary consideration?'. There are four radio button options: 'Alignment of the project with business objectives', 'Management of project risk', 'Cost of project controls', and 'IT project escalation process'. At the bottom, there's a 'NEXT' button, a 'Don't Know' link, and a 'Feedback' dropdown menu.

Dashboard > Set 1 (IT Resource Management)

Question 1 of 14 1%

Time Left:
19 mins 58 secs
END QUIZ

An IS auditor is reviewing IT priorities and coordination. Which of the following should be the primary consideration?

☐ Alignment of the project with business objectives

☐ Management of project risk

☐ Cost of project controls

☐ IT project escalation process

NEXT [Don't Know](#) Feedback

Figure 4.8: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Information Systems Acquisition and Development

A CISA aspirant should have a sound understanding of information system acquisition, development, and implementation processes. You should be able to understand how an organization evaluates, develops, implements, maintains, and disposes of its information systems and related components.

The following topics will be covered in this chapter:

- Project management structure
- Business case and feasibility analysis
- System development methodologies
- Control identification and design

You will now explore each of these in detail.

Project Management Structure

Project management structure can be primarily classified into the following three categories:

Functional Structured	Project Structure	Matrix Structured
The project manager has no authority. The project manager only advises peers on projects.	The project manager has formal authority on budget, schedules, and team members of the project.	Authority is shared between project manager and department heads.

Table 5.1: Categories of project management

For all the preceding project structures, the project should be approved and prioritized by the IT steering committee. A person in charge of the project must be appointed and should be made responsible for project execution. This project manager should be given the relevant resources and infrastructure to ensure the smooth completion of the project.

Project Roles and Responsibilities

IS auditors should have a basic understanding of the generic roles and responsibilities of individuals involved in the project management process. Further, an understanding of the project's organizational structure is very important when conducting an audit. In this section, you will look at some of the responsibilities of the important stakeholders.

Board of Directors

The **Board of Directors (BoD)** has the ultimate responsibility and accountability for IT governance.

IT Strategy Committee

The IT strategy committee guides and recommends the BoD on IT initiatives. It comprises board members and other experts in the field of IT.

Project Steering Committee

The project steering committee is responsible for project prioritization, monitoring, and control, and for approving project budgets. It comprises senior representatives from different business functions.

Project Sponsor

Project sponsors are the owners of the resultant systems under development. The project expenditure costs are assigned and allocated to the project sponsor.

The project sponsor is responsible for providing system specifications and other requirements.

They assume ownership of the project and are responsible for **User Acceptance Testing (UAT)** and system approvals.

System Development Management

System development management is responsible for providing technical support for the project.

Project Cost Estimation Methods

The following are four widely used methodologies to estimate the cost of system development projects:

- **Analogous estimate:** The cost of a new project is estimated on the basis of the experience of previous projects. This is the quickest estimation method.

- **Parametric estimate:** Past data is used to leverage statistical data (such as estimated hours and technological requirements) to estimate cost. This method is considered more accurate than analogous estimates.
- **Bottom-up estimate:** Detailed cost estimates of each activity are drawn up and the sum of all activities is considered to produce a cost estimate for the project. This is the most accurate estimate, but it is time-consuming.
- **Actual costs:** This is the same as analogous estimation where the actual cost of past projects is extrapolated to estimate costs.

Software Size Estimation Methods

Accurate estimates for the scope of software development efforts are important for the allocation of resources and time and for the monitoring of the project. Some widely used methodologies to estimate the size of system development are as follows:

- **Source Lines of Code (SLOC):** SLOC is a traditional way of estimating software size on the basis of a single parameter, such as the number of lines of code. However, this may not be effective in the case of complex systems with functionality other than code. Such functionality could include diagrams, objects, database queries, or graphical user interfaces.
- **Function Point Analysis (FPA):** FPA is an indirect technique to estimate the size of software. Function points are a unit of measurement for software size just like time is measured in hours or distance in miles. To arrive at a function point, different factors are considered, such as the complexity of the design, input, processing, outputs, and modules and their interactions. FPA is more consistent and appropriate than SLOC.
- **COCOMO:** COCOMO stands for Constructive Cost Model. It can be considered an advanced version of SLOC. In COCOMO, apart from the number of lines of code, the complexity of the system is also considered in drawing up the estimation.

Project Evaluation Methods

Monitoring the progress of the project and the project duration is a critical process in project management. Some widely used methodologies for project evaluation are as follows.

Critical Path Method

The **Critical Path Method (CPM)** is used to estimate the duration of a project. Any project will have a minimum of one critical path:

- A critical path is determined by identifying the longest path of dependent activities. The time required to finish the critical path is the shortest possible time required for finishing the project.
- No slack time is available for the activities on the critical path.

- Slack time is the time that acts as a buffer or extra time, and an activity can be delayed up to the limit of the slack time without impacting the overall project completion date.
- Project managers concentrate on activities with zero slack time (that is, those on the critical path), and if the critical path duration can be reduced, then it helps to minimize the overall project duration.

Program Evaluation Review Technique (PERT)

Like CPM, PERT is also a technique used to estimate project duration:

- The difference between PERT and CPM is that while CPM considers only a single scenario, PERT considers three different scenarios (optimistic (best), pessimistic (worst), and normal (most likely)). Based on these three scenarios, a single critical path is arrived at.
- PERT is considered more accurate and appropriate than CPM for calculating estimates of project duration.
- The following diagram will help you understand PERT:

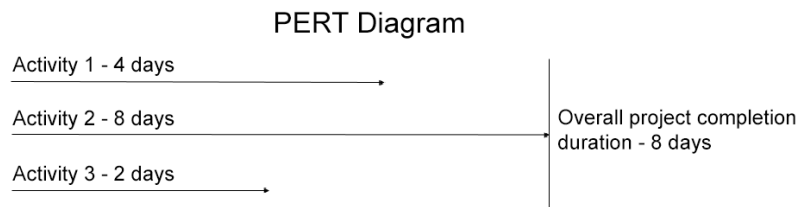


Figure 5.1: Program evaluation review technique

In the preceding diagram, the critical path is that of the activities. If more resources are allocated to Activity 2, the overall project duration can be reduced.

Therefore, providing more resources to Activity 1 and Activity 3 would not be feasible, and the emphasis should be on Activity 2.

Activity 2 has zero slack time. The critical path will always have zero slack time. Activity 1 has a slack time of 4 days (8 minus 4), and Activity 3 has a slack time of 6 days (8 minus 2).

Gantt Chart

The progress of an entire project can be read from a Gantt chart to determine whether the project is behind, ahead, or on schedule compared to the baseline project plan. A Gantt chart can also be used to track the achievement of milestones.

The following table will help you understand the Gantt chart:

Activity	Planned Duration (in weeks)	Actual Spent (in weeks)	Completion %	Status
Activity 1	4	4	90%	Delayed
Activity 2	5	3	100%	Before schedule
Activity 3	4	2	50%	On schedule
Activity 4	4	1	25%	On schedule

Table 5.2: Gantt chart

Earned Value Analysis

The objective of **Earned Value Analysis (EVA)** is to measure the progress of the project at any given point in time to forecast the completion date and the final cost and to analyze any variance in the budget.

EVA determines and evaluates the following factors on a periodic basis:

- What is the actual spending up to the present date, compared to the budget?
- What is the estimated completion time?
- What is the estimated total expenditure?

EVA helps to forecast the scheduled date and expected cost and determine the variance of cost and schedule at any given point during the project.

In EVA, it is assumed that a project can reasonably be completed within the original schedule. For example, suppose a development team has spent 8 hours of activity on the first day against a budget of 24 hours (over 3 days). The projected time to complete the remainder of the activity is 20 hours, so according to EVA, the analysis is as follows:

Particular	Day 1	Day 2	Day 3	Total
Budget	8	8	8	24
Completed	4 (Total Budget - Work Pending, for example, 24 - 20)	-	-	-
Delay	4	-	-	-

Table 5.3: EVA analysis

The above indicates a delay of four hours.

Timebox Management

The benefit of timebox management is that it ensures the timely completion of the project and thus prevents project cost overruns. In timebox management, the total resources allocated to a project, such as manpower, time, and money, are fixed and strict end dates are given. No deviation in either time or resources is permitted.

Timebox management is extensively applied in prototyping and **Rapid Application Development (RAD)** where time management is critical.

It helps to save time by integrating system testing and UAT. However, a quality assurance process will still need to be carried out.

Project Objectives, OBS, and WBS

The main goal for the implementation of any project is to achieve the project objectives. Project objectives should be specific, attainable, and measurable. **Object Breakdown Structure (OBS)** is one of the commonly accepted approaches for defining project objectives. OBS is a combination of separate components and involves their interaction with each other.

The next step is to design a **Work Breakdown Structure (WBS)**. WBS defines the individual components of the work to be done. It helps with cost and resource planning. OBS includes solutions, whereas WBS includes individual processes.

The Role of the IS Auditor in Project Management

An IS auditor plays a vital role in the project management process. This role may be executed during the project implementation stage or upon completion of the project. It includes the following tasks:

- To determine system objectives and requirements and to identify areas of control
- To determine major risks associated with the project and the relevant controls to be implemented to mitigate these
- To determine the appropriateness of the approach/methodology adopted for the **Software Development Life Cycle (SDLC)**
- To determine whether quality assurance testing and UAT are conducted before deployment of the system
- To determine the controls to be implemented to ensure the integrity of the production resources
- To determine the adequacy of the post-implementation review process

Key Aspects from the CISA Exam Perspective

The following table shows important aspects from the perspective of the CISA exam:

CISA Questions	Possible Answers
Techniques to prioritize project activities and determine project timelines	PERT CPM PERT is considered to be more effective than CPM.
The technique to monitor the progress of the project:	Gantt chart
The technique for software size estimation:	Function Point Analysis (FPA) Source Lines of Code (SLOC) FPA is more reliable when the system is more complicated, in terms of the complexity of inputs, outputs, files, graphical interfaces, linked modules and their interactions, diagrams, and queries. SLOC is a traditional method of estimating software size on the basis of a single parameter, that is, the number of lines of code.
The objective of time box management	To prevent project cost overruns and delays from scheduled delivery without impacting quality.
For early completion of the project, which activity should be addressed first?	The activity with zero slack time.
The technique for projecting estimates at completion	Earned Value Analysis (EVA). EVA helps to forecast the closure date and cost and to analyze the variance at any given point during the project.

Table 5.4: Key aspects from the CISA exam perspective

Business Case and Feasibility Analysis

It is very important to consider the business case and feasibility analysis before undertaking any new project. The IS auditor should have a basic understanding of the business case as well as the feasibility study.

Business Cases

A business case is a justification for a proposed project. The business case is prepared to justify the effort and investment in a proposed project and captures the reasoning for initiating a project or task. Generally, the business case is the precursor to the start of the project. It is a key element in decision-making for any project. The project sponsor is responsible for developing the business case.

The proposed return on investments (ROI)s, along with any other expected benefits, are the most important consideration for decision-making in any new project.

Feasibility Analysis

A feasibility study is an analysis that takes various factors into account, including economic, technical, and legal factors, to ascertain the likelihood of the project getting completed successfully. The feasibility study should consider how the project will impact the organization in terms of risk, costs, and benefits. It helps to assess whether a solution is practical and achievable within the established budgets and schedule requirements.

A feasibility study report generally includes the following elements:

Elements	Description
Scope	The report should include a detailed project plan, expected benefits, and associated risks.
Current Process	The report should include an analysis of the current process and its strength and a justification for an upgrade.
Requirements	The report should include the needs and requirements of the stakeholders of the proposed project.
Approach	The report should include a detailed approach to the execution of the project.
Evaluation	Alternatives should be evaluated to find the most effective solution. The feasibility report should include the following: • Resource requirements • Vendors' and third-party contractors' costs • Project schedule start and end dates
Review	Sign-off should be done by all stakeholders for decisions made on the basis of the feasibility report. If the project is rejected, details need to be documented for future reference.

Table 5.5: Elements of a feasibility study

Apart from the parameters mentioned in the preceding table, an organization may consider other parameters as per the needs and requirements of the project.

The IS Auditor's Role in Business Case Development

The IS auditor should have a good understanding of business case development for information systems. They play an important role in reviewing and evaluating the business case and feasibility study and are required to ensure that these are evaluated in an effective and unbiased manner. Generally, the following tasks are performed by the IS auditor while reviewing the feasibility study:

- Reviewing the approval process for the initiation of the project
- Reviewing the process followed for the development of the business case and feasibility study
- Reviewing the process followed for the evaluation of various alternatives
- Reviewing the appropriateness of the cost justification/benefits projected
- Determining whether the business case and feasibility analysis are aligned with the business objectives

System Development Methodologies

A system development methodology is a structure that organizations use for the design, development, and implementation of new systems. Different methodologies are available, with each of them having different characteristics. In this section, you will learn about the following concepts:

- SDLC models
- SDLC phases
- Software development methods

SDLC Models

Three widely used SDLC models are the traditional waterfall, the V-shaped model, and the iterative model. The following sections present each of them in detail.

Traditional Waterfall

This model aims to ensure that mistakes are identified at an early stage and not during final acceptance testing. The significant features of this method are as follows:

- The waterfall method is the most commonly adopted approach for developing business applications.
- It works well when requirements are well defined and do not undergo frequent changes.

- This approach is useful when prototypes are required to understand the design and requirements of the proposed system.

V-Shaped Model

The V-shaped model is a verification and validation model. The importance of this method is as follows:

- In this method, unit tests are conducted immediately once the program is written.
- A system test is carried out to evaluate the architectural specification and a final UAT phase is carried out to validate the requirements of the proposed system.
- It is iterative.

The significant aspects of this model are as follows:

- Requirements are developed and tested in iterations until the entire application is built and tested.
- Each development process goes through a cycle from requirement gathering to testing.

SDLC phases

- A CISA aspirant should have a basic understanding of the following phases of the SDLC.

Phase 1 – Feasibility Study

In the feasibility study, the expected benefits are outlined against the cost of the implementation of the system.

The feasibility study provides a justification for the implementation of the project.

Phase 2 – Requirements

The requirements of the new system are detailed and documented in this phase.

Users of the system should be involved during the requirement identification process.

Based on the requirements gathered, a baseline needs to be defined for the new system.

Phase 3 – Software Selection and Acquisition

The design should include the architectural and technical specifications of the new system. Security requirements should also be considered during this phase.

If an off-the-shelf system is to be purchased from the vendor, detailed requirements should be included in the request for proposal.

Phase 4 – Development

The development activity takes place in this phase.

In the case of a ready-made system, the configuration is conducted in this phase.

Phase 5 – Testing and Implementation

In this phase, different kinds of testing are conducted in this phase to verify and validate the developed system against the requirements.

Unit testing, system testing, and UAT are conducted.

Phase 6 – Post-Implementation

In this last SDLC phase, the following points should be taken care of:

- During this phase, post-implementation reviews are conducted, and **Return on Investment (ROI)** is assessed.
- Lessons learned and improvement plans for future projects are documented.

Software Development Methods

In this section, you will study some of the important system development methodologies.

Agile Development

Agile means “the ability to move quickly and easily.” In the Agile method, programmers do not spend much time on documentation. They can write a program straight away. Here are the objectives of the Agile approach:

- The objective of the Agile approach is to produce releasable software in short iterations without giving much importance to formal paper-based deliverables.
- Once each iteration is completed, the emphasis is placed on what went well and where there is scope for improvement in the following iterations.
- Agile is one of the most preferred approaches for programmers as it saves them a lot of planning, paperwork, and approval processes.

Prototyping

In the prototyping approach, the system is developed through trial-and-error methods. A prototype is basically a preliminary version of a system to test a concept or process or assumptions about functionality, design, or internal logic. A prototype model helps to save a considerable amount of time and cost for the organization. A few risks of the prototyping approach are given here:

- One of the potential risks of a prototype approach is that the finished product may not have adequate controls compared to traditional system development approaches. The prototype approach emphasizes user requirements more.
- In prototyping, design and requirements change too often and they are hardly documented or approved.
- The change control process is very weak in the prototype environment.
- The most effective testing method for the initial phase of prototyping is a top-down approach. In the top-down approach, testing begins with a system's major functionality and gradually moves to other functionalities.
- In prototyping, the major functionality is emphasized, such as screens and reports, thus shaping most of the proposed system's features in a short period.

Rapid Application Development

The following elements are used in RAD:

- A well-trained team of developers
- Prototypes
- Sophisticated tools and software for modeling, prototyping, and component reusability
- A central repository

With the use of the preceding elements, RAD aims for the quick development of the system while reducing cost and ensuring quality.

RAD relies on the prototype, which can be frequently updated to address the ever-changing user or business requirements.

Object-Oriented System Development

Object-Oriented System Development (OOSD) is a programming technique with the objective of making program code that is reusable and maintainable.

An object is basically a small piece of code in a program. The system is developed via the use and combination of different objects. OOSD uses a technique known as encapsulation, in which objects interact with each other. Encapsulation provides enhanced security for data.

The ability of two or more objects to interpret a message is termed polymorphism.

Component-Based Development

In component-based development, ready-made components (objects) are assembled to design and develop a specific application:

- As developers are not required to write programming code, they can concentrate on business functionality.
- Component-based development supports multiple development environments. Components can interact with each other irrespective of their programming language.
- As components are already available, it saves considerable time and cost in the development of the system. Also, it ensures quality, as components are already tested.
- Component-based development promotes modularity; that is, different components can be used independently.

Software Reengineering and Reverse Engineering

It is important to understand these two terms from a system development perspective:

- **Software reengineering:** Reengineering is the process of updating a system to enhance its functionality and efficiency. Software reengineering helps to support major changes in an organization's processes.
- **Reverse engineering:** Reverse engineering refers to the detailed analysis and study of a system with the objective of developing another similar system.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is a major risk associated with the Agile approach?	Lack of documentation.
What are the characteristics of the Agile approach?	Systematic review after completion of each iteration to identify areas of improvement. Quick and easy without much emphasis on paper documentation.

CISA Questions	Possible Answers
What are the characteristics of the waterfall approach?	The most common method of software development. Suitable when requirements are well defined and do not undergo frequent changes. After the completion of each stage, testing is done before moving to the next stage.
What are the characteristics of a prototype approach	Save a considerable amount of time and cost. Risk of inadequate controls. Effective testing methods for the initial phase of prototyping is a top-down approach.
Which technique uses a prototype that can be frequently updated to address the ever-changing user or business requirements?	Rapid Application Development (RAD).
Difference between reengineering and reverse engineering	Reengineering is the process of updating a system to enhance its functionality and efficiency. Reverse engineering, also called back engineering, is the process of understanding and extracting the design, architecture, components, and knowledge of a system with the objective of producing a similar system.
The benefit of OOSD	Ability to reuse the modules.
The benefit of component-based development	Ability to support multiple development environments.

Table 5.6: Key aspects from the CISA exam perspective

Control Identification and Design

An IS auditor needs to have a sufficient understanding of the various control techniques used while designing applications. In the next few sub-sections, you will go through some of the important controls built into an application system.

Check Digits

A check digit is an extra digit used for error detection. A check digit is arrived at by a mathematical algorithm. It is added to the original data to ensure that data is not altered.

By ensuring that the original data is not tampered with or altered, check digits help prevent transposition and transcription errors. The most widely used example of the use of a check digit is the bank account numbers assigned to customers.

For instance, suppose a bank account number is 630000241453. The last digit, 3, is the check digit, and if the other numbers are correct, then the check digit calculation will produce 3:

1. Add the numbers placed in odd digit positions: $6+0+0+2+1+5 = 14$.
2. Add the numbers placed in even digit positions: $3+0+0+4+4 = 11$.
3. Deduct the result of step 2 from that of step 1: $14 - 11 = 3$.

Therefore, the check digit value is 3.

This is a simple calculation for easy understanding. In real-life scenarios, calculations are more complicated.

Please note that the preceding calculation is only for the purposes of your learning and understanding. Such a calculation will not be tested in the CISA exam.

Parity Bits

Parity bits are used to verify complete and accurate data transmission. Parity bits are used as the simplest form of error-detecting code when data is transferred from one computer to another:

- An extra bit is added to the data in such a way that the total number of 1 bit in the data string is either even or odd. This extra bit is called a parity bit.
- This parity is then verified by the receiving computer to validate the data's accuracy and completeness during transmission.

The following figure will help you understand parity bits:

Parity Bits

Character	Sender	Parity Bit	Receiver	Parity
E	1000101	1	10001011	Even
A	1000001	0	10000010	Even
C	1000011	1	10000111	Even
q	1110001	0	11100000	Odd

→ Indicates error in data transmission

Figure 5.2: Parity bits

In the preceding diagram, even parity is being used at the sender's end. Similarly, odd parity can also be used.

Note

This diagram is only for learning purposes. In the CISA exam, such calculations will not be tested.

Checksums

Checksums work on the same principle as parity bits, but they have the capability to recognize complex errors through advanced mathematical formulas.

Cyclic Redundancy Checksums (CRC)/redundancy checksums are a more advanced version of checksums that work by increasing the complexity of the arithmetic.

Forward Error Control

Forward error control works on the same principle as redundancy checksums. In addition to detecting the error, it has the capability to correct the error. It helps the receiving computer correct the error.

Data Integrity Principles

The data integrity principles of **Atomicity, Completeness, Isolation, and Durability (ACID)** are described as follows:

- **Atomicity:** The principle of atomicity prescribes that a transaction is either processed completely or should not be processed at all. In case of an error or interruption, partial processing, if any, should be rolled back.
- **Consistency:** The principle of consistency prescribes that all integrity conditions must be applied to each transaction of the database.
- **Isolation:** The principle of isolation prescribes that each transaction should be separated from other transactions.
- **Durability:** The principle of durability prescribes that the database should be resilient enough to survive any system failures.

Limit Checks

Limit checks restrict the data input up to a certain predefined limit. Data is checked for one limit, either upper or lower; for instance, data should not be greater than 100.

Limit checks are input controls. These are a form of preventive control to restrict invalid inputs from being entered into the system. It ensures that only data within the predefined limit can enter the system.

Automated System Balancing

Automated system balancing reconciles the total input with the total output.

Any difference between the two is shown as an error for further investigation and correction. By detecting and highlighting this mismatch, automated system balancing helps to determine whether any transactions are lost during processing.

Sequence Checks

Sequence checks involve testing a list of items or files of records for correct ascending or descending sequences based on predefined requirements.

For example, sequence checks can be used to check whether vouchers are in sequence, thereby preventing the duplication of vouchers.

Decision Support Systems

A **Decision Support System (DSS)** is a semi-structured interactive decision-making framework. A DSS collects data from various sources and gives managers useful information about future predictions on the basis of past and current data.

The characteristics of a DSS are as follows:

- A DSS supports semi-structured or less-structured decisions.
- A DSS uses traditional data access and restoration techniques.
- A DSS is flexible and user-friendly in changing environments and with respect to user responses to the decisions made.

The following diagram depicts the characteristics of a DSS:

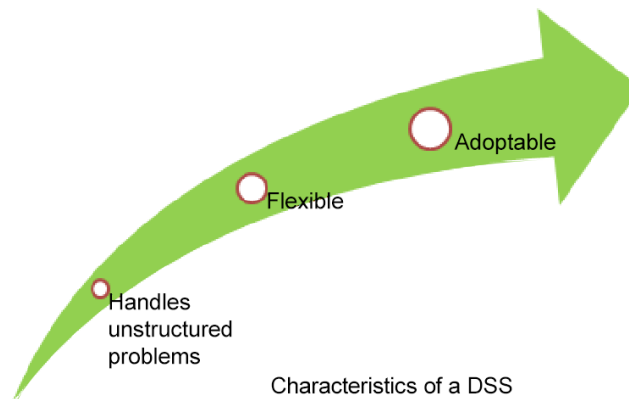


Figure 5.3: Characteristics of a DSS

These characteristics will help you understand the efficiency and effectiveness of a DSS, as described next.

DSS Efficiency versus Effectiveness

A DSS design principle is to concentrate less on productivity (that is, performing tasks quickly and reducing costs) and more on effectiveness (that is, performing the right tasks).

Design and Development

The most popular approach to DSS design and development is prototyping.

Risk Factors

A DSS has the following inherent risks that need to be considered while designing the system:

- Users might not be willing to use the system.
- The purpose or objective of the DSS may not be clear to the users.
- There may be a lack of expertise regarding how to use the system.

Decision Trees

Decision trees are a simple way to create a visualization based on clearly defined criteria of the paths toward decision-making. A decision tree can be of significant help in making the correct choice. It is used as a questionnaire to direct clients through a series of choices before they come to a conclusion.

Decision trees describe a framework that can be advantageous in the audit department when identifying opportunities and risks. It facilitates the decision-making process as well as allows a clear identification of the causes. Decision trees are one way of making reasonable and effective use of this data in auditing.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA questions	Possible answers
What is the best control to ensure that no transactions are lost during processing?	Automated system balancing.
What is the best technique to detect transposition and transcription errors?	Check digit.

CISA questions	Possible answers
Which data integrity principle requires that transactions are either processed completely or not processed at all? In case of an error or interruption, partial processing, if any, should be rolled back.	Atomicity.
Which technique is best to prevent the duplication of vouchers during data entry?	Sequence check.
What are the techniques to ensure data completeness and data integrity during transmission?	Cyclic redundancy checksum (first preference). Checksum (second best). Parity bits (third best).
Which technique is used to detect as well as correct errors by transmitting redundant information with each character?	Forward error control. (Please note that parity bit/checksums/CRC do not have the ability to correct errors. Forward error control has the ability to detect as well as correct errors.)
What are the characteristics of DSS?	DSS supports semi-structured or less-structured decisions. DSS uses traditional data access and restoration techniques. DSS is flexible and user-friendly in changing environments and with respect to user response to decision-making.
A questionnaire that leads the user through a series of choices to reach a conclusion is known as what?	Decision tree.

Table 5.7: Key aspects from the CISA exam perspective

Summary

In this chapter, you gained an understanding of project management structure and methodologies. You also learned about the importance of business case and feasibility studies. Additionally, you explored some important system-related controls such as check digits, parity bits, checksums, and principles of data integrity.

The following are the important topics covered in this chapter:

- PERT is a technique for estimating project duration. PERT is considered more accurate and appropriate compared to CPM for estimations of project duration. Gantt charts are primarily used to monitor the progress of the project. SLOC and FPA are techniques to estimate software size.
- The business case is a justification for the proposed project. It is prepared to justify the effort and investment in a proposed project and is a precursor to the start of the project. The first concern of an IS auditor is whether the new project meets the needs of the business. This should be established by an approved business case.
- The dictionary definition of agile is “able to move quickly and easily.” In the Agile method, the programmer does not spend much time on documentation. They are allowed to write their program straight away. Hence inadequate documentation is considered one of the major risks of the Agile approach.
- Limit checks restrict the data input up to certain predefined limits. Data is checked for certain limits, either upper or lower, as in, the number entered should not be greater than 100. A limit check is an input control. It is a preventive control to restrict invalid inputs from being entered into the system. It ensures that only data within the predefined limit can enter the system.

In the next chapter, you will explore the testing and implementation phases of project development.

Chapter Review Questions

Before you proceed to *Chapter 6, Information Systems Implementation*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

Dashboard > Set 1 (IT Resource Management)

Question 4 of 14

29%

Time Left:
21 mins 48 secs

END QUIZ

Which of the following roles, taken together, should not be entrusted to a single individual?

☐ Network administrator and quality assurance

☐ System administrator and application developer

☐ Security administrator and end user

☐ System analyst and database administrator

PREVIOUS

NEXT

Don't Know

Feedback

Figure 5.4: CISA practice question interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to <https://packt.link/yKHnk>. You will see the following screen:

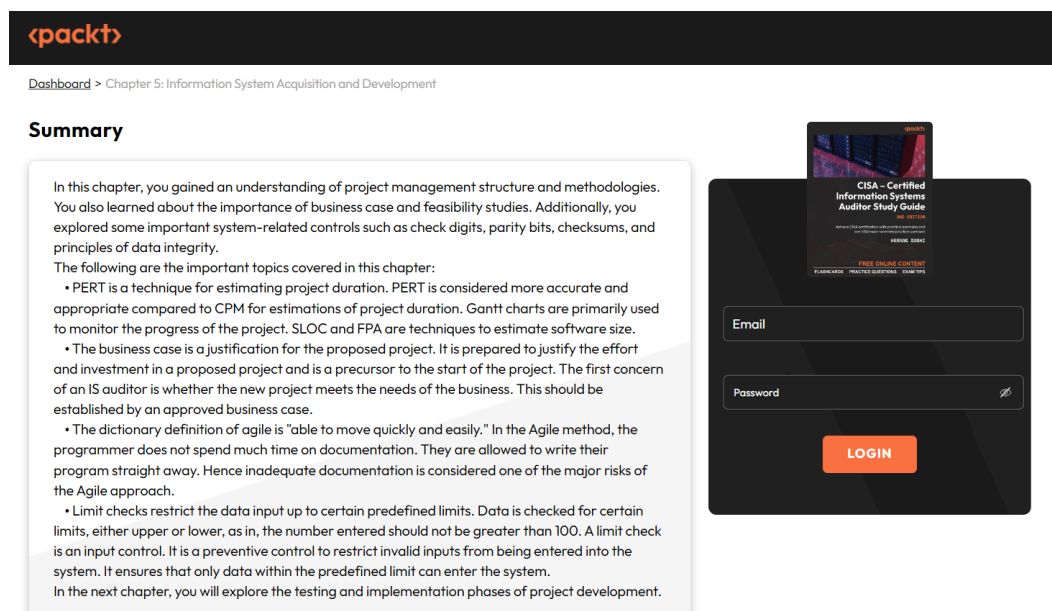


Figure 5.5: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 5.6: QR code to access *Chapter 5* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

Dashboard > Chapter 5: Information System Acquisition and Development

Chapter 5: Information System Acquisition and Development

Summary

In this chapter, you gained an understanding of project management structure and methodologies. You also learned about the importance of business case and feasibility studies. Additionally, you explored some important system-related controls such as check digits, parity bits, checksums, and principles of data integrity.

The following are the important topics covered in this chapter:

- PERT is a technique for estimating project duration. PERT is considered more accurate and appropriate compared to CPM for estimations of project duration. Gantt charts are primarily used to monitor the progress of the project. SLOC and FPA are techniques to estimate software size.
 - The business case is a justification for the proposed project. It is prepared to justify the effort and investment in a proposed project and is a precursor to the start of the project. The first concern of an IS auditor is whether the new project meets the needs of the business. This should be established by an approved business case.
 - The dictionary definition of agile is "able to move quickly and easily." In the Agile method, the programmer does not spend much time on documentation. They are allowed to write their program straight away. Hence inadequate documentation is considered one of the major risks of the Agile approach.
 - Limit checks restrict the data input up to certain predefined limits. Data is checked for certain limits, either upper or lower, as in, the number entered should not be greater than 100. A limit check is an input control. It is a preventive control to restrict invalid inputs from being entered into the system. It ensures that only data within the predefined limit can enter the system.
- In the next chapter, you will explore the testing and implementation phases of project development.

Chapter 5 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (16 Questions)

START

Set 2 (10 Questions)

START

Set 3 (21 Questions)

START

Set 4 (20 Questions)

START

Figure 5.7: Chapter summary and end-of-chapter question sets

- Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

Dashboard > Set 1 (IT Resource Management)

Question 4 of 14

29%

⌚ Time Left:

21 mins 48 secs

END QUIZ

Which of the following roles, taken together, should not be entrusted to a single individual?

☐ Network administrator and quality assurance

☐ System administrator and application developer

☐ Security administrator and end user

☐ System analyst and database administrator

PREVIOUS

NEXT

Don't Know

Feedback

Figure 5.8: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

6

Information Systems Implementation

It is very important for an information systems auditor to understand the implementation process of information systems. They need to determine, evaluate, and address various risks associated with the implementation process. Information systems implementation is the process of ensuring that a system is operational. It involves either the creation of a new system from scratch or the migration of an old system to a new one.

The following topics will be covered in this chapter:

- Testing methodology
- System migration
- Post-implementation review

By the end of the chapter, you, as an IS auditor, will have a firm understanding of the core concepts of information systems implementation.

Testing Methodology

Testing is one of the critical elements of the **System Development Life Cycle (SDLC)**. The objective of testing is to ensure that the system is capable of fulfilling its intended objective. For the CISA exam, you need to understand the following testing methodologies:

- Unit testing
- Integration testing
- System testing:
 - Functionality tests
 - Recoverability tests

- Security tests
- Load tests
- Volume tests
- Stress tests
- Performance testing
- Final acceptance testing:
 - **Quality Assurance Test (QAT)**
 - **User Acceptance Test (UAT)**
- Regression testing
- Sociability testing
- Pilot testing
- Parallel testing
- White box testing
- Black box testing
- Alpha testing
- Beta testing

Unit Testing

The following are some of the important aspects of unit tests:

- Unit tests include tests of each separate program or module.
- Testing is generally conducted by the developers themselves. It is conducted as and when a program or module is ready, and it does not need to wait until the completion of the entire system.
- Unit testing is done via a white box approach wherein the internal program logic is tested.

Integration Testing

An integration test examines the integration or connection between two or more system components. The purpose of an integration test is to validate accurate and correct information flow between the systems.

The following figure will help you understand the difference between unit testing and integration testing:

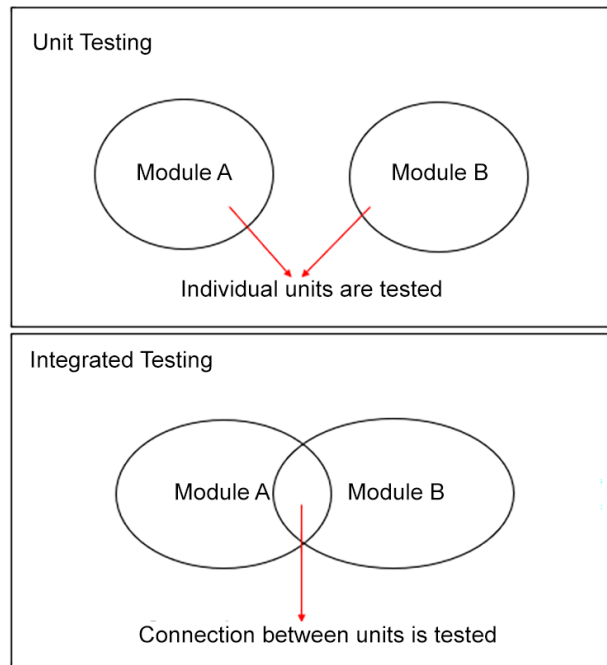


Figure 6.1: Difference between unit testing and integration testing

As we can see, in integration testing, the connection of units between modules is tested. Integration testing is also known as interface testing.

System Testing

System testing tests the entire system's capabilities. It covers end-to-end system specifications. It involves functionality tests, recoverability tests, security tests, load tests, volume tests, stress tests, and performance tests. Details of each of these tests are as follows:

Types of System Testing	What It Means
Recovery testing	Checking the ability of the system to recover after a hardware or software failure
Security testing	Testing security arrangements and identifying vulnerabilities in the system
Load testing	Testing the performance of the system during peak hours

Types of System Testing	What It Means
Volume testing	Testing to determine the maximum volume of records (data) that the application can handle
Stress testing	Testing to determine the maximum number of concurrent users/services the application can process
Performance testing	Comparing the performance of the system against the well-defined benchmark

Table 6.1: Types of system testing

Final Acceptance Testing

Final acceptance testing consists of two tests: a QAT and a UAT. Details of both tests are as follows:

Quality Assurance Test	User Acceptance Test
QAT focuses on technical aspects.	UAT focuses on functional aspects.
QAT is primarily performed by the IT department.	UAT is primarily performed by the user department.

Table 6.2: Differences between QAT and UAT

Regression Testing

Regression means the return to an earlier stage.

The objective of a regression test is to confirm that a recent change has not introduced any new faults and that other features are working correctly.

It must be ensured that the same data and test scenarios that were used in earlier tests are used for a regression test. This will confirm that there are no new errors or malfunctions.

Sociability Test

Sociability is the quality of being able to socialize, interact, or merge with others:

- The objective of the sociability test is to ensure that the new system works as expected in the existing infrastructure without having an adverse impact on the other existing systems.
- This test ensures that an application works as expected in the specified environment where other applications run concurrently.

Pilot Testing

A pilot test is a small-scale preliminary study for understanding and evaluating system functionality and other aspects:

- A pilot test is conducted for only a few units or a few locations to evaluate feasibility.
- The objective of the pilot test is to determine the feasibility of the new system before its full-fledged implementation.

Parallel Testing

Parallel testing involves the testing of a new system and comparing its results with that of an old system. The objective of parallel testing is to ensure that the new system meets the user requirements.

White Box Testing

In white box testing, the program logic is verified:

- To conduct a white box test, appropriate knowledge of the relevant programming language is a must.
- Unit testing usually includes white box testing.

Black Box Testing

In black box testing, the emphasis is on the functionality of the system:

- To conduct a black box test, knowledge of the relevant programming language is not mandatory.
- Black box testing is generally a feature of UATs and interface tests.

The following diagram further illustrates white box testing and black box testing:

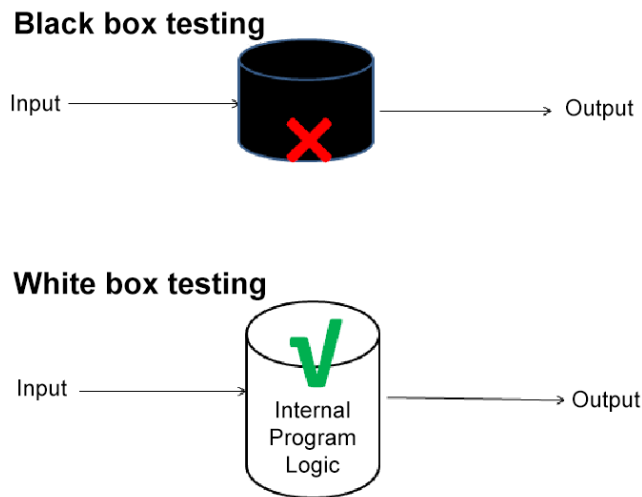


Figure 6.2: Black box testing and white box testing

For white box testing, a tester is required to have sufficient knowledge about programming because they need to evaluate and test the program.

Alpha Testing

Alpha testing is conducted by an internal user. The following are some of its characteristics:

- Alpha testing is conducted before beta testing.
- Alpha testing may or may not include a full functionality test.

Beta Testing

Beta testing is conducted by an external user. The following are some of its characteristics:

- Beta testing is conducted after alpha testing.
- Beta testing is generally conducted to test the full functionality of the program.

Testing Approach

Generally, there are two approaches to conducting a test: a bottom-up approach and a top-down approach. The following table highlights the differences between the two approaches:

Bottom-Up Approach	Top-Down Approach
• In a bottom-up approach, the test starts from a separate program or module and gradually, the complete system is tested.	• In a top-down approach, the test starts at a broad system level and moves toward a separate program and module.
• The benefit of a bottom-up approach is that the test can begin before the full system is completed. • It also has the advantage of early detection of faults in critical modules.	• The benefit of a top-down approach is the early detection of interface errors. • A top-down approach is more relevant for prototype-based system development.

Table 6.3: Differences between bottom-up and top-down approaches

You will now learn about the various testing phases in the life cycle of system development.

Testing Phases

Generally, in the SDLC, unit testing is conducted first. It is followed by integration testing, system testing, and final acceptance testing.

The following diagram depicts the phases of software development testing:

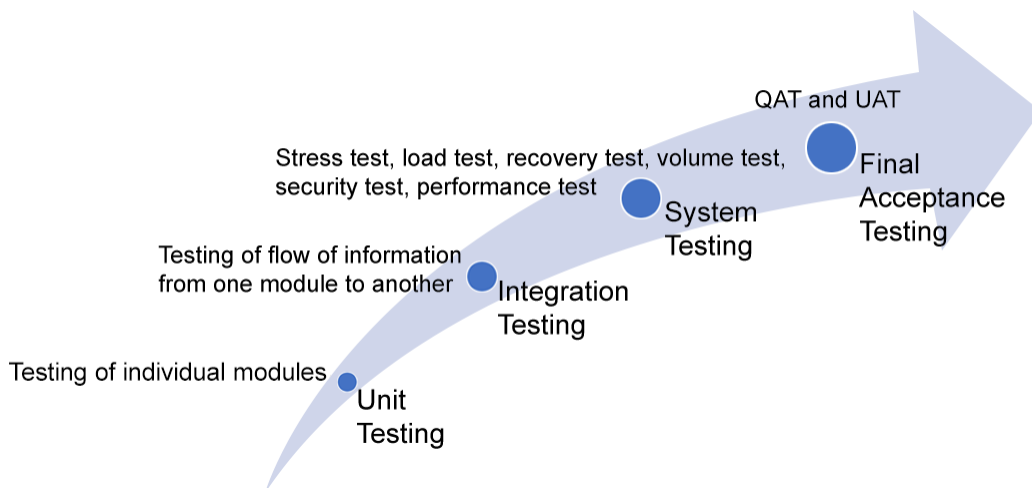


Figure 6.3: Phases of software development testing

Generally, unit tests are the first tests. They are followed by integration tests, system tests, and the final acceptance test.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
Which test is performed at the final stage by users outside the development team – that is, external users?	Beta testing
What is the test in which the testing of architectural design is conducted?	Integration test
What is the test for linked and connected modules?	Integration testing
In which of the tests does failure in testing have the greatest impact?	Acceptance test
Which test is performed to determine the ability of a new system to operate in the existing environment without having an adverse impact on other systems?	Sociability testing
What is a top-down testing approach?	Major functions are tested earlier, and it also ensures that interface errors are detected early.
What is a bottom-up testing approach?	Starts with individual modules and programs and gradually covers the full system
What is the most suitable approach for prototype-based development?	The top-down approach
What is the advantage of white box testing?	Determines the accuracy of program logic
What is the best approach for unit testing?	White box testing
Which test is performed to evaluate the performance of the system during normal and peak conditions?	Load testing

CISA Questions	Possible Answers
What is an effective method for conducting a stress test?	Use live data in the test environment: • Test data should be designed as per the live workload for accurate test results. • In any given scenario, the test environment should always be used (that is, the test should not be conducted in a live/production environment).
What is the most important factor for test data selection?	Test data should be designed as it is expected to be in live processing.
What is the objective of a system test?	To evaluate full system functionality
What is the objective of a parallel test?	To validate device functionality with user specifications
What kind of data should be used while conducting a regression test?	The same dataset as used in previous tests

Table 6.4: Key aspects from the CISA exam perspective

System Migration

System migration is the process of transferring IT resources (mostly data) to a new hardware or software platform with the purpose of gaining better business value.

IS auditors should ensure the following for efficient, effective, and accurate system and data migration:

- Processes should be in place to preserve the format, coding, structure, and integrity of the data to be migrated.
- Processes should be in place to test the migrated data for its integrity and completeness.
- Data conversion processes must have audit trails and logs to verify the accuracy and completeness of the converted data.

The migration process should ensure the following:

- There is no disruption of routine operations.
- There is appropriate security control over data, ensuring confidentiality, integrity, and availability.

The migration process should also ensure the availability of fall-back arrangements. That is, tools and applications should be available to reverse the migration if there is an error.

Furthermore, the last copy of the old data and the first copy of the converted data should be archived for future reference.

Changeover refers to the process of shifting to a new system and stopping the use of old systems. It is also known as the go-live technique, or the cutover technique. In the next sections, you will explore some of the approaches used to change to a new system.

Parallel Changeover

In this method, the new and old systems are operated in parallel for some time. Once the users are confident in using the new system, the old system may be discontinued. This helps minimize the risk of consequences of defects in the new system. A major challenge in this method is the requirement for more resources to maintain both systems.

It provides assurance that the new system meets the requirements before the old system is discontinued.

Parallel changeover provides the greatest redundancy.

Phased Changeover

In this method, changes are implemented in a phased manner. The system is broken down into different phases. Each old phase is gradually replaced by a new phase. This changeover from the old system to the new system takes effect in a pre-planned, phased manner.

Abrupt Changeover

In this method, a new system is implemented from a cut-off date, and the old system is completely discontinued once the new system is implemented. This process is also known as direct cutover. This is considered the riskiest approach with no scope for rollback if the new system fails.

It is very important to obtain sign-off from a user department before an abrupt changeover. It is the user department that should assume ownership of the project and provide sign-off for the completion and implementation of the system with regard to the agreed deliverables.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the benefit of parallel cutover?	Assurance that the new system is working as required before the old system is discarded
Which system migration method is the riskiest?	Direct cutover or abrupt cutover
Which system migration method has the greatest redundancy?	Parallel changeover
Who is responsible for signing off on the accuracy and completeness of the data migration to the new system?	Data owner/user
What is the greatest concern about direct cutover?	Lack of backup plan

Table 6.5: Key aspects from the CISA exam perspective

Post-Implementation Review

The post-implementation review is the process of determining and evaluating the performance of the system against the requirements and objectives defined in the business case. The post-implementation review is conducted once the project is implemented and completed. These are the objectives of conducting a post-implementation review:

- To determine the extent to which a project met its objectives and addressed the originally defined requirements
- To determine the cost-benefit analysis and return on investment
- To determine the lessons learned from the project to improve future projects

The project development team and business users should jointly conduct a post-implementation review. From the IS audit perspective, the post-implementation review is conducted to determine the adequacy and effectiveness of the system. The IS auditor's prime focus should be to determine the controls built into the new system.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the objective of the post-implementation review?	To determine the extent to which the project met its objective and addressed the originally defined requirements To conduct a cost-benefit analysis and work out the return on investment To determine the lessons learned from this project for the improvement of future projects
What should the area of focus of the IS auditor be during the post-implementation review?	To determine the adequacy and effectiveness of the security controls

Table 6.6: Key aspects from the CISA exam perspective

Summary

In this chapter, you understood various testing methodologies, different approaches to system migration and cutover techniques, and the objectives of post-implementation reviews. You also learned how to conduct post-implementation reviews of systems to determine whether project deliverables, controls, and requirements have been met.

The following are some important topics covered in this chapter:

- Unit tests include tests of each separate program or module. Testing is generally conducted by the developers themselves. They are conducted as and when a program or module is ready, and it is not necessary to wait until the entire system is completed. Unit testing is done through a white box approach wherein the internal program logic is tested.
- System migration is the process of transferring IT resources (mostly data) to a new hardware or software platform with the objective of gaining better business value.
- Changeover is the process of shifting to a new system and stopping the use of old systems. It is also known as the go-live technique or the cutover technique. Parallel changeover, phased changeover, and abrupt changeover are some ways to change to a new system.
- In white box testing, the program logic is verified. To conduct white box testing, appropriate knowledge of a relevant programming language is a must. White box testing is generally conducted during unit testing.

-
- Integration testing is performed to ensure the correct and accurate data flow between two or more systems. Integration testing aims to ensure the accuracy of the device interface's most critical components.
 - Regression testing is performed to ensure no errors have been introduced in improvements or corrections. Sociability testing is performed to ensure the new or changed system will operate without affecting the existing system.
 - Sociability is the quality of being able to merge with others. The objective of sociability testing is to ensure that the new system works as expected in the existing infrastructure without having any adverse impact on other existing systems.
 - A post-implementation review is conducted to determine the extent to which the project met its objectives and addressed the originally defined requirements, perform a cost-benefit analysis, determine the return on investment, and determine lessons learned from the project for the improvement of future projects.

In the next chapter, we will discuss various aspects of information systems operations, such as technology components, asset management, incident management, and database management.

Chapter Review Questions

Before you proceed to *Chapter 7, Information Systems Operations*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

Dashboard > Set 1 (Testing Methodology)

Question 4 of 20

20%

Time Left:
31 mins 52 secs

END QUIZ

In some instances, system interface failures occur when corrections are re-submitted to previously observed errors. This might indicate the absence of which of the following kinds of testing?

☐ Stress testing

☐ Integration testing

☐ Unit testing

☐ Security testing

PREVIOUS

NEXT

Don't Know

Feedback

Figure 6.4: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/3zWZj`. You will see the following screen:

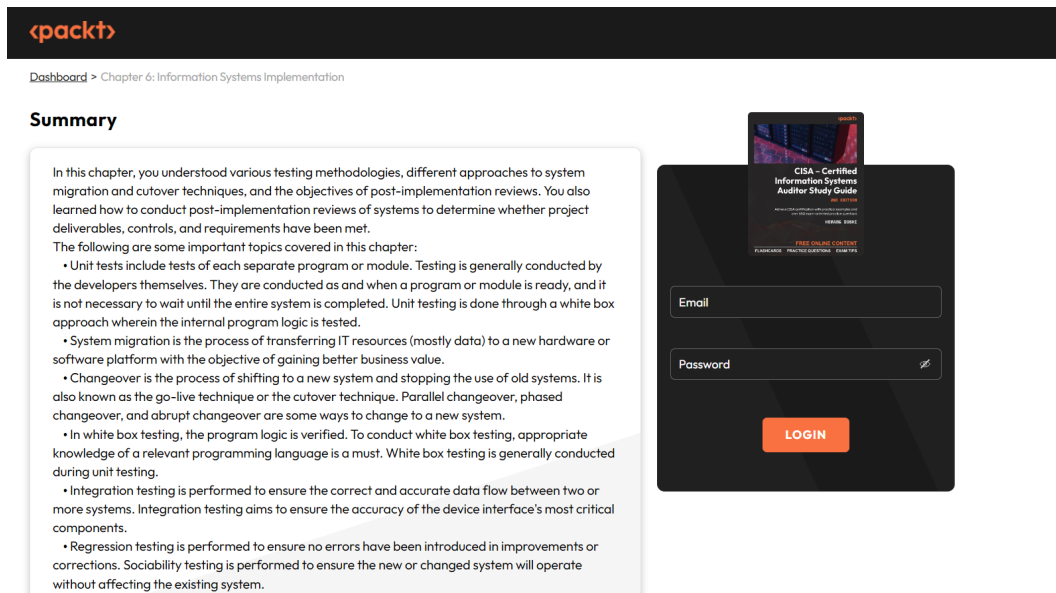


Figure 6.5: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 6.6: QR code to access *Chapter 6* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

[Dashboard](#) > Chapter 6: Information Systems Implementation

Chapter 6: Information Systems Implementation

Summary

In this chapter, you understood various testing methodologies, different approaches to system migration and cutover techniques, and the objectives of post-implementation reviews. You also learned how to conduct post-implementation reviews of systems to determine whether project deliverables, controls, and requirements have been met.

The following are some important topics covered in this chapter:

- Unit tests include tests of each separate program or module. Testing is generally conducted by the developers themselves. They are conducted as and when a program or module is ready, and it is not necessary to wait until the entire system is completed. Unit testing is done through a white box approach wherein the internal program logic is tested.
- System migration is the process of transferring IT resources (mostly data) to a new hardware or software platform with the objective of gaining better business value.
- Changeover is the process of shifting to a new system and stopping the use of old systems. It is also known as the go-live technique or the cutover technique. Parallel changeover, phased changeover, and abrupt changeover are some ways to change to a new system.
- In white box testing, the program logic is verified. To conduct white box testing, appropriate knowledge of a relevant programming language is a must. White box testing is generally conducted during unit testing.
- Integration testing is performed to ensure the correct and accurate data flow between two or

Chapter 6 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (20 Questions)

START

Set 2 (16 Questions)

START

Figure 6.7: Chapter summary and end-of-chapter question sets

- Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

[Dashboard](#) > Set 1 (Testing Methodology)

Question 4 of 20

20%

Time Left:

31 mins 52 secs

END QUIZ

In some instances, system interface failures occur when corrections are re-submitted to previously observed errors. This might indicate the absence of which of the following kinds of testing?

☐ Stress testing

☐ Integration testing

☐ Unit testing

☐ Security testing

PREVIOUS

NEXT

Don't Know

Feedback

Figure 6.8: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Information Systems Operations

Your Unique Sign-Up Code

Your unique sign-up code to unlock the online content is 8a9y8as. The sign-up link is <https://packt.link/cisasignup>.

Open the link, enter the code, and complete the sign-up process by following the instructions detailed in the *Instructions for Unlocking the Online Content* section of the *Preface*.

The objective of a well-managed **Information Systems (IS)** is to ensure the effectiveness and efficiency of IT processes and procedures through the optimal use of IS assets.

You will cover the following topics in detail in this chapter:

- Common technology components
- IT asset management
- Job scheduling
- End user computing
- System performance management
- Problem and incident management
- Change management, configuration management, and patch management
- IT service-level agreements
- Database management

Understanding Common Technology Components

The following are some of the important technologies of which a CISA aspirant should be aware:

- The types of servers
- **Universal Serial Bus (USB)**
- **Radio Frequency Identification (RFID)**

The Types of Servers

From the CISA exam perspective, it is important that you understand the basic workings of the following servers:

- **Print server:** For multiple users, a network printer is configured. Printing materials are captured in the print server and sent to the printer in a queue.
- **File server:** A file server helps in centralizing document repositories. It should be controlled with access restrictions. The file server makes group collaboration and document management easy.
- **Application or program server:** An application server hosts software programs. It also includes application business logic and communication with the application's database.
- **Web server:** A web server provides information and services through web pages. They are accessed through their URLs.
- **Proxy server:** A proxy service provides a connection between users and resources. It prevents direct access to the network and other resources.
- **Database server:** A database server stores data and information. It acts as a repository. Data is used by application servers and web servers for processing.

Other appliances, such as IDSs, firewalls, and other network devices, are covered in detail in *Chapter 10, Network Security and Control*.

Universal Serial Bus

A USB is a device that can be connected to different peripherals through a single standardized interface socket. It improves plug-and-play capabilities and can be connected or disconnected without rebooting the computer. Examples of the use of USBs include memory sticks, **Secure Digital (SD)** cards, and flash drives.

USBs – Risks

The following are some of the risks related to USBs:

- There is a risk of malware being transmitted during data transfer. It is advisable to use USB drives in read-only mode when transferring files from unknown sources. This will prevent the installation of software on the machine.
- There is a risk of data theft. It is advisable to disable the USB ports in the machines as much as possible.
- There is a risk of sensitive data stored on USB drives being lost or stolen. It is advisable to encrypt the contents of USB drives to prevent unauthorized access to them.
- There is a risk of data corruption when a USB device is removed improperly from a machine.

USBs – Security Controls

The following are some of the important controls that can be used to reduce the risks related to USB drives:

- Encryption is a very important security control that prevents unauthorized data access in the case of loss or theft of USB drives. A system should be enabled to access only encrypted devices.
- Hardening a system through centralized management is very important. It is advisable to disable all the USB ports for all the users. Approval for USB port access should be provided on a need-to-know basis.
- The physical movement of USBs should be restricted. Security personnel should be aware of USB drives and the risks related to them.
- Anti-virus should be enabled to automatically scan all removable media.
- It is advisable to put information such as contact details on USB drives, which can help in device retrieval if devices are lost. Also, whenever the device is inserted into the system, a pop-up message should appear about the content ownership and a legal notice about unauthorized access. However, details about the company or data should not be disclosed in these labels. Legal disclaimers about data usage may help to some extent.

Radio Frequency Identification

RFID is used to identify and locate assets within a limited radius. It uses radio waves to identify tagged objects. A tag includes a microchip and an antenna. The microchip in the tag stores the information, and the antenna is used to transmit information to an RFID reader.

RFID – Applications

The following are some of the applications of RFID:

- It is widely used in asset management. RFID helps to enable smoother asset management compared to paper-based or barcode-based systems.
- It helps to identify and locate any asset or inventory that is tagged.
- It helps to match and reconcile two tagged items. A trigger is generated in the case of an incorrect match.
- It helps to enable more effective and efficient business processes. RFID eliminates the need for manual processes.
- Through RFID, access control can be managed more effectively. It automatically checks whether an individual is authorized to physically access a facility.
- It helps in supply chain management by way of asset management, proper tracking, controlling movement, and updating payment systems.

RFID – Risks

The following are some risks associated with RFID:

- Unauthorized access to RFID-generated information may harm the organization's business.
- There is a risk of non-adherence to regulations if the RFID system uses personal information without the appropriate consent of the customer.
- Any attacks on RFID systems may impact business processes adversely.

RFID – Security Controls

The following are some security controls for RFID:

- Implementing physical and logical security controls for access to RFID systems and RFID-generated data. Access should be provided on a need-to-know basis
- Implementing technical controls such as encrypting data on tags and wireless communication, enabling tags to self-destruct on some events, and so on
- Ensuring management oversight for RFID systems and processes
- Existing policies being updated to address risks and control RFID systems and processes

IT Asset Management

IT assets include systems, data, networking components, and IT-related processes and procedures. An IS auditor should be able to determine and evaluate how effectively and efficiently IT assets are managed and controlled. The following are some of the important concepts of IT asset management:

- IT assets include people, information, infrastructure, and reputation.
- The first step in IT asset management is to identify and create an inventory of IT assets.
- The inventory of an IT asset should include details such as the following:
 - Owner
 - Custodian
 - Asset identification
 - Location
 - Security classification
- ZIT asset management is a very important element in designing and developing an effective security strategy.
- IT asset management includes both hardware and software.
- The IT department should have a list of approved software that can be installed and used. The installation of unapproved software is a serious violation that carries major legal, financial, and security risks. Processes should be in place to ensure that only standard approved software is installed.
- The synchronization of production source code and objects can be best controlled by date-and-time stamping source and object code. Date-and-time stamping helps here to ensure that the source and the object code are in sync.
- The first step of the implementation of an access control rule is creating a list of IT assets as an inventory. This is followed by categorization and grouping.

Performance Reports

IS auditor determines the effectiveness and efficiency of the IT system on the basis of the different types of reports as discussed below:

Availability Reports: An availability report is a document that provides information about the amount of time for which a system was available for use during a particular period of time. The report typically includes data on the system's uptime and downtime over that period as well as any maintenance or upgrades that may have occurred. For example, an availability report might show that a system was available for 99% of the time during the previous month, with 1% downtime due to scheduled maintenance.

IS auditors use availability reports to assess the reliability and performance of a system. By analyzing the data in the report, an auditor can determine how much downtime the system experienced over the reporting period and whether that downtime was planned or unplanned. This information can be used to identify areas where improvements are needed, such as in the system's infrastructure or processes.

Utilization Reports: Utilization reports are used to determine the level of use of a system, application, or resource. These reports provide data on how much of the system's capacity is being utilized over a specific period. Utilization reports are useful for identifying potential capacity issues and predicting resource requirements. For example, a utilization report for a server may show that the CPU utilization has been consistently high for several days, indicating the need for additional processing power.

Asset Management Reports: Asset management reports provide an inventory of assets, such as hardware, software, and other resources. These reports are used to track the status and location of assets, as well as to ensure that they are properly maintained and utilized. Asset management reports can help organizations make informed decisions about resource allocation, budgeting, and procurement. For example, an asset management report for a company's IT department might include a list of all computers, printers, and other hardware devices in use, along with information about their configuration, maintenance history, and location.

Hardware Error Reports: Hardware error reports provide information about system failures and other issues related to hardware components. These reports are used to diagnose and troubleshoot problems with hardware devices, such as servers, storage systems, and network switches. Hardware error reports can help organizations identify patterns of failure and implement preventive measures to reduce downtime and improve system reliability. For example, a hardware error report for a server may show that a particular hard drive has failed multiple times over the past year, indicating the need for a replacement.

Each of these reports provides valuable information to help organizations manage their IT systems effectively and efficiently, and they serve different purposes. Availability reports and hardware error reports focus on system performance and reliability, while utilization reports and asset management reports provide insights into resource allocation and usage.

Job Scheduling

A job schedule is a program used to run various processes automatically. Apart from scheduling batch jobs, it is also used to automate tape backups and other maintenance. While scheduling jobs, it is important to give optimum resource availability to high-priority jobs. As far as possible, maintenance functions should be performed during non-peak times.

The following are some of the advantages of using job scheduling software:

- It reduces the probability of error as manual intervention is eliminated.
- It increases the availability of records for job executions, thereby making it easier to take subsequent action on failure reports effectively.
- It provides a more secure environment compared to manual processes.

An IS auditor should consider the following aspects while reviewing the job scheduling process:

- Whether procedures for collecting and reporting key performance indicators are defined and implemented
- Whether the priority of each job has been identified and scheduled correctly
- Whether an audit trail is captured for each job
- Whether the job completion status is monitored and appropriate action is taken on failed jobs
- Whether approval roles are defined for scheduling, changing, or prioritizing jobs

End User Computing

In this section, you will look at some of the important aspects of **End User Computing (EUC)**.

EUC refers to a system wherein a non-programmer can create their own application. Various products are available to aid end users in designing and implementing systems according to their requirements without the help of IT. From a user's perspective, EUC is a quick way to build and deploy applications without having to rely on an IT department. These applications are generally flexible and can quickly address any new requirements or modifications.

This also reduces pressure on the IT department, which can then concentrate on more critical and complex applications.

The following are some of the inherent risks of EUC:

- Applications developed with EUC may not be subject to various tests and therefore may carry a risk to information security in terms of data integrity, confidentiality, and availability.
- Users may not adhere to change management and release management procedures.

- System controls in terms of authorization, authentication, audit trails and logs, encryption, and non-repudiation may not be given due importance.
- An appropriate redundancy and backup arrangement may not be addressed for business continuity.

To address the preceding risks, a documented policy of EUC should be available. Also, the auditor should ensure that an inventory of all such applications exists and that sensitive and critical applications are subject to the appropriate controls.

System Performance Management

It is important to understand the system architecture and features of each function that supports and manages a system's performance. In this section, you will go through some of the prominent functions.

Nucleus (Kernel) Functions

The nucleus is responsible for basic processes associated with the operating system. It manages process creation, interrupt handling support for input and output processes, allocation, the release of memory, and so on. The nucleus is a highly sensitive area where access is restricted to only authorized users. Above the nucleus are other operating system processes to support users. These processes are known as system software. System software ensures the integrity of a system and controls the system interfaces. Examples of system software include access control software, tape and disk management software, and job scheduling software.

Utility Programs

Utility programs help to manage and control computer resources. These programs support the operating system. Examples include disk tools, backup software, and data dictionaries. Many of these programs can function by bypassing the security system and function without producing an audit trail. It is very important to restrict and control the activities of utility programs.

Parameter Setting for the Operating System

Parameter setting is an important factor that determines how a system will function. Software control parameters handle data management, resource management, job management, and priority setting. A review of parameter setting is the most effective method to determine the functioning of controls within an operating system.

Registry

System settings and parameters are set in configuration files known as a registry. Control of the registry is an important aspect of IS auditing. Protecting the registry is important for ensuring the integrity, confidentiality, and availability of systems.

Activity Logging

It is very important to log activities for future analysis. Further, these logs should be appropriately protected as an intruder may attempt to alter logs to hide their activities. The best way to protect logs is to capture them in a centralized secure server using **Security Information and Event Management (SIEM)** software.

Software Licensing Issues

An IS auditor should ensure that software copyright laws are followed by the organization. Any violation may lead to regulatory consequences, reputational loss, and financial loss by way of penalties.

Even if an organization is using open source software, it is bound to abide by the terms and conditions of the software's usage.

The best way to determine the use of unauthorized software is to scan the entire network using automated tools and capture a list of installed software. This is followed by a review of this list by comparing it with the approved software list.

Some free software licensing types are as follows:

Type	Description
Open source	This software can be listed, modified, and redistributed as required. However, this should be done in accordance with the terms and conditions mentioned in the software license.
Freeware	Software is free but source code cannot be redistributed, for example, Adobe Reader.
Shareware	Software is available for free for a trial period and has limited functionality compared to the full version.

Table 7.1: Free software licensing types

An organization is bound to abide by the terms and conditions of the usage of all software. You will now explore source code management.

Source Code Management

Source code is a computer program that is created by a programmer. It is human-readable code. Source code is converted into object code by assemblers and compilers. Computers can understand object code but not source code. If an application is developed by a third-party vendor, it is essential for the organization to have access to its source code. If the source code is not supplied, it is important to arrange for an escrow agreement.

Access to the source code should be restricted. Any update to the source code should be managed by using a **Version Control System (VCS)**. Also, appropriate backups of the source code should be maintained.

Capacity Management

Capacity management is the process of planning and monitoring IT resources for their effective and efficient utilization. It ensures the smooth expansion or reduction of resources as per business requirements. It is necessary to obtain inputs from business users in order to manage capacity. Capacity management should be reviewed and updated on at least an annual basis.

The following are the advantages of capacity management:

- It ensures the availability of required resources at the optimal price.
- It aligns IT resources as per the requirements of the business.
- It reduces the risk of performance problems or failure through the constant monitoring of utilization thresholds.

Key Aspects from a CISA Exam Perspective

The following table covers the important aspects from a CISA exam perspective:

CISA Questions	Possible Answers
What is the major concern about the use of open source software?	Non-adherence to terms and conditions for the use of open source software
What is the best audit process to determine the use of unlicensed software?	Use of automated tools
What is the most important factor to examine the security configuration of an operating system?	Review parameter settings

Table 7.2: Key Aspects from the CISA exam perspective

Problem and Incident Management

As a CISA aspirant, you must be aware of the ways in which you can manage problems and incidents. Here are some of the most important concepts regarding this:

- The objective of problem management is to prevent the recurrence of an incident by identifying its root cause and taking appropriate preventive action.

- The elements of problem management are investigation, in-depth analysis, root cause analysis, and addressing the issues identified during the root cause analysis.
- Some widely accepted methodologies include fishbone analysis, Ishikawa cause and effect diagrams, 5 whys, and brainstorming. To prevent the recurrence of an incident, it is important to conduct a root cause analysis and address the issues.
- It is important to note the difference between problem management and incident management. The objective of problem management is reducing the number of incidents, whereas the objective of incident management is returning to a normal state as soon as possible after an incident, thereby minimizing the impact on the business.
- The primary risk of lack of attention to problem management is the interruption of business operations.
- An IS auditor should review problem reports and logs to ensure that problems are addressed in a time-bound manner.
- For effective incident management, it is very important to design and implement a support model in an efficient manner. Ineffective support models will not be able to prevent and react to potential outages.
- The best performance indicator for an outsourced help desk function is how quickly and effectively a solution is provided to users. It is vital to ensure that the end user is informed about the resolution and that consent for the resolution is obtained.

Network Management Tools

There are some widely used tools to manage networks. You need to understand these tools for the exam:

Tools	Description
Response time reports	To determine the response time taken by the host system to address the user's query.
Downtime reports	To determine and track the unavailability of telecommunication lines and circuits.
Help desk reports	To determine help desk activities, such as the nature of queries, number of open calls, turnaround time, and problems and their resolution.
Online monitors	To determine data transmission error and accuracy.
Network monitors	To provide real-time information on network nodes and status.

Tools	Description
Network protocol analyzer	A network diagnostic tool to determine and monitor packets flowing along a link. It produces network usage reports.
Simple Network Management Protocol (SNMP)	A TCP/IP-based protocol to monitor, control, and manage configuration. It collects statistics on performance and security.

Table 7.3: Network management tools

Next, you will explore some questions from the CISA exam perspective followed by a few self-assessment questions for you to review.

Key Aspects from a CISA Exam Perspective

The following table covers the important aspects from a CISA exam perspective:

CISA Questions	Possible Answers
Which tool is used to monitor and record network information?	Network protocol analyzer
What is the first step in the implementation of problem management?	Reporting an exception
What is the best method to prevent the recurrence of an incident?	Root cause analysis

Table 7.4: Key aspects from the CISA exam perspective

Change Management, Configuration Management, and Patch Management

CISA aspirants should be aware of the following aspects of change, configuration, and patch management processes for the exam.

Change Management Process

A change management process is used to change hardware, install software, and configure various network devices. It includes approval, testing, scheduling, and rollback arrangements.

When implementing a change, all relevant personnel should be informed and specific approval should be obtained from the relevant information asset owners.

To carry out changes, it is always advisable to use individual IDs rather than generic or shared IDs. Individual IDs help to establish accountability for any transaction.

For every change, transaction logs should be maintained. A transaction log is used as an audit trail for further investigation. A log should contain details such as date, time, user ID, terminal, and other relevant details of the transaction.

One of the most important aspects of change management control is code signing. Code signing provides assurance that software has been generated from a reputable source and that the code has not been modified after having been signed. The process employs the use of a hash function to determine the integrity and authenticity of code. Hash functions were discussed in *Chapter 11, Public Key Cryptography and Other Emerging Technologies*.

Patch Management

A patch is a set of changes to software that aim to update, fix, or improve it. It is important to test a patch before its implementation because patches may impact other systems and operations. Impact analysis is a very important aspect of patch management. Patch deployment without appropriate testing may result in system failure or disruption.

Configuration Management

Configuration management is considered one of the key components of network management. It determines network functionality both internally and externally. It ensures that the setup and management of a network are done appropriately.

Configuration management determines a base software release. The baseline is used to identify the software and hardware components that make up the specific versions of a system. In case of the failure of a new release, the baseline will be considered as a point to which to return.

Emergency Change Management

In some scenarios, there are business requirement changes that need to be implemented to which normal change management processes cannot be applied. These changes have a significant impact on business operations and a delay would be detrimental. Such changes should be carried out through an emergency change process. Emergency changes should be logged, and post facto approval should be obtained on the next working day.

Backout Process

It is advisable that the risk of a change having an adverse impact is reviewed and that a rollback plan is available to back out of changes in case that becomes necessary. There should be a process by which you can back out completely and restore the system to its previous state. This is known as a backout procedure.

The Effectiveness of a Change Management Process

Compliance testing will help to ensure that a change management process is applied consistently and that changes are appropriately approved.

The best method to determine the effectiveness of a control process is to first review a sample of implemented changes and then ask for relevant approvals for these changes. The process of identifying changes and then tracing them back through their records will provide the best evidence of unauthorized changes.

Key Aspects from a CISA Exam Perspective

The following table covers the important aspects from a CISA exam perspective:

CISA Questions	Possible Answers
What is the most important factor for patch management?	To test and conduct impact analysis before the installation of a patch
The procedure to restore a system to its prior state is known as:	A backout procedure
What is the objective of code signing?	To ensure that software has not subsequently been modified
What is the objective of library control software?	To prevent unauthorized changes or access
What is the best control for emergency changes?	Subsequent review and approval of all emergency changes
A key component of network management is:	Configuration management
What is the best method to determine the effectiveness of the change management process?	Select a few samples of changes and then trace back to their records

Table 7.5: Key aspects from the CISA exam perspective

IT Service-Level Management

In this section, you will first look at IT service management practices, followed by some assessment questions.

The following are some of the important aspects of service-level management:

- A **Service-Level Agreement (SLA)** defines the nature, expectations, escalations, and other relevant information for the services being offered.
- The SLA should be documented in non-technical terms and serve as the basis for measuring and monitoring services.
- Service-level management is the process of defining, documenting, and managing service requirements.
- The following characteristics should be considered to define an SLA:
 - Accuracy
 - Completeness
 - Timeliness
 - Security
- It is very important to monitor service levels at regular intervals to ensure that the objective of the service is achieved.
- It must be noted that when service delivery is outsourced, the accountability of the service still rests with the service receiver.
- It is the organization's responsibility to ensure that the service provider uses data for correct and agreed-upon purposes only. It should also ensure that service providers have appropriate controls in place to protect sensitive and critical data.
- An independent third-party audit report is the best assurance of the effectiveness of service provider controls.

Evaluating the Database Management Process

A **Database Management System (DBMS)** helps in organizing, controlling, and managing data. It aims to reduce data redundancy and improve access time. It also aims to provide appropriate security for sensitive data.

Advantages of Database Management

The following are some of the advantages of using a DBMS:

- Centralized data management reduces the cost, time, and effort it takes to manage data.
- It helps to improve database performance by reducing data redundancy.
- It helps to improve the efficiency of transaction processing.
- It ensures data consistency.
- It provides security for sensitive data.
- Various checks and controls in DBMSes ensure data integrity.
- It provides a structured way to manage user access.

Database Structures

It is important to understand various database structures to evaluate database risks. CISA aspirants should understand the following database models.

Hierarchical Database Model

The hierarchical model is illustrated in the following diagram:

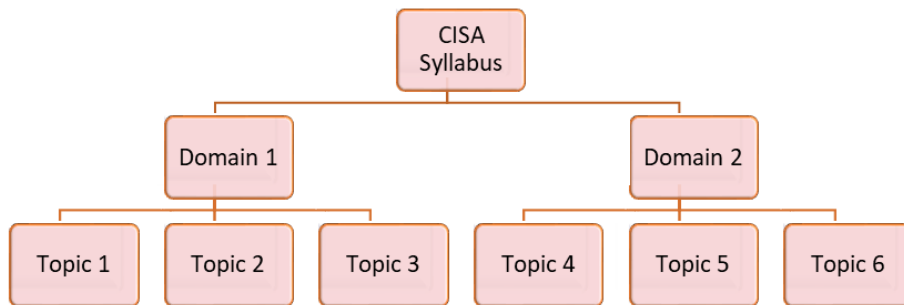


Figure 7.1: Hierarchical model of a database

From the preceding figure, you can observe the following:

- This model is arranged logically in an inverted tree pattern.
- Records are logically organized into a hierarchy of relationships.
- All records in the hierarchy are called nodes.
- Each node is related to the others in a parent-child relationship. The top parent record in the hierarchy is called the root record.

- Each parent record may have one or more child records, but no child record may have more than one parent record.
- The hierarchical data structure implements one-to-one and one-to-many relationships.

Network Database Model

In a network database model, each set is made up of an owner record and one or more member records.

The following diagram explains this model:

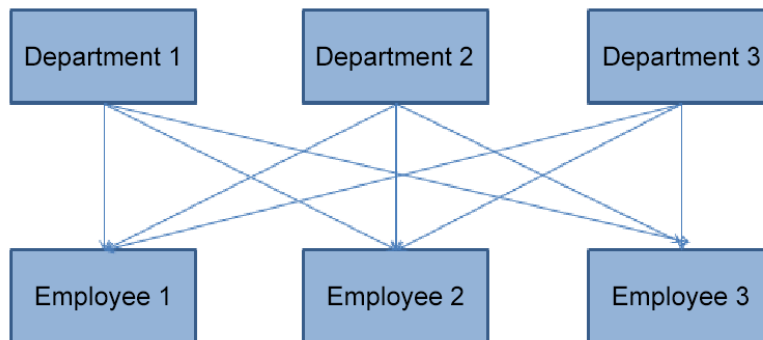


Figure 7.2: Network database model

This model keeps all records in sets.

The network model can show redundancy in data more efficiently than the hierarchical model.

Unlike the hierarchical model, the network model permits a record to be a member of more than one set at one time. This allows many-to-one and many-to-many relationship types.

Network databases directly address the location of a record on disk. This gives excellent retrieval performance.

Relational Database Model

The following are some of the important elements of relational database models:

- In a relational database, all the tables are related through one or more fields.
- Through these common fields, it is possible to connect all the tables in a database.
- For each table, one of the fields is identified as a primary key, which is the unique identifier for each record in the table. The primary key is used to join or combine data from two or more tables.
- Referential integrity refers to the integrity and correctness of data within a related table.

- The data in primary or master tables should be consistent with the data in related tables (also known as foreign tables).
- Any changes to the primary key must be applied to associated foreign keys.
- Referential integrity will prevent users from adding records in a foreign table, if records are not available in the primary table.
- At the same time, users cannot delete primary keys if related records are available in the foreign table.

The following diagram will help you to understand referential integrity:

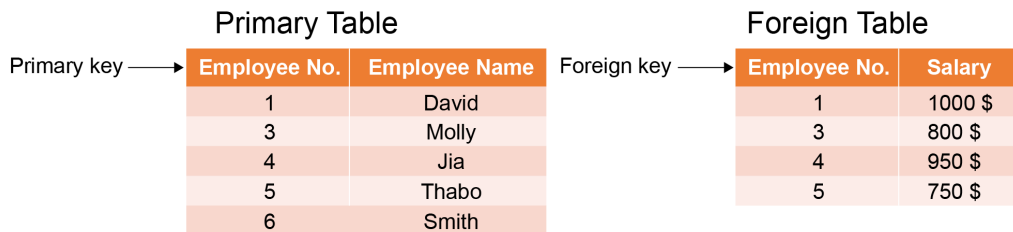


Figure 7.3: Relational integrity

The following will help you understand the preceding table in detail:

- Foreign tables are also known as related tables. Foreign keys are also known as related keys.
- Referential integrity will restrict adding anything to a foreign table for which there is no primary key. In the preceding table, employee number 2 cannot be entered in the foreign table as they do not exist in the primary table.
- Referential integrity will restrict deletion from the primary table as long as there is an associated foreign key. In the preceding table, employee number 1 cannot be deleted as they also exist in foreign tables. However, employee number 6 can be deleted from the primary table as they do not exist in any foreign tables.

Object-Oriented Database Model

The following are some of the important elements of the **Object-Oriented Database Model (OODM)**:

- An object-oriented database is a set of objects. Each object is an independently functioning application or program, assigned a specific task to perform.
- The OODM is designed to manage all these independent programs to quickly process large and complex requests.

- An object-oriented database provides a mechanism to store complex data such as images, audio, and video.

Database Normalization

The following are some of the important aspects of database normalization:

- Normalization is the process of reducing duplicate data and thus reducing data redundancy.
- Redundancy is considered a negative thing in a database environment as it means more effort and storage are required to handle data.
- Denormalization means normalization is not implemented. Denormalizing increases data redundancy.
- Disabling normalization will result in more redundant data, which may impact the consistency and integrity of data.
- When an IS auditor observes that some tables in a database are not normalized, they should review the justification and compensatory control for denormalization.

Database Checks and Controls

The following are some of the important checks and controls for the effective and efficient management of databases:

- **Concurrency control:** To prevent integrity issues during simultaneous updates by multiple users.
- **Table link/table reference check:** To identify table linking errors such as incomplete or inaccurate content in a database.
- **Integrity constraint:** To allow only valid predefined data to enter the database, and to prevent out-of-range data in the database. It is a preventive control.
- **Atomicity:** To ensure that either the entire transaction is processed or none of it is processed. This will ensure that partially executed transactions are rolled back and not processed.
- **Structured Query Language (SQL):** This helps to determine the portability of an application for connecting to a database.
- **Referential integrity:** This prevents the deletion of a primary table as long as it has associated foreign keys.
- **Normalization:** This is the process of removing duplicate data elements from a database and thus improving the database's performance.

- **Commitment and rollback controls:** This ensures that a transaction is completed in its entirety or not at all. It ensures integrity.
- **Tracing and tagging:** This is used to test applications, systems, and controls.
- **User spool and database limit control:** This helps to control space utilization and thus improve database query performance.
- **Restore procedure:** In the case of corruption in a database, the database can be restored to its last archived version. This is a corrective control.
- **Column- and row-level restrictions:** This helps to restrict particular sensitive columns or rows of a database to only a few authorized users. This means there is no need to have a separate database for such sensitive information.

Segregation of Duties

An IS auditor should understand the various roles and responsibilities of **Database Administrators (DBAs)** to ensure that an appropriate segregation of duties exists.

The following are some of the routine activities of a DBA:

- Conducting changes in the database table
- Conducting backup and recovery procedures
- Consulting on database interfaces
- Using tools and techniques to optimize database performance

It is very important to ensure that the DBA performs the preceding activities using their named account (and not a shared account) to establish accountability. Logs should be captured for all database activities. Logs should be restricted for modification and DBAs should not be provided with access to the log server.

From the perspective of control, DBAs should not be allowed to perform the following activities:

- Activities related to log capturing and the monitoring of DBA functions
- End user activities
- Security patch updates for the operating system

Key Aspects from a CISA Exam Perspective

The following table covers some important aspects from a CISA exam perspective:

CISA Questions	Possible Answers
Which key provides the assurance of database referential integrity?	Foreign key.
Denormalizing the tables in a database will increase which risk?	Redundancy risk/integrity risk.
What is the objective of concurrency control?	To prevent integrity issues during simultaneous updates by multiple users.
What is the objective of a table link check?	Assurance about the integrity of the database.
What is the objective of an integrity constraint?	It is a preventive control that checks for out-of-range data and restricts this from being entered into the database.
What feature ensures that partially executed transactions are rolled back and not processed?	Atomicity.
What is the objective of a commit and rollback control?	Commit features ensure that data is saved and updated in a database once transaction processing is completed. Rollback features ensure that partially completed transactions (due to interruption) are reversed and not saved. Thus, commit and rollback controls ensure that only a complete transaction is saved in the database.
The accountability of updating a database is best ensured by:	Log capturing and reviewing
Who holds the responsibility for authorizing access to data?	Data owner

Table 7.6: Key aspects from the CISA exam perspective

Summary

IS operations are the core of the IS cycle, and depending on the size of the enterprise and its business context, the nature of IS operations can vary.

In this chapter, you learned about various technology components and how to identify risks related to IT assets. You also explored IT operations and IT management practices. IT asset management is a very important element in designing and developing an effective security strategy.

The following were the important topics covered in this chapter:

- RFID is used to identify and locate assets within a limited radius. It uses radio waves to identify tagged objects. A tag includes a microchip and an antenna. The microchip in a tag is used to store the information and the antenna is used to transmit information to an RFID reader.
- Date-and-time stamping for both the source code and the object code will help to ensure that the code is in sync.
- Referential integrity refers to the integrity and correctness of data within a related table. The primary key and its associated foreign key must be consistent. Changes to the primary key must be applied to associated foreign keys. Referential integrity will prevent users from adding records in a foreign table. At the same time, users cannot delete primary keys if related records are available in foreign tables.

In the next chapter, you will learn about various risks, controls, and practices related to business resilience.

Chapter Review Questions

Before you proceed to *Chapter 8, Business Resilience*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

[Dashboard](#) > [Set 2 \(System Performance Management\)](#)

Question 1 of 14

1%

🕒 **Time Left:**
21 mins 56 secs

END QUIZ

An IS auditor suspects the use of unlicensed software. What should the auditor's first step be?

☐ Report the indications in the audit report

☐ Verify the software through testing

☐ Discuss the issue with auditee management

☐ Recommend immediate uninstallation of the software

NEXT

[Don't Know](#)

Feedback ▼

Figure 7.4: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/KEiVE`. You will see the following screen:

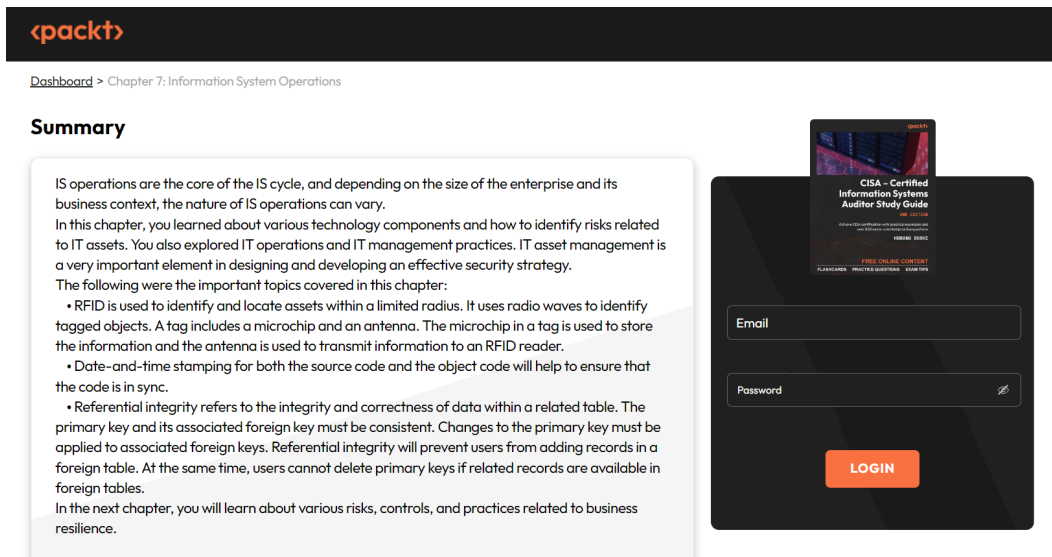


Figure 7.5: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 7.6: QR code to access *Chapter 7* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

Chapter 7: Information System Operations

Summary

IS operations are the core of the IS cycle, and depending on the size of the enterprise and its business context, the nature of IS operations can vary. In this chapter, you learned about various technology components and how to identify risks related to IT assets. You also explored IT operations and IT management practices. IT asset management is a very important element in designing and developing an effective security strategy. The following were the important topics covered in this chapter:

- RFID is used to identify and locate assets within a limited radius. It uses radio waves to identify tagged objects. A tag includes a microchip and an antenna. The microchip in a tag is used to store the information and the antenna is used to transmit information to an RFID reader.
- Date-and-time stamping for both the source code and the object code will help to ensure that the code is in sync.
- Referential integrity refers to the integrity and correctness of data within a related table. The primary key and its associated foreign key must be consistent. Changes to the primary key must be applied to associated foreign keys. Referential integrity will prevent users from adding records in a foreign table. At the same time, users cannot delete primary keys if related records are available in foreign tables.

In the next chapter, you will learn about various risks, controls, and practices related to business resilience.

Chapter 7 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (14 Questions)

START

Set 2 (14 Questions)

START

Set 3 (37 Questions)

START

Set 4 (35 Questions)

START

Figure 7.7: Chapter summary and end-of-chapter question sets

3. Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

[Dashboard](#) > [Set 2 \(System Performance Management\)](#)

Question 1 of 14

1%

Time Left:

21 mins 56 secs

END QUIZ

An IS auditor suspects the use of unlicensed software. What should the auditor's first step be?



Report the indications in the audit report



Verify the software through testing



Discuss the issue with auditee management



Recommend immediate uninstallation of the software

NEXT

[Don't Know](#)

Feedback



Figure 7.8: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Business Resilience

In this chapter, you will explore some important aspects of building a resilient business environment. Business resilience is the process by which prevention and recovery mechanisms are developed to deal with possible threats that a company might face. It is the ability to adapt quickly to disruptions while maintaining the ongoing business operations and safeguarding people, assets, and brand equity overall. Business resilience goes one step beyond recovering from disasters by providing post-disaster solutions to prevent expensive disruption, strengthen vulnerabilities, and sustain company operations in the face of new, unforeseen breaches.

The following topics will be covered in the chapter:

- **Business Impact Analysis (BIA)**
- Data backup and restoration
- System resiliency
- **Business Continuity Plan (BCP)**
- **Disaster Recovery Plan (DRP)**
- DRP – test methods
- **Recovery Time Objective (RTO)** and **Recovery Point Objective (RPO)**
- Alternate recovery site

Business Impact Analysis

An IS auditor should have a thorough understanding of the objectives of BIA. BIA is a process to determine and evaluate the impact of disruption on business processes and prepare accordingly to deal with such events.

The following are some of the important aspects of BIA:

- BIA determines critical processes that can have a considerable impact on business. It determines processes to be recovered as a priority to ensure an organization's survival.
- In order to conduct a successful BIA, it is necessary to obtain an understanding of the organization, its key business processes, and its dependency on IT and other resources. This can be determined from the outcome of the risk assessment.
- The involvement of senior management, the IT department, and end users is critical for a successful BIA.
- The following are some of the approaches when it comes to performing a BIA:
 - **Questionnaire approach:** It involves the development of a detailed set of questions that is then circulated among key users. The information obtained is then tabulated and analyzed to develop a BIA.
 - **Interview approach:** It involves interviewing key users. The information obtained is then tabulated and analyzed to develop a BIA.
 - **Meeting approach:** It involves holding meetings with key users to ascertain the potential business impact of various disruptions.
- As far as possible, the BIA team should also consider past transaction history to determine the possible impacts if systems are not available due to a particular incident.
- To determine the business impact, two independent cost factors need to be considered. The first one is downtime cost – meaning, for example, costs from a drop in sales, the cost of idle resources, and interest costs. Another cost element relates to alternative collection measures, such as the activation of a BCP and other recovery costs.
- Once the BIA is available for each process, it is important to prioritize the processes that need to be recovered first. This criticality analysis should be performed in coordination with IT and business users.
- The business process owner possesses the most relevant information, hence they are regarded as the best source for determining process criticality.
- Once the critical assets have been determined through the BIA, the next step is to develop a recovery strategy that ensures the recovery of critical assets as soon as possible to minimize the impact of the disaster. A recovery strategy is primarily influenced by the BIA.
- The BIA and risk assessment have almost the same elements, except for a downtime analysis, which is an additional component in the BIA. A downtime analysis determines the acceptable system downtime.
- The primary criterion for determining the severity of service disruption is the period during which the system will remain down. The higher the system downtime, the higher the disruption severity.

Key Aspects from the Perspective of the CISA Exam

The following table covers the key aspects from the perspective of the CISA exam:

CISA Questions	Possible Answers
Who can provide the best information to determine the criticality of the system?	Business process owner
Objective of BIA	To determine critical processes that have a considerable impact on business processes. It determines processes to be recovered as a priority to ensure the organization's survival.
What is the primary criterion to determine the severity of a service disruption?	Period of downtime
The recovery strategy is primarily influenced by	BIA

Table 8.1: Key aspects from the CISA exam perspective

Data Backup and Restoration

In information technology, a backup, or data backup, is a copy of computer data taken and generally stored in a remote location to be used later to restore the original data after a data loss event. Data loss can be the result of any number of internal or external factors, including computer viruses, hardware failure, file corruption caused by fire, natural calamities, and hacking attacks.

An organization should have a documented backup and recovery policy in place that clearly identifies the type of data and information for which backups are mandatory.

The following sections will take you through the different types of backup strategies.

Types of Backup Strategy

The backup policy should be approved by senior management. It should have clear and specific instructions regarding the organization's backup and retention procedure. The **CISA Review Manual (CRM)** covers the following types of backup strategies:

- Backup of the full database
- Backup of new data

- Differential backup
- Incremental backup

In a full backup, the entire database is backed up every time, regardless of previous backups. However, a full backup consumes a lot of time and space. To avoid this, many organizations resort to either a differential backup or an incremental backup. The following subsections explain the difference between differential and incremental backups:

Differential Backup	Incremental Backup
This type of backup covers only the new data created since the last full backup.	This type of backup covers only the new data created since the last backup (which could be either a full backup or another incremental backup).

Table 8.2: Difference between differential and incremental backup

The following example will help you understand this better:

Day	Differential Backup	Incremental Backup
Monday	A full backup is made on Monday.	A full backup is made on Monday.
Tuesday	A backup is made of new data created since Monday's full backup.	A backup is made of new data created since Monday's full backup.
Wednesday	A backup is made of new data created after Monday's backup (ignoring Tuesday's backup).	A backup is made of new data created since Tuesday's backup.
Thursday	A backup is made of new data created since Monday's backup (ignoring Tuesday's and Wednesday's backups).	A backup is made of new data created since Wednesday's backup.
Friday	A backup is made of new data created since Monday's backup (ignoring Tuesday's, Wednesday's, and Thursday's backups).	A backup is made of new data created since Thursday's backup.

Table 8.3: Differential and incremental backups explained

Storage Capacity for Each Backup Scheme

The following are some important requirements in terms of time and storage capacity for the different backup strategies:

- **Full backup:** Requires more time and storage capacity compared to the other two schemes
- **Differential backup:** Requires less time and storage capacity compared to a full backup, but more than an incremental backup
- **Incremental backup:** Requires less time and storage capacity compared to the other two schemes

Restoration Capability for Each Backup Scheme

The following details the effectiveness of the various schemes when it comes to data restoration:

- **Full backup:** The fastest of all three schemes
- **Differential backup:** Slower than a full backup, but faster than an incremental backup
- **Incremental backup:** The slowest of all three schemes

Advantages and Disadvantages of Each Scheme

The IS auditor should understand the following advantages and disadvantages of each backup strategy:

Advantages and Disadvantages	Full Backup	Incremental Backup	Differential Backup
Advantages	Unique repository in case of restoration	Faster backup and less media capacity is required	Faster backup compared to full backup and requires less capacity Quicker restoration compared to incremental backup
Disadvantages	Requires more time and capacity	Restoration requires more time	More media capacity required compared to incremental More restoration time required compared to full backup

Table 8.4: Advantages and disadvantages of the full, incremental, and differential backup strategies

Each method has its own advantages and disadvantages, as mentioned in the preceding table.

Key Aspects from the Perspective of the CISA Exam

The following table covers the key aspects from the perspective of the CISA exam:

CISA Questions	Possible Answer
Which type of backup is taken of the full database irrespective of the extent of the previous backup?	Full backup
Which type of backup is made only of the new data created since the last full backup?	Differential backup
Which type of data is made only of new data created since the last backup?	Incremental backup
Which type of backup strategy requires the largest storage capacity?	Full backup
Which is the most effective and fastest backup strategy for data restoration?	Full backup

Table 8.5: Key aspects from the CISA exam perspective

System Resiliency

System resilience is the ability of a system to withstand a disaster and recover from it within an acceptable timeframe. This section presents a detailed discussion of application and telecommunications resiliency.

Application Resiliency – Clustering

Clustering helps to protect an application against a disaster. The aim of clustering is to provide for the high availability of the system.

Application clustering often refers to a method of managing many servers through software. Clustered servers can help to create fault-tolerant systems and provide quicker responses and more capable data management for large networks.

An application that is clustered is protected against a single point of failure.

Application clusters can be either active-passive or active-active. In an active-passive setup, an application runs only on one active node, with the other passive nodes used only if the application fails on the active node.

In an active-active cluster setup, the application runs on every cluster. An active-active setup, though more expensive than an active-passive setup, provides faster application recovery, load balancing, and scalability.

Telecommunication Network Resiliency

In today’s business scenario, it is important to arrange for redundant telecommunication and network devices in order to ensure the continuity of business operations. The following are network protection methods:

- Alternative routing
- Last-mile circuit protection
- Long-haul network diversity
- Diverse routing

Alternative Routing

This is a method of routing the information through some alternative cables such as copper or fiber-optic cables.

Alternative routing can be further categorized into two types:

Last-Mile Circuit Protection	Long-Haul Network Diversity
Last-mile circuit protection is used to create redundancy for local communication.	This is used to create redundancy for long-distance communication.

Table 8.6: Categories of alternative routing

Diverse Routing

This is a method for routing information through split cables:

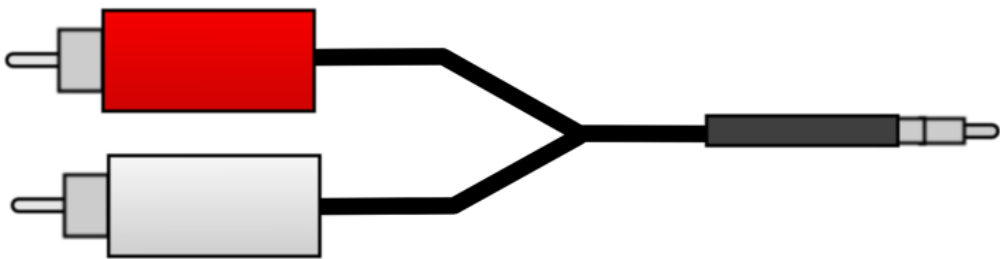


Figure 8.1: Diverse routing

In diverse routing, a single cable is split into two parts, whereas in alternative routing, two entirely different cables are used.

Business Continuity Plan

The objective of a BCP process is to manage and mitigate the risk of disaster to ensure the continuity of business operations. It is important that the BCP is reviewed and approved by senior management. This will ensure that the BCP is aligned with the business goals.

Steps of the BCP Life Cycle

The first step in preparing a BCP is to identify the processes of strategic importance for attaining the business objectives.

The following are the steps of the BCP life cycle:

1. Project and scope planning
2. Risk assessment and analysis
3. BIA
4. Business continuity strategy development
5. BCP development
6. Business continuity awareness training
7. BCP testing
8. BCP monitoring, maintenance, and update

Contents of the BCP

The plan should be well documented and written in simple language that can be understood by all. Interviewing the key personnel to determine their understanding of the BCP will help the auditor evaluate the plan's clarity and simplicity. The plan should clearly document each individual's responsibilities and accountability for specific tasks in the event of a disaster.

Responsibility for Declaring the Disaster

A key employee must be made responsible for declaring a disaster. If a disaster is not declared by anyone, the BCP would not be invoked, which would threaten business continuity.

A Single Plan

It is recommended to have a single continuity plan for the whole organization. In cases where BCPs are maintained by different business units, it should be ensured that all the plans have a uniform structure and approach and are consistent and linked to one another wherever required.

IT plans and procedures must be consistent with, and act in support of, the BCP. A copy of the BCP should be kept at an offsite location.

Backup Procedure for Critical Operations

A BCP should also consider the type and requirements of the backup procedure. Generally, for critical time-sensitive data, shadow file processing is recommended. In shadow file processing, exact duplicates of files are maintained, preferably at a remote site. Both files are processed concurrently. Shadow file processing can be implemented as a recovery mechanism for extremely time-sensitive transaction processing. It is important to ensure that the offsite location is not subject to the same risks as the primary site. If both the primary site and the offsite location operate from the same place, a disaster could put both out of action, which could have an adverse impact on business continuity.

The Involvement of Process Owners in the BCP

One important aspect in the successful development of a BCP is to get input from the process owners. The involvement of process owners is needed to identify critical processes, their dependencies, and the required level of RTO.

Ultimately, the protection of human life is a critical factor in any business continuity procedure. This takes precedence over all other elements.

BCP and Risk Assessments

It is recommended to review the BCP in terms of its adequacy every time a risk assessment is conducted in order to ensure that the BCP is aligned with the findings of the organization's latest risk assessment.

It is important that the BCP contains the level of information security required during the implementation of a business recovery process. The information security level may be the same, lower, or higher compared to that required during normal business operations. Based on the risk assessment, the worst-case scenarios and corresponding strategies can be incorporated into the BCP.

Testing the BCP

The adequacy of the BCP can be evaluated by performing a number of tests. The following are some of the important tests to be performed in order to evaluate the adequacy of a BCP:

- **Paper test/desk-based evaluation:** In this test, concerned staff do a walkthrough of the BCP and discuss what might happen if a service disruption of a particular type occurs.
- **Preparedness test:** In this test, preparedness is verified in a localized environment with the help of a simulated system crash. This is a cost-effective way to determine the adequacy of the plan. It also provides an opportunity to improve the plan incrementally. This is regarded as a localized version of a full test, wherein resources are expended only in the simulation of a system crash. A preparedness test includes a phase-wise simulation of the entire environment at a very reasonable cost and helps the recovery team understand the various challenges associated with the actual test scenario.
- **Full operational test:** In this test, the BCP is implemented in the context of actual service disruptions involving a complete shutdown of operations. A full operational test is to be conducted only after the paper test and preparedness test have been carried out. A full operational test is a costly and time-consuming affair and involves many challenges.

It must be noted that the results of the preceding tests should be properly documented and evaluated. It is not possible to evaluate the effectiveness of the BCP if test results are not properly documented and analyzed. Testing the BCP will help determine its effectiveness and identify any gaps. This provides an opportunity to improve the plan.

The following diagram summarizes the BCP requirements from the perspective of an IS audit:

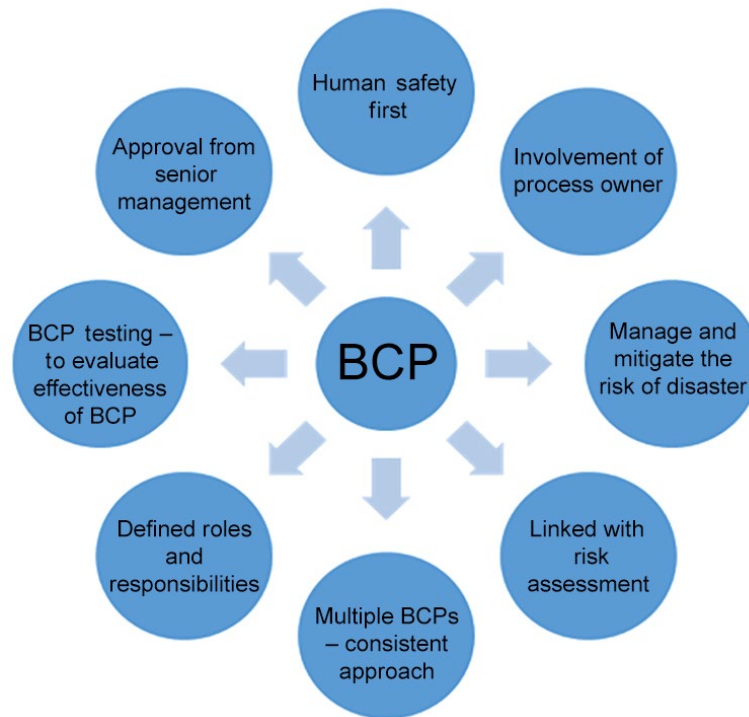


Figure 8.2: BCP requirements from the perspective of an IS audit

A CISA aspirant should be familiar with the aforementioned key aspects of the BCP.

Key Aspects from the Perspective of the CISA Exam

The following table covers the key aspects from the CISA exam perspective:

CISA Questions	Possible Answers
Which kind of test simulates a system crash and is performed on different aspects of the plan in a cost-effective way?	Preparedness test
The objective of testing the BCP is what?	To identify the limitations of the BCP and improve it
What is the ultimate critical factor in any business continuity procedure?	Protection of human life

CISA Questions	Possible Answers
What is the best way to determine the effectiveness of a BCP?	Examining the BCP test results
What factor is considered for the activation of an organization's BCP?	Period of outage
What should the BCP be aligned with?	Risk assessment

Table 8.7: Key aspects from the CISA exam perspective

Disaster Recovery Plan

A **Disaster Recovery Plan (DRP)** is a set of documented processes to recover and protect a business' IT infrastructure in the event of a disaster. It involves various plans for action to be taken before, during, and after a disaster.

A DRP is like insurance; you will only realize its importance when a disaster actually occurs.

The BCP versus the DRP

A CISA aspirant should be able to understand the difference between a BCP and a DRP. The objective of the BCP is to keep business operations functioning either from an alternate location or by means of alternative tools and processes. On the other hand, the DRP's objective is to restore normal business operations and advance the recovery from a disaster. The BCP is the overall architecture for business continuity, whereas the DRP is regarded as a technological aspect of the BCP with more focus on IT systems and operations.

Relationship between the DRP and the BIA

The first step in preparing any DRP is to conduct a BIA. A BIA is used to determine critical business processes and systems that need to be recovered as a priority in order for the organization to survive. Priorities are set on the basis of assigned RTOs and RPOs (discussed later in the chapter) for various processes.

If the results of the BIA are not used to design a DRP, all the required critical assets may not be covered in the DRP and, as a result, the DRP may not be adequate in helping an organization recover from a disaster.

Furthermore, an IS auditor should ensure that process owners are involved in the preparation of the BIA. The BIA and DRP may not be reliable if the input from the process owners is not considered.

Costs Associated with Disaster Recovery

Disaster recovery entails costs. Basically, two types of cost are associated with disaster recovery: downtime costs and recovery costs. Downtime costs include a loss of sales, idle resources, and salaries when the production of goods or services is at a standstill due to a disaster. These costs tend to increase over time, so the sooner the recovery, the lower the downtime costs.

Recovery costs are the costs associated with recovery procedures, such as additional costs related to the activation of the alternate site, and the costs related to the reparation of damaged assets.

The objective of a structured DRP is to minimize both downtime and recovery costs during a disaster. However, to maintain a DRP, additional costs in the form of resources, the recovery site, testing, and other maintenance are involved.

Data Backup

Data backup is an extremely important element of a DRP. Without access to backup data, all other efforts are in vain. It becomes very difficult to recover data following a disaster.

Considering the disaster recovery requirement, backup intervals should be aligned with the RPO. The RPO determines the maximum loss an organization can tolerate. Backup data should be taken in such a way that the latest backup supports the RPO. If the RPO is zero, then there should be real-time, online backups to ensure zero data loss.

DRP of a Third-Party Service Provider

Whenever an application or database is managed by a third-party service provider, an IS auditor should ensure the following requirements:

- DRP requirements should be incorporated in the service-level agreement with the third-party service provider. It is essential that the service provider have a contractual obligation (through an agreement) regarding the DRP arrangement. Without contractual obligations, it is difficult to enforce DRP requirements.
- The service-level agreement should also include a right-to-audit clause, and the DRP arrangement should be audited at least once a year, either by the recipient of the service or an independent auditor of service providers.

Resilient Information Assets

It is very important to first identify the assets that can be made more resilient to disaster. Resilient assets can withstand the effects of a disaster and prevent problems. Preventive control is always better than corrective control.

Service Delivery Objective

The service delivery objective is the level of service and operational capability to be maintained from an alternate site. It is directly related to business needs and is the level of service to be attained during disaster recovery. This is influenced by business requirements.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the Recovery Time Objective (RTO)?	The extent of acceptable system downtime
What is the Recovery Point Objective (RPO)?	The extent of acceptable data loss
Backup intervals should be best aligned with what?	The RPO
The service delivery objective is primarily influenced by what?	Acceptable operational capability during the disaster recovery phase
Disaster recovery prioritization is primarily influenced by what?	The BIA

Table 8.8: Key aspects from the CISA exam perspective

DRP – Test Methods

The objective of DRP testing is to ensure that recovery procedures are effective. Regular DRP testing and exercises are very important in determining the continued adequacy and effectiveness of the DRP. It helps to validate the compatibility of the offsite facility with the organization in case of a disaster. The following are some important methods for testing a DRP.

Checklist Review

This test is performed prior to a real test. A checklist is provided to all members of the recovery team for review. This checklist is updated regularly.

Structured Walkthrough

This includes a review of the DRP on paper. Team members review each step to evaluate the effectiveness of the DRP. The gaps, deficiencies, and constraints identified are addressed to improve the plan.

Tabletop Test

A tabletop test is conducted with the aim of practicing the coordination of efforts and the implementation of communication methodology among the relevant members of the recovery team.

Simulation Test

In this type of test, a disaster scenario is roleplayed and the adequacy of the DRP is determined. This does not include any actual activation of the recovery site.

Parallel Test

In this type of test, the recovery site is activated, while at the same time, the primary site continues to operate normally.

Full Interruption Test

This test is the most expensive and potentially disruptive. The primary site is completely shut down and operations are carried out from the recovery site as per the DRP.

This type of test should start with a simple exercise and once confidence is established, it should gradually expand to a full restoration test. Tests should be scheduled in a manner that minimizes any disruption to normal operations. Key recovery team members should be actively involved in test procedures. It is recommended to conduct full interruption tests on an annual basis once the individual test is performed satisfactorily.

Test results should be recorded and evaluated to determine the adequacy and effectiveness of the DRP.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the CISA exam perspective:

CISA Questions	Possible Answer
What is the primary objective of testing the offsite disaster recovery facility?	To validate the compatibility of the offsite facility
Which type of test involves the participation of key members to practice coordination efforts?	Tabletop test

CISA Questions	Possible Answer
Which type of test involves roleplaying the disaster scenario?	Simulation test
Which type of test involves reviewing each step of the plan to evaluate the effectiveness of the DRP?	Structured walkthrough
Which is the most disruptive kind of test?	Full operational test

Table 8.9: Key aspects from the CISA exam perspective

Recovery Time Objective (RTO) and Recovery Point Objective (RPO)

The RTO and RPO are crucial to designing a disaster recovery strategy. Hence, these two are extremely important aspects to understand from the exam perspective RTO.

The RTO is a measure of the organization's tolerance to system downtime. In other words, the RTO is the extent of the acceptable system downtime. For example, an RTO of 2 hours indicates that an organization will not be overly impacted if its system is down for up to 2 hours.

RPO

The RPO is a measure of the organization's tolerance to data loss. In other words, the RPO is the extent of acceptable data loss. For example, an RPO of 2 hours indicates that an organization will not be overly impacted if it loses data for up to 2 hours.

The following figure further explains each of them:

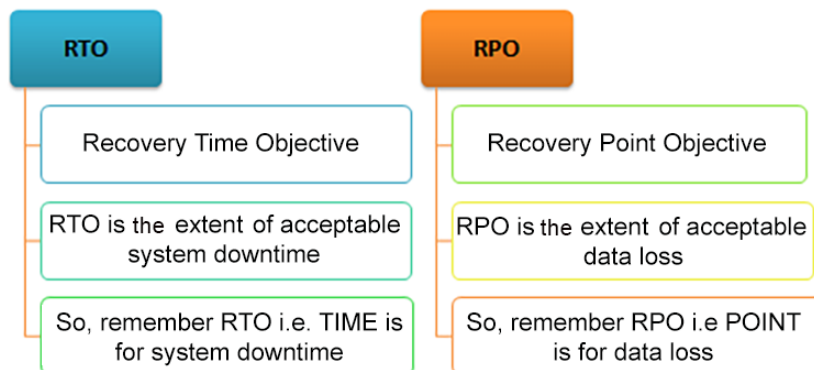


Figure 8.3: RTO and RPO

The following practical examples will help you better understand the preceding diagram:

Example 1: An organization can accept data loss for up to 4 hours. However, it cannot afford to have any downtime.

Solution:

RTO – 0 hours

RPO – 4 hours

Example 2: An organization takes a data backup twice daily; that is, at 12 a.m. and then at 12 p.m. What is the RPO?

Solution: Here, a data backup is done every 12 hours, so the maximum possible data loss is 12 hours. Hence, the RPO is 12 hours.

Example 3: An organization takes a data backup three times a day. The first backup is at 8 a.m., the second at 4 p.m., and the third at 12 a.m. What is the RPO?

Solution: Here, data backup is done every 8 hours, so the maximum data loss is 8 hours. Hence, the RPO is 8 hours.

Example 4: Following an incident, systems at the primary site went down at 3 p.m. These systems then resumed from the alternate site at 6 p.m., as per the defined RTO. What is the RTO?

Solution: The system was down for 3 hours, so the RTO is 3 hours.

Example 5: Identify the RTO and RPO in an instance where the BCP for an organization's critical system specifies that there should not be any data loss and service should resume within 36 hours.

Solution: Here, the organization accepts a system downtime of up to 36 hours, so the RTO is 36 hours. However, the organization cannot afford to have any data loss, so the RPO is 0 hours.

RTO – 36 hours

RPO – 0 hours

RTO and RPO for Critical Systems

When it comes to critical systems and data, organizations cannot afford to have much downtime or data loss. Hence, in the case of critical systems, generally, the RTO and RPO is zero, or near zero. A low RTO indicates that a system should be resumed at the earliest possible juncture. Similarly, a low RPO indicates that data loss should be minimal.

Put another way, if the RTO and RPO are low (that is, zero or near zero), systems and data will be critical for the organization.

RTO and RPO and Maintenance Costs

A low RTO indicates that systems are critical and need to be resumed as soon as possible. To achieve this objective, organizations need to invest heavily in redundancy. A hot site is ideal where the RTO is low. This will be a costly affair.

On the other hand, if the RTO is high, this indicates that systems are not that critical, and the organization can afford downtime to some extent. The organization need not invest in redundancy for systems with a high RTO. A cold site is ideal where the RTO is high.

A low RPO indicates that data is critical and should not be lost. For example, an organization with an RPO of 0 hours needs to ensure that there will not be any data loss at all. They should invest heavily in data backup management. Data mirroring or data synchronization is an ideal technique where the RPO is zero or very low. Hence, for a low RPO, data maintenance costs will be higher compared with a high RPO.

Thus, if the RTO and RPO are low (that is, zero or near zero), the cost of maintaining the environment is high.

RTO, RPO, and Disaster Tolerance

Disaster tolerance indicates the organization's tolerance level for the unavailability of IT facilities. A low RTO/RPO indicates that disaster tolerance is low, meaning that the organization cannot tolerate system downtime. On the contrary, a high RTO/RPO indicates that disaster tolerance is high, meaning that the organization can tolerate system downtime up to a certain level.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the CISA exam perspective:

CISA Questions	Possible Answer
What is the Recovery Time Objective (RTO)?	The extent of acceptable system downtime.
What is the Recovery Point Objective (RPO)?	The extent of acceptable data loss.
What indication does a low RPO/RTO provide about the system/data?	It indicates that the system/data is critical.

Table 8.10: Key aspects from the CISA exam perspective

Alternate Recovery Sites

An alternate recovery site is a separate location used for business operations when these cannot be carried out at the primary site (normal operating location) after a disaster has occurred.

In the aftermath of an incident, the primary site may not be available for business operations. To address such scenarios, organizations should have arrangements for the resumption of services from an alternate site to ensure the continuity of business operations. Many organizations cannot afford the discontinuity of business processes even for a single day, so they need to invest heavily in an alternate recovery site. These arrangements will vary according to the needs of the particular business.

From the CISA exam perspective, candidates should have an understanding of the following alternate recovery sites:

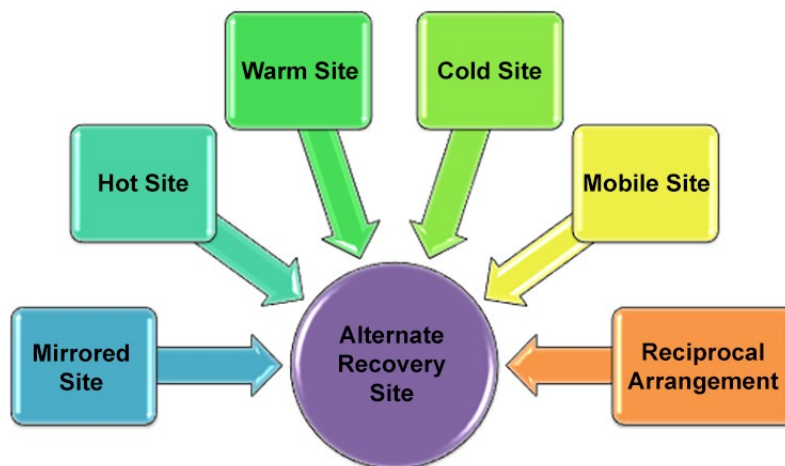


Figure 8.4: Types of alternate recovery sites

We will now explore each of the preceding alternate sites in detail.

Mirrored Site

A mirrored site is an exact replica of the primary site. When moving operations to a mirrored site, the following components are already factored in:

- The availability of space and basic infrastructure
- The availability of all business applications
- The availability of an updated data backup

A mirrored site can be made available for business operations in the shortest possible timeframe as everything (in terms of systems and data) has already been drawn up and made available. It must be noted that the cost of maintaining a mirrored site is very high compared to the other alternatives.

Hot Site

A hot site is the second-best alternative after a mirrored site. The following components are already factored in when moving operations to a hot site:

- The availability of space and basic infrastructure
- The availability of all business applications

However, for a hot site to function, the following component is also required:

- An updated data backup

Warm Site

The next-best alternative after a hot site is a warm site. It contains only a few required applications. The following components are already factored in when moving operations to a warm site:

- The availability of space and basic infrastructure
- The availability of a few business applications

However, for a warm site to function, the following components are also required:

- An arrangement regarding the required IT applications
- An arrangement for getting the required data

Cold Site

Cold sites generally do not have any business applications or data ready to go. The following component is already factored in when moving operations to a cold site:

- The availability of space and basic infrastructure

However, for a cold site to function, the following components are also required:

- An arrangement regarding the required IT applications
- An arrangement for getting the required data

Mobile Site

A mobile site is a movable vehicle equipped with the necessary computer equipment. A mobile site can be moved to any warm or cold site depending upon the business requirements. The scale of business operations will determine the need for a mobile site.

Reciprocal Agreement

In a reciprocal agreement, two organizations with similar capabilities and processing capacities agree to provide support to one another in the case of an emergency. Reciprocal agreements are not considered very reliable. A reciprocal agreement is the least expensive as it relies solely on an arrangement between two firms.

Summary

The following table summarizes the characteristics of each alternative recovery site:

Parameters/Types of Alternative Site	Mirrored Site	Hot Site	Warm Site	Cold Site
Space and basic infrastructure	Available	Available	Available	Available
IT equipment for processing	Available	Available	Less equipment available	Not Available
Database	Available	Not Available	Not Available	Not Available
Maintenance cost	Highest	-	-	Lowest
Recovery time	Fastest	-	-	Slowest

Table 8.11: Characters of each type of alternative recovery site

Mirrored sites offer the fastest mode of recovery, followed by hot sites. Cold sites provide the slowest mode of recovery. For a critical system, mirrored/hot sites are more appropriate, while for non-critical systems, cold sites will be sufficient. A reciprocal agreement has the lowest expenditure in terms of a recovery arrangement.

Summary

In this chapter, you explored various aspects of business resiliency, including BIA, data backups, BCP and DRP plans, and testing methodologies. You also learned about various processes to evaluate an organization's ability to continue business operations.

You have now acquired the relevant knowledge and skills required should business resilience appear in the CISA exam, along with a number of practical aspects like to derive RTO and RPO.

The following are some important points that you covered in this chapter:

- A BIA determines the impact arising from the unavailability of each system. The more critical the system, the higher the impact. A BIA is conducted on the basis of input from the business process owner.
- Once the critical applications have been identified through the BIA, the next step is to develop a strategy to recover the critical assets as soon as possible for the continuity of business operations. The BCP is the next step once the strategy has been developed. Testing procedures and training schedules can be designed following the development of the BCP.
- Diverse routing is a method of routing information through split cables, while alternative routing involves routing information through alternative cables, such as copper or fiber-optic cables. Bridges and gateways are used for network extensions.
- The main objective of testing an offsite facility is to validate the compatibility of the facility to support the organization in case of a disaster. The test results help to evaluate the adequacy and effectiveness of the offsite recovery facility.
- The RTO is a measure of an organization's tolerance to system downtime. In other words, it is the extent of acceptable system downtime. For example, an RTO of 2 hours indicates that an organization will not be overly impacted if its system is down for up to 2 hours.
- The RPO is a measure of an organization's tolerance to data loss. In other words, the RPO is the extent of acceptable data loss. For example, an RPO of 2 hours indicates that an organization will not be overly impacted if it loses data for up to 2 hours.

The next chapter will discuss various aspects of information asset security and controls.

Chapter Review Questions

Before you proceed to *Chapter 9, Information Asset Security and Control*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

Dashboard > Set 4 (DRP – Test Methods)

Question 5 of 13

38%

 **Time Left:**

20 mins 48 secs

END QUIZ

In which of the following tests is a roleplay for the disaster scenario prepared and the adequacy of the plan determined accordingly?

☐ Parallel test

☐ Simulation test

☐ Full interruption test

☐ Structured walkthrough

PREVIOUS

NEXT

Don't Know

Feedback



Figure 8.5: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/GXnvJ`. You will see the following screen:

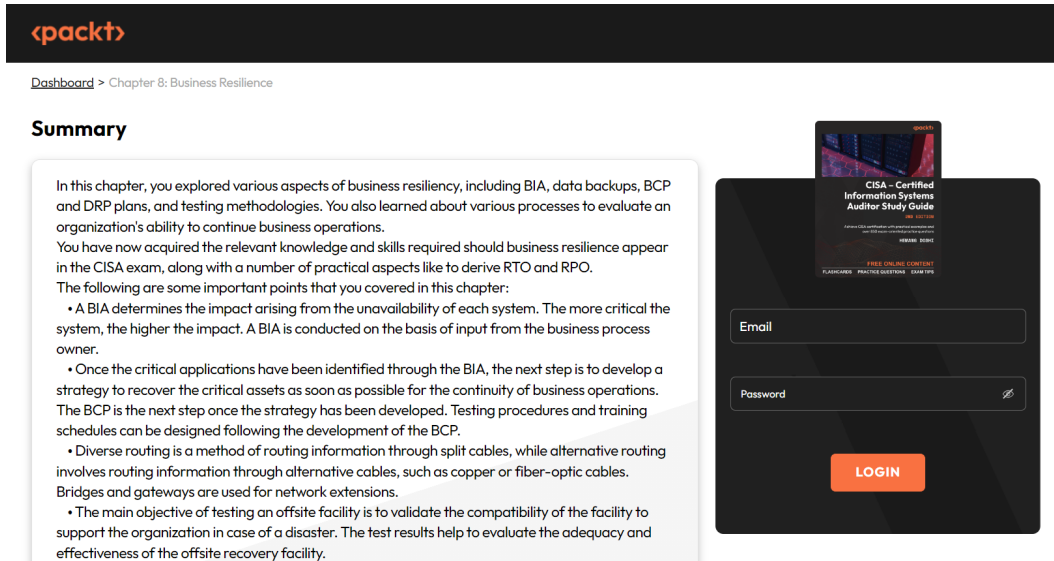


Figure 8.6: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 8.7: QR code to access *Chapter 8* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

Chapter 8: Business Resilience

Summary

In this chapter, you explored various aspects of business resiliency, including BIA, data backups, BCP and DRP plans, and testing methodologies. You also learned about various processes to evaluate an organization's ability to continue business operations.

You have now acquired the relevant knowledge and skills required should business resilience appear in the CISA exam, along with a number of practical aspects like to derive RTO and RPO.

The following are some important points that you covered in this chapter:

- A BIA determines the impact arising from the unavailability of each system. The more critical the system, the higher the impact. A BIA is conducted on the basis of input from the business process owner.

- Once the critical applications have been identified through the BIA, the next step is to develop a strategy to recover the critical assets as soon as possible for the continuity of business operations. The BCP is the next step once the strategy has been developed. Testing procedures and training schedules can be designed following the development of the BCP.

- Diverse routing is a method of routing information through split cables, while alternative routing involves routing information through alternative cables, such as copper or fiber-optic cables. Bridges and gateways are used for network extensions.

- The main objective of testing an offsite facility is to validate the compatibility of the facility to support the organization in case of a disaster. The test results help to evaluate the adequacy and

Chapter 8 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (18 Questions)

START

Set 2 (27 Questions)

START

Set 3 (28 Questions)

START

Set 4 (13 Questions)

START

Set 5 (11 Questions)

START

Figure 8.8: Chapter summary and end-of-chapter question sets

- Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

Dashboard > Set 4 (DRP - Test Methods)

Question 5 of 13

38%

Time Left:

20 mins 48 secs

END QUIZ

In which of the following tests is a roleplay for the disaster scenario prepared and the adequacy of the plan determined accordingly?

☐ Parallel test

☐ Simulation test

☐ Full interruption test

☐ Structured walkthrough

PREVIOUS

NEXT

Don't Know

Feedback

Figure 8.9: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

9

Information Asset Security and Control

Any data, system, network, and other communication structure that helps in achieving business goals is known as an information asset. Hence, securing an information asset is one of the key objectives of an organization.

The following topics will be covered in this chapter:

- Information asset security frameworks, standards, and guidelines
- Privacy principles
- Physical access and environmental controls
- Identity and access management
- Biometrics

By the end of this chapter, you will have learned how to keep intact any information assets' **confidentiality, integrity, and availability (CIA)**.

Information Asset Security Frameworks, Standards, and Guidelines

An information security framework is a set of documented policies, procedures, and processes that define how information is managed in an organization. There are two prime objectives of the framework:

- Lower risk and vulnerability
- Protect the enterprise by guarding the CIA of critical and sensitive information

Auditing the Information Security Management Framework

An IS auditor should consider the following aspects for auditing the information security management framework:

- Review the adequacy and approvals for various policies, procedures, and standards.
- Review security training and awareness programs and procedures. Determine the effectiveness of the program. It is advisable to interact with a few employees and evaluate their level of awareness.
- Determine whether proper ownership has been assigned for critical processes, systems, and data. The IS auditor should determine whether a data classification policy exists and evaluate its appropriateness. Also, the IS auditor should verify whether data custodians, such as system administrators and computer operators, are responsible for storing and safeguarding the data.
- Determine whether background verification is conducted for all new joiners and whether new users are required to sign a document stating that they should abide by the organization's IT security policy.
- Determine whether the access rights of terminated employees are revoked immediately. Also, the access rights of third-party service providers should be properly monitored and controlled.
- Determine whether an organization has an approved and documented security baseline policy and whether this security baseline is monitored for compliance.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the basis for designing and developing logical access controls?	The security policy
Who is accountable for the appropriate maintenance of security controls over information assets?	Data and systems owners
What is the first step in data classification?	Establishing ownership
Who is responsible for reviewing users' access rights?	The data owner
What is the first step when reviewing an IT security baseline?	To determine the sufficiency and adequacy of the baseline
What is the first step in data classification?	Establishing the data owners.

Table 9.1: Key aspects from the CISA exam perspective

Privacy Principles

Privacy is the right of an individual to demand the utmost care of their personal information that has been shared with any organization or individual. Individuals can demand that the use of their information is appropriate, legal, and only for the specific purpose for which the information was obtained.

The **Information Systems Audit and Control Association (ISACA)** describes several privacy principles that can be considered as a framework for privacy audits. The following are some of them:

- Organizations should obtain appropriate consent before the transfer of personal information to another jurisdiction.
- Organizations should specify the purposes for which personal information is collected.
- Organizations are required to retain personal information only as long as necessary.
- Organizations should have appropriate security safeguards for protecting personal information.
- Organizations should have an appropriate process for reporting compliance with the privacy policy, standards, and laws.
- Organizations should have an appropriate governance mechanism over the third-party service provider processing privacy data on behalf of the organization.
- Organizations should comply with applicable data protection regulations for the transfer of personal information across country borders.

Physical Access and Environmental Controls

Physical controls aim to protect information system processing facilities through physical mediums, such as locks, fences, **closed-circuit TV (CCTV)**, and devices that are installed to physically restrict access to a facility or hardware.

Similarly, environmental controls refer to measures taken to protect systems, buildings, and related supporting infrastructure against threats associated with their physical environment. Physical and environmental safeguards are often overlooked but are very important in protecting information. You will go through each of them in more detail in the following sections.

Environmental Controls

An IS auditor should consider the following aspects of environmental controls.

The following are four types of power failure:

- **Blackout:** Blackout indicates a complete loss of power.
- **Brownout:** Severely reduced voltage, which may place strain on electronic equipment or may even lead to permanent damage. Examples are sags, spikes, and surges:

- A sag is a rapid decrease in voltage level. Spikes and surges are rapid increases in the voltage level. These may result in data corruption in the server or the system.
- Sags, spikes, and surges may be prevented by using properly placed protectors.
- Surge and spike protection devices help to protect against high-voltage power bursts.
- The most effective control to protect against short-term reduction in electrical power is a power line conditioner. A power line conditioner helps to enhance the quality of power that is delivered to electrical equipment by compensating for the peaks and valleys in the power supply. When the electrical supply is low, it provides its own power and maintains a constant voltage.
- **Electromagnetic interference (EMI):** EMI is generally the result of electrical storms or noisy electrical equipment. EMI may result in system corruption or damage.

An **uninterruptible power supply (UPS)** can also support an organization during interruptions that last from a few seconds to 30 minutes. An alternative power supply medium (such as a power generator) is most effective when there is long-term power unavailability.

Alarm Controls

The following are some of the best practices for the maintenance of an alarm control panel:

- It should be accessible to security personnel at all times.
- It should be placed in a weatherproof box.
- It should have electrical power from a dedicated and separate circuit.
- It should be placed in adherence to local regulations and requirements.

Water and Smoke Detectors

The following are some of the best practices for the maintenance of water and smoke detectors:

- In the computer room, water detectors should be placed under raised floors and near drain holes.
- Smoke detectors should be installed above and below the ceiling tiles throughout the facilities and below the raised computer room floor.
- The location of the water and smoke detectors should be highlighted for easy identification and access.
- Responsibility should be assigned to a dedicated employee for remedial action in case of an alarm. A standard operating procedure should be available.
- The location of these devices is very important and should be placed in such a manner that they give early warning of an incident.

- The power supply of these devices should be sufficient.
- These devices should be tested at regular intervals.

Moreover, an emergency evacuation plan should be made available throughout the facility. Electrical wiring should be placed in fire-resistant panels and conduits. This conduit should ideally lie under the fire-resistant raised computer room floor.

Fire Suppression Systems

The following are some fire suppression systems.

Water-Based Sprinkler (WBS)

A WBS/suppression system makes use of an inexpensive and readily available medium of water to discharge onto flames through a normally fixed piping system.

In a WBS, fixed pipelines are placed at different places. In case of fire, water is discharged from the pipes. WBS is considered more effective and reliable than dry pipes as water always remains in the system piping. However, one disadvantage is that it exposes the premises to water damage if the pipe leaks or gets damaged.

Dry Pipe Sprinkler

In a dry pipe sprinkler system, the pipes are filled with pressurized air or nitrogen instead of water.

A dry pipe sprinkler system is one in which pressurized air or nitrogen is injected into the pipes. Water is not readily stored in the pipe.

When there is a fire alarm, a pump is activated and water is sent into the system. One of the advantages of a dry sprinkler is that it does not expose the premises to water damage due to leakage. However, it is less reliable than WBS.

Halon System

Halon gas starves the fire by removing oxygen from the air. It is not safe for humans and the environment. It is important to install an audible alarm and there should be a process to evacuate humans before the discharge of Halon gas. Halon gas is banned in most countries and wherever not banned, it is generally only used in unmanned data centers. Popular replacements for Halon gas are FM-200 and Argonite:

- **FM-200:** FM-200 is safe for the environment as well as humans. It is the most commonly used fire suppression gas.
- **Argonite:** Argonite is a mixture of 50% Argon and 50% Nitrogen. Although it is environmentally friendly and non-toxic, there have been cases where people have suffocated by inhaling Argon.

Carbon Dioxide Systems

CO₂ is not safe for humans. CO₂ systems are mostly installed in unmanned data centers and other places where there is no presence of humans. Most countries restrict the automatic release of CO₂ gas if any human is present in the area.

Physical Access Control

The objective of physical access control is to restrict and control access to premises, buildings, rooms, and data centers. Examples of physical access control include door locks, security guards, and access cards.

The following are a few common types of door locks.

Bolting Door Locks

These are traditional kinds of locks that require a metal key to open the gate. For these locks, the key should be under strict control, and no one should be allowed to duplicate the key.

Combination Door Locks (Cipher Locks)

In combination door locks, access is authorized through a numeric keypad or dial. Access numbers should be available only to authorized people. Access numbers should be changed on a frequent basis and should be mandatorily changed whenever an employee with access is transferred or terminated.

Electronic Door Locks

With electronic door locks, access is granted through a magnetic or embedded chip-based plastic card key. These access cards are difficult to duplicate. It is very easy to deactivate the access card in case of termination or when a card is lost. Alarms can also be configured to monitor unauthorized access. However, access card issuance and management processes should be carefully controlled.

Biometric Door Locks

Access can be granted through any of the biometric features of the user, such as voice, retina, fingerprint, and hand geometry.

Biometric access controls are generally used for critical and sensitive facilities.

Deadman Doors

Deadman doors are also known as mantrap or airlock entrances. In these cases, two doors are used, and for the second door to open, the first door must be closed and locked. Only one person is permitted in the gap between the first door and the second door.

A deadman door reduces the risk of tailgating or piggybacking wherein an unauthorized person follows an authorized person to gain unauthorized entry.

Deadman doors are also used in loading and unloading areas where outer doors open to load or unload from a truck and the inner doors cannot be opened to load or unload until the outer doors are closed and locked.

Identification Badge

Employees are required to have their identification badges (photo IDs) worn and displayed when in the office. For easier tracking, the badge should be different colors for employees and visitors. Visitors should be escorted by a responsible staff member.

CCTV Camera

CCTV cameras should be placed at strategic locations. Videos and images should be retained for a sufficient period, such as three months, for future requirements. For the security of high-sensitivity workstations, computer workstation locks should be used to prevent the computers from being turned on. It is advisable not to have visible or identifiable signs on the outside of facilities such as computer rooms.

Physical security is as important as logical security and should not have any scope for a loophole. It is advisable to define and document the roles and responsibilities of the personnel in charge of physical security.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the most effective control to protect against the long-term unavailability of electrical power?	An alternative power supply.
What is the most effective control to protect against short-term reduction in electrical power?	A power line conditioner.
What is the most effective control to protect against a high-voltage power burst?	A surge protection device.
What is the risk of carbon dioxide and Halon gas?	Suffocation in a closed room (both carbon dioxide and Halon gas reduce the oxygen in the atmosphere).
What is the most effective control regarding visitors?	Staff members should escort visitors.

CISA Questions	Possible Answers
What is the objective of having a raised floor in a computer room?	Safety of power and data cables (the floor is raised to accommodate the ventilation system, power, and data cables underneath the floor, thus protecting them from various risks and events).
What is the safest gas to be used as a fire extinguisher?	FM-200.

Table 9.2: Key aspects from the CISA exam perspective

Identity and Access Management

An IS auditor should review the logical access control of the organization with the prime objective of determining whether access is granted and controlled as per approved authorizations. As a CISA aspirant, you are expected to understand the concepts of identity and access management.

Logical access controls are a set of tools and protocols with the following objectives and purposes:

- **Identification:** Identification refers to the process of identifying a user or entity attempting to access a system, network, or resource. It involves providing a unique identifier or username to distinguish one individual from another. For example, when you enter your username or email address while logging into a website, you are providing identification information.
- **Authentication:** Authentication is the process of verifying the identity of a user or entity. It ensures that the person or entity claiming to be a particular user is indeed who they say they are. Authentication methods commonly include passwords, biometrics (such as fingerprints or facial recognition), smart cards, or cryptographic keys. By successfully authenticating, users gain access to the system or resource they are trying to use.
- **Authorization:** Authorization follows the authentication process and determines what actions or resources a user is permitted to access or perform within a system. It involves granting or denying permissions based on the user's identity, roles, or privileges. Authorization ensures that authenticated users are only allowed to perform actions or access resources that are appropriate for their level of authority. For example, an authorized user may have read-only access to certain files but not permission to modify or delete them.

- **Accountability:** Accountability refers to the concept of holding individuals or entities responsible for their actions and activities within a system. It involves tracking and logging user actions, such as system access, resource usage, or changes made. By maintaining accountability, organizations can monitor and audit user activities to detect potential security breaches, enforce compliance, and investigate any unauthorized or malicious behavior. Accountability also helps establish a clear audit trail, which can be useful for forensic analysis or legal purposes.

Together, these four concepts form the foundation of secure access control and user management within systems, networks, and resources. They help ensure that only authorized individuals or entities can access and perform appropriate actions, while also enabling organizations to track and trace user activities for security and auditing purposes.

Access Control Categories

The following are the major categories of access control:

Type	Description
Mandatory access control (MAC)	Control rules are governed by an approved policy. Users or data owners cannot modify the access role.
Discretionary access control (DAC)	Access control can be activated or modified by the data owner as per their discretion.

Table 9.3: Types of access control

MAC is considered more robust and stringent in terms of information security compared to DAC. To increase the effectiveness of DAC, it should be aligned in accordance with MAC.

Steps for Implementing Logical Access

To implement logical access controls, the following chronological steps are to be followed:

1. Prepare an inventory of the IS resources.
2. Classify the IS resources.
Identification of the owner of the data or application is the first step in the classification of an IS resource.
3. Perform the grouping/labeling of the IS resources.
4. Create an access control list.

Control Effectiveness

Preventive controls are considered more effective in terms of damage control compared to detective or deterrent controls. Automated controls are considered more effective compared to manual controls. For logical access control, an automated password management tool is considered the most effective preventive control. It ensures compliance with the password management policy.

As a best practice, log files should always be read-only and should not have editing enabled. The integrity of a log file is very important to function as an audit trail.

Default Deny Policy – Allow All Policy

Organizations can either have a default deny access control policy or an allow all access control policy. The following table shows the differences between the two:

Default Deny	Allow All
Denial of all traffic except predefined approved traffic.	Allow all traffic except predefined restricted traffic.
More prevalent when traffic is from an untrusted source to access a protected system.	More prevalent when traffic is from a trusted source to access an external system such as the internet.
This is considered part of a mandatory access policy.	This is considered part of a discretionary access policy.

Table 9.4: Differences between default deny and allow policies

It is recommended to implement a default deny access control policy. It is more stringent and robust compared to an allow all access control policy.

Degaussing (Demagnetizing)

The right kind of formatting is very critical to ensure that residual data from media cannot be recovered by an unauthorized person. To the extent possible, the media should be physically destroyed in such a manner that it cannot be reused. However, it may not be economical to destroy the media, and hence for these cases, extreme care should be taken for the complete deletion of the data such that it is not recoverable by any tool or technique.

One of these methods is to demagnetize the media record. This process involves increasing the alternating current field gradually from 0 to some maximum value and back to 0, leaving a very low residue of magnetic induction on the media. This process of demagnetization is also known as degaussing.

Naming Convention

A naming convention is an agreed structure for naming assets. It helps in the effective and efficient management of access rules. Generally, assets that are critical in nature are grouped and named under sensitive categories. Rules are defined for access to sensitive categories that may be more stringent compared to other categories. This reduces the number of rules required to adequately protect resources, which in turn facilitates security administration and maintenance efforts. The owners of the data or application, with the help of the security officer, usually set up naming conventions. These conventions should promote the implementation of efficient access rules and simplify security administration.

Factor of Authentication

The following three authentication factors can be used for granting access:

- Something you know (for example, a password, PIN, or some other personal information)
- Something you have (for example, a token, one-time password, or smart card)
- Something you are (for example, biometric features, such as fingerprint, iris scan, or voice recognition)

Two-factor authentication means the use of two authentication methods from the preceding list. For critical systems, it is advisable to use more than one factor of authentication for granting access.

Single Sign-On

Single sign-on (SSO) is a user authentication service that permits a user to use one set of login credentials (for example, a name and password) to access multiple applications. This increases the risk of a single point of failure. The impact of password compromise will be much more significant since the intruder needs to know only one password to gain access to all the related applications, which, therefore, is cause for greater concern. It is very important to implement strong password complexity for this kind of environment.

One example of SSO is Kerberos. Kerberos is an authentication service used to validate services and users in a **distributed computing environment (DCE)**. In a client-server environment, only users are authenticated; however, in a DCE, both users and servers authenticate themselves. At the initial logon time, the Kerberos third-party application is used to verify the client's identity.

Advantages of SSO

Now that you are familiar with how SSO works, take a look at its advantages as follows:

- Multiple passwords are not required. This encourages users to select a strong password.
- Improves the administrator's ability to manage users' accounts.

- Reduces administrative overhead costs in resetting passwords due to a lower number of IT help desk calls about passwords.
- Reduces the time taken by users to log in to multiple applications.

Disadvantages of SSO

The following are some disadvantages of SSO:

- SSO acts as a single authentication point for multiple applications, which constitutes a risk of a single point of failure.
- Support for all major operating system environments is difficult.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from a CISA exam perspective:

CISA Questions	Possible Answers
What is the objective of an IS auditor reviewing logical access control?	To determine whether access is granted and controlled as per the approved authorizations.
What is a major risk of shared user accounts?	Individual user accountability may not be established.
How can compliance with a password policy best be ensured?	With automated password management tools.
What is the most important consideration when reviewing system controls?	The alignment of security and performance requirements.
What is the best way to erase data?	Physical destruction. Demagnetization or degaussing in case media is to be reused. However, it must be noted that a few types of modern media, such as hard disks and tape drives, may not be reused if degaussing overwrites the servo pattern of the device.
What is the objective of using a naming convention?	To implement efficient access rules and simplify security administration.
What is the first step in the implementation of logical access controls?	To prepare an inventory of IS resources.

CISA Questions	Possible Answers
What is the most important control for SSO?	The implementation of a strong password policy.
What is a major risk of SSO?	It acts as a single authentication point for multiple applications. If this authentication is compromised, access to all the systems will be at risk.
What is the most effective control against identify theft?	Two-factor authentication.

Table 9.5: Key aspects from the CISA exam perspective

Biometrics

Biometric verification is a process through which a person can be uniquely identified and authenticated by verifying one or more of their biological features. Examples of these biometric identifiers include a palm print, hand geometry, fingerprints, retina and iris patterns, voice, and DNA.

Biometrics Accuracy Measure

The accuracy of a biometric system determines how well a system meets the objective. Accuracy measures determine the success factor of the biometric system. In this section, you will learn about a few biometrics accuracy measures.

False Acceptance Rate (FAR)

This is the rate of acceptance of a false person (that is, an unauthorized person). If biometrics allows access to an unauthorized person, then it is referred to as false acceptance.

False Rejection Rate (FRR)

This is the rate of rejection of the correct person (that is, an authorized person).

If biometrics does not allow access to an authorized person, then it is referred to as false rejection.

Cross-Error Rate (CER) or Equal Error Rate (EER)

This is the rate at which the FAR and FRR are equal. A biometric system with the lowest CER or EER is the most effective system. A biometric system with the highest CER or EER is the most ineffective system.

Note

It must be noted that the FAR and FRR are inversely proportionate. An increase in the FAR will result in a decrease in the FRR and vice versa. Also, if the FRR increases, the FAR will decrease. The CER or EER is an adjustment point where the FAR and FRR are equal.

An IS auditor should be most concerned about the FAR as one of the critical performance indicators. A high FAR poses the risk of unauthorized access to systems.

To evaluate the overall quantitative performance of a biometric system, it is important to consider the CER or EER.

Note

Among the current biometric identifiers, a retina scan is considered the most accurate and reliable identifier with the lowest FAR. An iris scan is also considered a very reliable biometric feature.

Control over the Biometric Process

An IS auditor should verify that the appropriate control is in place to protect the biometric information of the users. The following are some important aspects:

- Biometric information should be securely stored.
- Access to biometric information should only be available to authorized staff.
- The data flow between biometric devices to the server should be encrypted.
- User access should be revoked immediately upon resignation or termination.

Types of Biometric Attacks

An IS auditor should be aware of the following attacks that can exploit the weaknesses in biometric controls:

- **Replay attack:** In a replay attack, the attacker makes use of residual biometric characteristics (such as fingerprints left on a biometric device) to get unauthorized access.
- **Brute-force attack:** In a brute-force attack, the attacker sends numerous biometric samples with the objective to malfunction the biometric device.
- **Cryptographic attack:** In a cryptographic attack, an attacker attempts to obtain information by targeting algorithms or the encrypted information that transmits between biometric devices and access control systems.
- **Mimic attack:** In a mimic attack, the attacker attempts to reproduce a fake biometric feature of a genuine biometric user, for example, imitating the voice of an enrolled user.

Summary

In this chapter, you studied in detail the various frameworks and standards for information assets, different access control parameters, and biometrics-related risks and controls.

You learned about relevant skills to conduct an audit in accordance with the IS audit standards and a risk-based IS audit strategy, as well as evaluating potential opportunities and threats associated with emerging technologies, regulations, and industry practices.

The following are some important topics you covered in this chapter:

- Logical access controls are the most effective way to safeguard critical data within information processing facilities. Logical access controls are technical controls, such as authentication, encryption, firewalls, and IDSs, which are very difficult to bypass by a layperson.
- It is the responsibility of the appointed owner to ensure that their data and systems have appropriate security arrangements. System owners may delegate routine security responsibilities to a security administrator. However, it is the owners who remain accountable for the maintenance of appropriate security measures.
- It is the accountability and responsibility of the data owner to approve the access rights for the user. Once the user is approved, system administrators should then implement or update user authorization tables.
- It is very important to ensure that the applicable data privacy laws are adhered to. For example, one of the privacy principles requires organizations to use client data only for the purpose for which it is collected. The IS should ensure that consent has been obtained from the clients for the use of their data for promotional activities.
- A power line conditioner is a device intended to improve the quality of power that is delivered to electrical equipment. It compensates for the peaks and valleys in the power supply. When an electrical supply is low, it provides its own power and maintains a constant voltage. Surge and spike devices help to protect against high-voltage power bursts. An alternative power supply medium (such as a power generator) is most effective when there is long-term power unavailability.
- The **false acceptance rate (FAR)** is the rate of acceptance of a false person (that is, an unauthorized person). If biometrics allows access to an unauthorized person, then it is referred to as false acceptance.
- The **false rejection rate (FRR)** is the rate of rejection of the correct person (that is, an authorized person). If biometrics does not allow access to an authorized person, then it is referred to as false rejection.
- The **cross-error rate (CER)** or **equal error rate (EER)** is the rate at which the FAR and FRR are equal. A biometric system with the lowest CER or EER is the most effective system. A biometric system with the highest CER or EER is the most ineffective system.

In the next chapter, you will explore network-related aspects.

Chapter Review Questions

Before you proceed to *Chapter 10, Network Security and Control*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

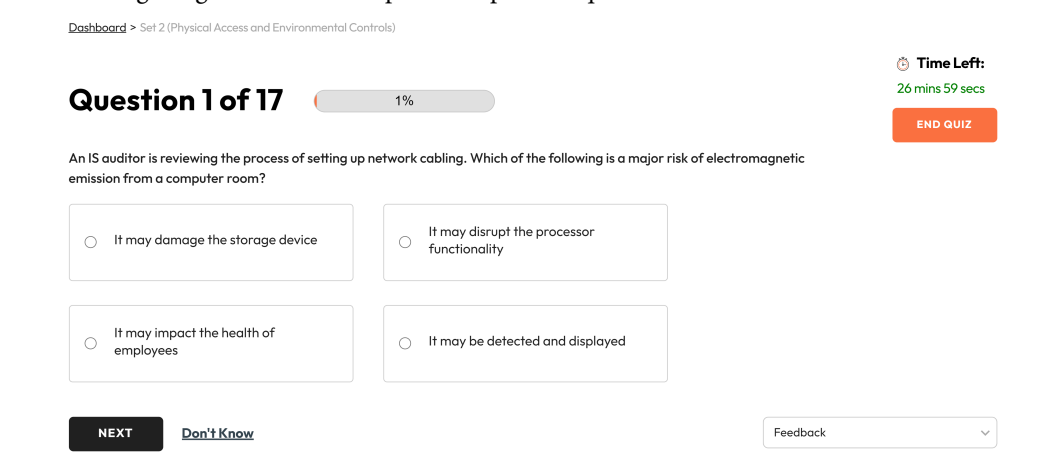


Figure 9.1: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to <https://packt.link/y5nCV>. You will see the following screen:

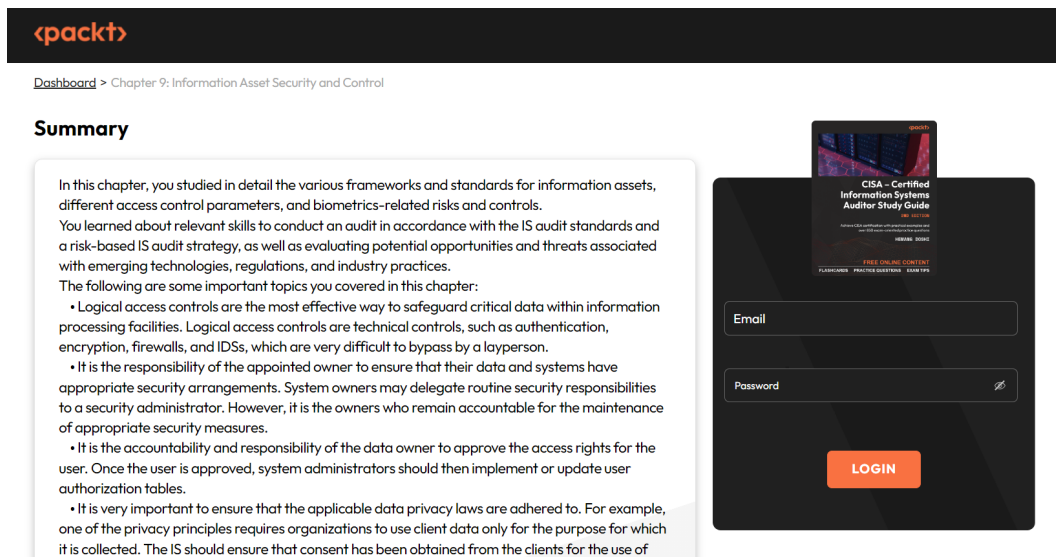


Figure 9.2: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 9.3: QR code to access *Chapter 9* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

[Dashboard](#) > Chapter 9: Information Asset Security and Control

Chapter 9: Information Asset Security and Control

Summary

In this chapter, you studied in detail the various frameworks and standards for information assets, different access control parameters, and biometrics-related risks and controls.

You learned about relevant skills to conduct an audit in accordance with the IS audit standards and a risk-based IS audit strategy, as well as evaluating potential opportunities and threats associated with emerging technologies, regulations, and industry practices.

The following are some important topics you covered in this chapter:

- Logical access controls are the most effective way to safeguard critical data within information processing facilities. Logical access controls are technical controls, such as authentication, encryption, firewalls, and IDSs, which are very difficult to bypass by a layperson.
- It is the responsibility of the appointed owner to ensure that their data and systems have appropriate security arrangements. System owners may delegate routine security responsibilities to a security administrator. However, it is the owners who remain accountable for the maintenance of appropriate security measures.
- It is the accountability and responsibility of the data owner to approve the access rights for the user. Once the user is approved, system administrators should then implement or update user authorization tables.
- It is very important to ensure that the applicable data privacy laws are adhered to. For example, one of the privacy principles requires organizations to use client data only for the purpose for which

Chapter 9 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (12 Questions)

START

Set 2 (17 Questions)

START

Set 3 (41 Questions)

START

Set 4 (15 Questions)

START

Figure 9.4: Chapter summary and end-of-chapter question sets

3. Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

[Dashboard](#) > Set 2 (Physical Access and Environmental Controls)

Question 1 of 17

1%

Time Left:

26 mins 59 secs

END QUIZ

An IS auditor is reviewing the process of setting up network cabling. Which of the following is a major risk of electromagnetic emission from a computer room?

☐ It may damage the storage device

☐ It may disrupt the processor functionality

☐ It may impact the health of employees

☐ It may be detected and displayed

NEXT

[Don't Know](#)

Feedback



Figure 9.5: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Network Security and Control

Network security and control is an important aspect of an IS audit. In this chapter, you will explore various components of the network, the OSI layer, and other security aspects of networking. You will learn about the functions of each type of firewall. This chapter also deals with the **Virtual Private Network (VPN)** and **Voice over Internet Protocol (VoIP)**.

The following topics will be covered in this chapter:

- Network and endpoint devices
- Firewall types and implementation
- VPN
- VoIP
- Wireless networks
- Email security

By the end of this chapter, you will be able to understand and evaluate various risks and controls related to networking.

Network and Endpoint Devices

The hardening and configuration of network and endpoint devices are very important from the perspective of information security. An IS auditor should therefore be aware of the basic functioning and capability of network devices to evaluate the risk and control associated with them. In this section, we will identify the risks associated with network security and related controls.

Open System Interconnection (OSI) Layers

The OSI model explains the layered steps of the network. In an OSI model, there are seven layers, and each layer is defined according to a specific function to be performed. All these layers collaborate to transmit the data from one layer to another. The following table shows the functions of each layer:

Layer	Name	Description
1 st	Physical layer	The physical layer converts bits into voltage for transmission. The physical layer is associated with cables and other hardware for the physical connection of the device to the network.
2 nd	Data link layer	The data link layer converts the electrical voltage into a data packet and it is forwarded to the network layer. A data packet received from the network layer is converted into electrical voltage and forwarded to the physical layer.
3 rd	Network layer	The function of the network layer is to insert the IP address into the packet header and route the packet to its destination.
4 th	Transport layer	The function of the transport layer is to provide an end-to-end data transport service and establish a logical connection between the two devices. The transport layer ensures the reliability of the data transfer to its destination in the proper sequence. This layer also manages traffic as per network congestion. In other words, it reduces data transmission during periods of high congestion and increases transmission during periods of low congestion.
5 th	Session layer	The function of the session layer is to establish a connection between two applications, maintaining the connection and terminating the connection when required. It is similar to a phone call, wherein the first connection is made and then the message is exchanged, and the connection is terminated.
6 th	Presentation layer	The function of the presentation layer is to translate the data as per the format of the application. The presentation layer provides services such as encryption, text compression, and reformatting.
7 th	Application layer	The function of the application layer is to provide an interface and communicate directly with the end user. It includes the protocols that support the applications.

Table 10.1: Functions of OSI layers

As shown in the preceding table, layers are the core of networking, and they will be repeatedly referred to throughout the chapter. You are advised to remember the sequence of all the layers with the help of the following figure:

Memory Technique to Remember OSI Layers

P D | N T | S P A

Or

Please Do Not Tell Sales People Anything

Or

People Do Not Throw Saugage Pizza Away

Figure 10.1: Remember the OSI layer sequence

Note: Although there will be no direct questions on the OSI layer in the CISA exam, a CISA aspirant should have a basic understanding of the OSI layer.

Networking Devices

An IS auditor should have a basic understanding of the following network devices.

Repeaters

Repeaters are used to address the risk of attenuation (weakening of the signal). A repeater receives the signal from one network and amplifies and regenerates a strong network. Repeaters extend the signal so that it can cover longer distances or be received on the other side of an obstruction.

Hubs and Switches

Hubs and switches are used to connect different devices for the exchange of data. A hub operates at layer 1 (physical layer), whereas a switch operates at layer 2 (data link layer) of the OSI model. A switch is regarded as a more advanced/intelligent version of a hub. A hub broadcasts a message to all connected devices, whereas a switch sends messages only to designated devices. A hub cannot store **Media Access Control (MAC)** addresses, whereas switches can store MAC addresses in a lookup table.

Bridges

Bridges have the same functionality as switches. They both operate at layer 2 (the data link layer) of the OSI model.

A bridge identifies the MAC address and directs the packet to its destination. It also has the ability to store the frame and can act as a storage and forwarding device. A device that collects data and sends it to another device is known as a forwarding device. Some popular forwarding devices include routers, switches, and hubs. A bridge has only a few ports for connecting devices, whereas a switch has many ports for device connection.

Routers

A router is regarded as a more advanced/intelligent version of a switch. It operates at layer 3 (the network layer) of the OSI model.

A bridge identifies the IP address and directs the packet to its destination. A router can monitor, control, and block network traffic. It can be considered a very basic level of firewall.

Routers can connect two different networks and each network remains logically separate and can function as an independent network. A router identifies the IP address, whereas a switch operates by identifying MAC addresses.

Gateway

A gateway has the capability to translate and connect different protocols and networks. It operates at layer 7 (the application layer) of the OSI model. A gateway can perform much more complex tasks than connection devices such as switches and routers.

Network Devices and the OSI Layer

The functionality of network devices depends upon the layer at which they operate. Devices operating at higher levels are more intelligent and capable compared with devices operating at lower levels. A CISA aspirant should be aware of the layer at which various devices operate:

Device	Layer
Hub	Physical Layer (1st Layer)
Switch	Data Link Layer (2nd Layer)
Bridge	Data Link Layer (2nd Layer)
Router	Network Layer (3rd Layer)
Gateway	Application (7th Layer)

Table 10.2: Network devices and the layers at which they operate

A gateway operates at the seventh layer, and so is the most intelligent device, whereas hubs operate at the first layer and have limited capabilities.

Network Physical Media

Physical media refers to the physical objects that are used to transmit and store data in network communication. Examples of network physical media include cables, storage media, and other networking equipment.

CRM covers the following types of network physical media.

Fiber-Optic Cables

Optical fiber is a thin and flexible fiber made of glass or plastic. Here are its characteristics:

- These cables carry binary signals as flashes of light.
- Fiber-optic cables are more secure than copper wire.
- Fiber-optic cables are the preferred choice for managing long-distance networks and handling high volumes of data.
- They are not impacted or affected by **electromagnetic interference (EMI)**.
- These cables have very marginal transmission loss.

Twisted Pair (Copper Circuit)

Twisted pairs are also known as copper circuits. Here are their characteristics:

- Copper wires are cheaper than fiber optics.
- There are two categories of twisted pair, that is, the shielded twisted pair (STP) or the unshielded twisted pair (UTP).
- STPs are less prone to EMI and crosstalk and so are more reliable than UTPs.
- A UTP is more sensitive to the effects of EMI and crosstalk (when one cable interferes with signals from adjacent cables).
- The parallel installation of UTPs should be avoided for long distances since they are more prone to crosstalk.

The following diagram shows various kinds of networking cables:

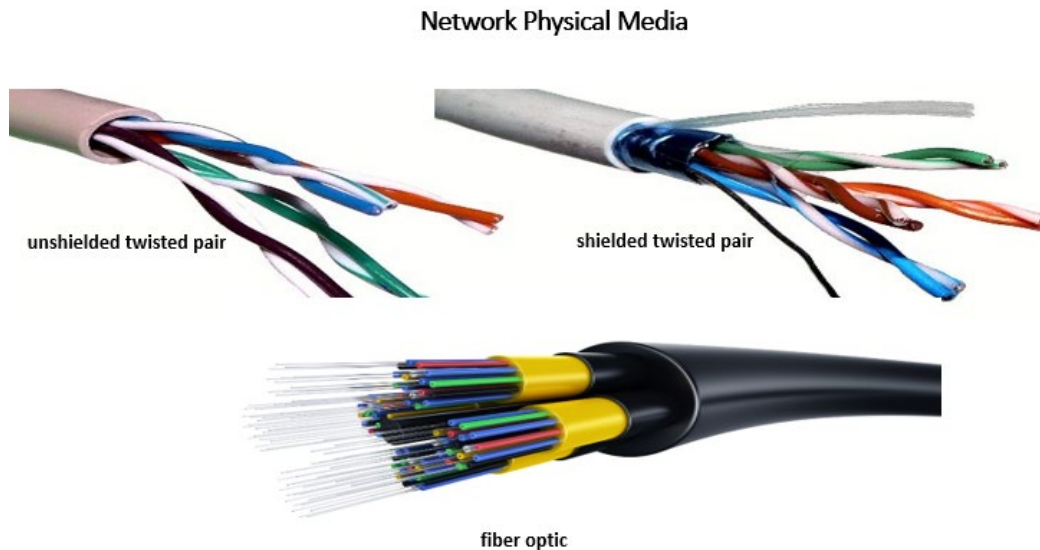


Figure 10.2: Various kinds of networking cables

Fiber-optic cable is regarded as the most secure cable for the purposes of data transmission.

Infrared and Radio (Wireless)

Wireless communication is established through infrared or radio waves.

Identifying the Risks of Physical Network Media

There are certain factors that determine the selection of particular media. IS auditors should be aware of these factors and the relevant risks that affect the performance of the media. The following are some of the major factors:

Attenuation

Attenuation is the loss or weakening of signal transmission. It can impact both wired and wireless transmissions. Distance and wire length have a direct impact on the severity of attenuation.

Electromagnetic Interference (EMI)

EMI is an interference or disturbance that impacts the quality of electrical signals. EMI is generally caused by connecting one electrical or electronic device to another. It may degrade the performance of the circuit or even stop it from functioning. With respect to network data, EMI may result in the

total loss of data or an increase in the error rate. Major causes of EMI are electrical storms or noisy electrical equipment (for example, motors, fluorescent lighting, and radio transmitters).

Crosstalk

Crosstalk happens when the signal from one cable gets mixed up with the signal from another cable. This generally happens for UTPs of cables that run close to one another.

Network Diagram

While auditing the network security, an IS auditor should first review the network diagram to understand the network architecture and determine the inherent risk or a single point of failure. A network diagram is a pictorial representation of network architecture that includes the computer, server, and other network devices such as cables, routers, devices, hubs, and firewalls. The diagram includes the details of the placement of each piece of network equipment and how they interact with each other.

Once the auditor is familiar with the network, it becomes easy to understand the risks and evaluate relevant controls.

Network Protocols

A CISA aspirant should have a basic understanding of the following network-related protocols. Here are the important network-related protocols that are crucial with respect to IS auditing/the CISA exam.

Dynamic Host Configuration Protocol

Dynamic Host Configuration Protocol (DHCP) is a protocol to manage the network configuration. A DHCP server dynamically assigns an IP address and other network configuration parameters to every device on a network so that it can communicate with other IP networks. Thus, IP address pool management is handled by the DHCP server for high-volume traffic.

One of the concerns regarding automatic IP allocation is the fact that any unauthorized individual can connect to the corporate network. Hence, physical network ports should not be kept open, and strong restrictions should be in place for access to the network port.

Transport Layer Security and Secure Socket Layer

Transport Layer Security (TLS) and **Secure Socket Layer (SSL)** are the protocols operating at the transport layer. They are used for privacy and data security for communications over the network. Both protocols use cryptographic functions to protect the confidentiality, reliability, and integrity of private documents traveling across the internet. SSL is now deprecated as it is vulnerable to attack.

Transmission Control Protocol and User Data Protocol

Transmission Control Protocol (TCP) and **User Data Protocol (UDP)** are the protocols operating at the transport layer. TCP is considered a reliable and connection-oriented protocol. TCP ensures that data packets are delivered to the destination. TCP provides enhanced error checking and correction. If a data packet is corrupted or lost during transmission, TCP resends the packet. It delivers packets in a sequence.

UDP is considered a connectionless protocol. UDP has unreliable service, and data packets may arrive out of order, be corrupted, or may get dropped. The destination does not acknowledge every packet it receives. One advantage of UDP is that it allows reduced latency as it does not perform error checking.

Secure Shell and Telnet

Secure Shell (SSH) and Telnet are remote terminal control protocols. Through these protocols, a user can connect to a terminal from a remote location. For instance, Mr. A of the USA can access the computer of Mr. B of India through these protocols.

SSH provides authentication and secure transmission for remote connection. However, it must be noted that Telnet traffic is not encrypted by default. It is advisable to use SSH in place of Telnet. If Telnet is used, it is advisable to use a dedicated leased line to reduce the security risk.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the perspective of the CISA exam:

CISA Questions	Possible Answers
What is the most secure and reliable transmission media?	Fiber optics
What offers the best security for a telecommunication network?	Dedicated lease lines
While auditing the network security aspect, what should an IS auditor first review?	Network diagram
Name a connectionless/stateless connection and unreliable protocol.	UDP
Which OSI layer routes packets between the nodes?	Network layer
Which OSI layer is primarily concerned with the reliability of data transfer between the systems?	Transport layer

Table 10.3: Key aspects from the CISA exam perspective

Firewall Types and Implementation

A firewall is a network security system designed to prevent unauthorized access to networks. It monitors and controls incoming and outgoing network traffic as per the defined rules. A firewall can be implemented either in software or hardware form.

The prime objective of a firewall is to allow only authorized uses of the system and network and thereby restrict unauthorized access.

The CISA Review Manual covers the following types and implementations of firewalls:

Types of Firewall	Types of Firewall Implementation
Packet Filtering Router	Dual-Homed Firewall
Stateful Inspection	Screened-Host Firewall
Circuit Level	Screened-Subnet Firewall
Application-Level	

Table 10.4: Types of firewall and firewall implementation

CISA aspirants need to understand the basics of each of the preceding types of firewalls and firewall implementation methods.

Types of Firewalls

The following are the basic characteristics of the different types of firewalls.

Packet Filtering Router

A packet filtering router is the simplest and earliest version of the firewall.

It tracks the IP address and port number of both the destination and source and takes action (either to allow or deny the connection) as per defined rules.

A packet filtering router operates at the network layer of the OSI framework.

Stateful Inspection

A stateful inspection firewall monitors and tracks the destination of each packet that is being sent from the internal network. It ensures that the incoming message is in response to the request that went out of the organization. A stateful inspection firewall operates at the network layer of the OSI framework.

Circuit-Level

A circuit-level firewall works on the concept of a bastion host and proxy server:

- It provides the same proxy for all services.
- It operates a session layer of the OSI.

Application-Level

An application-level firewall provides a separate proxy for each application. Here are a few of its characteristics:

- It operates at the application layer of the OSI.
- It controls applications such as FTP and HTTP.
- An application-level firewall is regarded as the most secure type of firewall.

What is a Bastion Host?

The objective of a bastion host is to protect the organization's network from outside exposure. Only bastion hosts are made available on the internet, and it is the only system that can be addressed directly from a public network. Bastion hosts are heavily fortified against attack.

Both application- and circuit-level firewalls work on the concept of bastion hosting.

The following are some of the common characteristics of a bastion host:

- The operating system of a bastion host is hardened and only essential services are activated. Vulnerabilities are removed as far as possible.
- Generally, an additional level of authentication is required before a user is allowed to access proxy services.
- Bastion hosts are configured in such a manner that access is allowed only for specific hosts.

What is a Proxy?

The following diagram explains the concept of proxy:

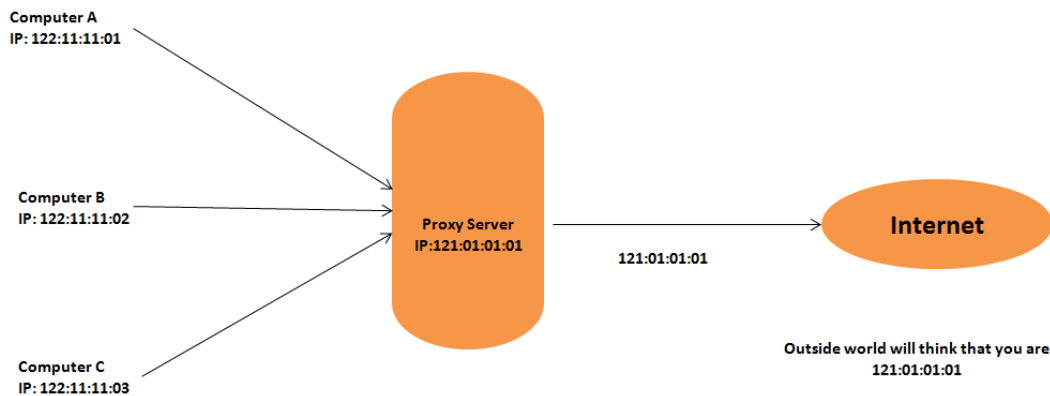


Figure 10.3: How a proxy works

A proxy can be regarded as a mediator. A proxy stands in between the internal and external networks.

No direct communication will be allowed between the internal and external networks. All communication will pass through the proxy server.

The outside world will not have the addresses of the internal networks. It can recognize only proxy servers.

Proxy technology operating at the session layer is referred to as a circuit-level proxy, while proxy technology operating at the application layer is referred to as an application-level proxy.

Types of Firewall Implementation

The following three types of firewall implementation are relevant to the CISA exam.

Dual-Homed Firewall

The following are the characteristics of a dual-homed firewall:

- A dual-homed firewall consists of one packet filtering router.
- It also has one bastion host with two **Network Interface Cards (NICs)**.

The following diagram illustrates the concept of a dual-homed firewall:

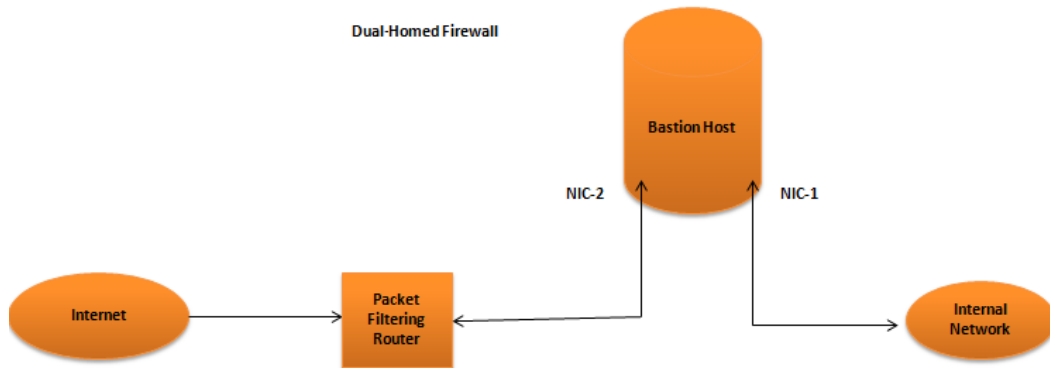


Figure 10.4: A dual-homed firewall

As can be seen in the preceding diagram, a dual-homed firewall consists of one packet filtering router and one bastion host with two network interface cards.

Screened-Host Firewall

The following are the characteristics of a screened-host firewall:

- A screened-host firewall consists of one packet filtering router.
- It also has one bastion host.

The following diagram illustrates the concept of a screened-host firewall:

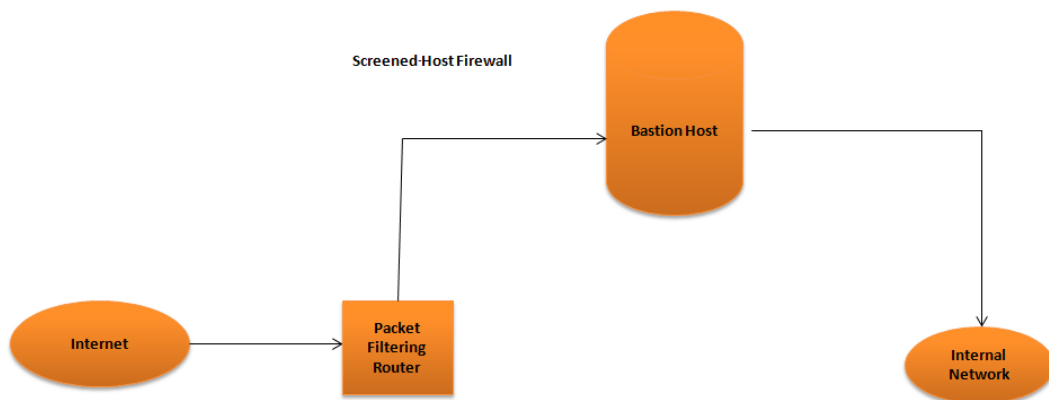


Figure 10.5: A screened-host firewall

As can be seen in the preceding diagram, the screened-host firewall consists of one packet filtering router and one bastion host.

Screened-Subnet Firewall (Demilitarized Zone)

A screened-subnet firewall is also referred to as a **demilitarized zone (DMZ)**. The following are the characteristics of a screened-subnet firewall:

- A screened subnet-firewall consists of two packet filtering routers.
- It also has one bastion host.
- Of the preceding firewall implementations, a screened-subnet firewall (demilitarized zone) is regarded as the most secure type of firewall implementation.

The following diagram illustrates the concept of a screened-subnet firewall:

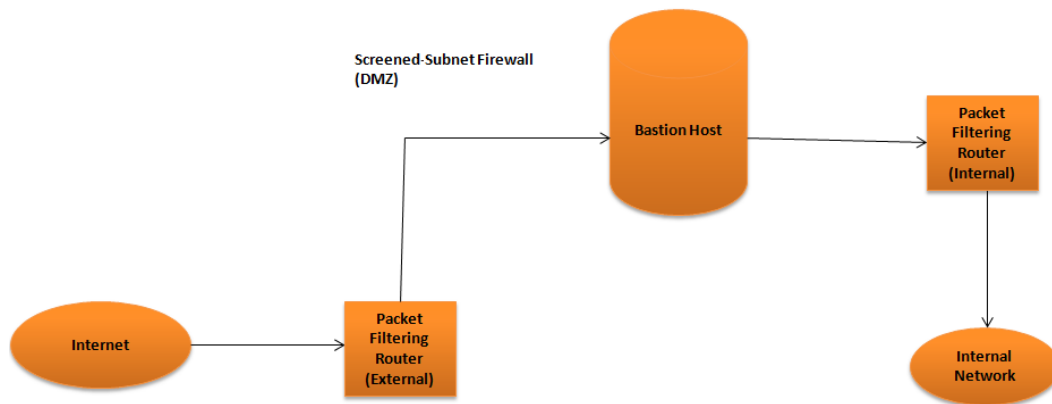


Figure 10.6: A screened-subnet firewall

As can be seen in the preceding diagram, the screened-subnet firewall consists of two packet filtering routers and one bastion host. A screened-subnet firewall is regarded as one of the most robust firewall arrangements.

The Firewall and the Corresponding OSI layer

An IS auditor should have a basic understanding of the OSI layer for each type of firewall. The following table illustrates the type of firewall and its corresponding OSI layer:

Firewall	OSI Layer
Packet Filtering Firewall	Network Layer (3rd Layer)
Stateful Inspection Firewall	Network Layer (3rd Layer)
Circuit-Level Firewall	Session Layer (5th Layer)
Application-Level Firewall	Application Layer (7th Layer)

Table 10.5: Type of firewall and its corresponding OSI layer

CISA aspirants should be aware of the OSI layer for each firewall type. The functionality of the firewall improves with the increase in layers. An application-level firewall that operates at the seventh layer is regarded as the most robust firewall.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the perspective of the CISA exam:

CISA Question	Possible Answer
What is the objective of a firewall?	To connect only authorized users to trusted networks (thereby restricting unauthorized access)
The most secure type of firewall is:	Application-level (as it works on the application layer of the OSI model)
The most secure implementation technique is:	Screened subnet firewall (DMZ)
The most stringent and robust configuration setting in the firewall is:	Deny all traffic and allow specific traffic
The firewall that permits traffic from an external source only if it is in response to traffic from internal hosts is:	Stateful inspection

Table 10.6: Key Aspects from the CISA exam perspective

VPN

A VPN is used to extend a private network through the use of the internet in a secure manner. It provides a platform for remote users to get connected to the organization's private network.

The prime objective of VPN technology is to enable remote users and branch offices to access applications and resources available in private networks of organizations. A VPN is created by establishing a virtual point-to-point connection through the use of dedicated circuits or tunneling protocols.

VPN technology, if properly configured, will reduce the risk associated with sensitive data traveling in an open public network.

Types of VPN

The following are some of the VPN connection types:

Type	Description
A remote access VPN	Through a remote VPN, authorized users can connect to the corporate network from anywhere. A VPN ensures that information is secure on the open internet.
An intranet VPN	An intranet VPN is used to connect branch offices within an enterprise WAN.
An extranet VPN	An extranet VPN is used to connect business partners and provide limited access to each other's corporate networks.

Table 10.7: Types of VPN connection

The following are some of the advantages of a VPN:

- A VPN helps organizations expand their corporate network in a cost-efficient manner.
- A VPN provides a platform to authorized remote users in terms of a secure and effective way of connecting to corporate networks.
- A VPN provides a platform for secure communication with business partners.
- A VPN provides a platform for efficient and effective supply chain management.

VPNs – security risks

The following are some of the risks associated with the use of a VPN:

- The risk of malware entering the network through remote access.
- One of the overriding risks of a VPN is that firewalls cannot adequately examine the encrypted VPN traffic.
- If a remote computer is compromised, an intruder may send malicious code through a VPN to enter the organization's private network.
- The risk of poor configuration management.

VPNs – Technical Aspects

A VPN provides a platform to hide information from a sniffer on the internet. Instead of using expensive dedicated leased lines, a VPN relies on a public IP infrastructure, which is cost-efficient. To protect the data, a VPN encrypts packets with **IP Security Standards (IPSec)**.

A VPN uses IPSec tunnel mode or IPSec transport mode. The IPSec tunnel mode is used to encrypt the entire packet, including the header. The IPSec transport mode is used to encrypt only the data portion of the packet. A VPN uses the data encapsulation or tunneling method to encrypt the traffic payload for secure transmission of the data.

Key Aspects from the Perspective of the CISA Exam

The following table covers the key aspects from the perspective of the CISA exam:

CISA Questions	Possible Answers
What is the most prevalent risk of a virtual private network?	The entry of malicious code into the network
Which is the most secure and cost-effective method for remote access?	A VPN

Table 10.8: Key aspects from the CISA exam perspective

Voice over Internet Protocol (VoIP)

VoIP is the transmission of voice and other content over IP networks. It is also known as IP telephony or internet telephony. It is made possible by digitalizing sounds into IP packets and transmitting them through a network layer where they are again decoded to sound. VoIP is a cost-effective solution for

long-distance calls. VoIP can be operated from IP infrastructure and very little additional telephony infrastructure is required.

A CISA aspirant is required to understand the following aspects of VoIP:

- It is very important to consider a backup arrangement for a VoIP system as data traffic normally has less reliability. A backup arrangement is required to ensure that communication is not interrupted in case of an undesirable event impacting the network service.
- Bandwidth capacity should be determined for voice traffic to ensure the quality of the service.
- VoIP infrastructure should be designed in consideration of laws and regulations, as certain countries have banned the use of VoIP. The risk of transmitting sensitive PII data through VoIP should also be considered. SMS messages may be in breach of certain regulations, such as HIPAA or PCI requirements.
- Traditional telephone lines are considered more secure than internet-based VoIP. IP packets may not be as secure as the physical wire security of traditional phone lines.

In the absence of effective security controls, a VoIP environment is subject to the following:

- The theft of data
- The loss of productivity due to the unavailability of the infrastructure
- Fines and penalties as a result of using corporate VoIP for unlawful activity
- Security breaches

VoIP infrastructure should have the following levels of control:

- Firewall arrangements for network traffic
- Data encryption
- Updated patches and antivirus for VoIP infrastructure
- Need-to-know access
- The use of VLAN to segregate VoIP from telephone systems and the implementation of firewalls between these two types of infrastructure
- The use of session border controllers (SBCs) to provide security to VoIP traffic, monitor DoS attacks, and provide network address and protocol translation features

A **distributed denial-of-service (DDoS)** attack aims to bring down the VoIP infrastructure of an organization. If an organization does not have a backup arrangement, this can have a severe impact. A DDoS attack can disrupt an organization's ability to communicate internally as well as externally.

A session border controller is deployed to protect VoIP networks. The aims of session border controllers are the following:

- Protect the session from malicious attacks, such as a denial-of-service attack (DoS) or DDoS
- Prevent toll fraud or premium rate fraud
- Encrypt signals
- Provide quality of service

VoIP toll fraud, or premium rate fraud, refers to a situation where an intruder hacks the VoIP system and takes over part of a VoIP phone network to use it for their own calls.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the CISA exam perspective:

CISA Questions	Possible Answers
Which is the best method to ensure the security and reliability of Voice over Internet Protocol (VoIP) and data traffic?	Segregation of VoIP infrastructure using VLAN
How can data traffic over VoIP be eavesdropped?	If the Address Resolution Protocol is corrupted
What is the primary requirement while considering a VoIP service?	Reliability and quality of VoIP service
Which is the most appropriate access control for the VoIP system?	Role-based access control
What is the objective of the session border controller?	The objectives of the session border controller are as follows: To protect the session from malicious attacks such as a denial-of-service (DoS) attack or distributed DoS. To prevent toll fraud or premium fraud The encryption of signals To provide quality of service

CISA Questions	Possible Answers
What is toll fraud?	VoIP toll fraud or premium rate fraud refers to a situation where an intruder hacks the VoIP system and takes over part of a VoIP phone. Generally it is used to make international/ high volume calls.

Table 10.9: Key aspects from the CISA exam perspective

Wireless Networks

A network connection not involving the use of a cable or wire is known as a wireless network. A wireless network is a computer network that uses wireless data connections between communication endpoints (nodes). Cell phone networks and wireless local area networks are examples of wireless networks.

CISA aspirants should be aware of the following controls regarding the protection of wireless (Wi-Fi) security:

- Enabling MAC filtering
- Enabling encryption
- Disabling SSID
- Disabling DHCP

Enabling MAC Filtering

Each system/PC/laptop/mobile has a unique identification number, which is known as the MAC address. This control allows access to only selected and authorized devices. Hence, the router restricts other unauthorized devices from accessing the network. Blacklist features can be used to specifically reject some MAC addresses.

A router has the option to enable MAC filtering, as indicated in the following screenshot:



The screenshot shows a web interface for MAC Filtering. The title is "MAC Filtering". Under the "Filter:" section, there are two radio buttons: "Allow only stations in list" and "Block all stations in list". The "Block all stations in list" option is selected and highlighted with a red rectangle. Below this is a "Stations List" section with an empty list box and a "Remove" button. At the bottom, there is a "MAC Address:" label followed by six input fields separated by colons, and an "Add" button.

Figure 10.7: MAC filtering

Thus, an organization can either allow only specific devices to be connected and block all other devices, or it can block specific devices and allow all other devices.

Enabling Encryption

Encryption is the process of converting data into an unreadable form. The process of encryption helps to scramble the data we send through the wireless network into code. Encryption is an effective way of restricting intruders when it comes to accessing the wireless network. **Wi-Fi Protected Access (WPA)** and **Wired Equivalent Privacy (WEP)** are the two main types of encryption. WPA-2 is the strongest encryption standard for wireless connection. These encryption methods only protect data in transit and not data on the device.

Disabling a Service Set Identifier (SSID)

An SSID is the name of a wireless network broadcast by a router. When a wireless device searches the area for wireless networks, it will detect and display a list of all available SSIDs:

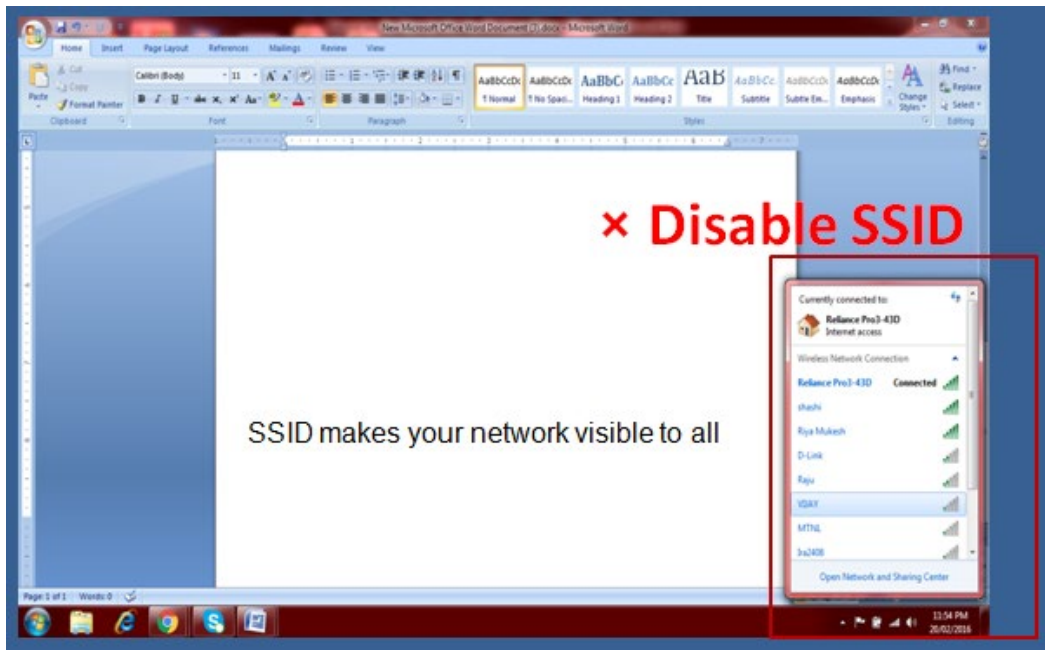


Figure 10.8: Disabling an SSID

Such open broadcasting is not required or necessary unless it is purposefully done to promote Wi-Fi, as in the case of a hotel, restaurant, lounge, mall, and so on.

Disabling DHCP

DHCP is a network management tool. It automatically assigns an IP address to each device connected to the network, which helps the devices communicate with other IP networks. If DHCP is disabled, then the IP address can be configured manually, that is, the static IP, and this helps to reduce the risk of unauthorized access.

Common Attack Methods and Techniques for a Wireless Network

The following are some common attack methods for wireless networks.

War Driving

War driving is a technique used by a hacker to search for wireless networks from a moving car or vehicle by using a laptop or other wireless devices with hacking tools or software. The same technique is used by IS auditors to test the wireless security of an organization.

War Walking

War walking is a similar process to war driving, where hackers search for wireless networks by walking with their devices instead of driving. This is commonly practiced in public areas, such as malls, hotels, and city streets.

War Chalking

War chalking is a technique of drawing a mark or symbol in a public area indicating the existence of an open wireless network. These symbols are subsequently used by others to exploit weak wireless networks.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What are the best practices for wireless security?	• Enabling MAC filtering • Enabling encryption • Disabling SSID • Disabling DHCP
Which encryption key provides the best security for data transmitted through a wireless network? (A dynamic or static key)	Dynamic (a dynamic key is changed frequently and hence is considered more secure than a static key)
Which technique is used by a hacker to search for wireless networks from a moving car or vehicle by using hacking tools and software? (The same technique is used by an IS auditor to test wireless security.)	War driving
Which is the strongest encryption standard for a wireless connection?	WPA-2 (Wi-Fi Protected Access)
Which protocol automatically assigns an IP address to each device connected to the network?	Dynamic Host Control Protocol
Why should DHCP be disabled?	DHCP automatically assigns an IP to each device. If DHCP is disabled, then the IP address needs to be configured manually – in other words, a static IP, and this helps to reduce the risk of unauthorized access.

CISA Questions	Possible Answers
Which encryption key is considered the most secure? (A MAC-based pre-shared key or a randomly generated PSK)	A randomly generated PSK is stronger than a MAC-based PSK (a MAC address of a computer is fixed and often accessible)

Table 10.10: Key aspects from the CISA exam perspective

Email Security

In this digital world, email is a widely used mode of official communication for both internal and external stakeholders. A lot of critical and sensitive information is shared through email. It is very important to secure email communication.

The following are some email-related risks and controls:

- Relying only on SMTP is not relatively secure as email security requires an end-to-end method, such as the use of digital signatures or the use of integrity checks at the transport level.
- Social engineering attacks such as phishing and spear phishing can be addressed through security awareness training of employees.
- Email attachments should be scanned by anti-malware software.
- Users should be trained on the security aspect of using email.
- Mail servers should be properly hardened and configured as per the organization's security policy and guidelines.
- The implementation of encryption technologies to protect user authentication and mail data should be considered.
- Digital signatures should be used to authenticate users in an untrusted network environment. Digital signatures are a good method for securing email transmissions because they cannot be forged on account of being encrypted.
- The installation of firewalls, routers, and IDSs to protect the mail server should be considered.

Key Aspects from the CISA Exam Perspective

The following table covers the key aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the objective of web and email filtering tools?	To prevent viruses and spam
What is the best method for ensuring email authenticity?	A digital signature

Table 10.11: Key aspects from the CISA exam perspective

Summary

In this chapter, you learned about the identification of network-related risks and pertinent controls. You explored different components of the network, including repeaters, hubs, switches, routers, and firewalls. You also learned about the basic structure of OSI layers and network physical media.

The following are some important topics you covered in this chapter:

- Optical fiber is a thin and flexible piece of fiber made of glass or plastic. Fiber-optic cables are considered to be more secure than copper wire. Fiber optics is the preferred choice for managing long-distance networks and handling high volumes of data. They are not impacted or affected by EMI and have very marginal transmission loss.
- The most stringent and robust configuration setting in firewall rules is “deny all traffic and allow specific traffic” (as opposed to “allow all traffic and deny specific traffic”). This restricts unknown traffic from entering critical systems and networks.
- A screened subnet firewall (demilitarized zone) is regarded as the most secure type of firewall implementation. A screened subnet firewall consists of two packet filtering routers and one bastion host. It provides the greatest security environment. A screened subnet firewall is also used as a demilitarized zone (DMZ).
- A VPN uses data encapsulation or the tunneling method to encrypt the traffic payload for secure transmission of data. A VPN uses the IPSec tunnel mode or the IPSec transport mode. The IPSec tunnel mode is used to encrypt the entire packet, including the header, while the IPSec transport mode is used to encrypt only the data portion of the packet.

-
- A digital signature helps to authenticate users in an untrusted network environment. Digital signatures are a good method of securing email transmissions because they cannot be forged as they are encrypted. A digital signature is used to track the sender and helps to detect spam messages.
 - War driving is a technique used by a hacker to search for wireless networks from a moving car or vehicle using a laptop or other wireless devices with hacking tools or software. The same technique is used by IS auditors to test the wireless security of an organization.

In the next chapter, you will study cryptography and other emerging technologies, such as cloud computing, mobile computing, virtualization, and the Internet of Things. In cryptography, you will explore the elements of public key infrastructure and the functions of symmetric as well as asymmetric keys.

Chapter Review Questions

Before you proceed to *Chapter 11, Public Key Cryptography and Other Emerging Technologies*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

Dashboard > Set 1 (Network and Endpoint Devices)

Question 1 of 41

1%

Time Left:
65 mins 56 secs

END QUIZ

An IS auditor is reviewing the implementation of network security. Which of the following is regarded as the most secure transmission medium?

☐ Fiber optic wires

☐ A UTP

☐ A twisted-pair wire

☐ A copper wire

NEXT

Don't Know

Feedback

Figure 10.9: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/EdgUf`. You will see the following screen:

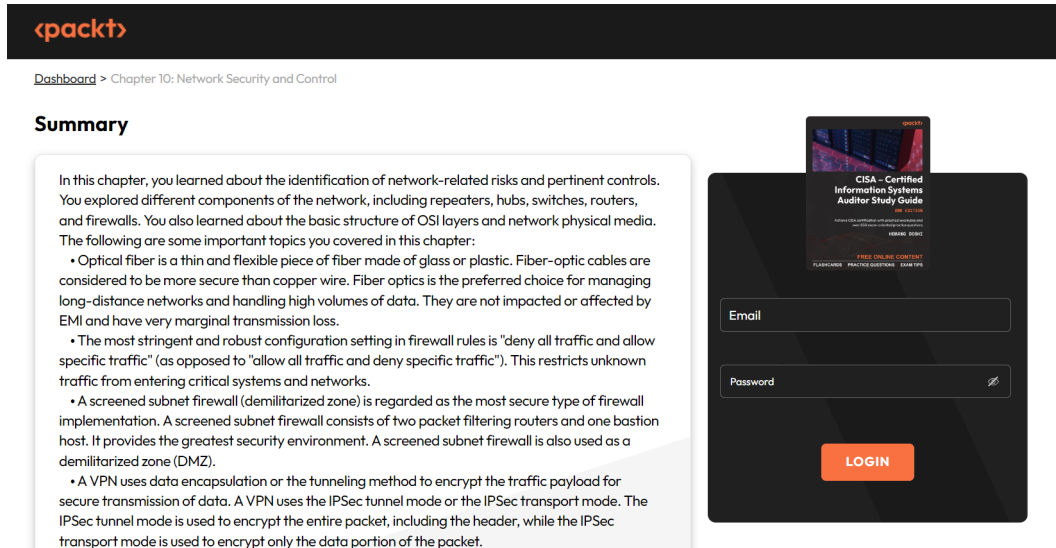


Figure 10.10: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 10.11: QR code to access *Chapter 10* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

[Dashboard](#) > Chapter 10: Network Security and Control

Chapter 10: Network Security and Control

Summary

In this chapter, you learned about the identification of network-related risks and pertinent controls. You explored different components of the network, including repeaters, hubs, switches, routers, and firewalls. You also learned about the basic structure of OSI layers and network physical media. The following are some important topics you covered in this chapter:

- Optical fiber is a thin and flexible piece of fiber made of glass or plastic. Fiber-optic cables are considered to be more secure than copper wire. Fiber optics is the preferred choice for managing long-distance networks and handling high volumes of data. They are not impacted or affected by EMI and have very marginal transmission loss.
- The most stringent and robust configuration setting in firewall rules is "deny all traffic and allow specific traffic" (as opposed to "allow all traffic and deny specific traffic"). This restricts unknown traffic from entering critical systems and networks.
- A screened subnet firewall (demilitarized zone) is regarded as the most secure type of firewall implementation. A screened subnet firewall consists of two packet filtering routers and one bastion host. It provides the greatest security environment. A screened subnet firewall is also used as a demilitarized zone (DMZ).

Chapter 10 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (41 Questions)

START

Set 2 (14 Questions)

START

Set 3 (10 Questions)

START

Figure 10.12: Chapter summary and end-of-chapter question sets

3. Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

[Dashboard](#) > Set 1 (Network and Endpoint Devices)

Question 1 of 41

1%

 Time Left:

65 mins 56 secs

END QUIZ

An IS auditor is reviewing the implementation of network security. Which of the following is regarded as the most secure transmission medium?

☐ Fiber optic wires

☐ A UTP

☐ A twisted-pair wire

☐ A copper wire

NEXT

[Don't Know](#)

Feedback



Figure 10.13: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Public Key Cryptography and Other Emerging Technologies

This chapter will concentrate on public key cryptography and other important aspects of information asset security and control. An IS auditor is required to have a thorough understanding of the elements of **Public Key Infrastructure (PKI)**. They should also have the ability to evaluate the functioning of public key cryptography and other technologies.

The following topics will be covered in the chapter:

- Public key cryptography
- Elements of PKI
- Cloud computing
- Virtualization
- Mobile computing
- **Internet of Things (IoT)**

By the end of the chapter, you will understand and be able to evaluate various aspects of PKI and other technologies.

Public Key Cryptography

Public key cryptography primarily comprises two processes: encryption and decryption. Encryption is the process of converting data into unreadable code so it cannot be accessed or read by any unauthorized person. This unreadable data can again be converted into a readable form by the process of decryption. Different types of algorithms are available for encryption and decryption. This section will explain the various aspects of public key cryptography.

First, you need to understand the concept of symmetric and asymmetric encryption and the difference between the two.

Symmetric Encryption versus Asymmetric Encryption

Encryption can be of two types: symmetric encryption or asymmetric encryption. The following table will help you understand the differences between the two terms:

Symmetric Encryption	Asymmetric Encryption
A single key is used to encrypt and decrypt the messages.	Two keys are used: one for encryption and another for decryption.
The key is said to be symmetric because the encryption key is the same as the decryption key.	Messages encrypted by a private key can be decrypted only by the corresponding public key. Similarly, messages encrypted by the public key can be decrypted only by the corresponding private key.
Comparatively faster computation and processing.	Comparatively slower computation and processing.
Comparatively, the symmetric encryption process is cheaper.	Comparatively, the asymmetric encryption process is costlier.
A major disadvantage of the symmetric encryption process is sharing of the key with other parties.	No such risk is faced in asymmetric encryption as two separate keys are used.
Example: AES (Advanced Encryption Standard) DES (Data Encryption Standard) 3DES (Triple Data Encryption Standard) Blowfish	Example: RSA (Rivest-Shamir-Adleman) DSA (Digital Signature Algorithm) ECC (Elliptic Curve Cryptography) ElGamal

Table 11.1: Differences between symmetric and asymmetric encryption

A major challenge in symmetric encryption is the exchange of keys as both the sender and receiver use the same key.

Encryption Keys

In an asymmetric environment, a total of four keys are available with different functions.

The following table indicates who possesses the different keys:

Type of Key	Availability
Sender's private key	The key is available only to the sender.
Sender's public key	The key is available in the public domain. The public key can be accessed by anyone.
Receiver's private key	The key is available only to the receiver.
Receiver's public key	The key is available in the public domain. The public key can be accessed by anyone.

Table 11.2: Different encryption keys and their availability

The keys discussed here are used to achieve the following objectives:

- Confidentiality
- Authentication and non-repudiation
- Integrity

Confidentiality

In asymmetric encryption, two keys are used—one for encryption and the other for decryption. Messages encrypted by one key can be decrypted by the other key. These two keys are known as private and public keys. The private key is available only to the owner of the key and the public key is available in the public domain.

Messages can be encrypted by the following means:

- **Receiver's public key:** If a message is encrypted using the public key of the receiver, then only the receiver can decrypt it as they are the only one with access to their private key. This will ensure message confidentiality as only the owner of the private key can read the message.
- **Receiver's private key:** The sender will not be in possession of the receiver's private key and hence this option is not feasible.

- **Sender's public key:** If a message is encrypted using the public key of the sender, then it can be decrypted only by using the private key of the sender. The receiver will not be in possession of the sender's private key and hence this option is not feasible.
- **Sender's private key:** If a message is encrypted using the private key of the sender, then anyone with a public key can decrypt it. The public key is available in the public domain and hence anyone can decrypt the message. This will not ensure the confidentiality of the message.

Hence, for message confidentiality, the receiver's public key is used to encrypt the message and the receiver's private key is used to decrypt the message.

Authentication

Authentication is ensured by verifying and validating some unique features of the sender. Generally, a document is validated by verifying the signature of the sender. This signature is unique for everyone. Similarly, for digital transactions, the private key is unique for each owner. Only the owner is in possession of their unique private key and no one else.

Each private key has a corresponding public key. A third person can authenticate the identity of the owner with the use of a public key. When the objective is to authenticate the sender of the message, the sender's private key is used to encrypt the hash of the message. The receiver will try to decrypt it with the use of the sender's public key, and if it is successfully decrypted, it indicates that the message is genuine, and the sender is authenticated.

Hence, for the authentication of the message, the sender's private key is used to encrypt the message and the sender's public key is used to decrypt the message.

Non-Repudiation

Non-repudiation refers to a situation wherein the sender cannot take back their responsibility for the digital message or transaction. Non-repudiation is established once the sender is authenticated. Hence, for non-repudiation, the same concept of authentication will apply.

Therefore, for the non-repudiation of the message, the sender's private key is used to encrypt the message and the sender's public key is used to decrypt the message.

Integrity

Integrity refers to the correctness, completeness, and accuracy of the data. The same concepts of authentication and non-repudiation apply to integrity. That is, to ensure the integrity of the message, the sender's private key is used to encrypt the message and the sender's public key is used to decrypt the message.

The following table will help you understand the use of different keys to achieve each of the preceding objectives:

Objective	Key Used	What to Encrypt
Confidentiality	Receiver's public key	Full message
Authentication/non-repudiation	Sender's private key	Hash of the message
Integrity	Sender's private key	Hash of the message
Confidentiality and authentication/ non- repudiation	For confidentiality: Use of the receiver's public key to encrypt the full message For authentication (non-repudiation): Use of the sender's private key to encrypt the hash of the message	
Confidentiality, integrity, and authentication/non-repudiation	For confidentiality: Use of the receiver's public key to encrypt the full message For integrity, authentication (non-repudiation): Use of the sender's private key to encrypt the hash of the message	

Table 11.3: The uses of different encryption keys and their objectives

The Hash of the Message

A hash value is a digital code of the message content. Some important features and functionality of the hash value are as follows:

- It is arrived at by using an algorithm.
- A hash value is also known as a message digest.
- The hash value is unique for each message.
- A slight change in the message/content will produce a different hash value.
- A hash value is used to ensure the integrity of the message/content.

A hash value is used to create a digital signature. A hash value, when encrypted with the sender's private key, becomes a digital signature. A digital signature is used to determine the integrity of a message and the authentication of the sender (that is, non-repudiation).

Combining Symmetric and Asymmetric Methods

The most efficient use of PKI is to combine the best features of asymmetric and symmetric methods. The challenge of asymmetric encryption is that it is an expensive and time-consuming process. Though symmetric encryption is comparatively much faster, it possesses risk as the symmetric key is shared with other parties. To combine the benefits of both and address their challenges, the following process is recommended:

1. For faster and inexpensive computation, encrypt the entire message with the help of a symmetric key.
2. Encrypt the symmetric key with the public key of the receiver.
3. Send the encrypted message (step 1) and the encrypted symmetric key (step 2) to the receiver.
4. The receiver will decrypt the symmetric key using their private key.
5. The receiver will use a symmetric key to decrypt the full message.

Thus, when a combined method is used, the symmetric key encrypts the full message and the receiver's public key encrypts the symmetric key.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
How can message confidentiality be ensured in asymmetric encryption?	Through the use of the receiver's public key for encryption and use of the receiver's private key for decryption
How can message authentication be ensured in asymmetric encryption?	Through the use of the sender's private key to encrypt the message/hash and the use of the sender's public key to decrypt the message/hash
How can message non-repudiation be ensured in asymmetric encryption?	Through the use of the sender's private key to encrypt the message/hash and the use of the sender's public key to decrypt the message/hash
How can message integrity be ensured in asymmetric encryption?	Through the use of the sender's private key to encrypt the hash and the use of the sender's public key to decrypt the hash

CISA Questions	Possible Answers
What increases the cost of cryptography?	Long asymmetric keys
How can symmetric and asymmetric methods be combined for strong encryption at the optimum cost?	Through the use of the symmetric key to encrypt the full message Through the use of the receiver's public key to encrypt the symmetric key

Table 11.4: Key aspects from the CISA exam perspective

Elements of PKI

PKI is a set of rules and procedures for the creation, management, distribution, storage, and use of digital certificates and public key encryption.

PKI Terminology

Before moving on to discuss the elements of PKI, you should have a basic understanding of the following associated terms:

- **Digital certificate:** A digital certificate is an electronic document used to prove the ownership of a public key. A digital certificate includes information about the key, the owner of the key, and the digital signature of the issuer of the digital certificate. It is also known as a public key certificate.
- **Certifying Authority (CA):** A CA is an entity that issues digital certificates.
- **Registration Authority (RA):** An RA is an entity that verifies user requests for digital signatures and recommends the CA issues them.
- **Certificate Revocation List (CRL):** A CRL is a list of digital certificates that have been revoked and terminated by the CA before their expiry date, and these certificates should no longer be trusted.
- **Certification Practice Statement (CPS):** A CPS is a document that prescribes practices and processes for the issuing and management of digital certificates by the CA. It includes details such as the controls that should be in place, the method for validating applicants, and the usage of certificates.
- **Public Key Infrastructure:** PKI is a set of roles, policies, and procedures for the issuance, maintenance, and revocation of public key certificates.

Processes Involved in PKI

The issuance of a public key involves the following different steps:

1. The applicant applies for a digital certificate to be issued by the CA.
2. The CA delegates the verification process to the RA.
3. The RA verifies the correctness of the information provided by the applicant.
4. If the information is correct, the RA recommends that the CA issue the certificate.

The CA issues the certificate and manages it through its life cycle. It also maintains the details of certificates that have been terminated or revoked before their expiry date. This list is known as the CRL. The CA also maintains a document called a **CPS** containing the **Standard Operating Procedure (SOP)** for the issuance and management of a certificate.

Certifying Authority versus Registration Authority

You can differentiate between the CA and RA with the help of the following:

Certifying Authority	Registration Authority
The CA is responsible for the issuance and management of digital certificates.	The RA is delegated with the function of verifying the correctness of the information provided by applicants.
The CA delegates some of the administrative functions, such as the verification of information provided by applicants.	After authentication of the information, the RA recommends the CA issues the certificate.
The CA authenticates and validates the holder of the certificate after issuance of the certificate.	The RA authenticates the information of the applicant before issuance of the certificate.

Table 11.5: The differences between CA and RA

An RA has the following functions:

- To verify and validate the information provided by the applicant.
- To verify that the applicant is in possession of a private key and that it matches the public key requested for a certificate. This is known as **Proof of Possession (POP)**.
- To distribute physical tokens containing private keys.
- To generate shared secret keys during the initialization and certificate pickup phase of registration.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
Which authority manages the life cycle of digital certificates?	Certifying authority.
What are the functions of a registration authority?	To verify and validate the information provided by the applicant. To verify that the applicant is in possession of the private key and it matches the public key requested for a certificate. This is known as Proof of Possession (POP). To distribute physical tokens containing private keys. To generate shared secret keys during the initialization and certificate pick-up phase of registration.
What is the name of the procedural document that details how to deal with compromised private keys?	Certification practice statement

Table 11.6: Key aspects from the CISA exam perspective

Cloud Computing

Cloud computing is the practice of using remote servers hosted on the internet to store, manage, and process data instead of a local server or a personal computer. Cloud computing simply means the use of computing resources through networks, typically the internet.

With cloud computing, users can access computing resources via the internet from anywhere, for as long as they need, without worrying about the maintenance or management of actual resources.

The following are some characteristics of cloud computing:

- It enables organizations to access data or applications from anywhere, anytime, and from almost any device.
- It allows organizations to scale IT resources as per business requirements at the optimum cost.
- It provides the capability to monitor, control, and report the usage of the resources.

Resources such as storage, processing power, memory, network bandwidth, and **Virtual Machines (VMs)** can be used through cloud computing.

Cloud Computing – Deployment Models

The following are some important details of the deployment models used in cloud computing.

The Private Cloud

A private cloud is used for the exclusive benefit of an organization. It is considered the most secure type of deployment as it is controlled and centralized by the organization. A cloud server is deployed either on-premises or off-premises.

The Public Cloud

The public cloud is open to all on a pay-per-use basis. It is considered highly scalable as services can be reduced or increased as per the client's requirements.

It is very important to consider the following requirements for the use of the public cloud:

- Legal and regulatory compliance (such as data localization)
- Backup
- Right to audit
- Security requirements

The Community Cloud

Cloud services are used by specific communities of consumers who have shared concerns. They can be managed by the organization or a third party. Data may be stored with the data of a competitor.

The Hybrid Cloud

The hybrid cloud is a combination of two or more types of models, that is, private, community, or public. An organization initially uses the private cloud and then, for additional requirements, the community or public cloud is used.

It makes cloud storage complex as more than one model is used.

Types of Cloud Services

Cloud services can be broadly categorized into three types: Infrastructure as a Service (IaaS), Platform as a Service (PaaS), and Software as a Service (SaaS).

IaaS: Infrastructure as a Service is a cloud computing model where users can access computing infrastructure, including servers, storage, and networking resources over the internet. With IaaS, users are responsible for managing their own operating systems, applications, and data. Examples of IaaS providers are Amazon Web Services (AWS), Microsoft Azure, and Google Cloud Platform.

PaaS: Platform as a Service is a cloud computing model where users can develop, run, and manage their own applications on a cloud platform provided by the service provider. PaaS providers offer a platform for building, testing, and deploying applications, and they are the ones who manage the underlying infrastructure, including the operating system, servers, and storage. Some examples of PaaS providers include Google App Engine, and Microsoft Azure App Service.

SaaS: Software as a Service is a cloud computing model in which users can access software applications over the internet without having to install or maintain the software on their own devices. Similar to PaaS, with SaaS also the service provider is responsible for managing the entire software application, including the infrastructure, security, and maintenance. Some SaaS providers are Google Docs, Google Sheets, Zoom, and Google Meet.

Each type of cloud service offers different benefits to users and caters to their different needs. IaaS provides flexibility and control; PaaS allows developers to focus on building applications without worrying about infrastructure, and SaaS offers the convenience of accessing software applications without having to manage the underlying infrastructure.

Cloud Computing – the IS Auditor’s Role

An IS auditor should consider the following risks and security controls for a cloud arrangement:

- Ensure compliance with relevant laws, regulations, and standards.
- Ensure compliance with privacy laws that restrict the movement of personal data to an offshore location.
- Ensure the availability of information systems and data on a continuous basis and evaluate the business continuity and disaster recovery plan of the cloud service provider.
- Ensure the integrity and confidentiality of information and sensitive data while stored and in transit.
- Ensure that the SLA includes clauses with respect to data ownership, data custody, and security administration related to cloud deployment models.
- Ensure the inclusion of the right-to-audit clause in the SLA.

Virtualization

Virtualization makes it possible to run multiple operating systems simultaneously on a single computer. It refers to the act of creating a virtual (rather than an actual) version of system-related hardware. With the use of virtualization, organizations can increase efficiency and reduce the cost of IT operations. Virtual resources such as the server, desktop, operating system, storage, and networks can be created with the help of virtualization tools.

Some important terms for virtualization are as follows:

- **Hypervisor:** Software or hardware used to create virtual resources.
This is the most important element of virtualization as it aids in the creation of virtual resources.
- **Host:** The original computer.
- **Guest:** Virtual resources created by a hypervisor.

The following are some of the risks of virtualization:

- The improper configuration of hypervisors may allow unauthorized access to guests.
- Attackers may be able to gain unauthorized access with the help of mechanisms called guest tools. A guest operating system is an operating system installed on a VM. It is usually different from the host operating system.
- Poor control of access to hypervisors.
- An attack on the host may impact all the guests as well.
- Performance issues with the host may impact all the guests as well.
- There is a risk of data leakage between guests if there is poor control of memory release and allocation.

The following are some important control requirements for a virtualized environment:

- Strong access control for the hypervisor dashboard and services
- The proper hardening of hypervisors and the guest operating system by disabling unused features and ports
- Encrypted hypervisor management communications
- Regular patch updates for the hypervisor
- The synchronization of the host as well as the guest to a trusted time server
- The disabling of hypervisor services such as file sharing between the host and the guest (if not used)

- The capturing of logs and proper monitoring of security events for hosts as well as guests
- File integrity monitoring of the hypervisor to monitor for signs of compromise

Mobile Computing

Mobile computing is the use of devices that do not require a physical connection to process, transfer, or store data.

Examples of mobile devices include smartphones, laptops, USB storage devices, digital cameras, and other similar technologies.

The following are some of the controls to reduce the risks related to mobile computing:

- **Mobile Device Management (MDM)** solutions should be used.
- Only data and applications that are absolutely necessary for processing should be stored on the device.
- Data stored on mobile devices should be backed up regularly to the organization's server.
- All mobile computing devices should be registered for tracking and monitoring control.
- Mobile devices that are stationed at a location should be physically locked.

All mobile devices should be installed with anti-malware software.

Strong encryption mechanisms should be used for data stored on mobile devices.

Access control should be enabled for mobile devices. Two-factor authentication can be used to further enhance security.

Organizations should have documented policies that restrict the usage of devices to official and approved purposes only.

Any loss or theft of a mobile device must be treated as a security breach and reported immediately in accordance with security management policies and procedures.

Mobile devices should be allowed to connect to the organization's network through some secure channel, such as a VPN.

Some MDM solutions provide remote wipe and lock features in case a mobile device is lost or stolen. These features help to protect confidential data on lost mobile devices and should be utilized.

It should be ensured that the MDM includes the tracking of a wide variety of devices and captures all access and activity logs.

Internet of Things (IoT)

IoT is a concept wherein devices have the ability to communicate and transfer data with each other without any human interference. IoT is an emerging concept and is being gradually adopted by organizations.

Although a specific risk of IoT depends on how it is used, an IS auditor should consider the following risks with respect to IoT:

- The impact of IoT on the health and safety of human life
- Regulatory compliance with respect to the use of IoT
- The impact of IoT on user privacy
- The impact of IoT on device vulnerabilities

Summary

In this chapter, you learned about relevant skills to conduct audits in accordance with IS audit standards and a risk-based IS audit strategy and to evaluate potential opportunities and threats associated with emerging technologies, regulations, and industry practices.

The following is a recap of some important topics covered in this chapter:

- In asymmetric encryption, two keys are used—one for encryption and the other for decryption. Messages encrypted by one key can be decrypted by another key. These two keys are known as private keys and public keys. A private key is available only to the owner of the key and a public key is available in the public domain.
- A certifying authority is an entity that issues digital certificates. It is responsible for the issuance and management of digital certificates.
- IoT is a concept wherein devices have the ability to communicate and transfer data with each other without any human interference.
- Mobile computing is the use of devices that do not require a physical connection to process, transfer, or store data. Examples of mobile devices include smartphones, laptops, USB storage devices, and digital cameras.

The next chapter will discuss various security testing and monitoring tools and techniques. You will also learn about different kinds of attacks and how to prevent them.

Chapter Review Questions

Before you proceed to *Chapter 12, Security Event Management*, it is recommended that you solve the practice questions from this chapter first. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

[Dashboard](#) > [Set 1 \(Network and Endpoint Devices\)](#)

Question 1 of 41

1%

 **Time Left:**

65 mins 56 secs

END QUIZ

An IS auditor is reviewing the implementation of network security. Which of the following is regarded as the most secure transmission medium?

☐ Fiber optic wires

☐ A UTP

☐ A twisted-pair wire

☐ A copper wire

NEXT

[Don't Know](#)

Feedback



Figure 11.1: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/Ud7jH`. You will see the following screen:

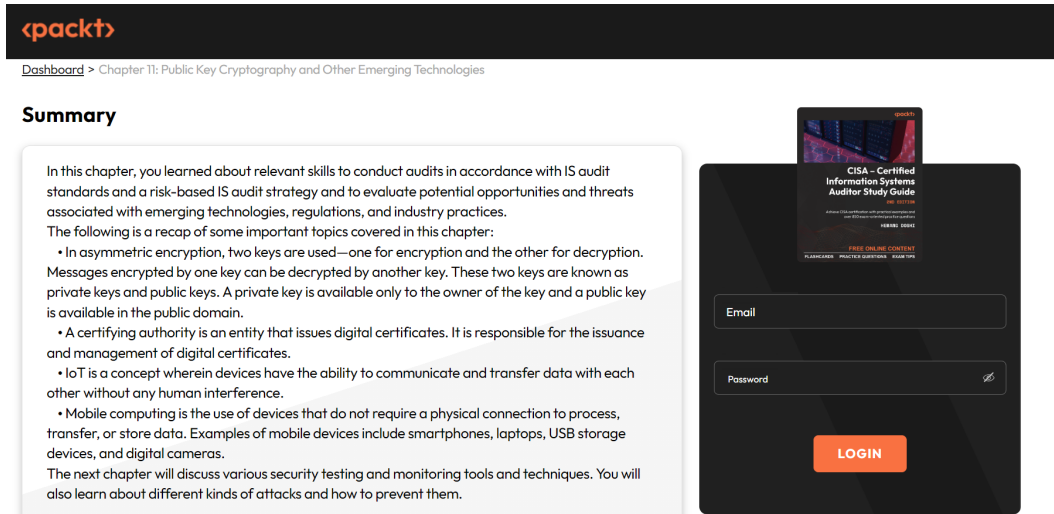


Figure 11.2: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 11.3: QR code to access *Chapter 11* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

Chapter 11: Public Key Cryptography and Other Emerging Technologies

Summary

In this chapter, you learned about relevant skills to conduct audits in accordance with IS audit standards and a risk-based IS audit strategy and to evaluate potential opportunities and threats associated with emerging technologies, regulations, and industry practices.

The following is a recap of some important topics covered in this chapter:

- In asymmetric encryption, two keys are used—one for encryption and the other for decryption. Messages encrypted by one key can be decrypted by another key. These two keys are known as private keys and public keys. A private key is available only to the owner of the key and a public key is available in the public domain.
 - A certifying authority is an entity that issues digital certificates. It is responsible for the issuance and management of digital certificates.
 - IoT is a concept wherein devices have the ability to communicate and transfer data with each other without any human interference.
 - Mobile computing is the use of devices that do not require a physical connection to process, transfer, or store data. Examples of mobile devices include smartphones, laptops, USB storage devices, and digital cameras.
- The next chapter will discuss various security testing and monitoring tools and techniques. You will also learn about different kinds of attacks and how to prevent them.

Chapter 11 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (12 Questions)

START

Set 2 (14 Questions)

START

Figure 11.4: Chapter summary and end-of-chapter question sets

3. Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

Dashboard > Set 1 (Network and Endpoint Devices)

Question 1 of 41

1%

🕒 Time Left:

65 mins 56 secs

END QUIZ

An IS auditor is reviewing the implementation of network security. Which of the following is regarded as the most secure transmission medium?

☐ Fiber optic wires

☐ A UTP

☐ A twisted-pair wire

☐ A copper wire

NEXT

[Don't Know](#)

Feedback

Figure 11.5: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Security Event Management

Security assessment is the process of identifying, implementing, and managing various security tools and techniques. This chapter will help you evaluate the organization's information security policies and practices and determine the risks associated with the **Information Systems (IS)** by understanding different attack methods and techniques.

The following topics will be covered in this chapter:

- Security awareness training and programs
- Information system attack methods and techniques
- Security testing tools and techniques
- Security monitoring tools and techniques
- Incident response management
- Evidence collection and forensics

Security Awareness Training and Programs

Automated controls alone cannot prevent or detect security incidents. Knowledge, experience, and awareness on the part of employees play a key role in mitigating information security risks. Security awareness programs are crucial in IT risk management.

Employees should be educated about various aspects of security events to minimize their impact. Security awareness programs should include the dos and don'ts regarding password frameworks, email usage, internet usage, social engineering, and other relevant factors.

Participants

Security awareness training should be provided to all employees and contractual staff irrespective of their job functions, designations, or authority. All employees within the organization should be aware of security requirements.

For job functions where critical data is processed or critical assets are handled, enhanced training should be provided. OS configuration, programmers, network engineers, job schedulers, and other critical functions should be provided with information security training at regular intervals.

Security Awareness Methods

Security awareness can be imparted to employees and contractual staff in the following ways:

- Workshop and training programs
- Security tips via email
- Documented security policies and procedures
- NDAs with employees and third-party vendors
- Awareness through newsletters, posters, screensavers, and so on
- Documented security roles and responsibilities
- Simulated drills and security scenarios

Social Engineering Attacks

In a social engineering attack, an intruder attempts to obtain sensitive information from users by using their social and psychological skills. They attempt to manipulate individuals into divulging confidential information such as passwords. This kind of attack can best be restricted and addressed by educating users through frequent security awareness training.

Evaluating the Effectiveness of Security Programs

It is important for an IS auditor to evaluate the effectiveness of various security programs. Discussions with employees will help an IS auditor to understand the state of awareness of information security requirements. Overall, security depends on the knowledge that employees in the field have. For instance, an increase in valid incident reporting indicates that employees are aware of the importance of security and are proactively following the incident reporting procedure.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects of security from the CISA exam perspective:

CISA Questions	Possible Answers
Which technique is used to obtain passwords without technical tools or programs?	Social engineering
What is the most effective way to minimize the impact of social engineering attacks?	Security awareness training
The risk of a phishing attack can be best addressed by:	User education

Table 12.1: Key aspects from the CISA exam perspective

Information System Attack Methods and Techniques

An IS auditor should be aware of the following methods and techniques in relation to IS attacks:

- **Alteration attack:** In this type of attack, the data or code is altered or modified without authorization. Cryptographic code is used to prevent alteration attacks.
- **Botnets:** Botnets are compromised computers and are also known as zombie computers. They are primarily used to run malicious software for DDoS attacks, adware, or spam.
- **Buffer overflow:** A buffer overflow, or buffer overrun, is a common software coding mistake that an attacker could exploit in order to gain access to the system. This error occurs when there is more data in a buffer than it can handle, causing the data to overflow into adjacent storage. Due to this, an attacker gets an opportunity to manipulate the coding errors for malicious actions. A major cause of buffer overflow is poor programming and coding practices.
- **Denial-of-Service attack (DoS):** A DoS attack intends to shut down a network or machine by flooding it with traffic. In a DoS attack, a single computer is used to flood a server with **transmission control protocol (TCP)** and **user datagram protocol (UDP)** packets. In a **Distributed Denial-of-Service (DDoS)** attack, multiple systems are used to flood the target system. The targeted network is bombarded with packets from multiple locations.
- **Data diddling:** Data diddling is a type of attack where information gets changed as it comes into a computer system. Most of the time, a data entry clerk or a computer virus does this. Data is altered before computer security can protect it. Data diddling requires very little technical knowledge. Apparently, there are no preventive controls for data diddling, so the organization needs to rely on compensatory controls.

- **Dumpster diving:** Dumpster diving is the technique of retrieving sensitive information from the trash or a garbage bin. To address the risk of dumpster diving, employees should be made aware of this kind of risk through frequent security awareness training. A document discarding policy should be in place and should define appropriate methods for discarding various pieces of information. One example is the use of a shredder to discard documents. The following diagram indicates how dumpster diving is performed:



Figure 12.1: Dumpster diving

Organizations should take the utmost care and avoid disposing of sensitive documents and other information in the garbage. For instance, confidential office documents should be mandatorily disposed of using paper shredder machines.

War dialing: War dialing is a technique in which tools are used to automatically scan a list of telephone numbers to determine the details of computers, modems, and other machines.

War driving: War driving is the technique of locating and getting access to wireless networks with the aid of specialized tools. An intruder drives or walks around the building while equipped with specialized tools to identify unsecured networks. The same technique is used by IS auditors to identify unsecured networks and thereby test the wireless security of an organization.

Eavesdropping: Eavesdropping is a process in which an intruder gathers information flowing through the network via unauthorized methods. Using a variety of tools and techniques, sensitive information, including email addresses, passwords, and even keystrokes, can be captured by intruders.

Email attacks and techniques: Here are a few types of email attacks and techniques:

- **Email bombing:** In this technique, attackers repeatedly send an identical email to a particular address.
- **Email spamming:** In this attack, unsolicited emails are sent to thousands of users.
- **Email spoofing:** In this attack, the email appears to originate from some other source and not the actual source. This is often an attempt to trick the user into disclosing sensitive information.

Juice jacking: In this type of attack, data is copied from a device attached to a charging port (mostly available in public places). Here, charging points act as data connections. This type of attack is also used to insert malware into the attached devices.

Interrupt attack: In this type of attack, the operating system is invoked to execute a particular task, thereby interrupting ongoing tasks.

- **Flooding:** This is a type of DoS attack that brings a network down by flooding it with a huge amount of traffic. The host's memory buffer cannot handle this huge volume of traffic.

Malicious Code

The following are some ways through which malicious actors use harmful programs to exploit systems:

- **Trojan horse:** In this attack, malicious software is disguised as legitimate software. Once installed, it starts taking control of the user's system.
- **Logic bomb:** A logic bomb is a program that is executed when a certain event happens. For example, a logic bomb can be set to delete files or databases at a future date.
- **Trapdoor:** This is also known as a backdoor attack. In this method, malware is placed inside the application. This malware is used to bypass normal security measures and gain unauthorized access to applications.
- **Man-in-the-middle attack:** In this attack, the attacker interferes while two devices are establishing a connection. Alternatively, the attacker actively establishes a connection between two devices and pretends to be each of them to the other device. If a device asks for authentication, it sends a request to the other device, and the response is then sent to the first device. Once a connection is established, the attacker can communicate and obtain information as desired.
- **Masquerading:** In this type of attack, an intruder hides their original identity, acting as someone else. This is done in order to access systems or data that are restricted. Impersonation can be implemented by both people and machines.
- **IP spoofing:** In IP spoofing, a forged IP address is used to break a firewall. IP spoofing can be regarded as the masquerading of a machine.

- **Message modification:** In this type of attack, a message is captured, altered, and deleted without authorization. These attacks can have a serious impact; for example, a fake message can be sent to a bank to make a payment, which may result in financial loss.
- **Network analysis:** In this type of attack, an intruder creates a repository of information pertaining to a particular organization's internal network, such as internal addresses, gateways, and firewalls. Intruders then determine what service and operating system are running on the targeted system and how it can be exploited.
- **Packet replay:** In this type of attack, an intruder captures data packets as data moves along a vulnerable network.
- **Pharming:** In this type of attack, website traffic is redirected to a bogus website. This is done by exploiting vulnerabilities in DNS servers. Pharming is a major concern for e-commerce websites and online banking websites.
- **Piggybacking:** In this type of attack, an intruder follows an authorized person through a secure door and is able to enter a restricted area without authentication. Piggybacking, also known as tailgating, is regarded as a physical security vulnerability.
- **Password sniffing:** A password sniffer is a small program that listens to all traffic in the attached network(s), builds data streams out of TCP/IP packets, and extracts usernames and passwords. These passwords are then used to gain unauthorized access to the system.
- **Parameter tampering:** The unauthorized modification of web application parameters with malicious intent is known as parameter tampering. As the hidden files on the web page are not visible, developers may feel safe passing data without proper validation. This creates a risk as an intruder may intercept the hidden data and may modify the parameter for malicious purposes.
- **Privilege escalation:** In a privilege escalation attack, high-level system authority is obtained by employees through some unauthorized methods by exploiting security flaws.
- **Race condition:** This is also known as **time-of-check to time-of-use (TOC/TOU)** attack. In this attack, intruders exploit a small window between the time when services are used and the time when security controls are applied. The greater the time gap between the time of use and the time of service, the greater the chances of race condition attacks.
- **Salami:** In this technique, a small amount of money is sliced from a computerized transaction and transferred to unauthorized accounts.
- **Social engineering:** In a social engineering attack, an attempt is made to obtain sensitive information from users by tricking and manipulating people. In this attack, the attacker does not require any technical tools and techniques to obtain information. Social engineering is generally conducted through dialogue, interviews, inquiries, and other social methods of interaction. The objective of social engineering is to exploit human nature and weakness in order to obtain critical and sensitive information. Adequate and effective security awareness training can help minimize the consequences of social engineering attacks.

- **Shoulder surfing:** In a shoulder surfing attack, an intruder or a camera captures sensitive information by looking over the shoulder of the user as they enter their details on their computer screen.

Passwords entered onto computers should be masked to prevent shoulder surfing attacks.

- **Traffic analysis:** In traffic analysis, communication patterns between entities are studied and information is deduced.
- **Virus:** A virus is a type of malicious code that can self-replicate and spread from one computer to another. A virus can take control of a user's computer and delete or alter sensitive files. It can also disrupt system functioning.
- **Worms:** Worms are destructive programs that can destroy sensitive data. However, worms do not replicate like viruses.

Biometric Attacks

The following are some attacks targeting biometric devices and systems:

- **Replay attack:** In a replay attack, an attacker makes use of residual biometric characteristics (such as fingerprints left on a biometric device) to obtain unauthorized access.
- **Brute-force attack:** In a brute-force attack, an attacker sends numerous biometric samples with the aim of causing the biometric device to malfunction.
- **Cryptographic attack:** In a cryptographic attack, an attacker attempts to obtain information by targeting algorithms or encrypted information that is transmitted between biometric devices and access control systems.
- **Mimic attack:** In a mimic attack, an attacker attempts to fake a biometric feature of a genuine biometric user.

Note

CISA aspirants should also understand the difference between active and passive attacks. Passive attacks are types of attacks in which only information is captured but not modified, inserted, or deleted. Examples of passive attacks include traffic analysis, network analysis, and eavesdropping. Active attacks attempt to alter system resources or affect their operations and involve some modification of the data stream or the creation of false statements.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
In which type of attack does internet traffic appear to originate from the internal IP of the organization?	IP spoofing
Which type of attack is caused by a hidden file on a web page?	Parameter tampering
In which kind of attack are no technical tools and techniques required to extract information?	Social engineering
What is the best way to reduce the risk of shoulder surfing?	Computer screens should be masked when entering passwords
What is an inherent risk of the data entry process for which there are no preventive controls?	Data diddling
What are some examples of passive attacks?	Traffic analysis, network analysis, eavesdropping
Which technique is used to test wireless security?	War driving
In which type of attack are computers used as zombie machines to perform DDOS, spam, or other kind of attacks?	Botnet
Which attack has the capability to circumvent two-factor authentication?	Man in the middle
What is the primary risk of poor programming and coding practices?	Buffer overflow
URL shortening services increase the risk of which attack?	Phishing

Table 12.2: Key aspects from the CISA exam perspective

Security Testing Tools and Techniques

An auditor should be aware of various security testing tools and techniques to determine the security environment of the organization. To evaluate the security risks and controls, an auditor should be well versed in auditing techniques.

General Security Controls

An IS auditor can adopt the following testing techniques for security controls.

Terminal Controls

The following are some important aspects of terminal controls:

- An auditor should obtain access cards and keys and attempt to enter a restricted area. This will ensure that access controls are effective and operational.
- An auditor should determine whether the terminal list has been updated and reconciled with addresses and locations. The IS auditor should select a few terminals and try to locate them in the network diagram.
- An auditor should verify whether any unsuccessful attempts to access the terminals are monitored at regular intervals and whether appropriate action is taken against violations of access rules.

Login IDs and Passwords

The following are some important aspects of login IDs and passwords:

- Auditors should ensure compliance with a clear desk and clear screen policy. Login IDs and passwords should not be openly available or written down somewhere for people to find.
- Auditors should use social engineering techniques to determine user awareness regarding password confidentiality.
- Auditors should also determine password complexity and password rules configured in the system, and they should be reconciled with the approved password policy of the organization. Auditors should also ensure that the vendor-provided default password is changed immediately.
- Passwords should be changed immediately when first logging on. Also, a procedure for mandatory password change at frequent intervals should be enforced for all users. Auditors should produce a password policy to determine the password change procedures.
- Auditors should determine whether the password table is in an encrypted form. To test this, the auditor should work with the system administrator and attempt to view the internal password table.
- Application logs should be verified to ensure that login IDs and passwords are not captured in a readable form.
- As an auditor, you should verify whether a given password is masked on the screen. It should not be visible.

Authorization Process

To review the authorization process, an access list should be obtained. Then, sample forms should be verified to ensure approval by the appropriate authority. Authorization should be provided on a need-to-know basis. Auditors should match the current roles of the employees vis-à-vis the access granted to them.

Automatic Logoff

Auditors should verify whether an automatic logoff procedure is enabled for unattended terminals. They should wait for the terminal to disconnect following the established period of inactivity.

Account Lockout

Auditors should verify whether an account lockout facility is enabled for unsuccessful access attempts. They should purposefully enter the wrong password a number of times. Accounts should be locked after a predefined number of unsuccessful attempts. Also, the auditor should verify the process of activating the account.

Controls on Bypassing Software and Utilities

Auditors should verify that system utility programs that can bypass normal login procedures are restricted and available on a need-to-know basis.

Essentially, auditors should determine control over the following programs that can bypass normal login procedures:

- **Bypass label processing (BLP):** BLP bypasses the reading of file labels by computer. This may impact access control as most of the access rules are based on file labels.
- **System exits:** These programs are used for the maintenance of the application. They generally exist outside of the computer security system and, thus, are not restricted or reported about in their usage.
- **Privileged login IDs:** These are generally administration IDs with unlimited access.

Log Capturing and Monitoring

To test the effectiveness of the log capturing and monitoring process, the IS auditor should select a sample of security reports and look for evidence of follow-up and investigation of access violations. It is important that logs should not be allowed to be edited, modified, or deleted in order to preserve their integrity.

Time Synchronization

It is important that all devices should have a common time. The objective of all computer clocks being synchronized to a common time network is to support incident investigation processes. If the timestamp is not the same on all devices, this will impact the investigation of any incident, and the audit trail may not be effective and reliable.

Network Penetration Tests

In penetration testing, the IS auditor uses the same techniques as used by hackers to gain access to critical systems/data. This helps the auditor determine the security environment of the organization. Penetration testing helps to identify the risk related to the confidentiality, integrity, and availability of ISs. The objective of penetration testing is to verify the control environment of the organization and to take corrective action in case a deficiency is noted. Penetration testing should only be performed by experienced and qualified professionals.

Aspects to be Covered within the Scope of the Audit

From an audit risk perspective, the following aspects need to be covered within the scope of auditing penetration testing:

- Precise details of IP addresses need to be included in the scope of the audit.
- Details of the testing technique (SQL injection/DoS/DDoS/social engineering, and so on) should be provided.
- The day and time of the attack (that is, either during office hours or after office hours) should be included.
- It is the responsibility of the penetration tester/auditor to provide an appropriate warning prior to the simulation to prevent false alarms from being raised with law enforcement bodies.

Types of Penetration Tests

The following are some of the penetration tests that can be used to evaluate the security environment of an organization.

External Testing

In external testing, an attack is conducted on the target's network perimeter from outside the target's system (that is usually the internet).

Internal Testing

In internal testing, an attack is conducted on the target from within the perimeter. This is done to determine the security risk if an actual attacker happened to come from within the organization.

Blind Testing

In a blind testing type of attack scenario, the tester is provided with limited or no knowledge of the target's ISs. Therefore, the tester is regarded as blind. Such a test is expensive because detailed analysis, study, and research is required for an attack.

Double-Blind Testing

Double-blind testing is the extension of blind testing wherein the administrator and security staff at the target organization are also unaware of the test. Both the tester and the security team are blind because no one is aware of the test details. It simulates a real attack. This helps to evaluate the incident handling and response capabilities of the target organization.

Targeted Testing

In targeted testing, both the target's IT team and penetration testers are aware of the testing scenarios. A penetration tester is aware of the target details and network structure.

Risks Associated with Penetration Testing

The following are some of the risks associated with penetration testing:

- A penetration testing attempt by an unqualified auditor may have an adverse impact on the target's system.
- Sensitive information relating to the target environment gathered during penetration testing can be misused by the tester.
- Inappropriate planning and timing of the attack may cause the system to fail.
- This is a simulation of a real attack and may be restricted by law or regulations. Such attacks without appropriate approval may have an adverse impact.

Threat Intelligence

Threat intelligence is intelligent information about likely attacks on the basis of an analysis of current trends. This information is organized and provided by service providers and **Computer Emergency Response Teams (CERTs)**. Threat intelligence is designed to help an organization understand common and severe external threats, such as zero-day threats, **advanced persistent threats (APTs)**, and other security exploits. Threat intelligence provides in-depth information about **indicators of compromise (IOC)** and thus helps the organization protect itself from attacks.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
What is the best way to protect an unattended PC?	Password-protected screen saver
What kind of penetration testing indicates a real kind of attack to determine the incident response capability of the target?	Double-blind testing
What is the most important control to preserve the integrity of logs?	Read-only access (edit and delete access should be disabled)
What is the first step once the password is compromised?	Change of password

Table 12.3: Key aspects from the CISA exam perspective

Security Monitoring Tools and Techniques

Monitoring security events is a very important aspect of information security. Two important monitoring tools are **Intrusion Detection Systems (IDSs)** and **Intrusion Prevention Systems (IPSs)**. IDSs only monitor, record, and provide alarms about intrusion activity, whereas IPSs also prevent intrusion activities.

Each of them is discussed in detail.

IDS

An IDS monitors a network (a network-based IDS) or a single system (a host-based IDS) with the aim of recognizing and detecting an intrusion activity.

Network-Based and Host-Based IDSs

The following table differentiates between network-based and host-based IDSs:

Network-based IDS	Host-based IDS
It monitors activities across the network	It monitors the activities of a single system or host
Comparatively, network-based IDSs have high false positives (in other words, a high rate of false alarms)	Host-based IDSs have low false positives (in other words, a low rate of false alarms)

Network-based IDS	Host-based IDS
Network-based IDSs are better at detecting attacks from outside	Host-based IDSs are better at detecting attacks from inside
Network-based IDSs inspect the content and header information of all packets moving across the network and identify irregular behavior	Host-based IDSs detect activities on a host computer, such as the deletion of files and the modification of programs

Table 12.4: Differences between network-based and host-base IDSs

Components of the IDS

The following table shows the various components of the IDS:

Components	Description
Sensors	The function of the sensors is to collect the data. Data can be in the form of network packets, log files, and so on.
Analyzers	The function of the analyzers is to analyze the data and determine the intrusion activity.
Administration console	An administration console helps the administrator to control and monitor IDS rules and functions.
User interface	A user interface supports the user in viewing the results and carrying out the necessary tasks.

Table 12.5: Various components of an IDS

Limitations of the IDS

The following are some of the limitations of the IDS:

- IDSs operate on the basis of policy definition. Weaknesses in policy definitions weaken the function of the IDS.
- IDSs cannot control application-level vulnerabilities.
- IDSs cannot control the backdoor into an application.
- IDSs cannot analyze the data that is tunneled into an encrypted connection.

Types of IDS

The following are the types of IDS.

Signature-Based

In signature-based IDS, the IDS looks for specific predefined patterns to detect intrusion. Patterns are stored as signatures and are updated at frequent intervals. This is also known as rule-based IDS.

Statistical-Based

Statistical-based IDSs attempt to identify abnormal behavior by analyzing the statistical algorithm. Any abnormal activity is flagged as an intrusion. For example, if normal login hours are between 7 a.m. and 5 p.m. and if a login is performed at 11 p.m., the IDS will raise this as an intrusion. Statistical IDS generates the most false positives compared with other types of IDS.

Neural Network

Neural networks work on the same principle as statistical-based IDS. However, they possess the advanced functionality of self-learning. Neural networks keep updating the database by monitoring the general pattern of activities. They are most effective in addressing problems that require consideration of a large number of input variables.

Placement of IDS

Network-based IDSs can be placed either between a firewall and an external network (that is, the internet) or between a firewall and the internal network. This is illustrated in the following diagram:

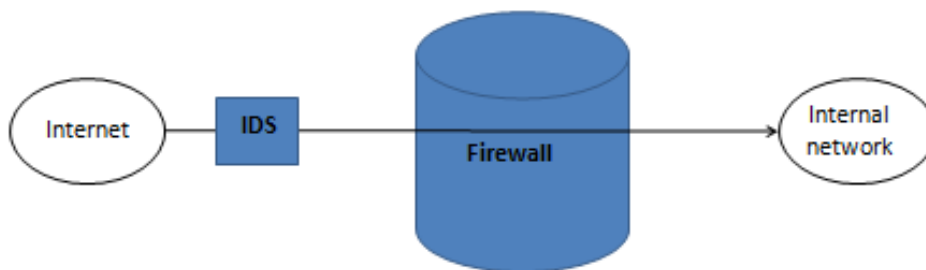


Figure 12.2: Placement of IDS between firewall and external network

If an IDS is installed between a firewall and an external network, it will be able to identify all intrusion attempts irrespective of whether intrusion packets bypassed the firewall:

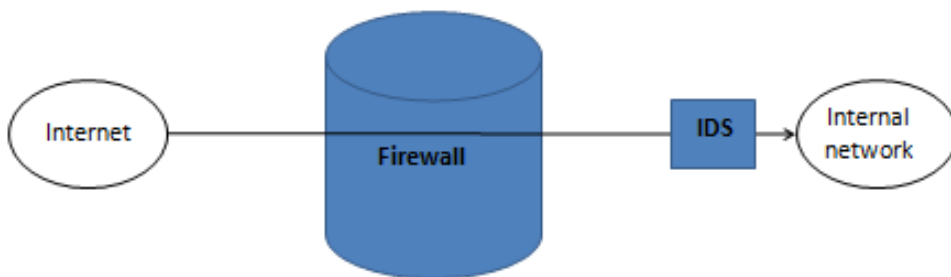


Figure 12.3: Placement of IDS between firewall and internal network

If an IDS is installed between a firewall and an internal network, it will be able to detect only those attempts that bypassed the firewall rules.

IPS

IPSs have the ability to not only detect intrusion attempts but also to prevent the impact of the intrusion attack.

Honeypots and Honey Nets

A honeypot is a decoy system set up to attract hackers and intruders. The purpose of setting a honeypot is to capture the details of intruders in order to proactively strengthen security controls. High-interaction honeypots provide a real environment to attack, whereas a low-interaction honeypot provides limited information.

A honey net is a combination of linked honeypots. A honey net is used for large network setups.

Key Aspects from the CISA Exam Perspective

The following table covers the important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
Which IDS has the capacity to update its database and self-learn?	Neural network-based IDS
Name the component of an IDS that collects the data.	Sensor
Which IDS has the highest number of false alarms?	Statistical-based IDS

CISA Questions	Possible Answers
A setup for capturing information pertaining to an intruder in order to proactively strengthen security controls is known as:	Honeypot
What is the first action performed by an intruder/attacker in preparation for a system attack?	Gathering information

Table 12.6: Key aspects from the CISA exam perspective

Incident Response Management

An incident response management policy is very important in minimizing damage from an incident and in recovering the operations at the earliest possible juncture.

Roles and responsibilities for incident management should be clearly defined. The following are some of the important functions relating to incident management:

- A coordinator should liaison with process owners
- An executive officer should oversee the incident response capability
- Security experts should investigate the incident
- A public relations team should manage the reputation of both internal and external stakeholders

The incident reporting procedure should be clearly defined, documented, and made available to all employees and relevant stakeholders.

Teams of experts should be available to investigate the incident to arrive at the root cause for preventive action. To address incidents properly, it is necessary to collect evidence as soon as possible after the occurrence. Legal advice may be needed in the process of evidence collection and protection.

Computer Security Incident Response Team

A **Computer Security Incident Response Team (CSIRT)** or **CERT** should be established within the organization with clear roles and responsibilities. They act as a centralized authority to evaluate and monitor all the incidents and issues related to information security. Learning from incidents should be documented for preventive as well as corrective actions.

Further, tools and techniques should be in place to identify and detect incidents in real time so that they could be acted on immediately to prevent further damage.

Key Aspects from the CISA Exam Perspective

The following table covers important aspects from the CISA exam perspective:

CISA Questions	Possible Answers
The primary objective of an incident response plan is:	To minimize the duration and impact of system outages and security incidents
The most important factor in improving the incident response process is:	Simulated testing of the incident response plan at regular intervals
A plan to detect and recover from an attack is known as:	An incident response plan
The best indicator to determine the effectiveness of the incident response team is:	The financial impact per security incident
What is the most important objective of time synchronization across all the devices?	To support incident investigation (A uniform time across all devices helps in the investigation of an incident)

Table 12.7: Key aspects from the CISA exam perspective

Evidence Collection and Forensics

Digital evidence can be used in legal proceedings provided it has been preserved in its original state. Evidence loses its integrity if the chain of custody is not maintained. The chain of custody refers to the process of identifying, preserving, analyzing, and presenting evidence in such a manner that it demonstrates the reliability and integrity of the evidence.

Chain of Custody

The following are some of the major considerations when demonstrating the chain of custody:

Identify

This refers to the practice of the identification of evidence. This process should not impact the evidence's integrity. Evidence should not be altered or modified in any way.

Preserve

This refers to the process of preserving evidence, such as the imaging of original media. This process should be followed in the presence of an independent third party. The process of preserving evidence should be documented for further reference.

Analyze

This refers to the process of interpreting and analyzing the evidence. This process should be performed on an image copy and not on the original evidence.

Present

This refers to the process of presenting the evidence to various authorities. This process should not impact the integrity of the evidence. Evidence should not be altered or modified in any way.

Key Elements of Computer Forensics

The following key elements of computer forensics should be considered by an IS auditor during audit planning.

Data Protection

An incident response procedure and plan should be in place to ensure that the required information is not deleted or altered.

Data Acquisition

All required information should be transferred in a controlled environment. Write blocker devices should be used to ensure that electronic media is write-protected. Volatile data such as open ports, open files, user login credentials, and other data helps to determine the status of the system. This information is lost when the computer is shut down.

Imaging

Imaging is the process of copying data bit for bit to prevent damage to the original data. It is used to obtain residual data such as deleted files and other information. Imaging is helpful when multiple analyses are performed. Imaging copies the disk surface sector by sector.

Extraction

The extraction process involves the identification and selection of data from imaged data.

Interrogation

Interrogation is the process of obtaining relevant data, such as IP addresses, telephone numbers, and other details from extracted data.

Ingestion/Normalization

Through the process of normalization, information is converted to a format that can be understood by an investigator. Binary or hexadecimal data is converted into readable characters or into other formats that are suitable for data analysis tools.

Reporting

Reporting involves the presentation of findings in a structured way. It includes details such as the objective and purpose of the review, the review process to be followed, and conclusions arising from the review. Reporting should not be ambiguous and open to misinterpretation and should be fit to be utilized in legal proceedings.

Protection of Evidence

An IS auditor should consider the following safeguards in order to protect evidence:

- Affected systems should not be rebooted. Rebooting the system could result in the loss or corruption of evidence.
- It is recommended to copy one or more images of the affected system.
- As far as possible, analysis should be performed on an image of the evidence and not on the original evidence.
- The chain of custody should be preserved to ensure the integrity of the evidence.

Summary

This chapter discussed the various aspects of security awareness training and programs, security testing, and monitoring tools and techniques. You also learned how to evaluate incident management policies and practices, and we discussed how to evaluate evidence collection and the forensics process.

The following is a recap of the important topics taught in this chapter:

- In a social engineering attack, an intruder attempts to obtain sensitive information from users through their social and psychological skills. They manipulate people into divulging confidential information such as passwords. This kind of attack can best be restricted and addressed by educating users through frequent security awareness training.
- Digital evidence can be used in legal proceedings provided it has been preserved in its original state. Evidence loses its integrity if the chain of custody is not maintained.
- The chain of custody refers to the process of identifying, preserving, analyzing, and presenting evidence in such a manner that it demonstrates the reliability and integrity of the evidence.

With this final chapter, you have acquired the skills and knowledge required to pass the CISA exam as well as perform IS audits. It is strongly recommended that you refer to the key aspects mentioned at the end of each topic and practice self-assessment questions in order to excel in the CISA exam.

Chapter Review Questions

Now that you have completed this chapter, it is recommended that you solve the practice questions from it. These chapter review questions have been carefully crafted to reinforce the knowledge you have gained throughout this chapter. By engaging with these questions, you will solidify your understanding of key topics, identify areas that require further study, and build your confidence before moving on to new concepts in the next chapter.

Note

A few of the questions may not be directly related to the topics in the chapter. They aim to test your general understanding of information systems concepts instead.

The following image shows an example of the practice questions interface.

[Dashboard](#) > Set 1 (Security Awareness Training and Programs)

Question 3 of 21

14%

Time Left:
33 mins 51 secs

END QUIZ

What is the best method to determine the effectiveness of security awareness training?

☐ To review the security training calendar

☐ To review the job description

☐ To ask the security team

☐ To interact with a number of employees

PREVIOUS

NEXT

[Don't Know](#)

Feedback

Figure 12.4: CISA practice questions interface

To access the end-of-chapter questions from this chapter, follow these steps:

1. Open your web browser and go to `https://packt.link/v3Rqk`. You will see the following screen:

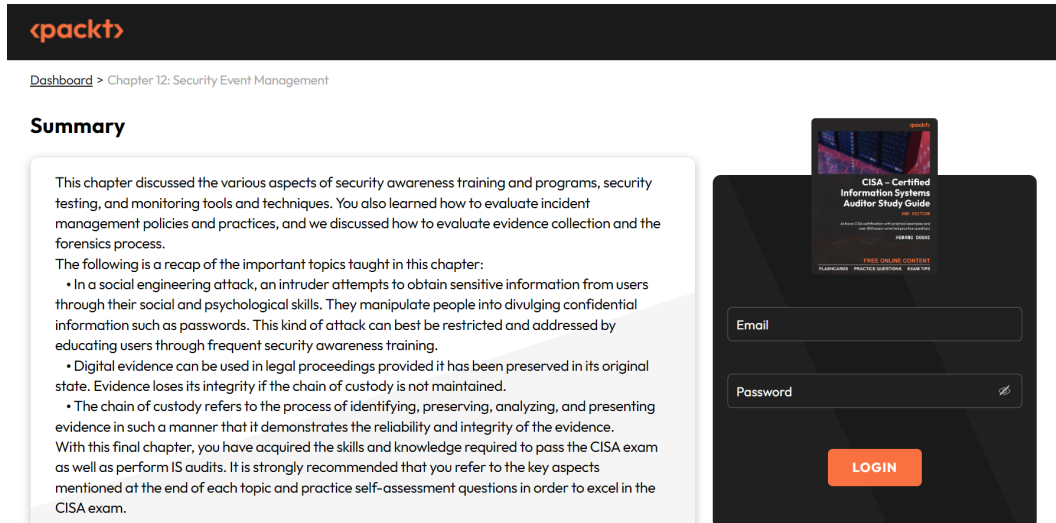


Figure 12.5: Chapter summary and login

You can also scan the following QR code to access the website:



Figure 12.6: QR code to access *Chapter 12* questions

2. Log in to your account using your credentials. If you haven't activated your account yet, refer to *Instructions for Unlocking the Online Content* in the *Preface* for detailed instructions.

After a successful login, you will see the following screen:

Chapter 12: Security Event Management

Summary

This chapter discussed the various aspects of security awareness training and programs, security testing, and monitoring tools and techniques. You also learned how to evaluate incident management policies and practices, and we discussed how to evaluate evidence collection and the forensics process.

The following is a recap of the important topics taught in this chapter:

- In a social engineering attack, an intruder attempts to obtain sensitive information from users through their social and psychological skills. They manipulate people into divulging confidential information such as passwords. This kind of attack can best be restricted and addressed by educating users through frequent security awareness training.

- Digital evidence can be used in legal proceedings provided it has been preserved in its original state. Evidence loses its integrity if the chain of custody is not maintained.

- The chain of custody refers to the process of identifying, preserving, analyzing, and presenting evidence in such a manner that it demonstrates the reliability and integrity of the evidence. With this final chapter, you have acquired the skills and knowledge required to pass the CISA exam as well as perform IS audits. It is strongly recommended that you refer to the key aspects mentioned at the end of each topic and practice self-assessment questions in order to excel in the CISA exam.

Chapter 12 Quizzes

CISA Study Guide 2nd Edition by Hemang Doshi

Select Quiz

Set 1 (21 Questions)

START

Set 2 (21 Questions)

START

Set 3 (11 Questions)

START

Set 4 (18 Questions)

START

Figure 12.7: Chapter summary and end-of-chapter question sets

- Click on any of the given sets to begin your practice quiz. The quiz sets are timed as you can see from the following image:

[Dashboard](#) > Set 1 (Security Awareness Training and Programs)

Question 3 of 21

14%

Time Left:

33 mins 51 secs

END QUIZ

What is the best method to determine the effectiveness of security awareness training?

☐

To review the security training calendar

☐

To review the job description

☐

To ask the security team

☐

To interact with a number of employees

PREVIOUS

NEXT

[Don't Know](#)

Feedback



Figure 12.8: Practice questions interface with timer

When the timer runs out, the quiz will submit automatically. Attempt each quiz multiple times till you are able to answer all questions not just correctly, but within the time limit as well.

Chapter Benchmark Score

Before moving on to the next chapter, it is recommended that you score an average of 75% on the end-of-chapter practice quizzes. By actively working toward meeting this benchmark score, you will ensure that you are well-equipped to tackle the concepts in the upcoming chapter.

Index

A

access: 1-2, 9, 16, 31, 35-36, 51-52, 56, 62, 65-66, 74, 85, 88, 94, 108, 127, 132, 149, 152-155, 157-159, 165, 170, 174, 189, 200, 203-206, 208, 210-213, 215-217, 219, 225, 229-232, 237-239, 241-243, 249, 255, 261, 263-265, 268, 273-281, 293

activities: 3-4, 11, 18, 21-22, 28, 36-37, 56-57, 67-68, 85-86, 94-95, 97-98, 105, 113-114, 158, 170, 211, 217, 284, 286

adware: 273

aligned: 2-3, 25, 67-69, 72, 86, 94, 101, 105, 119, 184-185, 189, 211

analysis: 7, 13, 16, 52, 55, 81-82, 99-100, 106, 111, 113, 115, 117-119, 123, 145, 147, 158, 160, 163, 177-178, 184, 211, 276-278, 282-283, 290-291

appetite: 24, 80

approval: 6, 52, 119, 121, 153, 157, 162-163, 280, 283

assessment: 2, 5-6, 19, 21, 23, 29, 60, 73, 79, 82, 104, 164, 178, 184-185, 271

assets: 2, 15, 18, 20-21, 36, 68-70, 73-74, 84, 86, 91, 94, 97, 151, 153-156, 172, 177-178, 188-189, 198, 203, 213, 217, 272

asymmetric: 247, 254-255, 258, 266

atomicity: 126, 169

auditing: 21-22, 47, 50, 52-53, 56, 84-86, 128, 158, 204, 211, 229, 279, 282

audits: 2, 10, 16, 22, 26, 28, 37, 53, 73, 98, 205, 266, 291

avoidance: 24

B

backdoor: 275, 285

backup: 17, 157-158, 170, 177, 179-181, 185, 189, 193-196, 239, 262

baseline: 114, 120, 163, 204

bastion: 232-235, 246

biometric: 208, 213, 215-217, 278

blacklist: 241

bolting: 208

bombarded: 273

bombing: 274

botnets: 273

bottom-up: 24-25, 75, 113, 140-141

brownout: 205

budgeting: 156

buffer: 114, 273, 275

C

cameras: 17, 209, 265-266
certifying: 259-260, 266
chalking: 244
changeover: 144, 146
charging: 275
charter: 2-4, 28
checklist: 190
checksums: 126, 130
clause: 97, 189, 263
clustering: 182
committee: 3, 6, 40, 55-57, 69, 77-78, 112
compliance: 11, 21, 23, 37, 42, 44-45, 52, 57, 68-70, 72-73, 84-85, 96, 98-99, 163, 204-205, 211-212, 262-263, 266, 280
controls: 2, 7-18, 21-23, 28-29, 37, 40, 43, 45, 52, 58, 84, 93, 97-98, 116, 122, 124, 126, 130, 145-146, 153-154, 157-158, 165, 169, 172, 198, 203, 205-206, 208, 210-212, 216-217, 223, 229, 231-232, 239, 241, 245-246, 259, 263, 265, 271, 273, 277, 279, 281, 287
crosstalk: 227, 229
custodian: 154

D

database: 8, 51, 104, 113, 126, 147, 151-152, 165-170, 179-180, 189, 286
deadman: 208-209
decrypt: 255-256, 258
degaussing: 212
detective: 15-16, 18, 29, 212
deterrent: 15, 17, 212
dialing: 274
diddling: 273
diligence: 92, 96
diving: 274

downtime: 155-156, 178, 189, 192-194, 198
dual-homed: 233-234

E

encrypted: 11-12, 153, 216, 230, 238, 245, 247, 255-256, 258, 264, 266, 278, 280, 285
enterprise: 6, 24, 60, 66-67, 69, 73, 79-80, 86, 172, 203
escrow: 97, 105, 159

F

filtering: 231, 233-235, 241-242, 246
firewall: 223, 226, 231-236, 239, 246, 276, 286-287
firewalls: 9, 16, 152, 217, 229, 231-232, 238-239, 245-246, 276
fishbone: 160
flooding: 273, 275
forensics: 271, 289-291
framework: 67, 70-72, 79, 84, 127-128, 203-205, 231

G

grouping: 155, 211
guidelines: 7, 28, 48-49, 72-73, 85, 203, 245

H

handling: 157, 227, 246, 282
hardening: 153, 223, 264
honeypot: 287
host-based: 284
hybrid: 95, 262

I

incident: 9, 17, 147, 151, 160-161, 178, 193,
195, 206, 271-272, 281-282, 288, 290-291
indicators: 156, 216, 283
intrusion: 284-287
inventory: 5, 153-157, 211

J

jacking: 275

L

layers: 223-226, 236, 246
logging: 158, 210-211, 280

M

magnetic: 208, 212
malicious: 93, 211, 238, 240, 273, 275, 277
management: 2-4, 6, 8-9, 14-15, 21, 24-25,
28-29, 36, 40, 51, 55-57, 59-60, 66, 68-69,
72-73, 75, 80-82, 84-87, 91-97, 99-100,
103, 105-106, 111-113, 116, 130, 147,
151-165, 169, 172, 178-179, 182, 184,
194, 203-204, 208, 210-213, 229, 237-238,
243, 259-261, 264-267, 271, 288, 291
mantrap: 208
mirrored: 195-197
mirroring: 194
models: 66, 84, 119, 161, 166-167, 262-263
monitoring: 9, 12, 16, 18, 37, 52-54, 58,
60, 67-68, 82, 84-86, 91, 93, 97-100,
105-106, 112-113, 159, 164, 170, 184,
265-266, 271, 281, 284, 286, 291

O

objectives: 2-3, 5, 8, 11-13, 15, 18-19, 25,
37, 40, 56-59, 67-70, 72, 75, 79-80, 84,
86, 91, 105, 116, 119, 121, 145-147,
177, 184, 203, 210, 255, 257
offsite: 95, 98, 185, 190, 198
onsite: 95
outsourced: 4, 68, 95-97, 106, 161, 165
overflow: 273
overriding: 238
owners: 58-59, 112, 162, 185,
188, 213, 217, 288
ownership: 112, 144, 153, 204, 259, 263

P

packet: 226, 230-231, 233-235, 238, 246, 276
patches: 163, 239
payload: 238, 246
pharming: 276
phishing: 245
policies: 7, 14-15, 24-25, 66-68, 71-74,
84-86, 92-94, 99, 154, 203-204,
212, 259, 265, 271-272, 291
policy: 24-25, 69-70, 72-75, 79, 86, 92, 157,
179, 204-205, 212, 245, 274, 280, 285, 288
preventive: 15-19, 21, 29, 126, 130, 156,
160, 169, 189, 212, 273, 288
programs: 94, 97, 104, 152, 158, 168,
204, 271-272, 275, 277, 281, 291

Q

queries: 113

R

recovery: 12, 17, 97, 170, 177-179, 182,
185-186, 188-192, 195, 197-198, 263
redundancy: 126, 144, 157, 165, 167, 169, 194
regression: 136, 138, 147
regulatory: 6-7, 11, 18, 22, 37, 68, 72,
84-85, 95-96, 98, 158, 262, 266
reporting: 3, 36-37, 40, 54-57, 60,
84-85, 91, 93-94, 98, 100, 105,
155-156, 205, 272, 288, 291
residual: 19, 21, 212, 216, 278, 290
resilience: 172-173, 177, 182, 198
response: 17, 24, 85, 231, 271,
276, 282-283, 288, 290
retention: 13, 179
risk-based: 2, 8, 19, 21-22, 28, 217, 266
router: 226, 231, 233-235, 241-242
rule-based: 285

S

sampling: 22, 29, 36, 40-42, 45, 60
screened: 235, 246
security: 9, 11-12, 14, 17, 52, 68-70, 73-75,
79, 86, 93, 105, 120, 122, 136-137, 143,
152-155, 157-158, 165, 170, 172, 185,
198-199, 203-206, 208-209, 211, 213,
217-218, 223, 229-231, 238-239, 241,
243, 245-247, 253, 262-263, 265-267,
271-277, 279, 281-284, 287-288, 291
simulation: 54, 186, 191, 282-283
skimming: 11
snapshot: 54
sniffing: 277
spamming: 275
spikes: 205-206
spoofing: 275-276
stamping: 155, 172

stateful: 231
steering: 77-78, 112
subnet: 246
surfing: 277
surges: 205-206
switches: 156, 225-226, 246
symmetric: 247, 254, 258

T

tabletop: 191
tailgating: 51, 208, 276
telnet: 230
testing: 12-13, 30, 42, 44-45, 52, 61, 87, 98,
107, 112, 116, 119-122, 127, 130-131,
135-141, 146-148, 162-163, 173, 184,
186, 189-190, 198-199, 218, 248, 263,
266-267, 271, 279, 281-283, 291-292
threats: 19-20, 75, 177, 205, 217, 266, 283
timebox: 116
tolerance: 192, 194, 198
top-down: 24-25, 75, 122, 140-141
tracing: 163, 169
tracking: 105, 154, 209, 211, 265
transfer: 9, 12, 24, 152, 205, 265-266
trapdoor: 275
trojan: 275
tunneling: 237-238, 246
two-factor: 12, 213, 265

V

v-shaped: 119-120

W

walking: 244
waterfall: 119



www.packtpub.com

Subscribe to our online digital library for full access to over 7,000 books and videos, as well as industry leading tools to help you plan your personal development and advance your career. For more information, please visit our website.

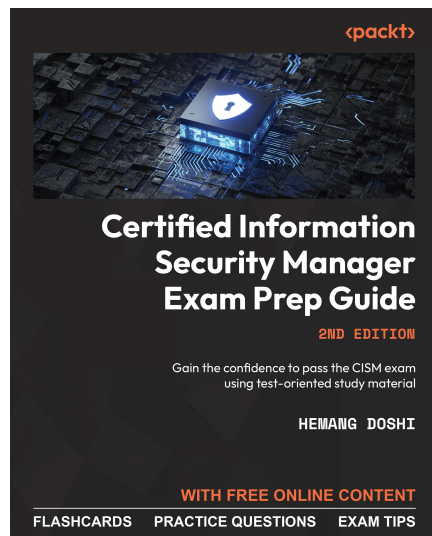
Why subscribe?

- Spend less time learning and more time coding with practical eBooks and Videos from over 4,000 industry professionals
- Improve your learning with Skill Plans built especially for you
- Get a free eBook or video every month
- Fully searchable for easy access to vital information
- Copy and paste, print, and bookmark content

At www.packtpub.com, you can also read a collection of free technical articles, sign up for a range of free newsletters, and receive exclusive discounts and offers on Packt books and eBooks.

Other Books You May Enjoy

If you enjoyed this book, you may be interested in these other books by Packt:

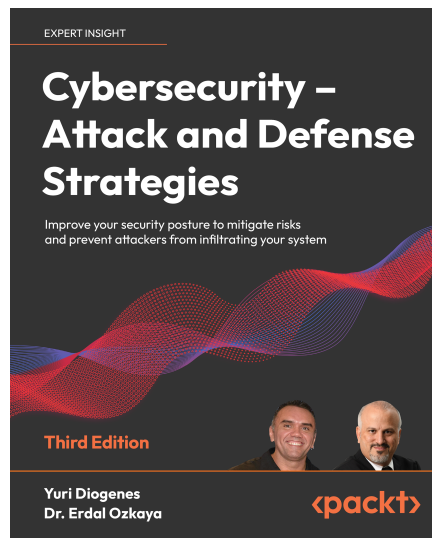


Certified Information Security Manager Exam Prep Guide – Second Edition

Hemang Doshi

ISBN: 978-1-80461-063-3

- Understand core exam objectives to prepare for the CISM exam with confidence
- Get to grips with detailed procedural guidelines for effective information security incident management
- Execute information security governance in an efficient manner
- Strengthen your preparation for the CISM exam using interactive flashcards and practice questions
- Conceptualize complex topics through diagrams and examples
- Find out how to integrate governance, risk management, and compliance functions



Cybersecurity – Attack and Defense Strategies - Third Edition

Yuri Diogenes, Dr. Erdal Ozkaya

ISBN: 978-1-80324-877-6

- Learn to mitigate, recover from, and prevent future cybersecurity events
- Understand security hygiene and value of prioritizing protection of your workloads
- Explore physical and virtual network segmentation, cloud network visibility, and Zero Trust considerations
- Adopt new methods to gather cyber intelligence, identify risk, and demonstrate impact with Red/Blue Team strategies
- Explore legendary tools such as Nmap and Metasploit to supercharge your Red Team
- Discover identity security and how to perform policy enforcement
- Integrate threat detection systems into your SIEM solutions
- Discover the MITRE ATT&CK Framework and open-source tools to gather intelligence

Share Your Thoughts

Now you've finished *CISA – Certified Information Systems Auditor Study Guide, Second Edition*, we'd love to hear your thoughts! If you purchased the book from Amazon, please [click here](#) to go straight to the Amazon review page for this book and share your feedback or leave a review on the site that you purchased it from.

Your review is important to us and the tech community and will help us make sure we're delivering excellent quality content.

Download a Free PDF Copy of This Book

Thanks for purchasing this book!

Do you like to read on the go but are unable to carry your print books everywhere?

Is your eBook purchase not compatible with the device of your choice?

Don't worry, now with every Packt book you get a DRM-free PDF version of that book at no cost.

Read anywhere, any place, on any device. Search, copy, and paste code from your favorite technical books directly into your application.

The perks don't stop there, you can get exclusive access to discounts, newsletters, and great free content in your inbox daily.

Follow these simple steps to get the benefits:

1. Scan the QR code or visit the link below:



<https://packt.link/free-ebook/9781803248158>

2. Submit your proof of purchase.
3. That's it! We'll send your free PDF and other benefits to your email directly.